MÁSTER UNIVERSITARIO EN SEGURIDAD DE LAS TECNOLOGÍAS DE LA INFORMACIÓN Y LAS COMUNICACIONES

TRABAJO FIN DE MÁSTER

DESARROLLO DE UN LABORATORIO TÉCNICO PARA EL ANÁLISIS DE STEALERS

StealLab

Autor

D. Julio César Rodríguez Infante

Director del Trabajo Fin de Máster

D. Alejandro Ramos

CURSO 2025-2026

RESUMEN

Los stealers o infostealers constituyen una amenaza relevante para la seguridad de la información porque buscan obtener activos reutilizables, como credenciales, cookies de sesión, tokens, datos de navegador, información financiera y metadatos del sistema. Su impacto puede extenderse más allá del robo inicial y facilitar fraude, apropiación de cuentas, acceso a servicios corporativos o intrusiones posteriores. Este Trabajo Fin de Máster desarrolla StealLab, un laboratorio técnico, seguro y reproducible para estudiar defensivamente comportamientos asociados a esta clase de amenaza.

La investigación adopta un estudio de caso técnico aplicado. El entorno se construye sobre KVM/libvirt, una red aislada sin salida a Internet, máquinas virtuales separadas por función, snapshots, captura de procesos, tráfico interno y un repositorio estructurado de evidencias. La validación combina M-001, como caso principal de integración benigna, y cuatro casos complementarios de validación (M-002 a M-005), todos con datos sintéticos DEMO/NO REAL y sin malware, credenciales, cookies, tokens, wallets, datos personales, infraestructura C2 ni Internet reales.

Los resultados permiten verificar el aislamiento, la restaurabilidad, la observación de procesos, el descubrimiento controlado de artefactos sintéticos, el staging local, la captura de tráfico HTTP interno, la integridad mediante hashes SHA-256 y la trazabilidad entre pruebas PV y evidencias EV. M-005 añade un contraste negativo de contención frente a un destino TEST-NET no alcanzable, interpretado conjuntamente con la ausencia de ruta y el fallo de conexión. También se evalúa el uso de un LLM únicamente como apoyo documental supervisado. La simulación benigna no sustituye al análisis de malware real, pero permite validar un método académico y éticamente controlado para construir, observar y documentar un laboratorio defensivo de comportamientos tipo stealer.

Palabras clave: infostealers, laboratorio defensivo, simulación benigna, evidencia digital, virtualización.

ABSTRACT

Stealers or infostealers are a relevant information-security threat because they seek reusable assets such as credentials, session cookies, tokens, browser data, financial information and system metadata. Their impact may extend beyond the initial theft and enable fraud, account takeover, access to corporate services or subsequent intrusions. This Master's Thesis develops StealLab, a technical, safe and reproducible laboratory for the defensive study of behaviours associated with this threat category.

Validation combines M-001, used as the main benign integration case, with four complementary validation cases (M-002 to M-005). All cases use only synthetic DEMO/NOT REAL data and exclude real malware, credentials, cookies, tokens, wallets, personal data, command-and-control infrastructure and Internet access.

The results verify isolation, restorability, process observation, controlled discovery of synthetic artefacts, local staging, internal HTTP traffic capture, SHA-256-based integrity and traceability between PV validation tests and EV evidence records. M-005 adds a negative containment contrast against a non-reachable TEST-NET destination, interpreted together with the absence of a route and the failed connection. The supervised use of an LLM is also assessed solely as documentary support. Benign simulation does not replace real-malware analysis, but it provides a valid academic and ethically controlled method for building, observing and documenting a defensive laboratory focused on stealer-like behaviours.

Keywords: infostealers, defensive laboratory, benign simulation, digital evidence, virtualization.

AGRADECIMIENTOS

Agradezco a mi tutor, D. Alejandro Ramos, la revisión del trabajo y las indicaciones realizadas para reforzar la profundidad investigadora, metodológica y documental de esta memoria. Sus observaciones han permitido orientar el proyecto hacia un resultado más académico, más crítico y más defendible como Trabajo Fin de Máster.

Agradezco también a mi familia el apoyo durante el desarrollo del máster y de este proyecto. Este trabajo ha requerido estudio, pruebas, documentación, revisión técnica y esfuerzo continuado, y no habría sido posible sin ese acompañamiento.

ÍNDICE DE CAPÍTULOS Y ANEXOS

PARTE I. INTRODUCCIÓN....16
1 INTRODUCCIÓN....17
1.1 Contexto general de la ciberseguridad actual....17
1.2 Motivación del trabajo....18
1.3 Alcance defensivo, ético y académico....18
1.4 Estructura de la memoria....19
2 DESCRIPCIÓN DEL PROBLEMA Y JUSTIFICACIÓN....21
2.1 Problema técnico....21
2.2 Problema metodológico....21
2.3 Justificación social, profesional y académica....22
2.4 Relación con la propuesta aprobada....22
PARTE II. FUNDAMENTACIÓN TEÓRICA Y ESTADO DE LA CUESTIÓN....25
3 ESTADO DE LA CUESTIÓN....26
3.1 Criterios de búsqueda y selección de fuentes....26
3.2 Evolución del fenómeno stealer....28
3.3 Malware-as-a-Service y economía de credenciales....29
3.4 Casos reales documentados....30
3.5 Brecha identificada....31
3.6 Relevancia actual de los stealers en la cadena de ataque....32
3.7 Delimitación entre estado del arte, estado de la cuestión y marco teórico....33
3.8 Principales líneas de investigación y documentación técnica relacionadas....33
3.9 Función metodológica de los casos reales y límites de transferencia....34
3.10 Herramientas defensivas y decisión de no convertir el TFM en catálogo....35
3.11 Brecha específica que cubre StealLab....36
3.12 Cronología razonada del fenómeno infostealer....37
3.13 Familias representativas y criterios de inclusión en la revisión....37
3.14 Economía de los logs robados y mercados de acceso....38
3.15 Relación entre infostealers, ransomware y compromiso de servicios corporativos....39
3.16 Lectura del fenómeno infostealer por capas OSI y TCP/IP....40
4 MARCO TEÓRICO Y CONCEPTUAL....42
4.1 Glosario de acrónimos, siglas y términos técnicos utilizados....42
4.2 Concepto de malware....50
4.3 Clasificación general del malware....51
4.4 Concepto de stealer o infostealer....52
4.5 Diferencias con otras categorías de malware....53
4.6 Tipología defensiva de stealers....54
4.7 Activos de información afectados....55
4.8 Ciclo operacional de alto nivel....56
4.9 Técnicas observables en marcos defensivos....57
4.10 Evidencia digital, trazabilidad y reproducibilidad....58
4.11 Simulación benigna frente a ejecución de malware real....59
4.12 Terminología esencial del dominio stealer....60
4.13 Impacto funcional del malware en confidencialidad, integridad y disponibilidad....61
4.14 Taxonomía operativa para la observación defensiva....61
4.15 Valoración del riesgo de los activos de información....62
4.16 Cadena operacional y puntos de observación....63
4.17 Relación con MITRE ATT&CK desde un uso defensivo....64
4.18 Evidencia digital: identificación, integridad, contexto e interpretación....65
4.19 Reproducibilidad y refutabilidad....65
4.20 Ética de laboratorio en análisis de malware....66
4.21 Modelo conceptual final aplicado al TFM....67
4.22 Glosario aplicado a la interpretación de evidencias....67
4.23 Modelo conceptual de observabilidad defensiva....68

4.24 Modelo de riesgo asociado a activos robados....69
4.25 Modelos OSI y TCP/IP como marco de análisis defensivo....70
4.26 Mapeo de categorías stealer a capas de observabilidad....71
PARTE III. PROPUESTA, DISEÑO E IMPLEMENTACIÓN....73
5 PREGUNTA DE INVESTIGACIÓN, PROPOSICIÓN Y OBJETIVOS....74
5.1 Pregunta de investigación....74
5.2 Proposición de trabajo....74
5.3 Objetivo general....75
5.4 Objetivos específicos....75
6 METODOLOGÍA....77
6.1 Tipo de investigación....77
6.2 Unidad de análisis y muestra técnica....77
6.3 Categorías de análisis....78
6.4 Instrumentos de recogida de datos....79
6.5 Procedimiento experimental....79
6.6 Criterios éticos y de seguridad....80
6.7 Amenazas a la validez previstas....80
6.8 Diseño de investigación aplicado....81
6.9 Operacionalización de categorías....81
6.10 Criterios de aceptación de pruebas....82
6.11 Protocolo de recogida y conservación de evidencias....83
6.12 Plan de análisis....83
6.13 Gestión de contradicciones y hallazgos negativos....84
6.14 Rol metodológico del LLM supervisado....84
6.15 Justificación epistemológica del diseño aplicado....85
6.16 Delimitación de casos y subcasos de validación....85
6.17 Matriz de categorías, indicadores e instrumentos....86
6.18 Criterios de rigor: credibilidad, dependencia, confirmabilidad y transferibilidad....86
6.19 Protocolo de análisis y regla de no sobreafirmación....87
6.20 Protocolo metodológico futuro para análisis estático de código de stealers con LLM supervisado....87
7 DISEÑO DEL LABORATORIO STEALLAB....89
7.1 Requisitos del laboratorio....89
7.2 Arquitectura general....89
7.3 Estado persistente y estado runtime....90
7.4 Seguridad del diseño....91
7.5 Arquitectura de StealLab por capas OSI y TCP/IP....92
8 IMPLEMENTACIÓN TÉCNICA....94
8.1 Repositorio canónico....94
8.2 Estructura del repositorio....94
8.3 Evidencias del repositorio....95
8.4 Datos sintéticos DEMO/NO REAL....96
8.5 PCAP y tráfico controlado....97
8.6 Snapshots documentados por qcow2....97
8.7 Implementación de M-001....98
8.8 Lectura técnica del estado libvirt verificado....99
8.9 Arquitectura lógica de comunicación....99
8.10 Datos sintéticos como instrumento experimental....100
8.11 Interpretación de los PCAP de validación....100
8.12 Nomenclatura EV y trazabilidad documental....101
8.13 Decisiones de exclusión técnica....101
8.14 Justificación de cada componente de la arquitectura....102
8.15 Razonamiento de aislamiento de red....102
8.16 Trazabilidad del procedimiento de implementación....103
8.17 Decisiones técnicas descartadas....103
8.18 Diseño teórico de VM-WIN-LAB....104

8.19 Procedimiento seguro previsto para una futura VM-WIN-LAB....105
8.20 Diseño de un flujo seguro para análisis de código fuente malicioso asistido por LLM....105
PARTE IV. PRUEBAS, VALIDACIÓN Y RESULTADOS....107
9 PLAN DE PRUEBAS Y VALIDACIÓN....108
9.1 Criterios de aceptación....108
9.2 Tratamiento de salidas de consola....109
10 CASOS DE VALIDACIÓN: M-001 Y CASOS COMPLEMENTARIOS....111
10.1 Finalidad del caso....111
10.2 Restricciones de seguridad....111
10.3 Datos sintéticos utilizados....112
10.4 Evidencias estáticas, dinámicas y de red....112
10.5 Interpretación defensiva....115
11 RESULTADOS....116
11.1 Resultado PV-01: aislamiento....116
11.2 Resultado PV-02: restaurabilidad....116
11.3 Resultado PV-03: procesos....117
11.4 Resultado PV-04: red....117
11.5 Resultado PV-05: repositorio....117
11.6 Resultado PV-06: informe técnico....118
11.7 Resultado PV-07: LLM supervisado....118
11.8 Síntesis de resultados frente a objetivos....119
11.9 Lectura analítica transversal de PV-01 a PV-07....119
11.10 Resultados que no deben sobreinterpretarse....119
11.11 Evidencias fuertes y evidencias de apoyo....120
11.12 Resultado metodológico principal....120
11.13 Modelo ampliado de lectura PV/EV....122
11.14 Lectura segura de M-001 y casos complementarios....122
11.15 Análisis detallado de resultados por categoría....123
11.16 Interpretación de hashes como evidencia de integridad....123
12 DISCUSIÓN....125
12.1 Comparación con literatura y casos reales....125
12.2 Valor de la simulación benigna....125
12.3 Riesgos de sobreinterpretación....126
12.4 Papel del LLM en el proceso documental....126
12.5 Discusión crítica sobre el realismo del laboratorio....126
12.6 Comparación con sandboxes automáticos....127
12.7 Implicaciones defensivas....127
12.8 Implicaciones académicas....128
12.9 Discusión sobre datos sintéticos....128
12.10 Discusión sobre generalización....128
12.11 Discusión sobre familias reales frente a simulación benigna....130
12.12 Discusión sobre la aportación frente a un catálogo de herramientas....130
12.13 Riesgos, controles y límites del LLM supervisado....131
12.14 Discusión sobre la extensión del laboratorio a Windows....131
12.15 Análisis teórico de código de stealers reales con LLM supervisado....132
PARTE V. CIERRE....134
13 LIMITACIONES Y AMENAZAS A LA VALIDEZ....135
13.1 Limitaciones técnicas....135
13.2 Limitaciones metodológicas....135
13.3 Amenazas a la validez....135
13.4 Limitaciones específicas del alcance experimental M-001 a M-005....137
13.5 Amenazas a la validez externa....137
13.6 Amenazas a la validez documental....138
13.7 Limitación por no implementación de VM-WIN-LAB....138
13.8 Limitación por no ejecución de análisis de código real....139
14 CONCLUSIONES....140

14.1 Conclusiones por objetivo....140
14.2 Respuesta a la pregunta de investigación....141
14.3 Contribución principal....142
15 TRABAJOS FUTUROS....144
15.1 Línea futura prioritaria: implementación controlada de VM-WIN-LAB....145
15.2 Línea futura: integración blue team por capas....145
15.3 Línea futura: análisis estático de código de stealers con LLM supervisado....146
16 REFERENCIAS....147
17 APÉNDICES....151
17.1 Diario de experimentos....151
17.2 Manual de instalación resumido....151
17.3 Manual de usuario resumido....151
17.4 Guía de solucionado de errores....152
17.5 Inventario de evidencias externas....152
17.6 Instrumento de verificación ética aplicado....152
17.7 Plantilla de ficha de evidencia EV....153
17.8 Plantilla de ficha de prueba PV....153
17.9 Manual de interpretación de evidencias....154
17.10 Comandos mínimos de verificación local....154
17.11 Protocolo de control de exposición de información....154
17.12 Protocolo de verificación de consistencia y reproducibilidad....155

ÍNDICE DE TABLAS

Tabla 1. Mapa de cumplimiento entre la propuesta aprobada y la memoria final.....22
Tabla 2. Criterios de búsqueda, selección y uso de fuentes.....26
Tabla 3. Evolución del fenómeno stealer y su implicación en StealLab.....28
Tabla 4. Malware-as-a-Service y economía de credenciales.....29
Tabla 5. Casos reales documentados y uso argumental en la memoria.....30
Tabla 6. Delimitación entre estado del arte, estado de la cuestión y marco teórico.....33
Tabla 7. Líneas de investigación y documentación técnica relacionadas.....34
Tabla 8. Herramientas defensivas vinculadas con las pruebas de validación.....35
Tabla 9. Cronología razonada del fenómeno infostealer.....37
Tabla 10. Economía de logs robados y tratamiento seguro de activos.....38
Tabla 11. Relación entre infostealers, impactos posteriores y límites del laboratorio.....39
Tabla 12. Lectura por capas del fenómeno infostealer y aplicación en StealLab.....41
Tabla 13. Inventario integral de acrónimos, nombres técnicos y términos del TFM.....42
Tabla 14. Clasificación general del malware y relación con StealLab.....51
Tabla 15. Diferencias entre stealers y otras categorías de malware.....54
Tabla 16. Activos de información afectados y representación segura.....55
Tabla 17. Técnicas observables en marcos defensivos y uso seguro.....57
Tabla 18. Comparación entre malware real y simulación benigna M-001.....59
Tabla 19. Taxonomía defensiva de stealers.....62
Tabla 20. Cadena operacional de alto nivel y tratamiento en StealLab.....63
Tabla 21. Riesgos éticos y medidas de control del laboratorio.....66
Tabla 22. Modelo conceptual de observabilidad defensiva.....68
Tabla 23. Modelo de riesgo asociado a activos robados.....69
Tabla 24. Relación entre categorías de observabilidad, capas y evidencias PV/EV.....72
Tabla 25. Relación entre objetivos, resultados y evidencias.....75
Tabla 26. Muestra técnica del estudio.....78
Tabla 27. Categorías de análisis y operacionalización inicial.....78
Tabla 28. Procedimiento experimental aplicado.....79
Tabla 29. Operacionalización ampliada de categorías de análisis.....81
Tabla 30. Criterios de aceptación ampliados de PV-01 a PV-07.....82
Tabla 31. Unidad de análisis y subunidades empíricas.....85
Tabla 32. Variables, categorías, indicadores e instrumentos.....86
Tabla 33. Protocolo seguro para análisis estático de código con LLM supervisado.....88
Tabla 34. Requisitos de diseño de StealLab.....89
Tabla 35. Arquitectura técnica verificada.....89
Tabla 36. Verificación runtime de libvirt.....90
Tabla 37. Estructura principal del repositorio StealLab.....94
Tabla 38. Organización interna de evidencias.....95
Tabla 39. Hashes de datos sintéticos M-001.....96
Tabla 40. Arquitectura lógica verificada de StealLab.....101
Tabla 41. Justificación arquitectónica de componentes.....102
Tabla 42. Decisiones técnicas descartadas y alternativas adoptadas.....104
Tabla 43. Diseño teórico de VM-WIN-LAB y controles de seguridad.....104
Tabla 44. Flujo seguro para análisis estático de código asistido por LLM.....106
Tabla 45. Plan de pruebas PV/EV.....108
Tabla 46. Evidencias asociadas a M-001 y casos complementarios.....112
Tabla 47. Matriz de trazabilidad caso-PV-EV.....119
Tabla 48. Clasificación de evidencias por fuerza probatoria interna.....120
Tabla 49. Síntesis de cumplimiento de objetivos.....120
Tabla 50. Lectura ampliada de PV/EV.....122
Tabla 51. Descomposición segura de M-001 a M-005.....123
Tabla 52. Comparación sintética de M-001 a M-005.....123
Tabla 53. Análisis defensivo con LLM por tipo de stealer.....132
Tabla 54. Amenazas a la validez y medidas de mitigación.....135

Tabla 55. Trabajos futuros priorizados.....144
Tabla 56. Manual de instalación resumido.....151
Tabla 57. Guía de solucionado de errores.....152
Tabla 58. Instrumento de verificación ética aplicado.....152
Tabla 59. Plantilla académica de ficha de evidencia EV.....153
Tabla 60. Plantilla académica de ficha de prueba PV.....153
Tabla 61. Protocolo de verificación de consistencia y reproducibilidad.....155

ÍNDICE DE FIGURAS

Figura 1. Estado runtime global de StealLab: dominios, red, pools y leases DHCP......91
Figura 2. Estructura canónica del repositorio y evidencias del caso M-001......95
Figura 3. Snapshot documentado de VM-LINUX-ANALYSIS asociado a PV-02......98
Figura 4. Estado de VM-SERVICES-SIM y servicio HTTP benigno en el puerto 8080......100
Figura 5. Configuración de StealLab-Net, bridge virbr-steal y direccionamiento interno......103
Figura 6. Verificación offline del staging local de M-003 mediante tamaño, SHA-256 y contenido del archivo comprimido......113
Figura 7. Verificación offline del PCAP de M-004 con comunicación HTTP interna entre 10.10.10.20 y 10.10.10.30:8080......113
Figura 8. Validación funcional del receptor HTTP benigno en VM-SERVICES-SIM......114
Figura 9. Verificación offline del contraste positivo-negativo y del cierre formal de M-005......115
Figura 10. Inventario y hashes SHA-256 principales del caso M-001......124

PARTE I. INTRODUCCIÓN

1 INTRODUCCIÓN

El robo de información se ha consolidado como uno de los problemas centrales de la ciberseguridad contemporánea. La digitalización de servicios personales, corporativos y financieros ha concentrado en los dispositivos de usuario un volumen elevado de credenciales, sesiones persistentes, tokens, configuraciones de acceso, información de navegador y metadatos de actividad. Esta concentración convierte el puesto de usuario en un objetivo de alto valor para amenazas especializadas en obtener información reutilizable.

Dentro de este contexto, los stealers o infostealers ocupan un lugar destacado. A diferencia de otras familias de malware cuyo impacto principal se relaciona con la destrucción, el cifrado o la indisponibilidad de sistemas, los stealers persiguen la extracción de información que puede ser vendida, reutilizada o combinada con otras técnicas. La credencial robada, la cookie de sesión o el token comprometido pueden convertirse en una puerta de entrada a servicios corporativos, repositorios, plataformas SaaS o sistemas internos.

El proyecto StealLab nace de la necesidad de disponer de un entorno académico y defensivo que permita estudiar esta amenaza sin recurrir a prácticas inseguras. La ejecución de malware real requiere medidas de contención, experiencia especializada y controles que exceden el alcance de muchos entornos docentes. Por ello, este TFM propone una aproximación controlada: construir un laboratorio reproducible y validarlo con una simulación benigna defensiva que represente comportamientos observables, sin incorporar capacidades dañinas ni datos reales.

El resultado esperado no es un producto de detección en producción ni una plataforma SOC, sino un laboratorio técnico documentado, trazable y defendible. La aportación reside en la combinación de arquitectura aislada, metodología de análisis, evidencias organizadas, criterios éticos y discusión crítica sobre lo que puede y no puede concluirse a partir de una simulación controlada.

1.1 Contexto general de la ciberseguridad actual

La ciberseguridad actual se caracteriza por la convergencia entre amenazas técnicas, modelos criminales industrializados y dependencia creciente de servicios digitales. El atacante no necesita necesariamente comprometer una infraestructura central si puede obtener credenciales válidas de un usuario con acceso legítimo. Esta realidad desplaza parte del problema hacia la identidad digital, la protección de endpoints, la gestión de sesiones y la visibilidad sobre comportamientos anómalos.

Los informes de amenazas recientes muestran que el malware sigue siendo relevante, pero su uso se integra cada vez más en cadenas de ataque orientadas a objetivos económicos. Los stealers son especialmente importantes en este escenario porque convierten el compromiso de un equipo individual en material aprovechable para accesos posteriores, venta de datos, fraude o extorsión.

La superficie de exposición ya no se limita al perímetro corporativo. Los usuarios operan simultáneamente con correo, identidad federada, repositorios de código, paneles cloud, mensajería y aplicaciones financieras; por ello, el compromiso de un endpoint puede transferirse a servicios que no residen físicamente en el equipo. ENISA describe un panorama de amenazas convergentes y Europol mantiene a los infostealers entre los habilitadores que suministran credenciales y accesos a otros actores. Esta evolución refuerza una lectura centrada en identidad, sesión y trazabilidad, además de la detección tradicional de archivos maliciosos (ENISA, 2025; Europol, 2026).

En ese escenario, la capacidad defensiva depende de correlacionar señales heterogéneas: procesos, ficheros, conexiones, autenticaciones y cambios de contexto. Un laboratorio

académico útil debe reproducir esa lógica de correlación sin reproducir el daño. StealLab adopta precisamente ese equilibrio: limita el realismo ofensivo, pero conserva los elementos necesarios para estudiar cómo se construye una afirmación técnica verificable a partir de observaciones controladas.

Desde una perspectiva de ingeniería de seguridad, este contexto obliga a analizar conjuntamente activo, identidad, sesión y canal de comunicación. El riesgo ya no se explica únicamente por la presencia de un ejecutable malicioso, sino por la capacidad de transformar información local en acceso reutilizable fuera del equipo comprometido. Esta visión amplía el foco desde el archivo hacia la cadena de confianza que une navegador, credenciales, aplicaciones, servicios remotos y mecanismos de autenticación. Por ello, un estudio académico sobre infostealers debe describir tanto el comportamiento técnico como el valor funcional de los datos afectados y las condiciones que permiten su explotación posterior (ENISA, 2024, 2025; MITRE, s. f.-b, s. f.-f).

1.2 Motivación del trabajo

La motivación principal del proyecto es transformar un problema técnico de alto impacto en un objeto de estudio académico controlado. Analizar stealers de forma realista, segura y reproducible exige un entorno que separe la teoría de la práctica ofensiva, que registre evidencias y que permita justificar cada decisión metodológica. StealLab responde a esa necesidad mediante un laboratorio aislado, un caso de validación benigno y una matriz de trazabilidad entre pruebas y evidencias.

La motivación también es pedagógica y profesional. El análisis de malware suele enseñarse mediante herramientas aisladas, mientras que la práctica real exige formular hipótesis, controlar el entorno, preservar evidencia y declarar incertidumbre. El proyecto pretende demostrar que la competencia técnica no consiste únicamente en ejecutar comandos, sino en poder explicar qué pregunta responde cada comando, qué evidencia produce y qué conclusión permite sostener.

La elección de una simulación benigna responde a una relación proporcional entre riesgo y conocimiento esperado. Para validar aislamiento, restaurabilidad, captura de procesos, tráfico y trazabilidad no resulta imprescindible introducir una muestra operativa. Esta decisión permite concentrar el valor del TFM en el diseño experimental y en la calidad de la evidencia, sin desplazar el esfuerzo hacia la contención de una amenaza real.

La motivación investigadora se apoya, por tanto, en una doble necesidad. La primera es técnica: disponer de un entorno donde los observables puedan aislarse, repetirse y conservarse. La segunda es epistemológica: evitar que la experiencia práctica se convierta en una sucesión de acciones sin criterio de prueba. En StealLab, cada componente se justifica por la pregunta que permite responder y por la evidencia que puede producir. Esta orientación convierte el laboratorio en un instrumento de conocimiento y no únicamente en una infraestructura de demostración, porque exige definir previamente qué se observará, cómo se interpretará y bajo qué límites se aceptará una conclusión.

1.3 Alcance defensivo, ético y académico

El alcance experimental opera exclusivamente con datos sintéticos DEMO/NO REAL. M-001 actúa como caso principal de integración y M-002 a M-005 como casos complementarios de validación. La comunicación de red se limita a servicios internos benignos de StealLab-Net; no existe conexión con infraestructura C2 ni Internet real. La memoria explica categorías de comportamiento desde una perspectiva analítica y evita instrucciones ofensivas o reproducibles contra terceros.

El alcance excluye deliberadamente persistencia maliciosa, evasión, robo real, abuso de cuentas, conexión a infraestructura externa y automatización ofensiva. Las exclusiones no son carencias ocultas, sino condiciones de validez: delimitan lo que el experimento puede demostrar. En consecuencia, cualquier analogía con familias reales se formula en términos de categorías observables y nunca como equivalencia funcional.

El tratamiento de evidencias sigue además un criterio de minimización. Las capturas incorporadas a la memoria muestran únicamente configuraciones y resultados del laboratorio; las salidas completas permanecen en el repositorio técnico. Esta separación reduce ruido, evita exposición innecesaria y permite que la memoria conserve una narrativa académica comprensible.

El alcance defensivo también determina la forma de redactar y comunicar los resultados. La utilidad académica no depende de aumentar el realismo ofensivo, sino de mantener una relación proporcionada entre riesgo, aprendizaje y capacidad de verificación. Un diseño éticamente robusto reduce exposición, evita reutilización indebida y conserva únicamente los elementos necesarios para estudiar aislamiento, observabilidad y trazabilidad. Esta proporcionalidad es coherente con los principios de evitar daño, minimizar riesgos y respetar el marco legal aplicable a la investigación en tecnologías de la información (ACM, 2018; DHS, 2012).

1.4 Estructura de la memoria

La memoria se organiza en cinco partes. La primera introduce el problema y su justificación. La segunda desarrolla el estado de la cuestión y el marco teórico. La tercera presenta la pregunta de investigación, los objetivos, la metodología, el diseño y la implementación. La cuarta expone el plan de pruebas, M-001 y los casos complementarios M-002 a M-005, los resultados y la discusión. La quinta cierra con limitaciones, conclusiones, trabajos futuros, referencias y apéndices.

La secuencia de capítulos responde a una lógica argumental acumulativa. Primero se delimita el problema y se revisa el conocimiento disponible; después se formula la pregunta, se define el método y se diseña el artefacto; finalmente se presentan las pruebas, los resultados, la discusión y las conclusiones. Esta organización evita separar artificialmente la construcción técnica de su justificación investigadora y permite rastrear cada decisión desde su fundamento hasta la evidencia que la sustenta.

2 DESCRIPCIÓN DEL PROBLEMA Y JUSTIFICACIÓN

El problema central abordado por este TFM es la dificultad de estudiar de forma segura, documentada y reproducible comportamientos asociados a stealers en un entorno académico. La amenaza es real y relevante, pero su análisis directo mediante malware operativo introduce riesgos técnicos, legales y éticos. Además, una memoria basada únicamente en instalación de herramientas o volcados de consola no constituye una investigación suficiente: es necesario formular un problema, justificar un método, definir categorías de análisis, validar resultados y discutir límites.

La propuesta aprobada establece como objetivo diseñar, construir y validar un laboratorio técnico para el análisis seguro de Stealers, con máquinas virtuales aisladas, red de pruebas controlada, mecanismos de captura, repositorio de evidencias y apoyo LLM supervisado. La memoria final debe demostrar que ese planteamiento se ha cumplido de forma coherente, aunque el alcance validado haya sido ajustado por motivos de seguridad: se sustituye el análisis de malware real por una simulación benigna defensiva documentada.

2.1 Problema técnico

Desde el punto de vista técnico, un laboratorio para análisis de stealers debe resolver aislamiento, restaurabilidad, visibilidad en host, visibilidad en red, control de evidencias y separación entre entorno de pruebas y sistemas reales. La ausencia de cualquiera de estos elementos puede invalidar la utilidad del laboratorio o introducir riesgo operativo. En StealLab, estos requisitos se abordan mediante KVM/libvirt, StealLab-Net, snapshots, VM-SERVICES-SIM, VM-LINUX-ANALYSIS, datos sintéticos y repositorio PV/EV.

El problema técnico puede expresarse como un conjunto de dependencias: si la red no está aislada, la prueba no es segura; si el estado no es restaurable, la repetición pierde control; si no existe telemetría, el comportamiento no es observable; y si la evidencia no se identifica e integra, el resultado no es auditable. Estas dependencias obligan a diseñar el laboratorio como un sistema y no como una colección de utilidades.

También debe distinguirse la configuración persistente del estado runtime. Una definición XML puede probar que la red o la máquina están declaradas, pero no que se encuentren activas en un instante concreto. StealLab conserva evidencias de ambos planos y documenta su temporalidad para evitar conclusiones incompatibles.

2.2 Problema metodológico

Desde el punto de vista metodológico, el reto consiste en convertir observaciones técnicas en resultados académicos. Un comando ejecutado o una salida de consola no constituyen por sí mismos una conclusión. Es necesario asociar cada prueba a un criterio de aceptación, una evidencia, una interpretación y una limitación. Esta memoria adopta un modelo PV/EV para mantener esa trazabilidad.

La dificultad metodológica principal consiste en evitar dos errores opuestos. El primero es sobreafirmar: interpretar una conexión HTTP interna como exfiltración real o un hash como prueba de autoría. El segundo es infrautilizar la evidencia: presentar capturas sin explicar el criterio de aceptación que satisfacen. El modelo PV/EV resuelve ambos problemas al vincular pregunta, procedimiento, evidencia, interpretación y límite.

Este enfoque convierte cada prueba en una unidad refutable. Un tercero puede revisar la evidencia, recalcular un hash o repetir el procedimiento y discrepar de la interpretación. Esa posibilidad de revisión es esencial para que el laboratorio tenga valor investigador y no sea únicamente una demostración técnica.

El problema metodológico puede formularse como una cuestión de inferencia: qué permite afirmar una evidencia y qué permanece fuera de su alcance. Una captura, un hash o una definición de red son datos observables, pero su significado depende del contexto, del procedimiento y del criterio de aceptación previamente fijado. La metodología debe impedir saltos lógicos entre dato y conclusión, especialmente cuando se trabaja con analogías respecto de amenazas reales. En este sentido, el valor del modelo PV/EV reside en disciplinar la interpretación y en hacer explícita la cadena que conecta objetivo, prueba, evidencia, resultado y limitación (Hevner et al., 2004; Peffers et al., 2007; Yin, 2018).

2.3 Justificación social, profesional y académica

La justificación social deriva del impacto del robo de credenciales y sesiones en usuarios y organizaciones. La justificación profesional se relaciona con la necesidad de formar analistas capaces de interpretar evidencias sin comprometer sistemas reales. La justificación académica reside en proponer un diseño reproducible y ético que permite estudiar una categoría de amenaza relevante sin convertir el TFM en una guía ofensiva.

Desde una perspectiva social, el robo de identidad digital afecta a usuarios aunque el dispositivo comprometido sea reconstruido, porque sesiones y tokens pueden conservar validez fuera del endpoint. Profesionalmente, este fenómeno exige coordinar respuesta de endpoint, identidad, SaaS y red. Académicamente, ofrece un caso adecuado para estudiar cómo traducir una amenaza compleja a categorías seguras de laboratorio.

La propuesta aporta además un modelo reutilizable en docencia: la misma arquitectura de pruebas puede emplearse para enseñar contención, observabilidad y preservación de evidencias con artefactos benignos. La transferibilidad se sitúa, por tanto, en el método de laboratorio y no en la supuesta representación exhaustiva de una familia de malware.

La justificación profesional se refuerza porque el análisis defensivo exige competencias transferibles: formular hipótesis operativas, documentar configuraciones, conservar evidencias, distinguir hechos de inferencias y comunicar incertidumbre. Estas capacidades son aplicables a respuesta a incidentes, threat hunting, análisis forense y validación de controles, incluso cuando las herramientas concretas cambian. Académicamente, la aportación se sitúa en la articulación de esas competencias dentro de un caso limitado y auditable, evitando confundir novedad científica con novedad instrumental. El proyecto aporta un método de estudio reproducible más que una pretensión de descubrir una nueva familia o técnica.

2.4 Relación con la propuesta aprobada

Tabla 1. Mapa de cumplimiento entre la propuesta aprobada y la memoria final

Elemento de la propuesta aprobada	Cumplimiento en StealLab	Evidencia o tratamiento en memoria
Laboratorio técnico seguro	Red aislada, VMs separadas por rol, ausencia de Internet desde las VMs y snapshots	Capítulos 7, 8, 9 y PV-01/PV-02
Análisis de Stealers	Tratamiento defensivo de comportamientos tipo stealer mediante M-001 y casos complementarios M-002 a M-005	Capítulos 3, 4, 10 y 12
Repositorio de evidencias	Estructura PV/EV con casos M-001 a M-005, hashes y manifiestos de cierre	Capítulos 8, 9, 11 y Apéndice 17.5
Uso LLM supervisado	Apoyo documental, no fuente de verdad ni decisión automática	Capítulos 6, 11, 12 y PV-07

Elemento de la propuesta aprobada	Cumplimiento en StealLab	Evidencia o tratamiento en memoria
Resultados esperados	Arquitectura, entorno virtual, metodología, evidencias, casos de estudio, memoria y defensa	Conclusiones y trabajos futuros

El mapa de cumplimiento debe interpretarse junto con el cambio de alcance experimental. La propuesta se mantiene en sus objetivos de diseño, construcción, observación y documentación; lo que se sustituye es el mecanismo de validación, pasando de una posible ejecución de muestras a un caso benigno. Esta modificación conserva la pregunta central y reduce el riesgo, pero limita explícitamente las conclusiones sobre comportamiento malicioso real.

La coherencia entre propuesta y memoria se verifica mediante correspondencia bidireccional: cada objetivo dispone de capítulos y evidencias asociados, y cada resultado del laboratorio responde a un objetivo declarado. No se incorporan resultados sin anclaje metodológico ni se mantienen objetivos sin tratamiento verificable.

El cumplimiento de la propuesta se interpreta de manera sustantiva y no meramente nominal. Los componentes comprometidos se traducen en requisitos verificables: aislamiento, separación de funciones, restaurabilidad, captura de observables, conservación de evidencias y apoyo documental supervisado. El ajuste principal consiste en sustituir la ejecución de una muestra maliciosa por una simulación benigna M-001. Esta adaptación conserva el objetivo de validar el laboratorio y reduce de forma proporcionada los riesgos legales, éticos y operativos.

PARTE II. FUNDAMENTACIÓN TEÓRICA Y ESTADO DE LA CUESTIÓN

3 ESTADO DE LA CUESTIÓN

El estado de la cuestión sitúa StealLab dentro del conocimiento existente sobre malware orientado al robo de información, análisis defensivo, laboratorios controlados y gestión de evidencias digitales. Este capítulo no se limita a nombrar familias de malware: organiza fuentes, casos, conceptos y limitaciones para justificar por qué tiene sentido construir un laboratorio académico seguro para estudiar comportamientos tipo stealer sin ejecutar malware real. (Page et al., 2021; ENISA, 2024, 2025)

La revisión se interpreta con una idea central: un stealer no debe analizarse solo como un fichero malicioso, sino como parte de una cadena de valor criminal en la que la información robada puede convertirse en acceso, fraude, extorsión, venta de logs o etapa previa a ataques más amplios. Por ello, las fuentes seleccionadas se usan para entender el fenómeno y para justificar decisiones metodológicas del laboratorio, no para reproducir técnicas ofensivas.

La revisión se articula en torno a cuatro ejes: evolución técnica del robo de información, industrialización económica, reutilización de identidades digitales y métodos defensivos de observación. Esta organización permite pasar de la descripción de familias a una explicación causal del problema: qué activos se buscan, por qué conservan valor, cómo se integran en cadenas posteriores y qué evidencia puede obtenerse de forma segura (European Union Agency for Cybersecurity [ENISA], 2024, 2025; Europol, 2023, 2025b).

El corpus combina publicaciones académicas, normas, informes institucionales, documentación judicial y análisis técnicos primarios. No todas las fuentes tienen la misma finalidad: las normas fijan conceptos y procedimientos; los artículos aportan métodos y resultados; los organismos describen tendencias; y los casos técnicos ilustran mecanismos concretos. Esta triangulación evita depender de una única narrativa y permite identificar coincidencias y discrepancias.

3.1 Criterios de búsqueda y selección de fuentes

La selección de fuentes se ha guiado por autoridad, relevancia defensiva, actualidad y trazabilidad. Se priorizan organismos públicos, marcos técnicos consolidados, documentación oficial y análisis publicados por equipos de inteligencia de amenazas reconocidos. Este criterio permite reducir el riesgo de incorporar información no verificada o procedente de contenidos sensacionalistas. (Page et al., 2021)

En ciberseguridad, la fuente no es neutra. Un blog técnico, un informe de empresa, una base de conocimiento institucional y una publicación académica no cumplen la misma función. En este TFM, las fuentes oficiales se emplean para definiciones y marcos; los informes de threat intelligence se emplean para casos reales; las publicaciones académicas se emplean para justificar método y discusión; y las herramientas se documentan solo como instrumentos defensivos.

El criterio de exclusión es igual de importante que el de inclusión. Se excluye cualquier fuente cuyo valor principal sea operativo ofensivo, evasión, explotación directa o descarga de muestras. Cuando una familia aparece en fuentes secundarias pero no se dispone de respaldo suficiente, se evita integrarla como caso cerrado. Esta regla protege la calidad académica y evita que el marco teórico se convierta en una recopilación no contrastada.

Tabla 2. Criterios de búsqueda, selección y uso de fuentes

Criterio	Aplicación	Razón metodológica
Autoridad	NIST, ENISA, MITRE, Mandiant/Google Cloud, documentación oficial de herramientas	Reduce ambigüedad terminológica y mejora trazabilidad

Criterio	Aplicación	Razón metodológica
Actualidad	Casos 2024-2025 cuando aportan contexto sobre credenciales, MaaS o infraestructura	El ecosistema infostealer cambia con rapidez
Orientación defensiva	Uso de fuentes para análisis, prevención, respuesta e interpretación	Evita contenido accionable ofensivo
Coherencia con StealLab	La fuente debe ayudar a explicar laboratorio, evidencia o límites	Impide convertir el TFM en catálogo

La revisión adopta un enfoque narrativo estructurado, no una revisión sistemática exhaustiva. Se documentan cadenas de búsqueda en español e inglés relacionadas con infostealer, password stealer, browser credential theft, web session cookie theft, Malware-as-a-Service, stolen logs, initial access, malware analysis, digital evidence y isolated laboratory. La búsqueda se concentra en publicaciones académicas revisadas por pares, normas, documentos institucionales y análisis técnicos primarios publicados entre 2013 y 2026, con incorporación selectiva de trabajos anteriores cuando constituyen antecedentes conceptuales. La lógica de transparencia se inspira en PRISMA 2020, aunque el alcance y el diseño de este TFM no permiten presentarlo como una revisión sistemática formal (Page et al., 2021).

La jerarquía de evidencia empleada distingue cinco niveles: normas y guías públicas; artículos académicos; informes de organismos policiales o de ciberseguridad; investigaciones técnicas de fabricantes; y documentación oficial de herramientas. Las fuentes comerciales se utilizan para describir campañas o familias concretas, pero sus afirmaciones se contrastan, cuando es posible, con MITRE ATT&CK, CISA, ENISA, Europol, resoluciones judiciales o literatura académica. Se excluyen repositorios de muestras, tutoriales de evasión y publicaciones sin autoría, fecha o metodología verificable. Esta regla fortalece la auditabilidad de la revisión y reduce el sesgo de dependencia de una única fuente.

La revisión documental se consolidó mediante consultas en repositorios institucionales y académicos vinculados con NIST, ENISA, Europol, CISA, MITRE ATT&CK, ACM, USENIX, IETF y documentación oficial de las herramientas utilizadas. La última consolidación documental se realizó el 11 de julio de 2026. No se conserva un registro completo del número inicial de resultados de todas las búsquedas históricas; por ello, la memoria no reconstruye retrospectivamente cifras que no pueden verificarse y reconoce esta limitación de trazabilidad bibliográfica.

Como estrategia reproducible para futuras actualizaciones, se definen combinaciones booleanas por bloques conceptuales. Un primer bloque identifica la amenaza mediante términos como (infostealer OR stealer OR "information stealer"); un segundo bloque delimita los activos mediante (credential* OR cookie* OR token* OR browser OR wallet*); y un tercero incorpora el propósito defensivo mediante (analysis OR detection OR sandbox OR "digital evidence" OR laboratory). Las cadenas se adaptan a la sintaxis de cada recurso, manteniendo documentados la fecha, los filtros, la fuente consultada y la decisión de inclusión o exclusión.

La lectura crítica se basa en cuatro preguntas: qué afirma la fuente, qué evidencia aporta, qué limitaciones reconoce y qué función cumple dentro del TFM. Una fuente puede ser válida para describir una campaña concreta sin ser suficiente para definir una categoría general. Del mismo modo, la documentación de una herramienta acredita su funcionamiento esperado, pero no demuestra por sí sola que la implementación local haya alcanzado ese estado. Esta separación entre conocimiento externo y evidencia propia reduce el riesgo de razonamiento circular.

La calidad de la revisión depende también de la función asignada a cada fuente. Una norma puede estabilizar terminología; un artículo revisado por pares puede aportar un método; un informe institucional puede describir tendencias; y un análisis de inteligencia de amenazas

puede documentar una campaña concreta. Mezclar estas funciones sin diferenciación aumenta el riesgo de atribuir autoridad general a una observación particular. Por ello, la selección debe valorar no solo quién publica, sino qué evidencia presenta, qué alcance declara y qué relación guarda con la pregunta del TFM. Esta lectura funcional permite integrar fuentes heterogéneas sin tratarlas como equivalentes (Page et al., 2021).

3.2 Evolución del fenómeno stealer

El fenómeno stealer tiene raíces en el spyware, los troyanos bancarios, los keyloggers y las botnets orientadas al robo de credenciales. Lo que cambia en la etapa reciente no es solo la existencia del robo de datos, sino la especialización del producto criminal: las familias modernas tienden a empaquetar información reutilizable y a integrarse en mercados donde los logs se venden como insumos para nuevas intrusiones. (Thomas et al., 2017; Nurmi et al., 2023)

La evolución técnica ha ampliado el tipo de activos buscados. Ya no se trata únicamente de contraseñas guardadas: también son relevantes cookies de sesión, tokens, perfiles de navegador, extensiones, wallets, información de sistema y referencias a servicios SaaS o cloud. Esta ampliación obliga a que un laboratorio académico no trate el dato robado como una unidad genérica, sino como una categoría con distinto valor defensivo. (Somé et al., 2025; Microsoft, 2025a)

La evolución económica también es decisiva. El modelo Malware-as-a-Service permite separar desarrollo, distribución, explotación y monetización. Esta separación dificulta la atribución y hace que el análisis de una muestra concreta no sea suficiente para comprender el fenómeno. StealLab responde a esta realidad modelando categorías observables, no una familia concreta.

Tabla 3. Evolución del fenómeno stealer y su implicación en StealLab

Etapa	Rasgo dominante	Implicación para StealLab
Robo puntual	Captura de contraseñas o formularios	Representar credenciales sintéticas
Perfil de navegador	Sesiones, cookies, extensiones y metadatos	Representar navegador_demo sin cookies reales
Economía de logs	Venta de paquetes por usuario/equipo	Repositorio PV/EV e integridad por hash
MaaS	Separación entre desarrollador y operador	Discusión sobre ecosistema, no reproducción

La literatura permite identificar una transición desde el robo aislado de contraseñas hacia la apropiación de perfiles de identidad digital. Los estudios sobre credenciales robadas muestran que el riesgo no depende únicamente de la contraseña, sino también del origen del compromiso y de la posibilidad de reutilización posterior (Thomas et al., 2017). En paralelo, los estudios sobre perfiles de navegador destacan que cookies, historiales, extensiones y almacenes locales forman un conjunto compuesto cuya exposición puede conservar valor incluso cuando la contraseña ha sido modificada (Somé et al., 2025; Tyler & Nunes, 2024).

Otra transformación relevante es la ampliación del objetivo técnico. Las campañas y mercados actuales ya no se limitan a una única plataforma o navegador: se orientan a perfiles de identidad, sesiones SaaS, credenciales cloud y activos de criptomonedas. El estudio de los perfiles de navegador confirma que estos directorios reúnen cookies, extensiones, permisos y decisiones de confianza, mientras los informes europeos describen un mercado criminal que combina accesos y servicios especializados (Somé et al., 2025; Europol, 2026). Esta evolución refuerza la decisión de StealLab de modelar categorías de activos y evidencias, en lugar de vincular el laboratorio a una familia o plataforma que podría quedar obsoleta.

La evolución del fenómeno puede interpretarse como un desplazamiento desde la captura de secretos aislados hacia la apropiación de contextos completos de identidad digital.

Contraseñas, cookies, tokens, perfiles y metadatos no tienen el mismo significado ni requieren la misma respuesta defensiva. Su combinación permite reconstruir relaciones entre usuario, dispositivo y servicio, aumentando el valor del conjunto respecto de cada elemento por separado. Esta transformación explica por qué una taxonomía basada exclusivamente en familias resulta insuficiente: para el análisis defensivo es más útil clasificar activos, mecanismos de acceso, persistencia de sesión y posibilidades de reutilización (Thomas et al., 2017; Campobasso & Allodi, 2020; Somé et al., 2025).

3.3 Malware-as-a-Service y economía de credenciales

Malware-as-a-Service (MaaS) describe la comercialización de capacidades maliciosas como servicio. En lugar de que cada operador desarrolle todo el malware, puede alquilar paneles, licencias, infraestructura o soporte. Este modelo reduce barreras de entrada, profesionaliza la oferta y acelera la sustitución de familias cuando una operación es interrumpida. (Patsakis et al., 2024; Europol, 2023)

La economía de credenciales transforma la información robada en activo monetizable. Un log puede venderse sin que el comprador conozca cómo se obtuvo; un operador puede usar credenciales expuestas para acceder a servicios SaaS; un actor posterior puede emplearlas en fraude o extorsión. Esta separación entre infección inicial e impacto final explica por qué el TFM analiza credenciales, sesiones y tokens como activos de riesgo. (Campobasso & Allodi, 2020; Nurmi et al., 2023)

StealLab no reproduce MaaS ni infraestructura criminal. Lo que hace es tomar de ese fenómeno una lección defensiva: si la información robada tiene valor, el laboratorio debe permitir observar qué tipo de información se representa, cómo se conserva la evidencia y qué límites tiene la interpretación. La memoria, por tanto, distingue entre contexto criminal real y simulación académica segura.

Tabla 4. Malware-as-a-Service y economía de credenciales

Concepto	Descripción defensiva	Relación con StealLab
MaaS	Comercialización de malware, paneles o soporte como servicio	Justifica estudiar ecosistema, no solo binarios
Log robado	Paquete de información extraída y reutilizable	Inspira clasificación de datos DEMO
Acceso inicial	Uso de credenciales para entrar a servicios	Conecta M-001 con riesgo real
Afiliado	Actor que distribuye o monetiza capacidades	Contexto, no elemento simulado

El MaaS puede entenderse como una organización modular de la actividad delictiva. Desarrollo, distribución, infraestructura, soporte, venta de accesos y explotación final pueden recaer en actores distintos. La literatura sobre mercados de malware muestra que estas separaciones reducen costes de entrada y facilitan la especialización, mientras los informes de Europol sitúan el crime-as-a-service como un multiplicador de escala y resiliencia del ecosistema (Patsakis et al., 2024; Europol, 2023).

Dentro de esta cadena, los logs robados funcionan como productos con atributos de calidad: frescura, geolocalización, conjunto de servicios, presencia de cookies, huella del dispositivo, privilegios y capacidad de recuperación. Los modelos de impersonation-as-a-service añaden filtros y automatización para seleccionar víctimas y reutilizar perfiles completos, lo que explica por qué el valor defensivo de una evidencia no se limita al fichero que contiene una contraseña (Campobasso & Allodi, 2020). El estudio empírico de la economía del malware también confirma que infraestructura, afiliados y mercados forman parte del fenómeno y deben considerarse en la interpretación, aunque no se reproduzcan en el laboratorio (Nurmi et al., 2023).

El modelo MaaS introduce una lógica de especialización semejante a una cadena de suministro ilícita. Desarrollo, distribución, soporte, alojamiento y monetización pueden separarse, de modo que la interrupción de un componente no elimina necesariamente el ecosistema. Desde la defensa, esta modularidad obliga a distinguir entre capacidad técnica, operador, infraestructura y consumidor final de los datos. También explica por qué la atribución basada únicamente en un artefacto puede ser frágil. Para StealLab, la consecuencia metodológica es centrar la observación en categorías verificables y evitar inferir identidad, afiliación o intención a partir de señales que solo demuestran transferencia o tratamiento de datos (Patsakis et al., 2024; Europol, 2023).

3.4 Casos reales documentados

Los casos reales se emplean como justificación externa del problema. El caso UNC5537/Snowflake documentado por Mandiant/Google Cloud es relevante porque muestra cómo credenciales previamente expuestas por infostealers pueden ser reutilizadas para acceder a instancias de clientes y habilitar extorsión. La enseñanza no es técnica ofensiva, sino defensiva: el endpoint comprometido puede convertirse en origen indirecto de un incidente corporativo posterior. (Google Cloud, 2024; Europol, 2025a)

Lumma/LummaC2 representa la dimensión MaaS y la importancia de la infraestructura. La disrupción pública de Lumma en 2025 ilustra que los infostealers pueden alcanzar escala significativa y que su interrupción requiere actuación coordinada de industria y autoridades. StealLab usa este caso para reforzar la necesidad de laboratorios defensivos, no para describir técnicas de ejecución. (Microsoft, 2025a; Europol, 2025a)

RedLine, Raccoon, Vidar, RisePro, MetaStealer, Ducktail y CookieMiner se tratan como referencias de contexto. Cada una ilustra una dimensión: robo de navegador, credenciales, wallets, especialización en cuentas corporativas, venta de logs o uso posterior de accesos. Ninguna de estas familias se descarga, ejecuta o replica en el laboratorio.

Tabla 5. Casos reales documentados y uso argumental en la memoria

Caso/familia	Dimensión ilustrada	Uso en la memoria
UNC5537/Snowflake	Reutilización empresarial de credenciales expuestas	Justificación de credenciales y sesiones como activos críticos
Lumma/LummaC2	MaaS, escala e infraestructura	Contexto de actualidad y necesidad defensiva
RedLine/Raccoon/Vidar	Familias asociadas a robo de datos de navegador y logs	Taxonomía, no ejecución
Ducktail	Especialización contra cuentas de negocio	Explica diversidad de objetivos
CookieMiner	Cookies y activos de criptomonedas	Conecta navegador y wallet_demo

La operación internacional contra RedLine y META, conocida como Operation Magnus, proporciona un ejemplo de intervención coordinada sobre plataformas de infostealers y sus servidores. La documentación judicial y policial muestra que estas familias no deben estudiarse únicamente por su código, sino también por la infraestructura, los clientes, los datos sustraídos y la posterior comercialización (U.S. Department of Justice, 2024a). De forma similar, las actuaciones contra Raccoon Infostealer acreditan la existencia de servicios de suscripción y paneles operativos usados por múltiples clientes (U.S. Department of Justice, 2024b). La incautación posterior de dominios vinculados a LummaC2 confirmó que la infraestructura de distribución y recepción forma parte del objeto de intervención, no solo el binario (U.S. Department of Justice, 2025).

Genesis Market constituye un antecedente especialmente útil para comprender la venta de identidades digitales completas. La actuación coordinada de 2023 describió un mercado de credenciales, cookies y fingerprints empleados para suplantar a víctimas, por lo que conecta directamente con la distinción entre secreto de autenticación y sesión ya autenticada (U.S.

Department of Justice, 2023). Otros casos amplían la diversidad: ICONICSTEALER ilustra el robo de datos de navegador (CISA, 2023); DUCKTAIL, la orientación hacia cuentas empresariales (WithSecure, 2022); CookieMiner, la combinación de cookies y activos de criptomonedas (Unit 42, 2019); y Vidar 2.0, la evolución continua de familias consolidadas (Trend Micro, 2025). Las alertas públicas sobre LokiBot constituyen además un antecedente institucional de malware orientado a extraer credenciales, wallets y datos de aplicaciones (CISA, 2020).

La actualidad del problema también se observa en la convergencia entre servicios criminales, loaders, initial access brokers e infostealers. El IOCTA 2026 incluye los infostealers entre los vectores de acceso que alimentan cadenas delictivas posteriores y subraya que las capacidades se combinan de forma modular. En StealLab esta convergencia se utiliza únicamente como evidencia externa de relevancia y para seleccionar categorías observables; no se reproducen muestras, infraestructura ni procedimientos de infección (Europol, 2026). Los informes de Meta sobre campañas dirigidas a cuentas empresariales refuerzan, además, la dimensión de abuso de activos comerciales y redes sociales (Meta, 2023).

Los casos reales deben leerse como evidencia contextual, no como plantillas de reproducción. Su utilidad consiste en mostrar relaciones plausibles entre compromiso de endpoint, exposición de identidad y consecuencias posteriores, así como en identificar activos que merecen protección prioritaria. Sin embargo, cada caso se desarrolla en condiciones organizativas, temporales y técnicas propias. La transferencia al laboratorio debe limitarse a categorías de análisis, evitando asumir que una simulación benigna reproduce escala, persistencia, evasión o impacto. Esta separación protege la validez del TFM y permite usar incidentes públicos para fundamentar relevancia sin convertirlos en equivalentes experimentales.

3.5 Brecha identificada

La brecha no consiste en que falten herramientas de análisis de malware. Existen sandboxes, analizadores de red, utilidades forenses y plataformas de inteligencia de amenazas. La brecha que aborda StealLab es más específica: disponer de un laboratorio académico, seguro, reproducible y trazable que permita estudiar comportamientos tipo stealer sin recurrir a malware real ni datos sensibles.

En muchos trabajos técnicos, el énfasis recae en instalar herramientas o pegar salidas de consola. Eso no basta para un TFM investigador. La brecha metodológica es convertir una práctica técnica en un objeto de estudio: pregunta, objetivos, unidad de análisis, evidencias, resultados, discusión y límites. StealLab se sitúa precisamente en ese espacio.

La aportación del proyecto es integradora. Une teoría sobre infostealers, diseño de red aislada, virtualización, caso benigno, captura de procesos, PCAP, hashes, PV/EV y revisión ética. Esa integración no sustituye un laboratorio profesional, pero sí aporta una base universitaria defendible.

La investigación sobre análisis dinámico ha producido sandboxes, técnicas de instrumentación y métodos de clasificación maduros, pero también ha mostrado limitaciones de evasión, variabilidad de ejecución y dificultad para reproducir resultados entre entornos (Or-Meir et al., 2019; Afianian et al., 2020; Avllazagaj et al., 2021). Estas limitaciones son especialmente relevantes en un contexto docente: aumentar el realismo mediante malware operativo puede reducir la seguridad y no garantiza, por sí mismo, mayor validez científica.

La brecha que aborda StealLab es, por tanto, de diseño y de evidencia. Se necesita un artefacto académico que permita formular afirmaciones modestas, contrastables y respaldadas por registros preservados. La literatura reciente sobre replicabilidad en análisis de malware señala que la ausencia de artefactos, configuraciones y protocolos claros dificulta

comprobar resultados publicados (Olszewski et al., 2025). StealLab responde con una arquitectura explícita, un caso benigno, criterios de aceptación y trazabilidad PV/EV.

La brecha puede definirse con mayor precisión como ausencia de un puente metodológico entre conocimiento sobre la amenaza y práctica académica segura. Las herramientas existentes resuelven funciones parciales, pero no garantizan por sí mismas que el estudiante formule criterios de aceptación, preserve evidencias o limite sus conclusiones. El problema no es disponer de virtualización, captura de red o hashing, sino integrarlos en un procedimiento que pueda ser revisado por terceros. Esta perspectiva desplaza la contribución desde la suma de componentes hacia la arquitectura de razonamiento que los conecta, coherente con design science y con la evaluación de artefactos en contexto (Hevner et al., 2004; Peffers et al., 2007).

3.6 Relevancia actual de los stealers en la cadena de ataque

Los stealers son relevantes porque convierten información local en acceso remoto potencial. Una contraseña almacenada, una cookie de sesión o un token pueden permitir que un atacante actúe como usuario legítimo. Por ello, la defensa moderna debe mirar más allá del malware como archivo y considerar la identidad digital como superficie de ataque. (MITRE, s. f.-b, s. f.-f; Google Cloud, 2025)

La relevancia aumenta en entornos híbridos y SaaS. Un dispositivo personal o corporativo puede contener sesiones persistentes de correo, CRM, repositorios, plataformas cloud, herramientas de colaboración o paneles administrativos. Si esos activos se exponen, el impacto puede producirse fuera del equipo inicial y en un tiempo posterior.

Esta lógica justifica que M-001 represente credencial, navegador, sistema y wallet mediante ficheros sintéticos. Aunque el caso sea benigno, el mapa conceptual corresponde a categorías reales de riesgo documentadas en marcos y casos públicos.

El desplazamiento hacia la identidad modifica la lógica de defensa. MITRE ATT&CK separa el acceso a credenciales, la obtención de credenciales desde navegadores y el robo de cookies de sesión, porque cada técnica produce capacidades distintas para el atacante (MITRE, s. f.-b, s. f.-e, s. f.-f). Una cookie válida puede reducir la utilidad de un cambio de contraseña inmediato si la sesión no se revoca, mientras un token de API puede mantener acceso programático hasta su expiración o revocación.

Los datos de respuesta a incidentes refuerzan esta lectura. M-Trends 2025 situó las credenciales robadas entre los principales vectores iniciales observados por Mandiant, con un 16 % de los casos investigados, y el caso UNC5537 mostró la reutilización de credenciales previamente expuestas en entornos Snowflake sin que la intrusión inicial tuviera que producirse dentro de la propia plataforma (Google Cloud, 2024, 2025). El porcentaje no se extrapola directamente a StealLab, pero sustenta la relevancia de modelar credenciales, sesiones y metadatos como activos diferenciados. El Microsoft Digital Defense Report 2025 sitúa este fenómeno dentro de una economía de cibercrimen cada vez más centrada en identidad, acceso y servicios especializados (Microsoft, 2025b).

La relevancia defensiva de los infostealers reside en que reducen la distancia entre compromiso local y acceso remoto legítimo. Cuando el dato sustraído conserva contexto de autenticación o sesión, el atacante puede operar mediante mecanismos aparentemente válidos y desplazar el incidente hacia servicios externos al endpoint. Esto exige respuestas coordinadas que incluyan revocación de sesiones, rotación de secretos y revisión de actividad en servicios, no solo limpieza del dispositivo. El marco conceptual del TFM debe reflejar esta continuidad entre endpoint e identidad, aunque StealLab no reproduzca servicios corporativos reales ni acciones de remediación sobre cuentas auténticas (MITRE, s. f.-b, s. f.-e, s. f.-f).

3.7 Delimitación entre estado del arte, estado de la cuestión y marco teórico

El estado del arte describe herramientas, técnicas y soluciones disponibles; el estado de la cuestión explica cómo se ha abordado el problema en fuentes relevantes; el marco teórico define conceptos y relaciones. Separar estos planos evita que el documento mezcle definiciones, casos y herramientas sin estructura.

En StealLab, el estado del arte incluye sandboxing, virtualización, análisis dinámico, captura PCAP, hashing y repositorios de evidencias. El estado de la cuestión incluye informes sobre infostealers, MaaS y casos reales. El marco teórico define malware, stealer, credencial, cookie, token, evidencia digital, simulación y reproducibilidad.

Esta separación es esencial para delimitar la aportación del TFM: el valor del trabajo no reside en una herramienta aislada, sino en la articulación entre conocimiento previo, diseño metodológico y validación técnica.

Tabla 6. Delimitación entre estado del arte, estado de la cuestión y marco teórico

Plano	Pregunta que responde	Ejemplo en StealLab
Estado del arte	Qué enfoques/herramientas existen	KVM/libvirt, PCAP, hashing, sandboxes
Estado de la cuestión	Cómo se entiende el problema	Infostealers, MaaS, casos Snowflake/Lumma
Marco teórico	Qué conceptos permiten interpretar	Malware, stealer, evidencia, simulación

A efectos metodológicos, el estado del arte se centra en la capacidad técnica disponible; el estado de la cuestión sintetiza controversias, tendencias y resultados publicados; y el marco teórico proporciona las categorías con las que se interpreta la evidencia. Esta separación evita usar una ficha de producto como prueba científica o una técnica de ATT&CK como demostración de que una conducta ocurrió. En StealLab, una afirmación solo se considera resultado cuando existe evidencia propia asociada; las fuentes externas sirven para contextualizarla.

La distinción también permite separar tres niveles de verdad: lo observado directamente en M-001, lo inferido a partir de esas observaciones y lo documentado por terceros sobre amenazas reales. Esta arquitectura argumental aplica una regla de no sobreafirmación: una PCAP interna prueba la existencia de un flujo capturado, pero no prueba una exfiltración criminal; una lista de técnicas ATT&CK orienta la lectura, pero no atribuye una familia; y un caso real demuestra plausibilidad externa, no equivalencia experimental.

La separación entre estos planos cumple una función argumental. El estado del arte delimita capacidades disponibles; el estado de la cuestión identifica consensos, controversias y vacíos; y el marco teórico proporciona las categorías con las que se interpretará la evidencia. Cuando estos niveles se confunden, una descripción de herramienta puede presentarse como explicación del fenómeno o una observación de campaña puede generalizarse como definición universal. En StealLab, mantener la distinción permite demostrar que la selección técnica deriva de un problema investigado y que los resultados se interpretan mediante conceptos previamente definidos, no mediante etiquetas añadidas después de observar las pruebas.

3.8 Principales líneas de investigación y documentación técnica relacionadas

Las líneas documentales relevantes se agrupan en análisis de malware, laboratorios aislados, análisis dinámico, análisis de red, evidencia digital y apoyo documental mediante LLM supervisado. Cada línea aporta una parte, pero ninguna por sí sola cubre el TFM completo. (Or-Meir et al., 2019; Afianian et al., 2020; NIST, 2006)

El análisis de malware aporta categorías de comportamiento y vocabulario. Los laboratorios aislados aportan contención. El análisis dinámico aporta observación de ejecución. El análisis de red aporta PCAP y flujo. La evidencia digital aporta integridad, identificación y contexto. El LLM supervisado aporta organización documental bajo revisión humana.

La combinación de estas líneas permite que StealLab no sea un catálogo de herramientas. Cada técnica se incluye porque resuelve una necesidad metodológica: observar, contener, preservar o interpretar.

Tabla 7. Líneas de investigación y documentación técnica relacionadas

Línea	Aporta	Límite
Análisis de malware	Categorías de comportamiento	No se ejecuta malware real
Laboratorio aislado	Contención y seguridad	No equivale a producción
Análisis de red	PCAP y comunicación	No C2 real
Evidencia digital	Trazabilidad e integridad	Depende del orden documental
LLM supervisado	Síntesis y coherencia	No fuente de verdad

El análisis estático estudia propiedades del artefacto sin ejecutarlo; el análisis dinámico observa su comportamiento durante la ejecución; y los enfoques híbridos combinan ambas fuentes. Las revisiones del área señalan que el análisis dinámico aporta contexto conductual, pero depende de la cobertura de ejecución y puede ser alterado por mecanismos de detección del entorno (Or-Meir et al., 2019; Afianian et al., 2020). Esta limitación justifica que StealLab no utilice la ausencia de un evento como prueba de ausencia de capacidad.

La línea forense aporta una disciplina complementaria: no basta con observar, también hay que preservar la relación entre artefacto, origen, fecha, herramienta y resultado. NIST SP 800-86 y NISTIR 8387 recomiendan integrar técnicas forenses en la respuesta a incidentes y mantener procedimientos de conservación verificables (NIST, 2006, 2022). StealLab traslada estos principios a escala académica mediante identificadores, hashes, matrices y repositorio estructurado.

Estas líneas pueden organizarse según el tipo de pregunta que resuelven. El análisis de malware pregunta qué hace un artefacto; la contención pregunta dónde puede hacerlo sin causar daño; la forensia pregunta cómo preservar lo observado; la observabilidad pregunta qué señales están disponibles; y la metodología pregunta qué conclusiones son legítimas. La aportación de StealLab emerge de su intersección. Ninguna disciplina aislada basta para sostener el resultado, porque una observación sin preservación pierde auditabilidad y una preservación sin interpretación carece de significado investigador (NIST, 2006, 2022; Or-Meir et al., 2019).

3.9 Función metodológica de los casos reales y límites de transferencia

Los casos reales cumplen una función argumental: muestran que el problema existe y que tiene consecuencias. No cumplen función experimental dentro de StealLab porque no se reproducen, no se descargan muestras y no se simulan infraestructuras criminales reales.

Esta distinción protege el TFM de dos riesgos. El primero es ético: no convertir el trabajo en guía ofensiva. El segundo es metodológico: no atribuir a M-001 capacidades que pertenecen a familias reales. El caso benigno valida el laboratorio; los casos reales justifican el objeto de estudio.

La comparación se realiza a nivel de categorías: credenciales, cookies, sesiones, logs, MaaS, acceso inicial y C2. StealLab representa esas categorías de forma segura mediante datos DEMO, HTTP interno y evidencias verificables.

La validez externa de M-001 procede de una analogía limitada: representa clases de datos y pasos observables que aparecen en fuentes reales, pero elimina intención, persistencia, evasión, infraestructura remota y daño. Esta estrategia se aproxima a una prueba de concepto

defensiva, no a una emulación completa de adversario. La diferencia debe permanecer visible en cada comparación para evitar que el lector atribuya al caso benigno propiedades no observadas.

El principio de proporcionalidad ética exige que el nivel de riesgo asumido sea coherente con la pregunta de investigación. El Menlo Report adapta principios de respeto, beneficencia, justicia y respeto al derecho al ámbito TIC, mientras el Código de Ética de ACM prioriza evitar daño y evaluar riesgos (DHS, 2012; ACM, 2018). En consecuencia, usar datos sintéticos y un receptor interno no es solo una restricción operativa, sino una decisión metodológica alineada con el objetivo del TFM.

La transferencia entre un caso real y una simulación controlada debe realizarse por abstracción, no por imitación. Se seleccionan propiedades relevantes -tipo de activo, necesidad de comunicación, observables de proceso o requisitos de evidencia- y se excluyen capacidades que aumentarían el riesgo sin ser necesarias para responder la pregunta. Este procedimiento conserva validez conceptual al tiempo que reduce validez ecológica, limitación que debe declararse. La comparación resultante es útil para diseñar categorías y discutir plausibilidad, pero no para atribuir eficacia, prevalencia o equivalencia funcional a M-001.

3.10 Herramientas defensivas y decisión de no convertir el TFM en catálogo

Una herramienta solo tiene sentido dentro de un procedimiento. KVM/libvirt no es relevante por sí mismo, sino porque permite crear VMs y redes aisladas. tcpdump y Wireshark no son relevantes por su nombre, sino porque permiten capturar y analizar tráfico. SHA-256 no es relevante como algoritmo aislado, sino como mecanismo de integridad documental. (NIST, 2006; SWGDE, 2025)

El TFM evita describir todas las opciones disponibles porque eso diluiría el problema. En cambio, explica la función de cada instrumento adoptado y lo vincula con PV/EV. Esta decisión responde a una exigencia académica: demostrar razonamiento, no acumulación de comandos.

La memoria principal conserva síntesis, tablas y resultados interpretados. Las salidas completas permanecen en el repositorio como evidencias externas. De este modo, los apéndices aportan valor académico sin convertirse en volcados de terminal.

Tabla 8. Herramientas defensivas vinculadas con las pruebas de validación

Instrumento	Función	PV relacionada
KVM/libvirt	Virtualización, redes y dominios	PV-01, PV-02
tcpdump/Wireshark	Captura y análisis PCAP	PV-04
SHA-256	Integridad de ficheros	PV-05
matriz PV/EV	Trazabilidad documental	PV-05/PV-06
LLM supervisado	Apoyo de redacción y síntesis	PV-07

La selección de herramientas sigue criterios de función, verificabilidad, licencia, mantenimiento y adecuación al alcance. libvirt documenta modos de red virtual sin reenvío a redes externas, mientras QEMU especifica qcow2 y qemu-img para gestionar imágenes y estados de disco (libvirt Project, 2026a, 2026b; QEMU Project, 2026a, 2026b). Estas fuentes permiten justificar el comportamiento esperado de la infraestructura sin confundir documentación del producto con evidencia de que la configuración concreta está correctamente aplicada.

Para la observación de red, tcpdump genera capturas y Wireshark facilita la decodificación de protocolos; para el análisis especializado, REMnux ofrece un conjunto defensivo de herramientas. Su mención no implica que todas sean necesarias en cada prueba (The Tcpdump Group, 2026; Wireshark Foundation, 2026; Zeltser, 2026). StealLab adopta el

principio de mínimo instrumento suficiente: cada herramienta debe responder a una pregunta, producir una evidencia identificable y tener un límite de interpretación explícito.

La selección instrumental debe obedecer al principio de suficiencia metodológica. Una herramienta se incorpora cuando produce un observable necesario, permite repetir una operación o conserva un artefacto verificable. Su popularidad o complejidad no constituyen por sí mismas criterios académicos. Este enfoque evita que la memoria se fragmente en descripciones de productos y permite explicar por qué una combinación limitada de virtualización, captura, hashing y documentación es adecuada para la pregunta planteada. La calidad del diseño depende de la coherencia entre función e instrumento, no del número de utilidades instaladas (NIST, 2006; SWGDE, 2025).

3.11 Brecha específica que cubre StealLab

La brecha específica se formula como una necesidad de puente entre teoría y práctica segura. La teoría sobre infostealers explica el riesgo, pero no demuestra cómo observarlo en un entorno docente. La práctica con malware real puede ser peligrosa y exceder el alcance universitario. StealLab se sitúa entre ambos extremos.

La contribución se mide por la coherencia entre diseño y validación. Si el laboratorio demuestra aislamiento, restaurabilidad, observabilidad, trazabilidad y ética, entonces cumple su objetivo dentro del alcance delimitado. No necesita demostrar todas las capacidades de familias reales para ser útil.

La brecha también es documental. Un laboratorio no documentado no es reproducible. Por eso el repositorio, las matrices y los hashes no son accesorios: son parte del resultado investigador.

Desde la perspectiva de design science, el laboratorio es un artefacto construido para resolver un problema definido y evaluado mediante criterios observables. La contribución no reside únicamente en el software o la infraestructura, sino en la relación entre necesidad, diseño, evaluación y comunicación del conocimiento (Hevner et al., 2004; Peffers et al., 2007). Esta lógica encaja con la pregunta de investigación de StealLab y con el uso de PV-01 a PV-07 como mecanismo de evaluación. La estrategia de estudio de caso mantiene la unidad de análisis, el contexto y los límites de generalización explícitos, conforme a la lógica metodológica de Yin (2018).

La brecha queda formulada de manera operacional: faltaba un procedimiento que uniera contención, restaurabilidad, observación de proceso, observación de red, integridad de artefactos, informe técnico y control del uso de LLM dentro de un caso no dañino. El TFM no pretende demostrar superioridad frente a sandboxes profesionales; pretende demostrar que esa combinación puede implementarse y verificarse con alcance, evidencias y límites transparentes.

La brecha no consiste en la inexistencia de sandboxes o de literatura sobre stealers, sino en la dificultad de combinar, dentro de un trabajo académico controlado, aislamiento verificable, datos no sensibles, restaurabilidad, observación multicapas y trazabilidad entre pregunta, prueba, evidencia y conclusión. StealLab aporta precisamente esa integración. Su contribución es metodológica y documental: convertir un conjunto de componentes técnicos conocidos en un procedimiento auditable que pueda ser examinado, repetido y refutado dentro del alcance definido.

La brecha específica puede expresarse como falta de trazabilidad entre arquitectura y afirmación. En numerosos laboratorios se describe qué componentes existen, pero no se documenta qué evidencia demuestra cada requisito ni qué límites afectan a la conclusión. StealLab aborda esa carencia al vincular diseño, prueba y evidencia mediante una estructura estable. La contribución no pretende competir con plataformas automatizadas, sino ofrecer un

modelo comprensible y evaluable para entornos universitarios, donde la transparencia del procedimiento y la capacidad de revisión son tan importantes como la riqueza de la telemetría.

3.12 Cronología razonada del fenómeno infostealer

La cronología de los infostealers puede dividirse en etapas conceptuales. Primero, robo de credenciales asociado a troyanos bancarios y spyware. Segundo, ampliación hacia perfiles de navegador y sesiones. Tercero, comercialización de logs. Cuarto, integración con MaaS. Quinto, uso de credenciales expuestas como acceso inicial a servicios corporativos. (Thomas et al., 2017; Campobasso & Allodi, 2020; Europol, 2025b)

Esta cronología ayuda a explicar por qué StealLab no se centra solo en una contraseña. El laboratorio representa categorías: credencial, navegador, sistema y wallet. Cada categoría corresponde a un tipo de activo que puede tener valor en una cadena de ataque real.

La cronología también explica el valor de la trazabilidad. Si el impacto puede aparecer después, la evidencia debe conservar contexto: ruta, hash, caso, PV, fecha si procede e interpretación. Sin esa trazabilidad, el análisis posterior pierde fuerza.

Tabla 9. Cronología razonada del fenómeno infostealer

Etapa	Objeto de interés	Representación segura
Troyanos/spyware iniciales	Contraseñas y formularios	credencial_demo.txt
Navegadores modernos	Cookies, sesiones, extensiones	navegador_demo.txt
Mercado de logs	Paquetes de datos por usuario	Repositorio PV/EV
MaaS	Operación como servicio	Contexto teórico
Acceso inicial	Reutilización de credenciales	Discusión de riesgo

Como hitos documentales, los estudios de 2017 sobre credenciales robadas cuantificaron la relación entre phishing, malware y brechas; en 2020 se formalizó el análisis de mercados de impersonation-as-a-service; en 2023 la intervención sobre Genesis Market expuso la comercialización de perfiles completos; en 2024 el caso Snowflake mostró el impacto corporativo de credenciales previamente sustraídas; y en 2025 las acciones contra Lumma y RedLine/META, junto con los informes de defensa digital, evidenciaron la escala de estas plataformas y la evolución de sus técnicas de entrega y explotación de identidades (Thomas et al., 2017; Campobasso & Allodi, 2020; U.S. Department of Justice, 2023; Google Cloud, 2024; Europol, 2025a; Microsoft, 2025a, 2025b).

Esta cronología no implica una sucesión lineal ni la desaparición de técnicas anteriores. Contraseñas, keylogging, robo de cookies y fraude bancario coexisten con tokens cloud y wallets. El valor de la periodización es analítico: permite observar cómo aumenta la modularidad, el volumen de datos y la separación entre compromiso inicial y monetización.

La cronología debe entenderse como una periodización analítica y no como una secuencia de sustitución completa. Técnicas antiguas y recientes coexisten, se recombinan y se adaptan a nuevas plataformas. El valor de dividir el fenómeno en etapas reside en observar cómo cambia el objeto económico: del secreto individual al perfil reutilizable y, posteriormente, al acceso comercializable. Esta evolución permite justificar por qué el TFM organiza los activos en categorías diferenciadas y por qué la protección debe considerar vigencia, revocabilidad y contexto, además de confidencialidad.

3.13 Familias representativas y criterios de inclusión en la revisión

Las familias se incluyen si ayudan a explicar una dimensión del fenómeno y si existe soporte documental razonable. No se incluyen para llenar una lista ni para sugerir que fueron analizadas en StealLab. El criterio principal es didáctico y defensivo.

RedLine, Raccoon, Vidar, RisePro, MetaStealer y Lumma se citan porque aparecen en fuentes públicas relacionadas con credenciales y logs. Ducktail se incluye por especialización

en activos empresariales. CookieMiner se usa como ejemplo de cookies y criptomonedas. Aurora y Citadel se tratan con cautela como referencias históricas o académicas, según fuente.

La denominación de una familia puede cambiar por rebranding, bifurcaciones, filtraciones de código o estrategias comerciales. Por ello, el nombre no se considera una categoría científica estable por sí mismo. Una familia se incluye cuando existe una fuente que describe objetivos, artefactos o infraestructura y cuando esa información ayuda a responder una pregunta del TFM. Las técnicas se normalizan mediante ATT&CK siempre que exista correspondencia razonable, evitando convertir etiquetas de proveedores en equivalencias automáticas.

El corpus final combina familias históricas, servicios comerciales y campañas especializadas. Citadel aporta antecedentes de malware financiero y botnets (Rahimian et al., 2014); RedLine, Raccoon y Lumma ilustran modelos de servicio y escala; DUCKTAIL, especialización empresarial; CookieMiner, cookies y criptomonedas; e ICONICSTEALER, recopilación de navegador. Esta selección maximiza diversidad conceptual sin sugerir que todas las familias fueron analizadas empíricamente.

El uso académico de nombres de familias requiere cautela porque las denominaciones pueden depender del proveedor, del momento de análisis o de cambios de marca. La familia es una unidad útil para contextualizar campañas, pero no siempre constituye una categoría estable para comparar capacidades. Por ello, la revisión debe distinguir entre nombre comercial, conjunto de técnicas y evidencia documentada. StealLab prioriza propiedades observables y tipos de activos, lo que reduce dependencia de taxonomías volátiles y facilita que el marco siga siendo válido aunque cambien las familias predominantes.

3.14 Economía de los logs robados y mercados de acceso

En el contexto infostealer, un log robado no es solo un registro técnico; es un paquete de información monetizable. Puede contener credenciales, cookies, tokens, información del sistema, capturas, wallets o referencias a servicios. Su valor depende de reutilización, vigencia y criticidad. (Campobasso & Allodi, 2020; Europol, 2025b)

Los mercados de acceso separan el compromiso inicial del impacto posterior. Una persona puede distribuir el stealer, otra vender el log y otra usar la credencial. Esta separación dificulta atribución y obliga a los defensores a centrarse en evidencia y mitigación, no solo en familia de malware.

La memoria usa este concepto para justificar por qué M-001 genera distintos ficheros DEMO. Cada uno representa una familia de activo; el laboratorio no monetiza ni exfiltra nada, pero permite discutir por qué esos activos serían sensibles si fueran reales.

Tabla 10. Economía de logs robados y tratamiento seguro de activos

Activo	Valor en mercado criminal	Tratamiento seguro
Credencial	Acceso a cuentas	DEMO/NO REAL
Cookie	Sesión persistente	Solo representación sintética
Token	Autorización programática	Conceptual, no real
Wallet	Valor financiero directo	wallet_demo sin claves
Sistema	Contexto para selección/evasión	sistema_demo

La estructura de un log robado puede incluir datos heterogéneos cuya combinación aumenta el valor: una contraseña indica un secreto, una cookie representa continuidad de sesión, el fingerprint facilita imitación del dispositivo y la información del sistema permite filtrar objetivos. Los mercados de impersonación explotan precisamente esa combinación para reducir señales de riesgo durante el acceso fraudulento (Campobasso & Allodi, 2020; U.S. Department of Justice, 2023).

Desde la defensa, esta economía obliga a responder por activo y no solo por endpoint. La remediación puede requerir cambio de contraseña, revocación de sesiones, rotación de tokens, revisión de reglas de correo, invalidación de claves, comprobación de actividad SaaS y reconstrucción del dispositivo. StealLab no ejecuta estas acciones sobre servicios reales, pero su taxonomía prepara una lectura de riesgo más precisa que una categoría genérica de datos robados.

El valor de un log depende de más factores que la mera cantidad de datos. La vigencia de las sesiones, los privilegios asociados, la criticidad de los servicios y la posibilidad de reproducir el contexto del dispositivo condicionan su utilidad. Desde una perspectiva defensiva, esta valoración obliga a priorizar respuestas por impacto potencial y no por extensión del fichero. La clasificación sintética de StealLab permite explicar estas diferencias sin manejar información sensible y muestra por qué credencial, cookie, token y wallet requieren controles y procedimientos de revocación distintos (Campobasso & Allodi, 2020).

3.15 Relación entre infostealers, ransomware y compromiso de servicios corporativos

Los infostealers no son ransomware, pero pueden facilitarlo. El ransomware requiere acceso y privilegios; una credencial robada puede ser una vía inicial. Esta relación no implica causalidad automática, pero sí una conexión operacional documentada: el robo de información puede preceder incidentes de mayor impacto. (ENISA, 2024; Google Cloud, 2025)

El compromiso de servicios corporativos se ve favorecido cuando las cuentas carecen de MFA, cuando se reutilizan contraseñas, cuando las sesiones duran demasiado o cuando los tokens no se revocan. Por eso, la defensa frente a infostealers no se limita a antivirus: incluye gestión de identidad, revocación de sesiones, vigilancia de credenciales y endurecimiento de navegadores.

StealLab no evalúa MFA ni servicios SaaS reales. Sin embargo, el marco teórico debe explicar esos conceptos porque justifican la relevancia del laboratorio. La simulación benigna se interpreta como un modelo seguro de observabilidad, no como reproducción de intrusión corporativa.

Tabla 11. Relación entre infostealers, impactos posteriores y límites del laboratorio

Riesgo posterior	Relación con infostealer	Límite de StealLab
Ransomware	Credenciales robadas pueden facilitar acceso	No se simula ransomware
Fraude	Sesiones o credenciales permiten suplantación	No se usan cuentas reales
SaaS comprometido	Acceso a plataformas externas	Solo discusión conceptual
Extorsión	Datos obtenidos pueden usarse para presión	No hay datos reales

La relación debe formularse como posibilidad de encadenamiento, no como determinismo. Las credenciales robadas pueden ser consumidas por afiliados de ransomware, initial access brokers u otros actores, pero la transición depende de privilegios, vigencia, controles de acceso y oportunidades posteriores. ENISA y Europol describen ecosistemas donde servicios y accesos se reutilizan entre actores, lo que respalda analizar el infostealer como habilitador potencial y no como sinónimo de ransomware (ENISA, 2024, 2025; Europol, 2023, 2024).

En servicios corporativos, MFA reduce ciertos usos de contraseña, pero no elimina todos los riesgos de sesiones, tokens o dispositivos ya confiables. La literatura sobre cookies muestra que la protección debe incluir atributos seguros, caducidad, revocación y controles del navegador, mientras los estudios sobre perfiles señalan que el directorio del usuario puede

concentrar múltiples artefactos sensibles (Tyler & Nunes, 2024; Somé et al., 2025). Esta diversidad justifica que la respuesta defensiva se base en el tipo de activo comprometido.

La relación entre infostealers y otros incidentes debe formularse como encadenamiento posible. La exposición de credenciales o sesiones puede reducir barreras de acceso, pero no determina por sí sola que se produzca ransomware, fraude o extorsión. Entre ambos eventos intervienen privilegios, controles de identidad, segmentación, detección y decisiones de otros actores. Esta precisión evita convertir correlaciones operativas en causalidad automática y permite situar StealLab en su alcance real: estudiar el origen potencial de un acceso y la evidencia asociada, no reproducir una intrusión corporativa completa (ENISA, 2024, 2025; Europol, 2023).

3.16 Lectura del fenómeno infostealer por capas OSI y TCP/IP

El análisis de stealers no debe limitarse al nivel de aplicación ni a la lectura de ficheros locales. Aunque el objetivo principal de estas amenazas es la información del usuario, su observación defensiva atraviesa varias capas de comunicación. El modelo OSI y el modelo TCP/IP permiten separar qué parte del fenómeno pertenece al endpoint, qué parte pertenece a la red y qué parte pertenece a servicios de aplicación como HTTP, DNS, SMB, LDAP o TLS. (ISO/IEC, 1994; IETF, 1989a, 1989b)

Desde esta perspectiva, un comportamiento tipo infostealer puede dejar señales en la capa de enlace cuando intervienen direcciones MAC, ARP, switching o segmentación; en la capa de red cuando aparecen direcciones IP, subredes, rutas o conectividad entre segmentos; en la capa de transporte cuando se observan puertos TCP/UDP, sesiones y flujos; y en la capa de aplicación cuando se identifican protocolos, cabeceras, nombres de host, solicitudes HTTP, consultas DNS o servicios corporativos. Esta separación evita interpretar una captura PCAP como si por sí sola explicara todo el incidente.

StealLab utiliza esta lectura por capas para justificar su diseño. La red StealLab-Net opera sobre un bridge virtual, el segmento 10.10.10.0/24 define el plano IP, las comunicaciones entre VM-LINUX-ANALYSIS y VM-SERVICES-SIM se verifican mediante puerto y flujo, y el caso M-001 representa una comunicación HTTP interna controlada. La memoria no afirma que se reproduzcan todos los vectores de un stealer real; afirma que se valida un subconjunto observable, seguro y trazable.

La tabla muestra que el laboratorio no se interpreta como una red corporativa completa, sino como un entorno controlado donde cada capa tiene una función metodológica concreta. Esta lectura ayuda a vincular el marco teórico de redes con las pruebas PV-01 y PV-04.

La lectura por capas permite evitar una descripción plana del fenómeno infostealer. Un stealer no debe entenderse únicamente como un programa que recopila información, sino como una secuencia de eventos observables en distintos planos: el plano del sistema operativo, el plano del sistema de ficheros, el plano de procesos, el plano de red y el plano de aplicación. El modelo OSI y el modelo TCP/IP no se utilizan en este trabajo como una clasificación rígida, sino como una herramienta de análisis para ordenar qué puede observarse, dónde puede observarse y qué evidencia puede conservarse.

En la capa de acceso a red o enlace, el interés defensivo se centra en la separación del laboratorio respecto de redes externas, la existencia de un bridge virtual controlado, la asignación de direcciones MAC virtuales y la ausencia de conectividad no prevista. En StealLab esta lectura se materializa en la red StealLab-Net y en el bridge virbr-steal. La importancia de esta capa no reside en detectar malware por sí misma, sino en garantizar que cualquier comunicación observada pertenece al entorno académico diseñado y no a un flujo accidental hacia terceros.

En la capa de Internet o red, el análisis se centra en direcciones IP, subredes, rutas, alcance de conectividad y ausencia de NAT o salida a Internet. Para un laboratorio de stealers, esta capa es crítica porque un comportamiento real de exfiltración podría intentar alcanzar servicios remotos. StealLab sustituye ese riesgo por comunicación interna controlada, de forma que la evidencia de red pueda interpretarse sin exponer datos reales ni contactar infraestructura externa.

En la capa de transporte, la observación se orienta a puertos, sesiones TCP, direccionalidad, origen, destino y temporalidad de las conexiones. Un stealer real podría usar distintos canales de salida; el laboratorio, en cambio, restringe la comunicación al flujo interno permitido. Esta decisión reduce el realismo ofensivo, pero aumenta la seguridad, la reproducibilidad y la aceptabilidad ética del experimento.

En la capa de aplicación, el foco se desplaza al protocolo, al contenido sintético transmitido, al servidor benigno de recepción y a la interpretación documental de lo observado. En StealLab el uso de HTTP interno no representa un C2 real, sino un mecanismo académico para generar tráfico analizable. Esta distinción es esencial: el objetivo no es reproducir una infraestructura criminal, sino demostrar que el laboratorio permite capturar e interpretar un comportamiento de transferencia controlada.

Tabla 12. Lectura por capas del fenómeno infostealer y aplicación en StealLab

Modelo/capa	Concepto defensivo	Aplicación en StealLab	Límite de interpretación
OSI 2 / Acceso TCP-IP	Enlace, bridge, MAC, ARP, segmentación local	Bridge virbr-steal y red virtual aislada	No se evalúan ataques de capa 2 como ARP spoofing
OSI 3 / Internet TCP-IP	IP, subred, ICMP, rutas	Segmento 10.10.10.0/24 y bridge 10.10.10.1	La reserva IP no equivale por sí sola a actividad runtime
OSI 4 / Transporte TCP-IP	TCP/UDP, puertos, sesiones	Comunicación controlada hacia servicio HTTP interno	No se mide evasión, cifrado de canal ni C2 real
OSI 7 / Aplicación TCP-IP	HTTP, DNS, SMB, LDAP, autenticación, cabeceras	HTTP benigno interno en VM-SERVICES-SIM	No se reproducen servicios reales ni credenciales reales
Host/endpoint	Procesos, ficheros, logs, artefactos	Datos DEMO, procesos y evidencias M-001	No sustituye telemetría EDR/SIEM completa

El modelo OSI de ISO/IEC 7498-1 es una arquitectura de referencia conceptual; la arquitectura de Internet descrita en RFC 1122 y RFC 1123 organiza los requisitos de hosts y aplicaciones en una pila práctica. Ambos modelos son útiles para razonar, pero no deben tratarse como una correspondencia perfecta ni como instrumentos de atribución (ISO/IEC, 1994; IETF, 1989a, 1989b). Para protocolos concretos, StealLab se apoya además en la especificación moderna de TCP y en la semántica de HTTP (IETF, 2022a, 2022b).

La observabilidad del endpoint constituye un plano complementario que no encaja por completo en las capas de red. Procesos, llamadas al sistema, ficheros, claves de configuración y memoria deben correlacionarse con flujos IP, sesiones TCP y mensajes de aplicación. De esta manera, un evento de red adquiere significado al vincularse con el proceso que lo originó y con el artefacto que contiene los datos sintéticos. La correlación, no una capa aislada, es la unidad mínima de interpretación defensiva.

La lectura por capas ofrece una matriz de localización de observables, pero no sustituye la correlación. Una dirección IP, un puerto o una solicitud HTTP adquieren significado cuando se vinculan con un proceso, un fichero y un momento determinado. De forma inversa, un proceso sin contexto de red puede no revelar si existió comunicación. La utilidad del modelo radica en ordenar fuentes de evidencia y detectar vacíos de visibilidad. En StealLab, esta organización ayuda a separar infraestructura, transporte, aplicación y endpoint, manteniendo claro que la atribución defensiva surge de combinar señales y no de observar una capa aislada (ISO/IEC, 1994; IETF, 1989a, 1989b).

4 MARCO TEÓRICO Y CONCEPTUAL

El marco teórico define los conceptos necesarios para comprender el resto de la memoria. No se asume conocimiento previo: cada acrónimo, herramienta, técnica, formato y familia citada se interpreta dentro del alcance defensivo del TFM. Este capítulo convierte la terminología dispersa en un vocabulario operativo común. (NIST, 2013; MITRE, s. f.-a)

El marco conceptual distingue entre amenaza real, modelo de laboratorio y evidencia observada. Esta distinción es imprescindible porque StealLab no ejecuta malware real. El valor del trabajo está en diseñar un laboratorio seguro que permita observar señales representativas y documentarlas de forma verificable.

El marco adopta una perspectiva socio-técnica: el comportamiento del malware se interpreta junto con el valor del activo, los mecanismos de identidad, la infraestructura de comunicación y el procedimiento de evidencia. Esta perspectiva es necesaria porque un mismo artefacto puede ser técnicamente pequeño y producir impacto elevado si concede acceso a un servicio crítico.

Las relaciones conceptuales se organizan con una regla de correspondencia: cada concepto debe asociarse a una señal potencial, una fuente de evidencia y un límite. De esta forma, el marco teórico no funciona como un glosario aislado, sino como la base de la operacionalización posterior.

4.1 Glosario de acrónimos, siglas y términos técnicos utilizados

La siguiente tabla se incorpora para evitar que el lector tenga que asumir significados implícitos. Incluye acrónimos académicos, términos de malware, activos de información, componentes de laboratorio, formatos, herramientas defensivas, organismos, familias citadas y etiquetas metodológicas. Cuando un término pertenece a una amenaza real, se define con enfoque defensivo y se aclara su tratamiento seguro en StealLab.

Tabla 13. Inventario integral de acrónimos, nombres técnicos y términos del TFM

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Académico	TFM	Trabajo Fin de Máster. Documento académico final que demuestra capacidad investigadora, metodológica y técnica en el máster.	Es la memoria StealLab y debe contener problema, objetivos, método, resultados, discusión y conclusiones.
Académico	TIC	Tecnologías de la Información y las Comunicaciones. Área que incluye sistemas, redes, software, datos y servicios digitales.	Contextualiza el máster y el campo de seguridad en el que se ubica StealLab.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Académico	MUSTIC	Máster Universitario en Seguridad de las Tecnologías de la Información y las Comunicaciones.	Define el marco académico y la plantilla que estructura el documento.
Académico	APA 7	Séptima edición de normas APA para citas, referencias y presentación académica.	Se usa para ordenar bibliografía y referencias de fuentes consultadas.
Académico	Estado del arte	Conjunto de técnicas, herramientas y soluciones existentes en un ámbito.	Sitúa KVM, libvirt, PCAP, sandboxes y herramientas defensivas.
Académico	Estado de la cuestión	Revisión crítica de cómo se ha tratado el problema en fuentes relevantes.	Justifica por qué los stealers requieren estudio defensivo.
Académico	Marco teórico	Conjunto de conceptos que permiten interpretar el fenómeno investigado.	Define malware, stealer, evidencia, simulación, trazabilidad y validez.
Académico	Metodología	Diseño razonado de cómo se investiga, recoge evidencia y analiza el resultado.	Estructura StealLab como investigación aplicada y estudio de caso técnico.
Académico	Unidad de análisis	Objeto principal que se estudia.	StealLab como sistema técnico-documental.
Académico	Muestra técnica	Conjunto de artefactos técnicos observados, no personas.	VMs, red, PCAP, hashes, M-001, PV/EV y repositorio.
Académico	Operacionalización	Transformación de conceptos abstractos en indicadores observables.	Aislamiento se mide con red; integridad con hashes; red con PCAP.
Académico	Validez interna	Grado en que el resultado se explica por el diseño y no por factores no controlados.	Se refuerza con red aislada, snapshots y evidencias.
Académico	Validez externa	Grado en que los resultados pueden trasladarse a otros contextos.	Limitada: M-001 no generaliza a todas las familias reales.
Académico	Validez de constructo	Grado en que las categorías usadas representan realmente lo investigado.	Impide confundir simulación benigna con malware real.
Académico	Validez documental	Calidad, localización, coherencia y trazabilidad de evidencias y anexos.	Se apoya en repositorio, matrices y hashes.
Académico	Reproducibilidad	Capacidad de repetir o reconstruir el procedimiento con información suficiente.	Rutas, comandos mínimos, snapshots, hashes y matriz PV/EV.
Académico	Refutabilidad	Posibilidad de contrastar o falsar una afirmación.	Si no existe PCAP o hash, la conclusión correspondiente debe revisarse.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Malware	Malware	Software, firmware o código insertado con propósito dañino o no autorizado que afecta confidencialidad, integridad o disponibilidad.	Objeto general del marco teórico; StealLab no ejecuta malware real.
Malware	Malicious code	Código malicioso; término próximo a malware usado en fuentes NIST.	Se usa como concepto de referencia, no como artefacto de laboratorio.
Malware	Stealer	Malware orientado a obtener información reutilizable del sistema o aplicaciones.	Categoría principal del TFM, tratada de forma defensiva.
Malware	Infostealer	Sinónimo habitual de stealer; enfatiza robo de información.	Se usa para describir el fenómeno de forma académica.
Malware	Password stealer	Stealer centrado en credenciales o almacenes de contraseñas.	Representado solo con credencial_demo.txt.
Malware	Cookie/session stealer	Stealer orientado a cookies o sesiones autenticadas.	Representado conceptualmente con navegador_demo.txt, sin cookies reales.
Malware	Keylogger	Software que registra pulsaciones de teclado.	Definido teóricamente; excluido de M-001.
Malware	Spyware	Software de vigilancia o recopilación de actividad.	Categoría relacionada; no objeto central.
Malware	Ransomware	Malware que cifra, bloquea o extorsiona afectando disponibilidad.	Se discute como posible impacto posterior habilitado por credenciales.
Malware	RAT	Remote Access Trojan/Tool; permite control remoto no autorizado.	Fuera del alcance validado.
Malware	Backdoor	Mecanismo de acceso oculto o no autorizado.	Definido para diferenciarlo de stealer.
Malware	Troyano	Software que aparenta legitimidad para lograr ejecución.	Algunos stealers se distribuyen como troyanos; no se simula distribución.
Malware	Gusano	Malware con capacidad de propagación autónoma.	Fuera del alcance.
Malware	Virus	Código que infecta otros ficheros o programas.	Fuera del alcance.
Malware	Web skimmer	Código malicioso que intercepta datos introducidos en webs, especialmente pagos.	Solo definido; no se implementa.
Malware	Cryptocurrency stealer	Stealer orientado a wallets, claves o extensiones de criptomonedas.	Representado de forma segura con wallet_demo.txt.
Malware	SaaS stealer	Stealer orientado a credenciales o tokens de plataformas SaaS.	Tratado por relación con casos reales; no hay cuentas reales.
Malware	Persistencia	Capacidad de mantenerse tras reinicios o cambios de sesión.	Excluida de M-001.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Malware	Evasión	Técnicas para evitar detección o análisis.	Excluida para no crear contenido ofensivo.
Malware	Ofuscación	Dificultar lectura o análisis de código.	Solo concepto; no se implementa.
Malware	Empaquetado	Uso de packers o contenedores para ocultar/modificar estructura de binarios.	Fuera del caso benigno.
Malware	Exfiltración	Salida no autorizada de datos hacia un actor externo.	No existe en StealLab; hay comunicación interna controlada.
Malware	Movimiento lateral	Desplazamiento del atacante entre sistemas internos.	No se simula.
Malware	C2	Command and Control; infraestructura de mando/control o recepción de datos de malware real.	Sustituido por VM-SERVICES-SIM como HTTP interno benigno.
Activos	Credencial	Dato que permite autenticación o identificación ante un servicio.	Representada con credencial_demo.txt.
Activos	Cookie	Dato de navegador usado para estado, preferencias o sesión.	No se usan cookies reales.
Activos	Cookie de sesión	Cookie asociada a una sesión autenticada.	Representada de forma sintética en navegador_demo.
Activos	Token	Valor que autoriza acceso o representa sesión/autorización.	No se usan tokens reales.
Activos	Token de API	Token usado para invocar servicios o APIs de forma programática.	Solo categoría conceptual.
Activos	API	Interfaz de programación de aplicaciones.	Relevante por tokens y servicios SaaS.
Activos	Wallet	Contenedor o material asociado a activos digitales.	Representada con wallet_demo.txt sin claves reales.
Activos	Clave privada	Secreto criptográfico que permite firmar o controlar activos.	Excluida; no se usa ninguna clave real.
Activos	Frase semilla	Secuencia que permite recuperar una wallet.	Excluida; no se usa ninguna frase real.
Activos	Perfil de navegador	Conjunto de datos locales de un navegador: historial, sesiones, extensiones y configuración.	Representado de forma abstracta con navegador_demo.txt.
Activos	Sesión	Estado autenticado mantenido entre cliente y servicio.	Se explica para justificar cookies y tokens.
Activos	Información de sistema	Datos del equipo, usuario, SO, red o configuración.	Representada con sistema_demo.txt.
Activos	Log	Registro técnico o, en economía infostealer, paquete de datos robados.	En StealLab se evita ambigüedad y se habla de evidencias o logs externos.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Activos	Logs robados	Paquetes de datos extraídos por stealers y comercializados.	Solo contexto; no se generan logs reales robados.
Activos	Mercado de acceso	Ecosistema donde se venden credenciales, sesiones o accesos.	Contexto de amenaza.
Activos	Acceso inicial	Primera entrada a un sistema o servicio.	Se discute como consecuencia posible de credenciales robadas.
Laboratorio	StealLab	Laboratorio técnico defensivo desarrollado en el TFM.	Unidad de análisis principal.
Laboratorio	StealLab-Net	Red libvirt aislada del laboratorio.	PV-01.
Laboratorio	KVM	Kernel-based Virtual Machine; virtualización integrada en Linux.	Base de ejecución de VMs.
Laboratorio	libvirt	Capa de gestión de virtualización y redes.	Gestiona redes, dominios y estado runtime.
Laboratorio	KVM/libvirt	Combinación de hipervisor y gestión usada en StealLab.	Base técnica del laboratorio.
Laboratorio	VM	Máquina virtual.	Unidad de separación por rol.
Laboratorio	VMs	Máquinas virtuales.	SERVICES, ANALYSIS y reserva WIN.
Laboratorio	VM-SERVICES-SIM	VM servidor interno benigno HTTP.	Receptor controlado, no C2 real.
Laboratorio	VM-LINUX-ANALYSIS	VM de análisis Linux y ejecución M-001.	Punto de preparación, ejecución y captura.
Laboratorio	VM-WIN-LAB	Reserva de diseño para futura VM Windows.	No implementada como alcance validado.
Laboratorio	Bridge	Interfaz/puente virtual que conecta VMs dentro de una red.	virbr-steal.
Laboratorio	virbr-steal	Nombre del bridge de StealLab-Net.	Evidencia de aislamiento de red.
Laboratorio	Storage pool	Conjunto de almacenamiento gestionado para discos de VMs.	Ruta 03_laboratorio/vms.
Laboratorio	qcow2	Formato de imagen de disco de QEMU con soporte de copy-on-write y snapshots.	Discos de VM-SERVICES-SIM y VM-LINUX-ANALYSIS.
Laboratorio	qemu-img	Herramienta para inspeccionar y gestionar imágenes QEMU.	Verifica snapshots y estado corrupt:false.
Laboratorio	qemu:///system	URI de conexión libvirt al daemon del sistema.	Usado para validar red y dominios reales.
Laboratorio	virsh	CLI de administración libvirt.	Verifica red, VMs y XML.
Laboratorio	Snapshot	Estado preservado de VM/disco para volver a una base conocida.	PV-02.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Laboratorio	Host	Equipo físico que ejecuta el laboratorio.	MSI-STEALTH-GS66.
Laboratorio	Endpoint	Equipo final donde se ejecuta actividad o se observan artefactos.	VM-LINUX-ANALYSIS actúa como endpoint de análisis.
Laboratorio	Sandbox	Entorno controlado para ejecutar/observar artefactos.	StealLab es laboratorio académico, no sandbox profesional automático.
Formatos y red	IP	Dirección de Protocolo de Internet.	10.10.10.1/24 y reservas internas.
Formatos y red	DHCP	Protocolo de asignación dinámica de direcciones.	Reservas para VMs en XML.
Formatos y red	NAT	Traducción de direcciones de red.	No se usa para salida a Internet en VMs.
Formatos y red	DNS	Sistema de nombres de dominio.	Relevante en malware real; no central en M-001.
Formatos y red	HTTP	Protocolo web sin cifrar.	Canal interno benigno de M-001.
Formatos y red	PCAP	Formato de captura de paquetes.	Evidencia EV-PCAP-003.
Formatos y red	XML	Formato de marcado estructurado.	Definición de red libvirt.
Formatos y red	JSON	Formato estructurado de datos.	Resultados finales M-001.
Formatos y red	TXT	Fichero de texto plano.	Fichas, evidencias y datos DEMO.
Formatos y red	DOCX	Formato editable de Word/OpenXML.	Memoria entregable editable.
Formatos y red	PDF	Formato de documento portable.	Versión renderizada para revisión.
Formatos y red	UUID	Identificador único universal.	Identifica red StealLab-Net en libvirt.
Formatos y red	STP	Spanning Tree Protocol.	Parámetro del bridge en XML; no foco del TFM.
Formatos y red	SHA-256	Algoritmo hash criptográfico de 256 bits.	Verifica integridad de DEMO y PCAP.
Defensa	SOC	Security Operations Center.	Contexto profesional; StealLab no es SOC.
Defensa	EDR	Endpoint Detection and Response.	Comparación: StealLab no sustituye EDR.
Defensa	SIEM	Security Information and Event Management.	Trabajo futuro para correlación de eventos.
Defensa	IOC	Indicator of Compromise.	Se define; M-001 genera indicadores de laboratorio, no IOCs reales.
Defensa	IOA	Indicator of Attack/Activity.	Se usa para comportamiento observable.
Defensa	TTP	Tácticas, Técnicas y Procedimientos.	Lenguaje de análisis defensivo.
Defensa	MITRE ATT&CK	Base de conocimiento de tácticas y técnicas adversarias.	Usada como vocabulario defensivo.
Defensa	T1555.003	Subtécnica de MITRE: credenciales desde navegadores.	Justifica credencial_demo y navegador_demo.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Defensa	T1539	Técnica de MITRE: robo de cookie de sesión web.	Justifica representar sesiones sin datos reales.
Defensa	Sigma	Formato de reglas de detección SIEM.	Trabajo futuro defensivo.
Defensa	YARA	Herramienta/reglas para identificar patrones en ficheros.	Trabajo futuro defensivo.
Defensa	Wireshark	Analizador de protocolos y capturas de red.	Análisis de PCAP.
Defensa	tcpdump	Herramienta de captura de paquetes por consola.	Captura EV-PCAP.
Defensa	REMnux	Distribución/toolkit Linux para análisis de malware.	Referencia defensiva, posible extensión futura.
Fuentes y casos	NIST	National Institute of Standards and Technology.	Definiciones y guías de malware.
Fuentes y casos	ENISA	Agencia de la Unión Europea para la Ciberseguridad.	Contexto de amenazas europeo.
Fuentes y casos	MITRE	Organización responsable de ATT&CK.	Técnicas defensivas de referencia.
Fuentes y casos	Mandiant	Equipo de inteligencia de amenazas de Google Cloud.	Caso UNC5537/Snowflake.
Fuentes y casos	Google Cloud	Proveedor y publicador del análisis Mandiant.	Fuente del caso Snowflake.
Fuentes y casos	Microsoft Digital Crimes Unit	Unidad de Microsoft dedicada a acciones contra cibercrimen.	Contexto Lumma y disrupciones.
Fuentes y casos	UNC5537	Actor/cluster documentado por Mandiant en caso Snowflake.	Ejemplo de reutilización de credenciales expuestas.
Fuentes y casos	Snowflake	Plataforma cloud/data warehouse afectada en el caso UNC5537.	Caso externo de impacto SaaS.
Fuentes y casos	Lumma	Familia infostealer/MaaS reciente.	Contexto, no analizada.
Fuentes y casos	LummaC2	Nombre asociado a Lumma y su infraestructura/servicio.	Contexto de ecosistema criminal.
Fuentes y casos	RedLine	Infostealer ampliamente citado en casos de credenciales/logs.	Contexto.
Fuentes y casos	Raccoon	Infostealer asociado a robo y comercio de información.	Contexto.
Fuentes y casos	Vidar	Infostealer citado en exposiciones de credenciales.	Contexto.
Fuentes y casos	RisePro	Familia citada en casos de credenciales expuestas.	Contexto.
Fuentes y casos	MetaStealer	Familia citada en investigaciones de credenciales.	Contexto.
Fuentes y casos	Ducktail	Infostealer especializado en cuentas empresariales/sociales.	Contexto de especialización.

Categoría	Término o acrónimo	Definición aplicada	Tratamiento en StealLab
Fuentes y casos	CookieMiner	Malware asociado a cookies y activos de criptomonedas.	Contexto para navegador/wallet.
Fuentes y casos	Aurora	Infostealer usado como caso en literatura reciente sobre vectores de infección.	Contexto bibliográfico, no ejecutado.
Fuentes y casos	Citadel	Malware/botnet de robo de información financiera estudiado académicamente.	Referencia histórica, no analizada.
Metodología	PV	Prueba de validación.	Estructura PV-01 a PV-07.
Metodología	EV	Evidencia.	Ficheros y artefactos asociados a pruebas.
Metodología	M-001	Caso de simulación benigna defensiva.	Valida StealLab sin malware real.
Metodología	DEMO/NO REAL	Marca de datos sintéticos no sensibles.	Garantiza ausencia de datos reales.
Metodología	Artefacto	Elemento observable usado o producido en prueba.	Script benigno, PCAP, hash, informe, ficha.
Metodología	Dato sintético	Dato creado artificialmente para prueba.	Evita privacidad y exposición.
Metodología	Comportamiento observable	Señal registrable sin inferir intenciones no demostradas.	Base de análisis de M-001.
Metodología	Simulación benigna	Representación controlada y no dañina de un patrón.	Sustituye malware real por seguridad ética.

La tabla anterior debe leerse como glosario operativo de la memoria. No sustituye el desarrollo conceptual de las secciones siguientes: su función es asegurar que todos los términos técnicos quedan definidos antes de ser utilizados en la argumentación.

La terminología técnica de este TFM debe leerse de forma funcional: cada término se define por su significado general, por su uso en ciberseguridad y por su relación concreta con StealLab. Así, una sigla como PCAP no es solo un formato de captura, sino un soporte de evidencia de red; SHA-256 no es solo una función hash, sino un mecanismo de integridad documental; y VM no es solo una máquina virtual, sino una unidad controlada del laboratorio.

En un trabajo sobre stealers, los conceptos de credencial, cookie, token, wallet, clave privada y perfil de navegador no deben tratarse como sinónimos. Una credencial suele identificar un secreto de autenticación reutilizable, una cookie de sesión mantiene el estado de una sesión ya autenticada, un token puede representar autorización delegada, una wallet concentra activos criptográficos y un perfil de navegador puede agrupar múltiples artefactos de identidad digital. Esta distinción justifica que StealLab utilice ficheros sintéticos separados para representar categorías de riesgo sin introducir datos reales.

Los términos IOC, IOA y TTP también deben diferenciarse. Un indicador de compromiso apunta a una señal observable concreta, como un hash, una IP o una ruta. Un indicador de ataque describe un patrón de comportamiento, como la recolección de determinados tipos de artefactos. Una TTP combina tácticas, técnicas y procedimientos usados por actores de amenaza. El laboratorio no atribuye actividad a actores reales; únicamente permite representar observables defensivos y relacionarlos con categorías técnicas conocidas.

Las definiciones del glosario se apoyan en fuentes normativas y técnicas según la naturaleza de cada término: NIST para malware, respuesta a incidentes y evidencia; MITRE ATT&CK para tácticas y técnicas; ISO/IEC e IETF para modelos y protocolos de red; SWGDE para

conservación; y documentación oficial de libvirt, QEMU, Wireshark, tcpdump y REMnux para herramientas. Cuando no existe una definición universal de infostealer, el TFM adopta una definición funcional explícita y mantiene separadas la categoría analítica y los nombres comerciales de familias (NIST, 2006, 2013, 2022; MITRE, s. f.-a; SWGDE, 2025).

El glosario debe interpretarse como un sistema de control semántico. Su función es reducir ambigüedades que afectan a la validez de constructo: exfiltración no equivale a transferencia interna; C2 no equivale a servidor benigno; IOC no equivale a prueba concluyente; y simulación no equivale a ejecución de malware. Estas diferencias se mantienen en los capítulos de metodología, resultados y discusión.

El glosario cumple además una función de normalización semántica. En ciberseguridad, un mismo término puede variar entre documentación académica, fabricantes y comunidades técnicas. Establecer una definición operativa evita que conceptos como log, evidencia, sesión, token o sandbox cambien de significado entre capítulos. Cada entrada debe leerse en relación con el alcance del TFM: no pretende agotar todas las acepciones posibles, sino fijar el sentido con el que el término interviene en la pregunta, la metodología y la interpretación de resultados.

4.2 Concepto de malware

El concepto de malware se utiliza en este TFM en sentido funcional. No depende únicamente de que un fichero tenga una extensión concreta o de que pertenezca a una familia conocida, sino de su finalidad y efectos no autorizados. NIST describe malware como software, firmware o código introducido con propósito perjudicial o con impacto adverso sobre confidencialidad, integridad o disponibilidad. Esta definición permite analizar el fenómeno sin caer en una clasificación superficial.

La confidencialidad se ve afectada cuando la información se expone a quien no debe acceder a ella. La integridad se afecta cuando los datos o sistemas son alterados. La disponibilidad se afecta cuando un recurso deja de estar operativo. Los stealers impactan principalmente en confidencialidad, pero sus consecuencias pueden derivar en impactos de integridad y disponibilidad si las credenciales robadas se usan para modificar datos, desplegar ransomware o acceder a sistemas críticos.

En StealLab se evita ejecutar malware real. Esto no impide estudiar malware como objeto teórico: permite construir una frontera clara entre definición académica, fenómeno real y simulación benigna. La definición de malware se usa para justificar por qué son necesarios controles de aislamiento incluso cuando el caso M-001 no es malicioso.

El malware puede definirse como software, código o componente lógico diseñado o utilizado para producir efectos no autorizados sobre un sistema, sus datos, sus usuarios o sus comunicaciones. La característica central no es únicamente la presencia de código ejecutable, sino la combinación de intención, contexto de uso, impacto y ausencia de autorización. Una misma técnica de programación puede ser legítima en una herramienta administrativa y maliciosa cuando se usa para ocultarse, recolectar secretos o transmitir información sin consentimiento.

Desde la perspectiva de la seguridad de la información, el malware puede afectar a la confidencialidad, la integridad y la disponibilidad. Los stealers impactan principalmente en la confidencialidad, porque su propósito se relaciona con la obtención de datos sensibles. No obstante, también pueden afectar indirectamente a la integridad si modifican configuraciones, manipulan artefactos o alteran el entorno; y a la disponibilidad si generan inestabilidad, consumo de recursos o facilitan intrusiones posteriores.

En este TFM, malware es un concepto de referencia teórica, no una muestra real ejecutada. El laboratorio no necesita ejecutar malware real para estudiar categorías defensivas relevantes.

La simulación benigna M-001 representa patrones observables de forma controlada, con datos sintéticos y sin funcionalidades dañinas. Esta decisión limita la validez externa frente a una familia real, pero fortalece la seguridad, la ética y la reproducibilidad del trabajo.

NIST caracteriza el malware como software o firmware destinado a ejecutar procesos no autorizados con impacto adverso sobre un sistema. La definición es deliberadamente amplia: incluye código que destruye, altera, espía, controla, cifra o extrae información, y permite clasificar una muestra por sus capacidades y no solo por el nombre asignado por un proveedor (NIST, 2013).

En este TFM se adopta una definición funcional de tres componentes: existencia de código o lógica ejecutable; ausencia de autorización o finalidad dañina; y efecto potencial sobre activos o controles. Esta formulación evita llamar malware a cualquier script de laboratorio. M-001 reproduce una secuencia observable, pero carece de intención no autorizada, datos reales, persistencia y destino externo; por ello se define como simulación benigna y no como muestra maliciosa.

El concepto de malware combina una dimensión técnica y otra de autorización. No basta con que un programa modifique el sistema; la calificación depende de que la conducta sea dañina, engañosa o no consentida respecto del objetivo legítimo del usuario u organización. Esta distinción permite separar herramientas administrativas de uso dual de su empleo malicioso y evita definir el fenómeno únicamente por rasgos de código. En StealLab, el término se utiliza para contextualizar la amenaza, mientras M-001 permanece deliberadamente fuera de esa categoría por carecer de intención dañina, datos reales y capacidad ofensiva (NIST, 2013).

4.3 Clasificación general del malware

La clasificación de malware puede hacerse por familia, por vector, por objetivo o por comportamiento. Para un TFM defensivo resulta más útil una clasificación funcional: qué intenta hacer el artefacto y qué evidencias produce. Una misma muestra real puede actuar como troyano, stealer, loader y backdoor; por ello, clasificar solo por nombre puede ocultar funciones relevantes.

La clasificación funcional permite explicar por qué StealLab se centra en infostealers. No se estudia propagación autónoma como en gusanos, ni cifrado como en ransomware, ni control remoto persistente como en RAT. Se estudian categorías de recolección, agregación y comunicación de datos, porque esas son las señales defensivamente relevantes para el caso M-001.

Esta clasificación también evita confusiones terminológicas. Un keylogger roba información, pero lo hace capturando pulsaciones; un web skimmer roba datos introducidos en una web; un cryptocurrency stealer busca activos digitales; un SaaS stealer prioriza accesos corporativos. Todos comparten el riesgo de confidencialidad, pero no son idénticos.

Tabla 14. Clasificación general del malware y relación con StealLab

Categoría	Foco principal	Relación con StealLab
Stealer	Información reutilizable	Objeto conceptual principal
Ransomware	Disponibilidad/extorsión	Impacto posterior posible
RAT/backdoor	Control remoto	Fuera del alcance
Keylogger	Pulsaciones	Solo conceptual
Web skimmer	Formularios web/pagos	Solo conceptual

La clasificación del malware ayuda a separar objetivos, comportamientos y evidencias. Un virus se caracteriza por asociarse a otros ficheros y propagarse mediante infección; un gusano se propaga por red; un troyano se presenta como software aparentemente legítimo; un ransomware busca cifrar o bloquear activos; un RAT facilita control remoto; un spyware observa o recopila información; un downloader descarga componentes adicionales; un

dropper instala otros elementos; y un stealer se especializa en localizar y extraer información sensible.

Estas categorías no son excluyentes. Una misma campaña puede combinar loader, stealer, RAT y mecanismos de persistencia. Por ello, desde el punto de vista defensivo conviene clasificar por comportamiento observable y no solo por nombre de familia. La pregunta relevante no es únicamente "qué familia es", sino qué activos busca, qué fuentes consulta, qué procesos crea, qué ficheros toca, qué conexiones intenta y qué evidencia deja.

StealLab se centra en la categoría stealer, pero toma elementos de otras clasificaciones para delimitar su alcance. No estudia ransomware porque no cifra datos; no estudia RAT porque no habilita control remoto; no estudia botnets porque no modela coordinación distribuida; y no estudia evasión porque no busca superar defensas. Su foco es la observación segura de recolección, agregación y comunicación controlada de datos sintéticos.

Las taxonomías por nombre de familia son insuficientes porque una misma muestra puede actuar como troyano por su distribución, stealer por su objetivo, loader por su función y bot por su control remoto. Una clasificación defensiva robusta separa vector de entrada, capacidad, objetivo, persistencia, canal de mando y efecto. Esta visión multidimensional es coherente con las guías de NIST y con la literatura de análisis dinámico (NIST, 2013; Or-Meir et al., 2019).

También es necesario distinguir clasificación y atribución. Observar acceso a un perfil de navegador permite describir una conducta, pero no identificar automáticamente una familia; detectar una URL o un hash conocido puede apoyar atribución, pero su valor depende de contexto, fecha y calidad de la fuente. StealLab prioriza categorías de comportamiento porque son más estables y reproducibles que las etiquetas comerciales.

Las clasificaciones de malware son modelos analíticos y no compartimentos excluyentes. Un mismo artefacto puede actuar como troyano por su mecanismo de entrega, como stealer por su finalidad y como backdoor por capacidades adicionales. Por ello, una taxonomía rigurosa debe indicar el criterio empleado: objetivo, propagación, persistencia, control remoto o impacto. Para StealLab, la clasificación por finalidad resulta especialmente útil porque permite centrar el estudio en la obtención de información y diferenciarla de cifrado, destrucción o control interactivo, sin asumir que las familias reales posean una única función.

4.4 Concepto de stealer o infostealer

Un stealer o infostealer es malware orientado a localizar, recopilar y transferir información sensible o reutilizable. La palabra reutilizable es esencial: el valor no está únicamente en ver un dato, sino en poder usarlo después para autenticarse, suplantar, automatizar acceso, venderlo o combinarlo con otros datos.

Los activos típicos incluyen credenciales de navegador, cookies, sesiones, tokens, perfiles locales, información del sistema, datos financieros y artefactos de wallets. MITRE ATT&CK recoge técnicas relacionadas con credenciales desde navegadores y robo de cookies de sesión, lo que confirma que estas categorías forman parte de un lenguaje defensivo reconocido.

En StealLab el stealer se traduce a un modelo seguro. M-001 no roba, no exfiltra, no persiste y no evade. Representa categorías mediante ficheros DEMO y produce tráfico interno controlado. La definición de stealer sirve para orientar la observación, no para reproducir una amenaza.

Un stealer o infostealer es una categoría de malware orientada a identificar, recolectar y transferir información útil para abuso posterior. Su valor no reside necesariamente en tomar control persistente del equipo, sino en convertir el dispositivo afectado en una fuente temporal de secretos, sesiones, identificadores, perfiles y contexto del usuario. Por ello, el impacto de

un stealer puede extenderse más allá del equipo comprometido hacia servicios web, correo, plataformas SaaS, repositorios, wallets o accesos corporativos.

El rasgo diferencial de un infostealer moderno es la orientación a identidad digital. No solo puede interesarse por contraseñas, sino también por cookies, tokens, formularios guardados, historiales, extensiones, ficheros locales, información del sistema y elementos que permiten perfilar al usuario. En un contexto corporativo, una credencial personal reutilizada o una sesión expuesta puede actuar como puente hacia sistemas externos, incluso cuando el equipo inicial no pertenece directamente a una red empresarial.

En StealLab, este concepto se representa mediante una abstracción segura. M-001 no roba información, no extrae secretos reales y no contacta infraestructura externa. En su lugar, organiza ficheros DEMO que representan categorías de datos y genera evidencias de ejecución y comunicación interna. De esta forma, el concepto de infostealer se estudia desde sus observables defensivos, no desde su capacidad dañina.

No existe una única norma internacional que delimite exhaustivamente la categoría infostealer. En la práctica, fabricantes, organismos y marcos de conocimiento coinciden en describir malware cuyo objetivo predominante es localizar, recopilar y transferir información reutilizable del endpoint. MITRE ATT&CK distribuye estas conductas entre descubrimiento, acceso a credenciales, colección y exfiltración, mientras CISA utiliza la categoría en alertas sobre familias concretas (MITRE, s. f.-b, s. f.-c, s. f.-e, s. f.-f; CISA, 2023).

La definición operativa adoptada es: software malicioso cuya función principal consiste en obtener artefactos de identidad, sesión, configuración o valor financiero susceptibles de reutilización o comercialización. La frase función principal permite diferenciar un stealer de un RAT que también copia ficheros o de un ransomware que además exfiltra datos. La definición incluye tanto recolectores especializados como módulos de robo integrados en cadenas más amplias.

Un infostealer puede definirse funcionalmente como malware cuya capacidad principal consiste en localizar, recopilar y preparar información reutilizable procedente del sistema o de aplicaciones. La relevancia de esta definición reside en el destino funcional del dato: autenticación, continuidad de sesión, fraude, selección de objetivos o monetización. No todas las familias buscan los mismos activos ni emplean el mismo mecanismo de salida, por lo que la categoría debe analizarse mediante subfunciones observables. StealLab adopta esta definición funcional para representar tipos de información sin reproducir adquisición no autorizada ni comunicación con infraestructura externa.

4.5 Diferencias con otras categorías de malware

Diferenciar stealer, spyware, keylogger, RAT y ransomware es necesario para delimitar el alcance. El stealer busca información reutilizable; el spyware observa; el keylogger captura entradas; el RAT controla; el ransomware cifra o bloquea. En la práctica puede haber solapamientos, pero la distinción conceptual evita conclusiones imprecisas.

Esta distinción afecta al diseño experimental. Si el TFM estudiara ransomware, habría que tratar disponibilidad, cifrado y recuperación. Si estudiara RAT, habría que tratar persistencia y control remoto. Al estudiar stealers, el foco se desplaza hacia confidencialidad, activos, sesiones, tráfico e integridad de evidencias.

Por ello, M-001 excluye keylogging, persistencia, evasión y C2 real. No son omisiones accidentales: son delimitaciones que mantienen el caso dentro de un entorno seguro y defendible.

Tabla 15. Diferencias entre stealers y otras categorías de malware

Concepto	Rasgo diferencial	Motivo para delimitar
Stealer	Robo de información reutilizable	Objeto del TFM
Spyware	Vigilancia continua	Relacionado pero no central
Keylogger	Captura de teclado	Excluido por privacidad
RAT	Control remoto	Excluido por riesgo
Ransomware	Cifrado/extorsión	Solo impacto posterior

Un keylogger captura entradas; un password stealer accede a almacenes o formularios; un session stealer obtiene artefactos ya autenticados; un RAT ofrece control interactivo; un loader instala otras cargas; un banking trojan manipula operaciones financieras; y un ransomware busca interrupción o extorsión. Las categorías pueden solaparse, pero el objetivo predominante y el efecto esperado permiten diferenciarlas (NIST, 2013; MITRE, s. f.-a).

Esta distinción tiene consecuencias en la respuesta. Ante ransomware se priorizan contención de propagación y recuperación; ante robo de sesión se requiere revocación; ante token cloud, rotación y auditoría de actividad; ante wallet, evaluación criptográfica y financiera. StealLab no ejecuta esas respuestas, pero su clasificación evita asumir que todas las exposiciones se remedian mediante un simple cambio de contraseña.

La diferencia entre categorías debe establecerse por finalidad dominante y no por ausencia absoluta de capacidades secundarias. Un ransomware puede recopilar información antes de cifrar; una RAT puede extraer credenciales; y un stealer puede incorporar mecanismos de persistencia. La frontera analítica se sitúa en el objetivo que organiza la operación. Este criterio permite comparar comportamientos sin afirmar exclusividad y ayuda a que la metodología no confunda una señal genérica -por ejemplo, una conexión saliente- con una categoría concreta. La atribución exige un conjunto coherente de evidencias, no un único indicador.

4.6 Tipología defensiva de stealers

La tipología defensiva clasifica stealers por activos y señales observables, no por instrucciones de ataque. Esto permite hablar de password stealers, cookie/session stealers, cryptocurrency stealers, web skimmers, SaaS stealers e infostealers generalistas sin describir cómo operar ninguno.

Cada tipo plantea preguntas defensivas distintas. Si el objetivo son credenciales, interesan almacenes de navegador y gestores. Si el objetivo son cookies, interesan sesiones y expiración. Si el objetivo son wallets, interesan claves y extensiones. Si el objetivo es SaaS, interesan tokens, MFA, permisos y logs de acceso.

StealLab no cubre todas esas variantes de forma empírica. Las representa como mapa conceptual y valida un subconjunto seguro mediante M-001. Este enfoque permite ampliar el laboratorio en trabajos futuros sin modificar la base metodológica.

La tipología defensiva de stealers debe organizarse según el activo perseguido y no únicamente según el nombre comercial de la familia. Un browser stealer se orienta a artefactos de navegador; un password stealer prioriza credenciales; un cookie o session stealer busca sesiones autenticadas; un wallet stealer persigue claves, frases semilla o extensiones de criptoactivos; un token stealer se orienta a tokens de API, mensajería, repositorios o servicios SaaS; un file grabber selecciona documentos por rutas o extensiones; y un system profiler recopila contexto técnico del equipo.

Cada tipo genera necesidades defensivas diferentes. Las credenciales exigen rotación y revisión de reutilización; las cookies requieren invalidación de sesiones; los tokens obligan a revocación y auditoría de permisos; las wallets implican riesgo financiero inmediato; los ficheros locales pueden requerir análisis de exposición documental; y el perfilado del sistema

puede facilitar ataques posteriores. Por ello, una taxonomía útil debe conectar activo, impacto, evidencia y respuesta.

El laboratorio no reproduce cada subtipo mediante malware real, pero sí puede teorizar y preparar escenarios sintéticos separados. Esta separación permite diseñar futuras simulaciones benignas por categoría: una para credenciales sintéticas, otra para cookies ficticias, otra para tokens de prueba, otra para wallets simuladas y otra para inventario de sistema. El beneficio metodológico es que cada caso puede validarse sin mezclar riesgos ni evidencias.

La tipología puede ampliarse con dos dimensiones transversales: plataforma y modalidad operativa. Un stealer puede ser monolítico o modular, local o multiplataforma, autónomo o integrado en MaaS, y orientado a usuarios, empresas o activos de criptomonedas. Las campañas multiplataforma documentadas en 2026 muestran que el sistema operativo ya no es un criterio suficiente para delimitar el riesgo (Somé et al., 2025; Europol, 2026).

Para StealLab, la tipología más útil combina activo objetivo y evidencia esperada. Browser stealer se asocia a rutas de perfil, bases de datos y sesiones; credential stealer, a almacenes de autenticación; wallet stealer, a extensiones o material criptográfico; system profiler, a inventario del host; y SaaS stealer, a tokens o configuraciones de acceso. Esta relación permite diseñar pruebas sin replicar código ofensivo.

Una tipología defensiva debe organizarse según necesidades de protección y respuesta. Clasificar por activo -credenciales, navegador, sesiones, wallets o información del sistema- permite asociar cada categoría con controles, evidencias y medidas de remediación. Esta aproximación resulta más estable que una lista de familias y facilita operacionalizar el análisis: cada tipo puede vincularse con rutas, formatos, procesos o flujos esperables. En StealLab, la tipología no pretende describir implementación maliciosa, sino construir un mapa de observación seguro y justificar la selección de datos sintéticos.

4.7 Activos de información afectados

Un activo de información es cualquier elemento que posee valor por su contenido, contexto o capacidad de habilitar una acción. En stealers, el activo más importante no siempre es el documento más visible, sino aquel que permite acceso: credencial, cookie, token, wallet, configuración, historial o perfil.

La criticidad de un activo se evalúa por reutilización, persistencia y alcance. Una cookie puede ser útil mientras la sesión esté vigente; un token puede permitir llamadas automatizadas; una wallet puede representar pérdida directa; una credencial puede abrir acceso si no hay MFA. Esta clasificación mejora la interpretación de riesgo.

En M-001, los activos reales se sustituyen por ficheros sintéticos. Esta sustitución permite explicar el riesgo sin crear riesgo. Los hashes de esos ficheros demuestran integridad y permiten al lector verificar que el contenido de laboratorio no ha sido alterado.

Tabla 16. Activos de información afectados y representación segura

Activo	Riesgo si fuera real	Representación
Credencial	Acceso a cuentas	credencial_demo.txt
Cookie	Sesión autenticada	navegador_demo.txt
Token	Autorización programática	Conceptual
Wallet	Pérdida financiera	wallet_demo.txt
Sistema	Contexto técnico	sistema_demo.txt

Un activo de información es cualquier dato, artefacto o representación digital que tiene valor para una persona, una organización o un atacante. En el dominio infostealer, los activos más relevantes no son siempre documentos evidentes; con frecuencia son pequeños secretos

reutilizables: credenciales, cookies, tokens, claves, identificadores de sesión, configuraciones de navegador, perfiles de aplicación, extensiones, historiales y metadatos del sistema.

Las credenciales permiten autenticación directa; las cookies y tokens permiten continuidad de sesión o autorización delegada; las claves privadas y frases semilla pueden permitir control de activos criptográficos; los ficheros locales pueden contener información sensible; y los datos de sistema permiten valorar el entorno, idioma, usuario, hostname, software instalado o posibles objetivos posteriores. La combinación de varios activos en un mismo paquete aumenta el riesgo porque permite reconstruir una identidad digital más completa.

StealLab reduce el riesgo sustituyendo cada activo por equivalentes sintéticos. La memoria no debe afirmar que se capturaron credenciales, cookies, tokens o wallets reales. Lo validado es la existencia de ficheros DEMO, hashes, ejecución controlada y tráfico interno. Esta precisión protege la validez del trabajo: el laboratorio demuestra capacidad de modelado y observabilidad, no explotación de datos auténticos.

El valor de un activo depende de alcance, privilegio, vigencia, revocabilidad y reutilización. Una contraseña puede ser de bajo valor si está protegida por MFA y no se reutiliza; una cookie administrativa vigente puede tener alto impacto; un token con permisos mínimos puede ser menos crítico que una clave sin caducidad; y una frase semilla no es revocable del mismo modo que una sesión. La evaluación debe considerar tanto el secreto como el mecanismo de control que representa.

El perfil de navegador debe tratarse como activo compuesto. La investigación reciente muestra que directorios de usuario y extensiones pueden concentrar cookies, historiales, contraseñas, tokens y configuración, lo que convierte el navegador en una superficie de identidad y no solo en una aplicación de consulta web (Somé et al., 2025; Anliker & Lain, 2025). StealLab abstrae esa complejidad mediante navegador_demo.txt, pero la discusión conserva la naturaleza múltiple del riesgo.

Los activos afectados difieren en confidencialidad, vigencia y revocabilidad. Una contraseña puede cambiarse; una cookie requiere invalidar la sesión; un token puede necesitar rotación en el servicio emisor; y una clave privada puede no admitir recuperación sin sustituir la identidad criptográfica. Esta diversidad condiciona tanto el impacto como la respuesta. El marco teórico debe, por ello, evitar la expresión genérica datos robados cuando sea posible y especificar el tipo de activo, la función que cumple y el control defensivo aplicable. StealLab representa estas categorías de forma sintética para mantener la distinción sin exponer secretos reales.

4.8 Ciclo operacional de alto nivel

El ciclo operacional de un stealer puede describirse en términos de entrega, ejecución, descubrimiento local, recolección, agregación, comunicación, transferencia y monetización. Esta secuencia se presenta a nivel conceptual, sin instrucciones accionables, para ordenar las evidencias defensivas.

En StealLab solo se modelan etapas seguras: preparación de datos sintéticos, ejecución controlada, agregación de resultados, comunicación HTTP interna y documentación. No se simula phishing, descarga maliciosa, persistencia, evasión, cifrado, C2 real ni monetización.

La utilidad del ciclo es metodológica: cada etapa sugiere qué se podría observar. La ejecución controlada puede generar procesos; la comunicación puede generar PCAP; la agregación puede generar ficheros; la preservación puede generar hashes e informes.

El ciclo puede mapearse de forma defensiva a ATT&CK: descubrimiento de sistema y aplicaciones; acceso a almacenes de credenciales; recopilación de datos; preparación o staging; comunicación; y exfiltración. Las técnicas concretas varían, y no todas aparecen en

cada familia (MITRE, s. f.-b, s. f.-c, s. f.-g, s. f.-h). El mapeo permite construir hipótesis de observación sin asumir una secuencia única.

Tras la transferencia comienza una fase económica que no siempre es visible en el endpoint: clasificación, empaquetado, publicación, venta, prueba de acceso y explotación. La separación entre ciclo técnico y ciclo de monetización explica por qué el impacto puede aparecer días o meses después de la infección. M-001 finaliza en la recepción interna controlada; cualquier inferencia sobre mercados o acceso posterior procede de literatura externa.

El ciclo operacional permite estudiar el fenómeno como proceso y no como evento instantáneo. Identificación de fuentes, recopilación, preparación, transferencia y uso posterior pueden dejar evidencias distintas y estar separados temporalmente. Esta descomposición favorece la observabilidad porque permite formular preguntas específicas para cada fase: qué proceso accede, qué artefacto se crea, qué flujo se inicia y qué registro conserva el evento. En StealLab, el ciclo se reduce deliberadamente a etapas benignas necesarias para validar el método, sin incorporar persistencia, evasión, propagación o monetización.

4.9 Técnicas observables en marcos defensivos

MITRE ATT&CK no se usa como manual de ataque, sino como vocabulario defensivo. T1555.003 ayuda a denominar la categoría de credenciales desde navegadores. T1539 ayuda a denominar el riesgo de cookies de sesión. Usar estas referencias mejora precisión terminológica y conecta StealLab con marcos reconocidos.

La observabilidad no implica detección automática. StealLab valida que existen evidencias de un flujo controlado, no que se detecta una técnica real en producción. Esta diferencia evita confundir laboratorio académico con EDR o SIEM.

La relación con ATT&CK también permite justificar por qué navegador_demo y credencial_demo existen como ficheros separados. Representan categorías defensivas distintas aunque ambas estén vinculadas al acceso a cuentas.

Tabla 17. Técnicas observables en marcos defensivos y uso seguro

Referencia	Concepto defensivo	Uso seguro
T1555.003	Credenciales desde navegadores	Justifica credencial/navegador DEMO
T1539	Cookies de sesión web	Justifica sesión sintética
Credential Access	Táctica de acceso a credenciales	Contexto, no ejecución
Exfiltration	Movimiento de datos fuera del sistema	No se realiza; solo comunicación interna

ATT&CK debe utilizarse como una ontología de comportamientos, no como un mecanismo automático de prueba. La técnica T1555.003 describe obtención de credenciales desde navegadores; T1539, robo de cookies de sesión; T1217, descubrimiento de información del navegador; T1082, descubrimiento del sistema; T1005, datos del sistema local; T1074.001, staging local; y T1041, exfiltración sobre canal de C2 (MITRE, s. f.-b, s. f.-d, s. f.-e, s. f.-f, s. f.-g, s. f.-h, s. f.-i, s. f.-j).

En StealLab, estas técnicas sirven para seleccionar señales comparables, pero el caso no satisface todas sus condiciones. Por ejemplo, una transferencia HTTP interna de datos sintéticos se parece formalmente a un flujo de salida, pero no se etiqueta como T1041 porque no existe C2 ni información sustraída. El lenguaje ATT&CK se aplica con criterio conservador y siempre acompañado del límite de equivalencia.

Los marcos defensivos ofrecen un vocabulario común para describir comportamientos, pero no sustituyen la evidencia local. Mapear una observación a ATT&CK ayuda a comparar informes y organizar hipótesis, aunque la correspondencia debe justificarse por acciones concretas y no por semejanza superficial. Una técnica es una categoría analítica, no una

prueba de familia ni de intención. Por ello, StealLab utiliza el mapeo como apoyo interpretativo y mantiene separadas tres capas: evento observado, categoría defensiva propuesta y nivel de confianza de la interpretación (MITRE, s. f.-a).

4.10 Evidencia digital, trazabilidad y reproducibilidad

La evidencia digital exige identidad, integridad, contexto e interpretación. Un fichero sin contexto tiene valor limitado; un hash sin ruta y caso también. En StealLab, cada evidencia se asocia a identificador EV, prueba PV, ruta, función e interpretación.

La trazabilidad permite pasar de la pregunta de investigación a la conclusión. La cadena es: objetivo, prueba, evidencia, resultado, interpretación y límite. Si falta un eslabón, la conclusión pierde fuerza.

La reproducibilidad no significa que cualquier lector tenga el mismo hardware, sino que pueda comprender y repetir el procedimiento en un entorno equivalente. Rutas, hashes, snapshots, red libvirt y matrices hacen posible esa reproducción razonable.

La evidencia digital es cualquier elemento técnico que puede sostener una afirmación dentro del análisis: un fichero, un hash, una captura de tráfico, una salida seleccionada, una configuración, una captura visual, una ficha PV/EV o un informe técnico. Para que una evidencia sea útil no basta con conservarla; debe estar identificada, contextualizada, fechada cuando proceda, vinculada a una prueba y acompañada de una interpretación proporcional.

La trazabilidad conecta pregunta, objetivo, prueba, evidencia y conclusión. En StealLab, PV identifica pruebas de validación y EV identifica evidencias. Esta nomenclatura evita que los resultados dependan de una narración informal. Una afirmación como "el laboratorio captura tráfico controlado" debe poder relacionarse con una prueba concreta, un PCAP, un hash o una ficha de evidencia; si no existe esa relación, la afirmación debe degradarse a hipótesis, diseño previsto o trabajo futuro.

La reproducibilidad exige que otro evaluador pueda entender el procedimiento y repetirlo en condiciones equivalentes. En una memoria académica no es necesario volcar toda la consola, pero sí explicar qué se hizo, qué evidencia quedó y dónde se conserva el detalle completo. La refutabilidad exige aceptar que una prueba pueda no confirmar lo esperado; por ello, StealLab separa evidencia observada, interpretación defensiva y limitación.

La evidencia digital es información de valor probatorio almacenada o transmitida en forma binaria. Su utilidad depende de que pueda vincularse con un origen, un procedimiento y una afirmación. NISTIR 8387 subraya la necesidad de preservar integridad y metadatos, mientras SWGDE recomienda documentar adquisición, herramientas, fechas y verificaciones (NIST, 2022; SWGDE, 2025).

El hash criptográfico apoya la integridad al permitir detectar cambios, pero no demuestra por sí solo quién creó el fichero, cuándo se obtuvo o si su contenido es verdadero. FIPS 180-4 define SHA-256 dentro de la familia Secure Hash Standard, y la posición de SWGDE sobre hashes insiste en interpretar sus límites (NIST, 2015; SWGDE, 2019). Por ello, StealLab combina hash, ruta, identificador EV, prueba PV, descripción y contexto.

La evidencia digital adquiere valor cuando puede relacionarse con su origen, método de obtención y contexto. La integridad criptográfica demuestra que un artefacto no ha cambiado desde el cálculo del hash, pero no prueba por sí sola quién lo creó, qué significa ni si la captura fue completa. La trazabilidad complementa esa limitación mediante identificadores, rutas, fechas, herramientas y relación con la prueba. La reproducibilidad exige, además, que el procedimiento esté descrito con suficiente precisión para repetirlo o reconstruirlo. Estos tres conceptos son interdependientes y forman el núcleo documental de StealLab (NIST, 2006, 2022; SWGDE, 2025).

4.11 Simulación benigna frente a ejecución de malware real

Esta sección es crítica para el TFM. Una muestra real de malware es un artefacto malicioso operativo que puede incluir robo de datos, persistencia, evasión o comunicación con infraestructura externa. Una simulación benigna es un artefacto controlado que reproduce señales limitadas sin daño ni datos reales. M-001 pertenece a la segunda categoría.

La simulación benigna no debe presentarse como equivalente funcional de un stealer real. Su validez es metodológica: permite aislar variables, repetir el experimento, evitar daño y comprobar que el laboratorio captura evidencias. Su limitación es externa: no representa evasión, familias Windows reales, C2 cifrado ni comportamiento adversario completo.

La decisión de no usar malware real se justifica por ética, seguridad y alcance académico. Ejecutar muestras reales exige protocolos adicionales, autorizaciones, aislamiento reforzado, experiencia especializada y gestión de riesgos. En este TFM, el objetivo aprobado se cumple mediante análisis seguro de comportamientos representativos, no mediante peligrosidad del artefacto.

La diferencia también afecta al lenguaje. No debe decirse que M-001 exfiltra datos, sino que genera comunicación HTTP interna controlada con datos DEMO. No debe decirse que analiza Lumma o RedLine, sino que valida categorías defensivas inspiradas en comportamientos tipo stealer. Esta precisión es parte de la calidad científica del trabajo.

Tabla 18. Comparación entre malware real y simulación benigna M-001

Dimensión	Malware real	Simulación benigna M-001
Riesgo	Puede dañar, propagarse o contactar infraestructura	Diseñada para no dañar ni salir del laboratorio
Datos	Puede acceder a información real	Solo DEMO/NO REAL
Comunicación	Puede usar C2 real o cifrado	HTTP interno benigno
Validez	Mayor realismo externo	Mayor control interno y ético
Conclusión permitida	Análisis de muestra concreta	Validación de laboratorio y observabilidad

La simulación benigna es una técnica de investigación que representa un comportamiento de interés sin incorporar la capacidad dañina del fenómeno original. En este TFM, la simulación no busca imitar un stealer real en todos sus detalles, sino reproducir categorías observables de forma segura: preparación de datos sintéticos, lectura controlada, agregación documental y comunicación interna hacia un servicio benigno.

La ejecución de malware real introduce riesgos técnicos, legales y éticos: propagación accidental, contacto con infraestructura externa, tratamiento de datos reales, generación de daño, activación de mecanismos no previstos o almacenamiento de material peligroso. Por el contrario, M-001 elimina credenciales reales, cookies reales, tokens reales, wallets reales, C2 real, Internet, persistencia y evasión. Esta reducción de riesgo no es una debilidad oculta, sino una decisión metodológica explícita.

La diferencia entre simulación y emulación también es relevante. Una emulación intenta reproducir con mayor fidelidad un comportamiento técnico concreto; una simulación académica puede abstraer el fenómeno para estudiar variables seleccionadas. StealLab opera en este segundo sentido: selecciona propiedades defensivas observables y las convierte en pruebas controladas. Por ello, sus conclusiones no deben generalizarse a todas las familias de stealers, pero sí sostienen la viabilidad del laboratorio como entorno de análisis seguro.

La simulación benigna ofrece alta controlabilidad y bajo riesgo, pero menor validez ecológica. La ejecución real aumenta realismo conductual, aunque introduce posibilidad de fuga, evasión del sandbox, dependencia de infraestructura y variabilidad entre ejecuciones. Los estudios

sobre evasión y bifurcación de comportamiento muestran que una muestra puede ocultar o modificar su actividad al detectar el entorno (Afianian et al., 2020; Avllazagaj et al., 2021).

La decisión adecuada depende de la pregunta. Si se pretende identificar una familia o estudiar evasión, M-001 es insuficiente. Si se pretende validar aislamiento, captura, preservación y trazabilidad, una simulación controlada es suficiente y más ética. Esta correspondencia entre pregunta y método evita presentar la seguridad como una debilidad no reconocida; se documenta como intercambio explícito entre realismo, control y riesgo.

La simulación benigna conserva estructura de observación y elimina intención dañina. Su validez depende de declarar qué propiedades representa y cuáles excluye. Puede ser adecuada para estudiar flujo de evidencia, separación de roles, captura de procesos o tráfico controlado, pero no para evaluar evasión, persistencia, cobertura de detección o comportamiento adaptativo. Esta asimetría no invalida el método; define su constructo. StealLab utiliza la simulación como instrumento de validación de laboratorio, no como sustituto funcional de una muestra, y mantiene explícita esa frontera en resultados y conclusiones.

4.12 Terminología esencial del dominio stealer

La terminología esencial incluye credencial, cookie, sesión, token, wallet, C2, exfiltración, log robado y acceso inicial. Estos términos no deben usarse como sinónimos porque cada uno implica controles defensivos distintos. Una credencial puede rotarse; una cookie puede invalidarse; un token puede revocarse; una wallet puede requerir medidas de custodia completamente diferentes.

En StealLab todos los términos sensibles se transforman en representaciones seguras. Esto permite explicar el fenómeno sin exponer datos reales. La tabla integral de acrónimos incorporada al inicio del marco teórico cumple la función de primera definición, mientras que esta sección refuerza el uso específico del dominio stealer.

El lector debe interpretar cualquier mención a credenciales, cookies, tokens o wallets como categoría conceptual salvo que se indique expresamente que se trata de un fichero DEMO. En ningún punto del laboratorio se manipulan activos reales de terceros.

Se distinguen tres grupos semánticos. El primero describe activos: credencial, cookie, token, wallet y perfil. El segundo describe operaciones: descubrimiento, colección, staging, transferencia, exfiltración y monetización. El tercero describe evidencia: artefacto, evento, IOC, IOA, hash, PCAP y cadena de custodia. Mantener estos grupos separados evita confundir el objeto robado con la conducta y con la señal usada para inferirla.

También se diferencia LLM supervisado de análisis autónomo. En el TFM, el modelo lingüístico puede ayudar a ordenar texto, comparar definiciones o proponer síntesis, pero cada afirmación se valida contra fuentes y evidencias humanas. Esta limitación es coherente con NIST AI RMF, su perfil para IA generativa y las recomendaciones de OWASP sobre riesgos de contenido no fiable, exposición de datos y dependencia excesiva (NIST, 2023, 2024; OWASP Foundation, 2025). Los estudios exploratorios que aplican LLM al análisis de stealers muestran potencial para resumir y explicar código, pero también la necesidad de verificación experta y de no convertir la salida del modelo en evidencia primaria (Ruellan et al., 2025).

La terminología del dominio debe distinguir activo, mecanismo y consecuencia. Credencial designa información de autenticación; sesión representa continuidad de un estado ya autenticado; token expresa autorización o identidad delegada; y log robado describe un paquete criminal que puede combinar múltiples categorías. Confundir estos términos dificulta valorar el impacto y seleccionar la respuesta. La precisión terminológica también evita que el

lector interprete navegador, wallet o sistema como fuentes homogéneas. En el TFM, cada término se vincula con una representación sintética y con un límite explícito de interpretación.

4.13 Impacto funcional del malware en confidencialidad, integridad y disponibilidad

La tríada confidencialidad, integridad y disponibilidad permite conectar malware con gestión de riesgo. Un stealer afecta de forma primaria a la confidencialidad porque expone información. Sin embargo, la reutilización de esa información puede impactar integridad si permite modificar datos, o disponibilidad si habilita ransomware o bloqueo de servicios.

Esta relación explica por qué una amenaza aparentemente silenciosa puede ser crítica. El usuario quizá no perciba pérdida inmediata de disponibilidad, pero la exposición de una cookie o credencial puede producir consecuencias posteriores. El tiempo entre robo e impacto puede dificultar detección y respuesta.

En StealLab, esta relación se modela sin daño. El laboratorio representa activos y comunicación controlada para que el lector entienda la cadena de riesgo, pero no produce un incidente real.

En los infostealers, la afectación primaria suele ser la confidencialidad, pero las consecuencias pueden extenderse a integridad y disponibilidad. Una sesión robada puede permitir modificar datos, crear reglas, alterar configuraciones o eliminar recursos; un acceso posterior puede culminar en cifrado o interrupción. El modelo CIA ayuda a ordenar impactos, aunque no sustituye el análisis de identidad, privacidad, autenticidad y responsabilidad (NIST, 2013).

La relación causal debe formularse por etapas: el stealer expone un activo; el activo puede habilitar acceso; el acceso puede producir modificaciones o indisponibilidad. StealLab valida la primera representación y la observabilidad de su transferencia interna, pero no demuestra las etapas posteriores. Esta separación protege la validez de constructo.

Este epígrafe profundiza en el efecto de las acciones maliciosas sobre las propiedades de seguridad y no repite la definición general presentada anteriormente. En un escenario tipo stealer, la confidencialidad resulta directamente afectada por la obtención no autorizada de secretos; la integridad puede verse comprometida cuando esos secretos permiten modificar cuentas, sesiones o configuraciones; y la disponibilidad puede degradarse como consecuencia indirecta de bloqueos, fraude, respuesta a incidentes o intrusiones posteriores. La separación ayuda a interpretar el riesgo sin atribuir a M-001 impactos que no fueron ejecutados.

El modelo de confidencialidad, integridad y disponibilidad permite situar el impacto sin reducirlo a una única dimensión. Los stealers afectan principalmente a la confidencialidad, pero el uso posterior de las credenciales puede alterar integridad de datos, configuraciones o transacciones, y eventualmente provocar indisponibilidad mediante bloqueo de cuentas o incidentes derivados. La relación es indirecta y debe formularse como cadena de consecuencias posibles. StealLab se centra en la primera dimensión y utiliza las restantes para discutir riesgo, sin afirmar que M-001 haya producido alteración o interrupción real.

4.14 Taxonomía operativa para la observación defensiva

La taxonomía defensiva clasifica por tipo de activo, señal observable y riesgo. Esta taxonomía es más útil que una lista de familias porque permite razonar sobre nuevos casos. Si mañana aparece otra familia, puede clasificarse según si busca contraseñas, cookies, tokens, wallets, SaaS o información del sistema.

La taxonomía también ayuda a diseñar experimentos. Un caso orientado a navegador requeriría datos sintéticos de perfil; un caso orientado a wallet requeriría wallet_demo; un caso orientado a SaaS requeriría tokens ficticios; un caso orientado a sistema requeriría metadatos benignos.

StealLab adopta esta taxonomía como marco estable para comparar casos sin alterar los principios éticos. En la fase experimental complementaria, M-002 a M-005 aplican esa lógica a descubrimiento, staging local, comunicación interna y contención negativa, siempre con artefactos sintéticos y sin reproducir capacidades maliciosas reales.

Tabla 19. Taxonomía defensiva de stealers

Eje taxonómico	Pregunta defensiva	Ejemplo seguro
Activo	Qué tipo de dato se representa	credencial_demo/wallet_demo
Señal	Qué se puede observar	Proceso, fichero, PCAP
Canal	Cómo se comunica	HTTP interno
Riesgo	Qué podría pasar si fuera real	Acceso, fraude, extorsión
Límite	Qué no se puede afirmar	Familia real específica

Además del activo objetivo, la taxonomía incorpora mecanismo de acceso, alcance, persistencia del secreto y canal de salida. Dos stealers orientados al navegador pueden diferir radicalmente si uno busca contraseñas cifradas localmente y otro cookies activas; dos recolectores de tokens pueden producir riesgos diferentes según permisos y duración. Una taxonomía multidimensional permite diseñar controles y respuestas específicos.

La taxonomía también admite familias híbridas. Un loader con módulo de robo, un RAT con funciones de colección o un banking trojan con extracción de cookies pueden clasificarse por capacidades concurrentes. En la memoria se reserva el término stealer para los casos en los que la obtención de información es central, y se utilizan etiquetas compuestas cuando la fuente documenta más de una función.

La taxonomía operativa se utiliza como instrumento de observación, no como mecanismo de atribución de familias. Clasifica comportamientos según el activo objetivo, el origen del dato, la preparación local, el canal de comunicación y la evidencia generada. Gracias a esta orientación, una misma categoría puede analizarse con datos sintéticos sin reproducir código malicioso. El resultado es una estructura compatible con la comparación entre casos, pero suficientemente prudente para no inferir identidad, autoría o capacidades no observadas.

Una taxonomía operativa debe permitir pasar del concepto al dato. Cada categoría necesita una definición, un indicador, una fuente de evidencia y una regla de interpretación. Por ejemplo, observabilidad de red no equivale a cualquier paquete capturado, sino a la capacidad de asociar un flujo con origen, destino, protocolo y contexto. Esta estructura reduce ambigüedad y facilita comparar pruebas. En StealLab, la taxonomía funciona como puente entre el marco teórico y la matriz metodológica, evitando que las categorías se introduzcan después de observar los resultados.

4.15 Valoración del riesgo de los activos de información

El riesgo asociado a un activo depende de su poder de reutilización. Una credencial sin MFA puede ser crítica; una cookie de sesión vigente puede reducir barreras de autenticación; un token de API puede permitir automatización; una wallet puede representar pérdida irreversible. Por eso la clasificación debe ir más allá de nombre de fichero.

El riesgo también depende del contexto. Una credencial de un foro no tiene el mismo impacto que una credencial de administrador cloud. Una cookie caducada no tiene el mismo valor que una sesión válida. Un token con permisos mínimos no equivale a un token privilegiado. StealLab no mide esos impactos porque no usa datos reales; los explica conceptualmente.

La decisión de usar datos sintéticos permite publicar hashes y rutas sin comprometer privacidad. Es un equilibrio entre realismo y seguridad.

Se propone valorar cada activo mediante seis atributos: privilegio concedido, alcance de recursos, tiempo de validez, posibilidad de revocación, facilidad de detección y criticidad de negocio. Esta matriz evita asignar el mismo riesgo a todos los ficheros. Una cookie caducada y un token administrativo vigente pueden pertenecer a la misma categoría general de sesión, pero requieren prioridades distintas.

La seguridad del navegador ilustra esta dependencia contextual. Los estudios sobre cookies y controles de navegador muestran que atributos, aislamiento, canales seguros y mecanismos de vinculación pueden reducir ciertos abusos, mientras la integridad insuficiente de cookies ha sido históricamente una fuente de vulnerabilidad (Zheng et al., 2015; Squarcina et al., 2023; Tyler & Nunes, 2024). StealLab no evalúa estos mecanismos, pero los incorpora en la interpretación del riesgo.

La valoración considera simultáneamente sensibilidad, reutilización, alcance y persistencia del daño. Una contraseña puede revocarse, mientras que una cookie activa o un token puede permitir acceso inmediato; determinados metadatos del sistema pueden facilitar reconocimiento; y un perfil completo de navegador puede combinar múltiples elementos con valor agregado. En StealLab estas relaciones se representan de forma sintética para estudiar su significado defensivo, sin asignar valores económicos ni simular explotación posterior.

El riesgo asociado a un activo depende de probabilidad de uso, impacto, vigencia y capacidad de revocación. Dos secretos técnicamente similares pueden tener consecuencias muy distintas según privilegios, alcance y servicio afectado. Una valoración defensiva debe considerar también dependencia entre activos: una cookie puede eludir temporalmente la necesidad de contraseña, y un perfil de navegador puede reunir múltiples elementos de confianza. StealLab no cuantifica riesgo económico, pero incorpora esta lógica cualitativa para justificar por qué separa las categorías de datos y por qué evita tratarlas como ficheros equivalentes.

4.16 Cadena operacional y puntos de observación

La cadena operacional debe leerse como modelo analítico, no como receta. Se usa para ordenar evidencias: preparación, ejecución, acceso a artefactos, agregación, comunicación y documentación. StealLab conserva solo las etapas necesarias para validar observabilidad.

La cadena real puede incluir distribución mediante phishing, malvertising, cracks, loaders, abuso de extensiones o ingeniería social. Estos vectores se mencionan únicamente como contexto. M-001 se ejecuta manualmente en entorno controlado para evitar simular engaño o propagación.

Esta separación entre cadena real y cadena de laboratorio fortalece el trabajo porque impide confundir contexto de amenaza con procedimiento experimental.

Tabla 20. Cadena operacional de alto nivel y tratamiento en StealLab

Fase real	Riesgo	Tratamiento en StealLab
Distribución	Engaño o descarga maliciosa	No se reproduce
Ejecución	Inicio de código	Script benigno
Recolección	Acceso a datos	Datos DEMO
Comunicación	Contacto con C2	HTTP interno
Monetización	Venta/reutilización	Solo discusión

La cadena se representa como un grafo de posibilidades y no como una secuencia rígida. Descubrimiento y colección pueden ocurrir en paralelo; el staging puede omitirse; la transferencia puede usar HTTP, APIs, mensajería o almacenamiento intermedio; y la

monetización puede recaer en otro actor. ATT&CK ayuda a describir nodos, pero la evidencia temporal es necesaria para afirmar orden (MITRE, s. f.-a, s. f.-g, s. f.-h, s. f.-i).

Para cada etapa se define una señal mínima: proceso o comando para ejecución; acceso a ruta para colección; fichero agregado para staging; flujo y cabecera para comunicación; recepción verificada para transferencia. M-001 produce solo señales benignas asociadas a una ruta controlada. Este diseño facilita refutar afirmaciones: si falta la señal mínima, la etapa no se declara validada.

La cadena se descompone en puntos de observación que puedan asociarse con evidencias concretas: preparación de datos, acceso local autorizado, lectura de ficheros DEMO, creación de procesos, generación de artefactos, comunicación interna, captura de tráfico y conservación del resultado. Esta descomposición permite analizar qué capa aporta cada evidencia y dónde podrían aparecer falsos negativos. La finalidad no es reconstruir una campaña criminal completa, sino demostrar qué propiedades del laboratorio son observables y bajo qué condiciones.

Los puntos de observación se distribuyen entre endpoint, sistema de ficheros, proceso, red y repositorio documental. Ningún punto ofrece por sí solo una visión completa. La correlación permite reforzar una interpretación cuando varias fuentes independientes son coherentes, mientras una discrepancia obliga a revisar temporalidad, configuración o cobertura. Este principio sustenta la triangulación defensiva: un artefacto preparado, un proceso observado y un flujo capturado describen dimensiones complementarias. En StealLab, la cadena se diseña para que cada etapa produzca evidencia separada y pueda revisarse sin depender de una única captura.

4.17 Relación con MITRE ATT&CK desde un uso defensivo

MITRE ATT&CK proporciona un lenguaje común para describir técnicas adversarias. En este TFM, ese lenguaje se usa para reforzar definiciones y no para guiar ejecución. T1555.003 y T1539 son suficientes para justificar los activos de navegador y sesión representados en M-001.

El uso defensivo de ATT&CK implica traducir técnicas en preguntas de observación: qué activo se busca, qué evidencia podría dejar, cómo se preserva y qué límite tiene la interpretación. Esta traducción es más adecuada para un TFM académico que copiar procedimientos técnicos.

StealLab podría ampliarse en trabajos futuros con matrices ATT&CK más extensas, pero la memoria actual mantiene el alcance en las técnicas directamente relacionadas con credenciales y sesiones.

ATT&CK es una base de conocimiento de comportamientos adversarios observados y no una lista de requisitos de un laboratorio. Sus identificadores favorecen interoperabilidad entre análisis, detecciones y respuesta, pero una técnica puede tener múltiples implementaciones y una observación puede corresponder a más de una técnica (MITRE, s. f.-a).

El mapeo de StealLab se etiqueta como analogía defensiva. Se registra la técnica de referencia, la señal de M-001, la diferencia respecto de una conducta real y la evidencia PV/EV. Esta estructura evita el error frecuente de considerar que mencionar T1555.003 convierte cualquier lectura de un fichero sintético en robo de credenciales.

ATT&CK debe emplearse como lenguaje de comportamiento y no como mecanismo automático de atribución. Una técnica puede aparecer en múltiples familias y contextos legítimos; su identificación requiere evidencias suficientes y conocimiento del entorno. El valor para el TFM reside en normalizar descripciones y relacionar observables con controles o hipótesis de detección. El mapeo debe conservar incertidumbre, indicar si es conceptual o

empírico y evitar afirmar que una técnica ocurrió cuando solo se representó de forma benigna (MITRE, s. f.-a, s. f.-b, s. f.-e, s. f.-f).

4.18 Evidencia digital: identificación, integridad, contexto e interpretación

Una evidencia digital se vuelve académicamente útil cuando se puede identificar, verificar e interpretar. Identificación significa saber qué es y dónde está. Integridad significa poder comprobar que no cambió. Contexto significa conocer por qué se generó. Interpretación significa conectarla con una pregunta o criterio.

Los hashes SHA-256 cubren integridad, pero no contexto. Las rutas cubren ubicación, pero no interpretación. Las matrices PV/EV integran ambos elementos. Esta es una diferencia importante frente a una carpeta de ficheros sin explicación.

En StealLab, una evidencia como EV-PCAP-003 no se interpreta solo como un archivo pcap. Se interpreta como prueba de observabilidad de tráfico interno controlado, con límite explícito: no es C2 real.

Las normas ISO/IEC 27037, 27041, 27042 y 27043 organizan identificación, recogida, adquisición, aseguramiento, análisis e investigación de evidencia digital. Aunque StealLab no pretende implementar una cadena de custodia judicial completa, adopta sus principios de competencia, repetibilidad, documentación y preservación (ISO/IEC, 2012, 2015a, 2015b, 2015c).

La evidencia se evalúa en dos planos. En el plano técnico, se comprueba formato, hash, legibilidad y correspondencia con el evento. En el plano argumental, se comprueba si la evidencia sostiene exactamente la afirmación. Una PCAP puede demostrar direcciones y contenido transmitido; no demuestra intención. Un snapshot puede demostrar existencia de un estado; no garantiza por sí solo restauración exitosa. Esta distinción guía la clasificación de evidencias fuertes y de apoyo.

La evidencia puede analizarse en cuatro dimensiones complementarias. Identificación responde qué objeto es; integridad, si ha cambiado; contexto, dónde y cómo se obtuvo; e interpretación, qué conclusión permite sostener. La ausencia de una dimensión debilita las demás: un hash sin identificación no localiza el artefacto y una captura sin contexto puede admitir explicaciones alternativas. Esta estructura ayuda a separar propiedades del fichero de afirmaciones sobre el comportamiento. StealLab aplica esta lógica mediante nombres normalizados, rutas, hashes, fichas y relación PV/EV (NIST, 2006, 2022).

4.19 Reproducibilidad y refutabilidad

Reproducibilidad y refutabilidad son garantías de seriedad. Si un lector puede reconstruir el procedimiento y comprobar hashes, red, VMs y PCAP, entonces la memoria no depende de una afirmación subjetiva. Si una evidencia falta, la conclusión se puede cuestionar.

La ruta canónica, el árbol del repositorio, el inventario histórico y las evidencias posteriores documentadas, los snapshots qcow2 y la red libvirt activa son piezas de reproducibilidad. No son detalles administrativos; son parte del soporte empírico.

La refutabilidad obliga a redactar con prudencia. Si una VM está apagada, se dice que está registrada pero apagada; no se afirma IP runtime. Esa precisión evita errores y mejora credibilidad.

La reproducibilidad requiere materiales y procedimiento suficientes para obtener resultados comparables; la replicabilidad exige repetir el estudio de manera independiente; y la repetibilidad se refiere a ejecuciones bajo condiciones semejantes. La literatura reciente advierte que muchos trabajos de análisis de malware no publican configuraciones, muestras o artefactos suficientes para ser comprobados (Olszewski et al., 2025).

StealLab mejora estas propiedades mediante versiones, rutas, configuración de red, hashes, criterios de aceptación y descripción de límites. Sin embargo, no garantiza resultados idénticos en cualquier host: versiones de kernel, libvirt, QEMU, captura y tiempo de ejecución pueden introducir variación. Por ello, el objetivo es una reconstrucción auditable y no una identidad binaria absoluta.

La reproducibilidad no exige obtener siempre bytes idénticos en cualquier entorno, sino disponer de suficiente información para repetir el procedimiento y evaluar diferencias. En sistemas complejos pueden variar timestamps, identificadores o orden de eventos; lo esencial es declarar qué propiedades deberían mantenerse. La refutabilidad complementa este principio al definir qué observación obligaría a rechazar una afirmación. En StealLab, aislamiento, restaurabilidad o trazabilidad deben expresarse mediante criterios comprobables, evitando conclusiones formuladas de manera que ningún resultado pueda contradecirlas.

4.20 Ética de laboratorio en análisis de malware

La ética de laboratorio implica minimizar riesgo, proteger terceros, no manipular datos reales, no contactar infraestructura maliciosa y no publicar instrucciones ofensivas. En ciberseguridad académica, la utilidad del conocimiento debe equilibrarse con responsabilidad.

El uso de simulación benigna no es una renuncia al análisis, sino una decisión de diseño proporcionada al objetivo investigador. Permite trabajar sobre categorías de amenaza sin introducir daño y mantiene el documento revisable por terceros sin exponer material sensible.

La ética también afecta a los anexos. No basta con que el experimento sea seguro; la documentación también debe serlo. Por eso se eliminan volcados extensos y se conservan evidencias externas controladas.

Tabla 21. Riesgos éticos y medidas de control del laboratorio

Riesgo ético	Medida en StealLab	Efecto
Datos reales	DEMO/NO REAL	Protección de privacidad
C2 real	VM-SERVICES-SIM	No contacto externo
Malware real	M-001 benigno	Reducción de riesgo
Volcados extensos	Síntesis y repositorio	Claridad y seguridad

El Menlo Report traslada al ámbito TIC los principios de respeto a las personas, beneficencia, justicia y respeto al derecho e interés público. El Código de Ética de ACM añade obligaciones de evitar daño, respetar privacidad y evaluar riesgos de sistemas (DHS, 2012; ACM, 2018). Estos principios se concretan en minimización de datos, aislamiento, no contacto con terceros, ausencia de muestras operativas y revisión humana.

La ética también afecta a la comunicación. Un documento defensivo debe explicar comportamientos sin proporcionar instrucciones innecesarias de despliegue, evasión o explotación. StealLab conserva el detalle necesario para reproducir la validación benigna, pero excluye credenciales reales, C2, persistencia y técnicas de ocultación. La decisión se registra como límite y no se presenta como equivalencia con análisis profesional de malware real.

La ética del laboratorio no se limita a cumplir una prohibición, sino que orienta decisiones de diseño, acceso, almacenamiento y publicación. Debe aplicarse el principio de mínima capacidad peligrosa: incorporar solo aquello necesario para responder la pregunta y excluir funciones que aumenten riesgo sin aportar evidencia relevante. También deben considerarse exposición accidental, reutilización de artefactos, datos personales y efectos sobre terceros. StealLab materializa estos principios mediante aislamiento, datos sintéticos, ausencia de C2 real y revisión humana de los resultados (ACM, 2018; DHS, 2012).

4.21 Modelo conceptual final aplicado al TFM

El modelo conceptual final une cinco ideas. Primera: los stealers son amenazas de confidencialidad centradas en datos reutilizables. Segunda: los datos robados pueden habilitar impactos posteriores. Tercera: un laboratorio académico debe priorizar seguridad y trazabilidad. Cuarta: una simulación benigna puede validar observabilidad sin ser malware real. Quinta: los resultados deben interpretarse con límites explícitos.

Este modelo permite que la memoria conecte teoría y práctica. Las familias reales justifican el fenómeno; MITRE aporta vocabulario; NIST y ENISA aportan marco; M-001 aporta validación controlada; PV/EV aporta trazabilidad.

La conclusión conceptual es clara: StealLab no demuestra cómo funciona un stealer real concreto, sino cómo construir y validar un entorno defensivo para estudiar señales representativas de forma segura.

El modelo integra cinco capas causales: amenaza documentada, activo de información, comportamiento observable, evidencia preservada e interpretación limitada. La amenaza externa justifica el objeto; el activo define el riesgo; el comportamiento orienta la captura; la evidencia permite contraste; y la interpretación responde a la pregunta sin exceder los datos.

Como artefacto de design science, StealLab se evalúa por utilidad respecto del problema y por rigor de construcción y comunicación (Hevner et al., 2004; Peffers et al., 2007). El resultado no es una teoría universal de infostealers, sino una instancia verificable de cómo estudiar de manera segura un subconjunto de comportamientos.

El modelo conceptual final organiza el TFM como una cadena de transformación: amenaza documentada, categorías defensivas, requisitos del laboratorio, observables, evidencias e inferencias limitadas. Cada nivel restringe al siguiente y evita que una conclusión exceda lo que la evidencia permite. Esta estructura también facilita la defensa oral, porque muestra que la arquitectura no se eligió de forma arbitraria y que las pruebas derivan de conceptos previamente definidos. El modelo es, por tanto, una representación del razonamiento investigador además de una descripción del sistema.

4.22 Glosario aplicado a la interpretación de evidencias

El glosario extendido se ha integrado al inicio del marco teórico como tabla integral para que ningún acrónimo quede sin definir. Esta sección conserva su función interpretativa: explicar por qué ese glosario es necesario en un TFM de seguridad.

La terminología técnica de ciberseguridad es densa y a menudo polisémica. Log puede significar registro legítimo o paquete robado; muestra puede significar malware real o artefacto benigno; C2 puede confundirse con un simple servidor HTTP. El glosario evita esas confusiones.

La primera aparición de cada acrónimo mantiene su definición completa o remite de forma coherente al glosario. Esta práctica mejora la legibilidad para lectores no especializados en análisis de malware.

Para reforzar el glosario, los términos deben agruparse por función. En el grupo de identidad se incluyen credencial, cookie de sesión, token, API key, OAuth, bearer token y MFA. En el grupo de activos criptográficos se incluyen wallet, clave privada y frase semilla. En el grupo de observabilidad se incluyen PCAP, hash, IOC, IOA, TTP, evento, proceso y artefacto. En el grupo de laboratorio se incluyen VM, snapshot, bridge, KVM, libvirt, qcow2 y red aislada.

El término C2 debe tratarse con especial cuidado. En malware real, command and control describe infraestructura de mando, control o recepción de datos. En StealLab no existe C2 real. El servidor VM-SERVICES-SIM es un servicio interno benigno usado para generar una

evidencia de comunicación controlada. Confundir ambos conceptos debilitaría el rigor del TFM; por eso el documento debe hablar de servidor benigno interno y no de infraestructura C2.

El término LLM supervisado designa un modelo de lenguaje utilizado como apoyo documental, no como perito autónomo ni como fuente primaria. Su función aceptable es ayudar a ordenar evidencias, proponer taxonomías, resumir logs seleccionados, identificar posibles categorías de comportamiento y mejorar la claridad del informe. Sus salidas deben verificarse contra evidencias reales del laboratorio y no pueden cerrar por sí solas una conclusión.

Los términos de virtualización se completan con una distinción entre configuración persistente y estado runtime. El XML de libvirt describe redes y dominios, pero el estado operativo debe comprobarse mediante interfaces, procesos, rutas y conectividad. Del mismo modo, qcow2 admite copy-on-write y snapshots, pero la existencia de metadatos no sustituye una prueba de restauración (libvirt Project, 2026a, 2026b; QEMU Project, 2026a, 2026b).

En red, PCAP es el contenedor de paquetes capturados; TCP es el protocolo de transporte; HTTP define semántica de mensajes de aplicación; y DNS resuelve nombres. Estos términos se mantienen separados para que una evidencia no sea descrita de forma imprecisa. La PCAP de M-001 contiene un flujo HTTP sobre TCP dentro del segmento IP del laboratorio; cada nivel aporta una afirmación diferente (IETF, 2022a, 2022b; Wireshark Foundation, 2026).

A diferencia del inventario inicial de siglas, este glosario se orienta a resolver ambigüedades durante la lectura de resultados. Términos como evidencia, indicador, observable, hallazgo, artefacto, integridad, snapshot y trazabilidad no se utilizan como sinónimos. La precisión terminológica es necesaria porque una captura constituye un artefacto, pero solo adquiere valor probatorio cuando se vincula con un procedimiento, un contexto, una marca temporal y una afirmación limitada.

Aplicar el glosario a la evidencia significa utilizar términos con reglas consistentes. Capturado no equivale a exfiltrado; definido no equivale a activo; reservado no equivale a asignado en runtime; e íntegro no equivale a verdadero. Estas distinciones evitan que el vocabulario incremente artificialmente la fuerza de una conclusión. El glosario aplicado funciona como control de calidad semántico: obliga a seleccionar verbos y sustantivos acordes con el estado observado y a declarar cuándo una afirmación es inferida o permanece no demostrada.

4.23 Modelo conceptual de observabilidad defensiva

La observabilidad defensiva es la capacidad de captar señales relevantes de un sistema sin asumir intenciones no demostradas. En StealLab, esa observabilidad se distribuye en capas: estática, dinámica, red y documental.

La capa estática incluye datos sintéticos, scripts benignos y hashes. La capa dinámica incluye procesos y ejecución controlada. La capa de red incluye PCAP HTTP interno. La capa documental incluye fichas, matrices, informe y checklist. La fuerza del laboratorio reside en relacionar esas capas.

Observabilidad no equivale a detección. StealLab no genera alertas, no sustituye EDR y no correlaciona SIEM. Su objetivo es documentar un fenómeno bajo condiciones controladas. Esa delimitación mejora la precisión de resultados.

Tabla 22. Modelo conceptual de observabilidad defensiva

Capa	Elemento observado	Evidencia
Estática	Datos DEMO y hashes	EV-M001-001
Dinámica	Procesos y ejecución	EV-PROC
Red	HTTP interno y PCAP	EV-PCAP

Capa	Elemento observado	Evidencia
Documental	Matriz e informe	PV/EV, EV-INF

La observabilidad se modela mediante tres preguntas: qué ocurrió, dónde se observó y con qué grado de confianza. Las fuentes de host responden sobre procesos y ficheros; las de red, sobre flujos y protocolos; las de aplicación, sobre solicitudes y respuestas; y las documentales, sobre configuración y procedimiento. La confianza aumenta cuando fuentes independientes convergen.

Se definen tres niveles de conclusión: observación directa, inferencia técnica y contextualización externa. Por ejemplo, el hash calculado es observación directa; afirmar que un fichero no cambió entre dos comprobaciones es inferencia basada en igualdad de hash; y relacionar el tipo de dato con mercados criminales es contextualización bibliográfica. La separación reduce la confusión entre telemetría y narrativa.

La observabilidad puede entenderse como capacidad para reconstruir un estado o comportamiento a partir de señales disponibles. No depende solo del volumen de registros, sino de su cobertura, sincronización, contexto y relación con preguntas concretas. Un sistema puede generar abundante telemetría y, aun así, no permitir atribuir un evento a un proceso. StealLab adopta una observabilidad orientada a evidencias mínimas suficientes: cada fuente debe aportar una dimensión diferenciada y combinarse con las demás para sostener una interpretación prudente.

4.24 Modelo de riesgo asociado a activos robados

El modelo de riesgo se basa en reutilización, persistencia y criticidad. Reutilización significa que el dato permite actuar en otro servicio; persistencia significa que el dato sigue siendo válido; criticidad significa que el impacto potencial es alto. Esta matriz ayuda a explicar por qué no todos los datos robados tienen el mismo valor.

La cookie de sesión puede ser crítica si permite mantener acceso sin reintroducir contraseña. El token de API puede ser crítico si tiene permisos amplios. La wallet puede ser crítica porque algunos activos digitales no admiten reversión. La información de sistema puede parecer menor, pero puede apoyar selección o evasión.

Como StealLab no usa datos reales, no mide daño efectivo. Modela categorías de riesgo para demostrar que el laboratorio entiende el fenómeno y lo representa de forma segura.

Tabla 23. Modelo de riesgo asociado a activos robados

Activo	Reutilización	Persistencia	Representación segura
Credencial	Alta	Hasta rotación	credencial_demo
Cookie	Alta si sesión válida	Hasta expiración	navegador_demo
Token	Variable según permisos	Hasta revocación	Conceptual
Wallet	Muy alta	Alta si clave existe	wallet_demo sin claves
Sistema	Media	Variable	sistema_demo

La Parte II cierra con un marco conceptual completo para interpretar el resto del documento. A partir de aquí, la memoria pasa de la justificación teórica a la propuesta, diseño e implementación del laboratorio, manteniendo los principios establecidos: seguridad, trazabilidad, reproducibilidad, ética y ausencia de datos o malware reales.

El modelo de riesgo se expresa de forma cualitativa como combinación de probabilidad de reutilización e impacto potencial. La probabilidad aumenta con vigencia, compatibilidad del dispositivo, ausencia de MFA, reutilización y baja detectabilidad; el impacto aumenta con privilegios, alcance, sensibilidad y criticidad del servicio. No se asigna una puntuación universal porque los pesos dependen del contexto organizativo.

La respuesta defensiva se vincula con la propiedad del activo: las contraseñas se cambian, las sesiones se revocan, los tokens se rotan, las claves se sustituyen, las wallets pueden requerir

migración de fondos y los endpoints se investigan. Esta relación convierte la taxonomía en una guía de razonamiento, sin transformar el TFM en procedimiento operativo contra sistemas reales.

El modelo de riesgo debe considerar el ciclo de vida del activo. Algunos datos pierden valor rápidamente; otros conservan utilidad hasta su revocación; y otros, como determinadas claves, pueden requerir sustitución completa. La respuesta defensiva depende de esa persistencia. También importa el alcance: un token limitado a una función no tiene el mismo impacto que una sesión administrativa. En StealLab, el modelo se usa para jerarquizar conceptos y justificar representaciones sintéticas, no para estimar pérdidas económicas ni probabilidad estadística de abuso.

4.25 Modelos OSI y TCP/IP como marco de análisis defensivo

El modelo OSI organiza la comunicación de red en siete capas conceptuales: física, enlace, red, transporte, sesión, presentación y aplicación. El modelo TCP/IP agrupa esas funciones en un esquema más práctico: acceso a red, Internet, transporte y aplicación. Ambos modelos son abstracciones; no describen por sí solos una herramienta concreta, pero permiten razonar de forma ordenada sobre dónde se produce una señal, qué protocolo interviene y qué tipo de evidencia puede recogerse.

En un TFM sobre stealers, esta distinción resulta útil porque el fenómeno combina artefactos locales y comunicación. La lectura de ficheros o perfiles de usuario pertenece al plano del endpoint; la comunicación hacia un servicio interno o externo puede observarse en red; la resolución de nombres, las cabeceras HTTP, el uso de TLS o los puertos utilizados pertenecen a capas superiores; y la segmentación o el bridge virtual pertenecen a capas inferiores. Si no se separan estos planos, se corre el riesgo de atribuir a la red lo que solo se ha observado en el host, o de atribuir al host lo que solo aparece como flujo de red.

StealLab aplica los modelos OSI y TCP/IP como una matriz de interpretación defensiva. No se utilizan para enseñar explotación de red, sino para ordenar evidencias: qué demuestra una PCAP, qué demuestra un hash, qué demuestra una reserva DHCP y qué demuestra la existencia de un snapshot. De este modo, el análisis se mantiene verificable y evita conclusiones excesivas.

El modelo OSI divide la comunicación en siete capas conceptuales: física, enlace, red, transporte, sesión, presentación y aplicación. Aunque en un laboratorio virtual algunas capas no se observan como en una red física tradicional, el modelo sigue siendo útil para separar responsabilidades. La capa física queda abstraída por el host y la virtualización; la capa de enlace aparece en el bridge y las MAC virtuales; la capa de red se expresa en IP y subredes; la capa de transporte en puertos y sesiones; y la capa de aplicación en HTTP interno, datos sintéticos y servidor benigno.

El modelo TCP/IP agrupa las funciones en menos capas: acceso a red, Internet, transporte y aplicación. Esta simplificación resulta práctica para StealLab porque permite conectar el diseño técnico con evidencias concretas: acceso a red mediante virbr-steal, Internet mediante el segmento 10.10.10.0/24, transporte mediante conexiones TCP internas y aplicación mediante el intercambio HTTP benigno. La memoria puede usar ambos modelos de forma complementaria: OSI para explicación didáctica y TCP/IP para análisis operativo.

La utilidad defensiva de estos modelos está en localizar controles y evidencias. Si una prueba falla, el modelo por capas ayuda a preguntar de forma ordenada: existe la interfaz virtual, existe IP, existe ruta, existe puerto abierto, existe servicio, existe contenido esperado y existe evidencia conservada. Esta lógica convierte el modelo OSI y TCP/IP en una herramienta de diagnóstico y no solo en teoría introductoria.

ISO/IEC 7498-1 define siete capas conceptuales, mientras RFC 1122 organiza la arquitectura de Internet en capas de enlace, Internet, transporte y aplicación. En la práctica, los límites pueden cruzarse y las implementaciones no siempre exponen telemetría en la misma capa (ISO/IEC, 1994; IETF, 1989a). StealLab utiliza los modelos como herramienta de localización de evidencia, no como descripción física exhaustiva.

La capa de transporte se interpreta conforme a la especificación vigente de TCP, y la capa de aplicación conforme a la semántica de HTTP. Esto permite describir conexiones, puertos, cabeceras, métodos y cuerpos sin atribuir significado malicioso automático (IETF, 2022a, 2022b). El carácter benigno del flujo depende del contexto experimental, no del protocolo empleado.

OSI y TCP/IP son modelos de abstracción que permiten ordenar funciones, no copias exactas de una implementación. Su utilidad defensiva consiste en separar problemas de enlace, direccionamiento, transporte y aplicación, facilitando identificar dónde se produce una observación y qué herramientas pueden capturarla. Sin embargo, muchos fenómenos atraviesan varias capas y el endpoint añade un plano que no queda completamente descrito por la pila de red. StealLab utiliza ambos modelos de manera complementaria y evita forzar correspondencias rígidas (ISO/IEC, 1994; IETF, 1989a, 1989b).

4.26 Mapeo de categorías stealer a capas de observabilidad

Las categorías de comportamiento tipo stealer pueden mapearse a capas de observabilidad. La recolección de datos sintéticos se observa principalmente en el host; el empaquetado o generación de resultados se observa en sistema de ficheros; la comunicación interna se observa en transporte y aplicación; y el aislamiento se comprueba en red, virtualización y configuración de libvirt. Esta lectura permite que cada evidencia PV/EV tenga una función precisa.

Por ejemplo, PV-01 no demuestra que M-001 sea un stealer, sino que el entorno mantiene una red definida, aislada y persistente. PV-03 no demuestra detección EDR, sino observabilidad básica de procesos. PV-04 no demuestra C2 real, sino capacidad de capturar tráfico HTTP interno controlado. PV-05 no demuestra análisis forense completo, sino conservación organizada de evidencias. La fortaleza del TFM está en declarar estas fronteras y no ocultarlas.

Este mapeo se utiliza en capítulos posteriores para evitar una lectura plana de las pruebas. Cada prueba valida una propiedad concreta del laboratorio, no todas las propiedades posibles de un entorno de análisis de malware.

El mapeo por capas permite vincular cada categoría de stealer con una superficie observable. Un password stealer se interpreta principalmente en capa host y aplicación, porque el interés está en fuentes locales de credenciales y aplicaciones que las almacenan. Un cookie stealer añade relevancia de aplicación web y sesión. Un token stealer se conecta con aplicaciones, API y servicios SaaS. Un file grabber se observa en sistema de ficheros. Un system profiler se observa en comandos, APIs del sistema y artefactos de inventario. Un módulo de comunicación se observa en transporte y aplicación.

Esta lectura evita confundir activo afectado con canal de salida. Por ejemplo, una cookie es un activo de aplicación, pero su transferencia puede observarse en transporte y red. Una wallet puede residir como fichero o extensión de navegador, pero su impacto se manifiesta en el plano financiero. Un token de API puede almacenarse en un fichero de configuración, pero su abuso ocurre en servicios remotos. Por tanto, el análisis defensivo debe seguir la cadena activo-origen-comportamiento-evidencia-impacto.

En StealLab, la representación de estas categorías se limita a datos sintéticos. La tabla de capas no debe interpretarse como evidencia de que todos esos subtipos se ejecutaron. Su

función es preparar una matriz conceptual para futuras extensiones: cada nuevo caso benigno debería declarar qué activo simula, qué capa observa, qué evidencia produce y qué límite ético mantiene.

Tabla 24. Relación entre categorías de observabilidad, capas y evidencias PV/EV

Categoría	Capa principal	Evidencia asociada	Interpretación defensiva
Aislamiento de red	Enlace/red	PV-01, virbr-steal, StealLab-Net	Control del perímetro del laboratorio
Identidad IP y direccionamiento	Red	Segmento 10.10.10.0/24, reservas DHCP	Diseño de comunicación controlada
Sesión y puertos	Transporte	PCAP y servicio HTTP interno	Observación de flujo permitido
Protocolo de aplicación	Aplicación	HTTP interno hacia VM-SERVICES-SIM	Simulación benigna de comunicación
Procesos y ficheros	Host	PV-03, ficheros DEMO, hashes	Trazabilidad local y conservación de evidencia
Restaurabilidad	Virtualización	Snapshots qcow2	Repetibilidad y control experimental

El mapeo final puede representarse como una matriz entre categoría de activo, plano del endpoint, plano de red, plano de aplicación y evidencia. Las credenciales sintéticas aparecen como fichero y contenido; el proceso de envío, como telemetría de host; la conexión, como flujo TCP/IP; la solicitud, como HTTP; y la recepción, como registro del servidor. Ninguna columna aislada demuestra la cadena completa.

La correlación temporal y los identificadores comunes son esenciales para unir capas. M-001, PV y EV actúan como claves documentales; direcciones, puertos, hashes y marcas de tiempo actúan como claves técnicas. Cuando dos señales no pueden vincularse de forma fiable, se presentan como evidencias separadas y se evita construir una narrativa causal no demostrada.

El mapeo por capas debe interpretarse como matriz de cobertura. Una categoría puede requerir señales de varias fuentes: acceso a un fichero en host, creación de proceso, resolución de nombre, conexión de transporte y solicitud de aplicación. La ausencia de una señal puede deberse a falta de cobertura y no necesariamente a inexistencia del comportamiento. Por ello, el mapeo debe registrar tanto lo observable como los vacíos de telemetría. Esta lectura permite diseñar pruebas más transparentes y evita que una única capa se convierta en criterio absoluto de validación.

PARTE III. PROPUESTA, DISEÑO E IMPLEMENTACIÓN

5 PREGUNTA DE INVESTIGACIÓN, PROPOSICIÓN Y OBJETIVOS

5.1 Pregunta de investigación

¿En qué medida es posible diseñar, construir y validar un laboratorio académico, seguro y reproducible para observar, registrar y analizar comportamientos defensivamente representativos de stealers sin ejecutar malware real ni utilizar datos sensibles reales?

La pregunta contiene cinco condiciones acumulativas: diseño técnico, construcción efectiva, validación, seguridad y reproducibilidad. Responder afirmativamente exige demostrar todas ellas dentro del alcance delimitado. No basta con que las máquinas virtuales existan; debe probarse que la arquitectura limita conectividad, puede restaurarse, produce señales observables y conserva evidencias interpretables.

La formulación evita preguntar si StealLab detecta todos los stealers o reproduce una campaña real, porque ese objetivo sería incompatible con la muestra y con las restricciones éticas. El objeto de inferencia es el laboratorio como artefacto técnico-documental, no el universo completo de malware.

La pregunta integra cuatro dimensiones que deben mantenerse diferenciadas: construcción del artefacto, seguridad del entorno, reproducibilidad del procedimiento y capacidad de análisis defensivo. Su formulación no pregunta si StealLab detecta malware real ni si supera a una plataforma profesional. Esta delimitación es esencial porque determina qué evidencia es pertinente y qué resultados quedarían fuera de alcance. Una pregunta bien acotada reduce el riesgo de que el capítulo de resultados responda a cuestiones no planteadas o que las conclusiones se amplíen más allá de la muestra.

5.2 Proposición de trabajo

La proposición de trabajo sostiene que un laboratorio virtualizado, aislado y documentado puede validar capacidades defensivas básicas de observación y trazabilidad sobre comportamientos tipo stealer mediante una simulación benigna, siempre que se delimiten explícitamente el alcance, los criterios éticos, las evidencias y las amenazas a la validez.

La proposición se considera respaldada si PV-01 a PV-07 cumplen sus criterios y si las limitaciones no contradicen la afirmación central. Es una proposición condicional: el laboratorio es válido para estudiar un subconjunto de comportamientos observables mediante una simulación benigna, no para caracterizar capacidades internas, evasión o impacto de muestras reales.

También se establece una condición de falsación práctica. Si la red presentara reenvío externo, si no pudiera acreditarse restaurabilidad o si los resultados carecieran de trazabilidad, la proposición debería rechazarse o reformularse. Esta condición impide que la evaluación dependa únicamente de una valoración subjetiva del autor.

La proposición funciona como expectativa verificable y no como afirmación garantizada. Debe poder rechazarse si el laboratorio no demuestra aislamiento, restaurabilidad, observabilidad o trazabilidad. Su valor metodológico reside en anticipar la relación entre diseño y resultado antes de ejecutar las pruebas. Al formular condiciones de aceptación y de fallo, la proposición evita una evaluación puramente confirmatoria y permite incorporar hallazgos negativos sin tratarlos como errores de redacción.

5.3 Objetivo general

Diseñar, construir y validar StealLab como laboratorio técnico seguro, documentado y reproducible para el análisis defensivo de comportamientos asociados a stealers, utilizando datos sintéticos, red aislada, evidencias trazables y un caso de simulación benigna denominado M-001.

El objetivo general integra producto y conocimiento. El producto es el laboratorio StealLab; el conocimiento es la demostración razonada de qué puede observarse en él, con qué evidencias y bajo qué límites. Esta doble dimensión explica por qué la memoria dedica atención equivalente a arquitectura, metodología y discusión.

El objetivo general se considera alcanzable cuando el diseño puede materializarse, el aislamiento y la restaurabilidad se verifican, las pruebas producen evidencias interpretables y la documentación permite reconstruir la relación entre procedimiento y conclusión. No exige detectar todas las variantes de stealers ni demostrar eficacia frente a malware real. Esta delimitación convierte el objetivo en una meta evaluable dentro de los recursos y restricciones éticas del TFM.

El objetivo general combina una acción de ingeniería -diseñar y construir- con una acción investigadora -validar y analizar-. Esta combinación refleja la naturaleza aplicada del TFM. El artefacto no constituye el resultado completo hasta que se evalúa mediante criterios explícitos y se discuten sus limitaciones. Por ello, el cumplimiento del objetivo debe demostrarse con correspondencia entre requisitos, pruebas, evidencias y conclusiones, y no únicamente con la existencia de máquinas virtuales o documentación técnica.

5.4 Objetivos específicos

• OE1. Definir el marco conceptual y el estado de la cuestión sobre malware, stealers, credenciales, sesiones y laboratorios defensivos.

• OE2. Diseñar una arquitectura de laboratorio basada en virtualización, red aislada y separación de roles.

• OE3. Implementar un repositorio de evidencias con identificadores PV/EV, hashes y documentación verificable.

• OE4. Validar aislamiento, restaurabilidad, captura de procesos, captura de tráfico, informe técnico y apoyo LLM supervisado.

• OE5. Analizar críticamente los resultados, límites y amenazas a la validez del enfoque benigno.

• OE6. Documentar trabajos futuros para ampliar el laboratorio hacia Windows, SIEM y análisis comparativo.

Tabla 25. Relación entre objetivos, resultados y evidencias

Objetivo	Resultado esperado	Capítulo principal	Pruebas/Evidencias
OE1	Marco teórico y estado de la cuestión robustos	3 y 4	Referencias y taxonomías
OE2	Arquitectura StealLab documentada	7	PV-01, PV-02
OE3	Repositorio trazable	8 y 9	PV-05, matrices, hashes
OE4	Validación técnica	9, 10 y 11	PV-01 a PV-07
OE5	Discusión crítica y límites	12 y 13	Amenazas a la validez
OE6	Líneas futuras justificadas	15	Trabajo futuro

Los objetivos específicos forman una secuencia lógica. OE1 y OE2 establecen la base conceptual y arquitectónica; OE3 y OE4 implementan observabilidad y control; OE5 valida el caso; y OE6 convierte los resultados en documentación académica. La secuencia evita validar antes de definir y evita concluir antes de preservar evidencia.

El grado de cumplimiento se evalúa de forma diferenciada. Un objetivo puede considerarse cumplido dentro del alcance sin afirmar cobertura total. Esta precisión es especialmente importante para OE5: se valida M-001 como caso benigno y no como sustituto de una muestra real.

Los objetivos específicos descomponen el problema en resultados parciales verificables y evitan que la evaluación dependa de una conclusión global difícil de auditar. Cada objetivo debe tener una sección de tratamiento, al menos un indicador y una respuesta final. Esta trazabilidad permite detectar desequilibrios: un objetivo puede estar ampliamente documentado mientras otro conserve evidencia limitada. Reconocer esas diferencias mejora la honestidad metodológica y evita declarar un cumplimiento uniforme cuando la profundidad real varía entre dimensiones.

6 METODOLOGÍA

La metodología se plantea como investigación aplicada de carácter técnico, con diseño de estudio de caso y enfoque descriptivo-interpretativo. El objeto no es medir la eficacia estadística de un detector, sino construir y validar un artefacto técnico bajo criterios de seguridad, trazabilidad y reproducibilidad. La unidad de análisis es el laboratorio StealLab; M-001 constituye el caso principal de integración y M-002 a M-005 son casos complementarios de validación vinculados a las PV existentes.

La metodología combina revisión documental, diseño experimental controlado, implementación técnica, recogida de evidencias y análisis crítico. La dimensión documental permite justificar conceptos; la dimensión experimental permite validar el laboratorio; la dimensión crítica evita sobreafirmar resultados.

6.1 Tipo de investigación

El TFM se encuadra como investigación aplicada porque desarrolla un artefacto técnico orientado a resolver un problema práctico: disponer de un laboratorio seguro para analizar comportamientos asociados a stealers. También tiene componente exploratorio, dado que delimita cómo representar de forma benigna un fenómeno malicioso sin usar malware real.

El diseño se aproxima a design science porque construye y evalúa un artefacto destinado a resolver un problema definido, y se apoya en un estudio de caso porque la evaluación se concentra en una instancia contextualizada. La combinación permite razonar sobre utilidad, rigor y límites sin presentar los resultados como generalización estadística (Hevner et al., 2004; Peffers et al., 2007; Yin, 2018).

La evaluación es principalmente cualitativa y verificativa, aunque incorpora elementos cuantitativos como número de evidencias, hashes y estados. La unidad de calidad no es una métrica de detección, sino la correspondencia entre criterio de aceptación y evidencia conservada.

La investigación aplicada se caracteriza por producir conocimiento mediante la resolución estructurada de un problema concreto. En StealLab, el laboratorio es simultáneamente objeto construido e instrumento de observación. El estudio de caso delimita el contexto y evita generalizar fuera de la configuración analizada, mientras design science aporta la lógica de diseñar y evaluar un artefacto. Esta combinación resulta más adecuada que un experimento causal clásico, porque no se pretende estimar efectos poblacionales ni comparar tratamientos aleatorizados, sino demostrar propiedades de un sistema dentro de condiciones controladas (Hevner et al., 2004; Peffers et al., 2007; Yin, 2018).

6.2 Unidad de análisis y muestra técnica

La unidad de análisis es StealLab como sistema técnico-documental. La muestra técnica no está formada por personas, sino por artefactos: VMs, red, PCAP, scripts benignos, datos sintéticos, matrices, fichas PV y evidencias EV. Esta delimitación evita confundir el TFM con

una investigación poblacional y permite evaluar el laboratorio con criterios de ingeniería y trazabilidad.

Tabla 26. Muestra técnica del estudio

Elemento de la muestra técnica	Función	Estado
Host MSI-STEALTH-GS66	Soporte físico del laboratorio	Documentado por usuario y evidencias de host.
StealLab-Net	Red aislada del laboratorio	Activa, persistente y autostart según virsh qemu:///system.
VM-SERVICES-SIM	Servidor HTTP interno benigno	Implementada; 10.10.10.30:8080; apagada tras el cierre de M-005.
VM-LINUX-ANALYSIS	Estación Linux de análisis	Implementada; 10.10.10.20; apagada tras el cierre de M-005.
VM-WIN-LAB	Reserva de diseño	No implementada como VM real validada.
M-001 a M-005	Caso principal y casos complementarios benignos	M-001 validado; M-002, M-003, M-004 y M-005 cerrados/PASS.
04_evidencias	Repositorio técnico	Organizado por PV/EV y casos; manifiestos e integridad documentados.

La unidad de análisis no es cada fichero aislado, sino el sistema StealLab como artefacto sociotécnico compuesto por arquitectura, procedimientos, evidencias y reglas de interpretación. La muestra técnica es intencional y está formada por los elementos necesarios para validar las propiedades definidas: dominios virtuales, red, discos, snapshots, datos sintéticos, los casos M-001 a M-005, tráfico interno, PCAP, hashes y registros PV/EV. Esta selección no pretende representatividad estadística de la población de malware.

La unidad de análisis debe diferenciarse de los elementos que generan datos. StealLab constituye el caso principal de estudio; M-001, los casos complementarios M-002 a M-005, las pruebas PV y los artefactos EV funcionan como subunidades que permiten observar propiedades del sistema. La muestra es intencional y técnica, no probabilística, porque selecciona componentes necesarios para evaluar el diseño. Esta decisión impide realizar inferencias estadísticas sobre poblaciones de malware, pero permite análisis profundo de coherencia interna, trazabilidad y reproducibilidad del laboratorio.

6.3 Categorías de análisis

Tabla 27. Categorías de análisis y operacionalización inicial

Categoría	Definición operativa	Indicador
Aislamiento	Separación del laboratorio respecto a redes reales e Internet	Red StealLab-Net, bridge virbr-steal, sin NAT/forward operativo hacia Internet.
Restaurabilidad	Capacidad de volver a un estado base	Snapshots documentados en qcow2.
Observabilidad host	Capacidad de registrar procesos y eventos	Evidencias EV-PROC.
Observabilidad red	Capacidad de capturar comunicación controlada	PCAP y evidencias EV-PCAP.
Trazabilidad	Relación entre prueba, evidencia y conclusión	Matriz PV/EV e inventario.
Seguridad ética	Ausencia de datos reales y capacidades ofensivas	Restricciones M-001.
Apoyo documental LLM	Uso supervisado como ayuda de síntesis	PV-07 y revisión humana.

Las categorías se diseñan para cubrir el ciclo completo de una prueba segura. Aislamiento y restaurabilidad controlan el entorno; observabilidad de procesos y red controla la captura; trazabilidad e informe controlan la conversión de salidas en evidencia; y el uso supervisado de LLM controla el apoyo documental. La ausencia de una categoría dejaría un hueco entre ejecución y conclusión.

Estas categorías no son independientes. Por ejemplo, una PCAP solo adquiere valor si el aislamiento permite conocer el contexto de red y si la trazabilidad la relaciona con M-001. El análisis se realiza, por tanto, mediante triangulación de evidencias y no por indicadores aislados.

Las categorías se definieron antes de interpretar los resultados para reducir el sesgo retrospectivo. Cada una dispone de indicadores observables y de una regla de aceptación. El aislamiento se apoya en configuración y pruebas de conectividad; la restaurabilidad, en snapshots y estado de discos; la observabilidad, en procesos y tráfico; la integridad, en hashes; y la trazabilidad, en la relación PV/EV. Cuando una evidencia no cubre completamente un indicador, se clasifica como apoyo y no como demostración principal.

Las categorías actúan como constructos intermedios entre objetivos abstractos y evidencias concretas. Para ser útiles deben ser conceptualmente distintas, observables y suficientemente estables para aplicarse antes y después de las pruebas. Aislamiento, restaurabilidad, observabilidad e integridad no son sinónimos y requieren indicadores diferentes. La operacionalización evita que una misma evidencia se utilice indiscriminadamente para demostrar varias propiedades sin justificar la relación.

6.4 Instrumentos de recogida de datos

Los instrumentos son técnicos y documentales: comandos de verificación, salidas resumidas, PCAP, hashes SHA-256, fichas de evidencia, matrices PV/EV, bitácora de laboratorio, informe técnico M-001 y revisión humana de apoyo LLM. Las salidas completas se conservan en el repositorio y no se pegan íntegramente en la memoria.

Los instrumentos se seleccionan por su capacidad para producir artefactos exportables y revisables. virsh y qemu-img describen infraestructura y estado; herramientas del sistema describen procesos y sockets; tcpdump produce PCAP; SHA-256 identifica contenido; y las fichas PV/EV conservan contexto. La herramienta no se considera evidencia por sí misma: la evidencia es la salida identificada y asociada a una pregunta.

Cuando una salida depende del instante de observación, se registra la temporalidad. Esta precaución evita mezclar, por ejemplo, una verificación persistente realizada con la VM apagada y una captura runtime posterior con la VM en ejecución.

La distinción entre técnica e instrumento mejora la claridad metodológica. La observación técnica es la estrategia; virsh, qemu-img, tcpdump, hashes y fichas PV/EV son instrumentos concretos. Cada instrumento tiene cobertura y limitaciones propias: puede describir configuración, estado, tráfico o integridad, pero no sustituye a los demás. La selección se justifica por complementariedad y por capacidad de producir resultados verificables, no por exhaustividad tecnológica.

6.5 Procedimiento experimental

Tabla 28. Procedimiento experimental aplicado

Fase metodológica	Actividad	Resultado
Preparación	Definición de red, VMs, rutas, repositorio y datos sintéticos	Arquitectura y precondiciones documentadas.
Control ético	Exclusión de malware, datos sensibles, C2 e Internet reales	M-001 a M-005 bajo simulación benigna y contención.

Fase metodológica	Actividad	Resultado
Ejecución	Aplicación controlada de M-001 y casos complementarios	Evidencias diferenciadas por caso.
Captura	Registro de procesos, estados y tráfico interno cuando procede	EV-PROC, EV-PCAP y EV de caso.
Preservación	Hashes, manifiestos, matrices e inventario	Trazabilidad de evidencias.
Interpretación	Análisis por PV, casos y objetivos	Resultados, discusión y límites.

El procedimiento sigue una lógica de precondiciones, ejecución y cierre. Antes de cada caso se verifica el entorno; durante la ejecución se capturan las señales previstas; después se calculan hashes cuando procede, se organiza el repositorio y se interpreta el resultado. Cada fase puede auditarse de manera independiente y la ausencia de una precondición impide considerar válida la fase posterior.

La repetibilidad se apoya en datos sintéticos estables y en estados restaurables. La reproducibilidad externa queda limitada por diferencias de host, versiones y herramientas, pero el protocolo aporta información suficiente para reconstruir la intención, los componentes y los criterios de aceptación.

El procedimiento se ejecuta con una política de estado conocido. Antes de la prueba se comprueba el entorno y se identifica el punto de restauración; durante la ejecución se registran únicamente los observables previstos; y al finalizar se calculan hashes, se clasifican evidencias y se documentan incidencias. La secuencia evita mezclar resultados de sesiones distintas y permite distinguir entre configuración persistente, estado runtime y artefactos producidos por el caso.

6.6 Criterios éticos y de seguridad

• No utilizar malware real en la validación documentada.

• No utilizar credenciales, cookies, tokens, wallets ni datos personales reales.

• No contactar infraestructura C2 real ni Internet desde las VMs.

• No incluir técnicas de evasión, persistencia o exfiltración real.

• No automatizar decisiones críticas mediante LLM.

• No publicar volcados de consola que contengan información innecesaria o sensible.

El estudio no involucra participantes humanos ni trata datos personales reales; por tanto, el consentimiento informado no resulta aplicable al alcance desarrollado. La evaluación ética se centra en la prevención de daño tecnológico y de exposición de terceros: uso exclusivo de datos sintéticos, ausencia de malware real, red sin salida a Internet, inexistencia de C2, minimización de capturas y revisión de secretos antes de conservar o publicar una evidencia. Estos controles siguen principios de respeto, proporcionalidad y transparencia aplicados a investigación TIC (Association for Computing Machinery, 2018; Department of Homeland Security, 2012).

6.7 Amenazas a la validez previstas

Se anticipan amenazas de constructo, internas, externas y documentales. La amenaza de constructo consiste en confundir transferencia benigna con exfiltración; la interna, en atribuir una observación a un caso sin controlar el estado previo; la externa, en generalizar desde Linux y cinco escenarios benignos diseñados en un mismo laboratorio; y la documental, en perder correspondencia entre evidencia, versión y conclusión.

Las mitigaciones se incorporan desde el diseño: etiquetado DEMO/NO REAL, snapshots, verificación de red, criterios previos, hashes y regla de no sobreafirmación. Aun con estas medidas, las amenazas no desaparecen; se reducen y se hacen visibles para el lector.

Las amenazas se analizan desde el diseño y no únicamente después de obtener resultados. Entre ellas se incluyen dependencia del entorno local, cambios de estado entre capturas, interpretación excesiva de una única ejecución, pérdida de contexto al separar una evidencia de su procedimiento y sesgo de confirmación al seleccionar capturas favorables. La mitigación combina criterios previos, conservación de resultados negativos, hashes, registros de estado y separación explícita entre evidencia fuerte, evidencia de apoyo e inferencia.

6.8 Diseño de investigación aplicado

El diseño del trabajo se aproxima a un estudio de caso técnico con enfoque aplicado. La unidad de análisis no es una población humana, sino un artefacto técnico-metodológico: el laboratorio StealLab y su comportamiento ante un caso benigno M-001. Esta elección es coherente con la naturaleza del TFM, que desarrolla y valida un entorno de análisis en condiciones controladas.

El diseño combina una dimensión descriptiva, porque documenta arquitectura, componentes y evidencias; una dimensión evaluativa, porque contrasta pruebas PV con criterios de aceptación; y una dimensión interpretativa, porque discute qué significan los resultados y qué no permiten concluir.

El artefacto se evalúa mediante una cadena de evidencia. La pregunta de investigación se descompone en objetivos; los objetivos se traducen a categorías; las categorías se operacionalizan mediante PV; y cada PV se sostiene con EV. Esta cadena permite rastrear una conclusión desde el texto final hasta la observación técnica de origen.

La estrategia es deliberadamente conservadora: una prueba se considera superada solo cuando el criterio previo y la evidencia coinciden. La presencia de un componente no probado se registra como diseño o trabajo futuro y no se incorpora al conjunto de resultados validados.

El diseño aplicado organiza ciclos de construcción, observación y evaluación. La fase de diseño traduce la pregunta en requisitos; la implementación materializa el artefacto; la validación compara evidencias con criterios; y la discusión interpreta los resultados frente al conocimiento previo. Esta secuencia no es estrictamente lineal, porque los hallazgos pueden obligar a revisar documentación o criterios, pero cada iteración debe conservar trazabilidad. Así se evita modificar retrospectivamente los objetivos para que coincidan con lo observado.

6.9 Operacionalización de categorías

La operacionalización transforma conceptos abstractos en elementos observables. Aislamiento se observa mediante red libvirt, ausencia de NAT/forward e IP interna. Restaurabilidad se observa mediante snapshots. Observabilidad de host se observa mediante procesos y eventos. Observabilidad de red se observa mediante PCAP. Trazabilidad se observa mediante PV/EV, hashes y repositorio.

Tabla 29. Operacionalización ampliada de categorías de análisis

Categoría	Indicador observable	Evidencia asociada	Criterio de lectura
Aislamiento	Red StealLab-Net activa, bridge virbr-steal, segmento 10.10.10.0/24 y ausencia de ruta externa en M-005	PV-01, XML libvirt, validación qemu:///system, M-005	La red está definida y la contención se observa en el escenario documentado
Restaurabilidad	Snapshots qcow2 base	PV-02, qemu-img info	Existe punto de retorno documentado

Categoría	Indicador observable	Evidencia asociada	Criterio de lectura
Host	Procesos, baseline y operaciones locales controladas	PV-03; M-001 a M-005 según caso	Permite observar actividad local básica
Red	PCAP HTTP interno y contraste negativo TEST-NET	PV-04; M-001, M-004 y M-005	Permite analizar flujos controlados sin afirmar aislamiento universal
Repositorio	Estructura, identificadores, hashes y manifiestos	PV-05; evidencias de M-001 a M-005	Permite auditoría documental
Informe	EV-INF-001 e integración académica de resultados	PV-06	Permite comunicación técnica
LLM supervisado	Instrucción registrada, respuesta y revisión humana	PV-07	Apoyo documental, no fuente de verdad

Operacionalizar implica convertir conceptos abstractos en condiciones comprobables. Por ejemplo, aislamiento no equivale a declarar que una red es privada: requiere revisar su definición, la ausencia de forward/NAT y el comportamiento observado. Del mismo modo, reproducibilidad no significa que dos ejecuciones sean idénticas en cada byte, sino que el procedimiento, los datos de entrada, los controles y los criterios permitan obtener resultados comparables y explicar las variaciones.

Operacionalizar implica definir qué observación concreta representa cada categoría y qué resultado se considerará suficiente. La definición debe incluir también resultados ambiguos o negativos. Por ejemplo, una configuración declarada puede apoyar persistencia del diseño, pero no actividad runtime; un hash apoya integridad, pero no autenticidad del contenido. Incorporar estas restricciones en la operacionalización reduce sobreinterpretación y facilita que otro evaluador revise la misma evidencia con criterios explícitos.

6.10 Criterios de aceptación de pruebas

Cada prueba PV debe tener un criterio de aceptación previo. Sin criterio, el resultado podría interpretarse de forma arbitraria. En StealLab, aceptar PV-01 no significa que se haya probado resistencia frente a todos los escapes de VM; significa que se ha verificado una red libvirt aislada, con bridge e IP interna, sin requerir salida a Internet para M-001. Aceptar PV-04 no significa que se detecte cualquier C2; significa que se captura tráfico HTTP controlado en el escenario definido.

Tabla 30. Criterios de aceptación ampliados de PV-01 a PV-07

PV	Criterio de aceptación	Resultado verificable	Límite
PV-01	Red aislada definida, activa y persistente; contraste negativo controlado	StealLab-Net y M-005 sin ruta útil a 192.0.2.1	Valida esta configuración y destino de prueba, no todas las fugas posibles
PV-02	Snapshots base identificables	Snapshots en qcow2 con corrupt:false	No sustituye backup externo
PV-03	Baseline y actividad local observable	EV-PROC y evidencias de casos complementarios	No equivale a EDR
PV-04	PCAP interno generado y hasheado; contraste negativo cuando procede	EV-PCAP-003, EV-PCAP-005, EV-PCAP-006 y EV-PCAP-007	No hay C2 ni Internet reales
PV-05	Repositorio organizado, trazable y con integridad verificable	PV/EV, hashes y manifiestos de cierre	Inventario final verificado: 171 ficheros; conservar trazabilidad por hashes y manifiesto.
PV-06	Informe técnico del caso principal	EV-INF-001	Informe de caso benigno, no pericial

PV	Criterio de aceptación	Resultado verificable	Límite
PV-07	LLM revisado por humano	EV-LLM-001 a 003	No valida evidencias automáticamente

Los criterios se formulan de manera binaria cuando la propiedad lo permite y de manera graduada cuando existe incertidumbre. Una prueba puede clasificarse como superada, superada con limitaciones, no superada o no verificable. Esta última categoría impide convertir la ausencia de datos en resultado favorable. La clasificación se registra junto con la evidencia principal, las evidencias auxiliares y el límite de interpretación.

6.11 Protocolo de recogida y conservación de evidencias

La recogida de evidencias sigue una lógica de mínima suficiencia: se conserva lo necesario para verificar resultados sin trasladar al cuerpo de la memoria salidas extensas de consola. Los ficheros completos permanecen en el repositorio, mientras la memoria contiene síntesis, rutas, hashes y tablas de interpretación. Esta separación mejora la calidad académica y mantiene la auditabilidad del estudio.

El protocolo de conservación incluye: nomenclatura EV, ubicación en repositorio, relación con PV, cálculo de hash cuando procede, resumen interpretativo y registro en matriz. Cuando una evidencia sea textual extensa, se cita su ruta y función; cuando sea visual, se incluirá captura solo si aporta información no sustituible por texto.

El ciclo de vida de la evidencia incluye identificación, adquisición, preservación, descripción, verificación y referencia. Los identificadores EV evitan depender exclusivamente de rutas; los hashes permiten comprobar integridad de contenido; y las fichas registran origen, finalidad y límite. Este modelo adapta principios de ISO/IEC 27037 y NIST a un contexto académico sin pretender constituir una cadena de custodia judicial.

La conservación fuera del cuerpo principal cumple dos funciones: mantiene legible la memoria y preserva el detalle necesario para auditoría. Las capturas seleccionadas se incorporan únicamente cuando aportan una visión sintética que no puede expresarse con igual claridad mediante texto o tabla.

El protocolo debe asegurar continuidad entre generación, identificación, almacenamiento y consulta. La evidencia debe conservar su relación con caso, prueba, herramienta y contexto, minimizando cambios posteriores. El hash es un control importante, pero requiere acompañarse de nomenclatura, ubicación y descripción. La conservación también debe aplicar minimización: guardar lo necesario para verificar la conclusión sin acumular datos sensibles o salidas irrelevantes. Esta combinación de integridad y proporcionalidad fortalece la auditabilidad del repositorio (NIST, 2006, 2022; SWGDE, 2025).

6.12 Plan de análisis

El análisis de resultados se realiza en cuatro capas. La primera capa es descriptiva: qué existe y dónde. La segunda es verificativa: qué evidencia confirma el criterio. La tercera es interpretativa: qué significa para la pregunta de investigación. La cuarta es crítica: qué límite o amenaza a la validez permanece. Este esquema se aplica a todas las PV para evitar conclusiones generales no sustentadas.

La comparación final se realiza en tres direcciones. Primero, cada PV se contrasta con su criterio. Segundo, los resultados se contrastan con los objetivos. Tercero, la interpretación se contrasta con literatura y casos reales para evaluar plausibilidad, sin asumir equivalencia. Esta triangulación separa validación interna de relevancia externa.

Los hallazgos se clasifican como verificados, inferidos o no demostrados. Solo los verificados forman parte del resultado empírico; los inferidos se presentan con lenguaje condicional; y los no demostrados se trasladan a limitaciones o trabajos futuros.

El plan de análisis define cómo se transforma la evidencia en resultado. Debe distinguir descripción, comparación con el criterio, interpretación y límite. Esta secuencia evita que la conclusión aparezca directamente después de una captura sin explicar el razonamiento. La triangulación entre fuentes puede aumentar confianza cuando los registros son coherentes, mientras las contradicciones deben conservarse y discutirse. El análisis es principalmente cualitativo-técnico, apoyado por recuentos descriptivos que no pretenden inferencia estadística.

6.13 Gestión de contradicciones y hallazgos negativos

Un resultado negativo o una limitación no invalida necesariamente el TFM. Por ejemplo, si una VM está registrada pero apagada, la conclusión correcta no es negar su existencia, sino distinguir entre definición persistente y estado de ejecución. Si domifaddr no devuelve IP porque la VM está apagada, la interpretación adecuada es que no hay dirección runtime observable en ese momento, aunque el XML de red contenga reservas DHCP. Esta precisión fortalece la memoria porque evita sobreafirmar.

La gestión de contradicciones exige distinguir momento, plano y fuente. Una VM puede aparecer apagada en una comprobación de inventario y ejecutándose en una captura posterior; no existe contradicción si ambas evidencias están fechadas y se refieren a estados temporales distintos. Del mismo modo, una red persistente puede estar definida aunque se encuentre inactiva.

Los hallazgos negativos se conservan cuando modifican la interpretación. La ausencia de ruta por defecto apoya aislamiento; la ausencia de VM-WIN-LAB limita cobertura; y la falta de una muestra real impide inferir evasión o persistencia. Documentar estas ausencias aumenta la credibilidad porque muestra qué se buscó y qué no se encontró.

6.14 Rol metodológico del LLM supervisado

El uso de LLM se limita a apoyo documental: síntesis, organización de resultados, ayuda en redacción y revisión de coherencia. No se usa para validar hashes, no sustituye el análisis humano, no ejecuta acciones sobre el laboratorio y no se presenta como fuente académica. La evidencia PV-07 demuestra precisamente que su salida fue sometida a revisión humana.

Las amenazas a la validez se identifican desde el diseño. La principal amenaza externa es que M-001 a M-005 no representan la diversidad de familias de stealers ni sus condiciones operativas. La amenaza de constructo es confundir simulación benigna con malware real. La amenaza de conclusión es sobreinterpretar resultados técnicos. La mitigación consiste en declarar restricciones, asociar evidencias y discutir límites.

El LLM se integra bajo un modelo human-in-the-loop. Sus propuestas se someten a revisión contra fuentes y evidencias, se descartan afirmaciones no sustentadas y no se le proporciona autoridad para clasificar una prueba como superada. Esta separación entre asistencia lingüística y validación técnica reduce el riesgo de alucinación y automatización acrítica (NIST, 2024).

La trazabilidad del uso de IA debe permitir reconocer qué tareas se delegaron: organización, detección de inconsistencias, reformulación y apoyo bibliográfico. Los cálculos de hash, el estado de infraestructura y la interpretación final permanecen bajo control humano.

6.15 Justificación epistemológica del diseño aplicado

El TFM se sitúa en una modalidad de investigación aplicada porque no se limita a revisar literatura ni a describir herramientas existentes. Construye un artefacto técnico, lo somete a un conjunto de pruebas y extrae conclusiones sobre su capacidad para observar un fenómeno delimitado. La validez del trabajo no se basa en el número de muestras maliciosas ejecutadas, sino en la coherencia entre problema, diseño, evidencias y límites.

La decisión de utilizar una simulación benigna se justifica desde tres planos. En el plano ético, reduce riesgo y evita exposición de datos reales. En el plano metodológico, permite controlar variables y repetir la prueba. En el plano académico, hace explícita la diferencia entre estudiar una amenaza y reproducirla. Esta distinción es esencial para un TFM universitario en seguridad: el conocimiento generado debe ser útil para defensa, formación y análisis, no para facilitar abuso.

El diseño aplicado no pretende reemplazar un sandbox profesional ni un entorno de análisis de malware real. Su contribución es ofrecer un laboratorio comprensible, auditable y reproducible en el que se pueda validar aislamiento, captura, trazabilidad e informe técnico. Por ello, las pruebas PV-01 a PV-07 son tan importantes como M-001: demuestran que el entorno es controlado antes de interpretar cualquier resultado.

6.16 Delimitación de casos y subcasos de validación

La unidad de análisis principal es el laboratorio StealLab como sistema técnico-documental. M-001 se mantiene como caso principal de validación funcional de extremo a extremo. M-002, M-003, M-004 y M-005 se incorporan como casos complementarios de validación: amplían la cobertura observable del mismo laboratorio sin constituir nuevas PV ni alterar la unidad de análisis.

La ampliación a cinco casos no convierte la muestra en representativa de familias de malware. El trabajo sigue orientado a validar el método y la arquitectura bajo condiciones controladas. M-002 comprueba descubrimiento de artefactos sintéticos; M-003, agrupación y staging local; M-004, comunicación HTTP interna benigna; y M-005, un contraste positivo-negativo de contención. La generalización continúa siendo analítica, no estadística.

Tabla 31. Unidad de análisis y subunidades empíricas

Elemento	Rol metodológico	Evidencia asociada	Conclusión posible
StealLab	Unidad de análisis principal.	Repositorio, red, VMs, PV/EV.	Laboratorio validado para análisis seguro dentro del alcance.
M-001	Caso principal de integración benigna.	Datos DEMO, ejecución, procesos, PCAP e informe.	Cadena extremo a extremo observable y trazable.
M-002	Caso complementario: descubrimiento controlado.	Corpus DEMO y EV-M002-004.	Enumeración controlada de artefactos sintéticos.
M-003	Caso complementario: agrupación/staging local.	m003_corpus_demo.tar.gz y EV-M003-004.	Agrupación local e integridad verificables.

Elemento	Rol metodológico	Evidencia asociada	Conclusión posible
M-004	Caso complementario: HTTP interno benigno.	EV-PCAP-005, EV-M004-008 y manifest.	Comunicación interna observable con HTTP 200.
M-005	Caso complementario: contención negativa.	EV-PCAP-006/007 y EV-M005-004 a EV-M005-010.	Control interno permitido y destino TEST-NET no alcanzable en la configuración probada.
PV-01 a PV-07	Pruebas de validación.	EV asociadas.	Cierre de requisitos mediante la matriz PV existente.
VM-WIN-LAB	Reserva de diseño.	XML/reserva DHCP, no VM real validada.	Trabajo futuro, no alcance ejecutado.

M-001 actúa como caso principal de integración. Los casos M-002 a M-005 son complementarios y se relacionan con PV ya existentes: M-002 con PV-03/PV-05; M-003 con PV-03/PV-05; M-004 con PV-03/PV-04/PV-05; y M-005 con PV-01/PV-03/PV-04/PV-05. Esta relación evita crear una PV adicional por cada ejemplo y mantiene la trazabilidad entre pregunta de validación, evidencia y conclusión.

6.17 Matriz de categorías, indicadores e instrumentos

En investigaciones técnicas aplicadas, las variables no siempre son magnitudes numéricas. En este TFM se emplean categorías de análisis operacionalizadas mediante indicadores verificables. Por ejemplo, aislamiento se operacionaliza mediante red activa, bridge, ausencia de forward/NAT y reservas internas; integridad se operacionaliza mediante hashes; restaurabilidad mediante snapshots; trazabilidad mediante matriz PV/EV; observabilidad mediante procesos y PCAP.

Tabla 32. Variables, categorías, indicadores e instrumentos

Categoría	Indicador	Instrumento	Criterio de aceptación
Aislamiento	Red StealLab-Net activa, bridge interno, segmento privado.	virsh net-info, XML, evidencia PV-01.	Red persistente, autostart y sin salida documentada a Internet.
Restaurabilidad	Snapshots qcow2 presentes.	qemu-img info.	Snapshot base por VM validada.
Integridad	Hashes SHA-256 de datos y PCAP.	sha256sum.	Hash reproducible y asociado a fichero.
Observabilidad host	Procesos y ejecución M-001 registrados.	Captura de procesos y evidencias EV-PROC.	Ejecución documentada sin datos reales.
Observabilidad red	PCAP HTTP interno.	tcpdump/Wireshark/PCAP.	Tráfico interno entre VMs o hacia servicio benigno.
Trazabilidad	Matriz PV/EV y repositorio.	matriz_pv_ev, inventario, bitácora.	Cada prueba se vincula a evidencias.
Ética	Ausencia de malware y datos reales.	Checklist ético y restricciones M-001.	Sin C2 real, sin Internet, sin persistencia.

La matriz funciona como contrato metodológico entre diseño y resultados. Para cada categoría identifica qué se observa, con qué instrumento, qué evidencia se espera y qué afirmación puede sostenerse. El instrumento no se confunde con la evidencia: tcpdump es un instrumento de captura, el PCAP es el artefacto generado y la interpretación del flujo constituye el resultado analítico. Esta distinción mejora la auditabilidad y facilita futuras réplicas.

6.18 Criterios de rigor: credibilidad, dependencia, confirmabilidad y transferibilidad

Aunque estos términos se emplean con frecuencia en investigación cualitativa, son útiles para reforzar la calidad de un TFM técnico. La credibilidad se refiere a que las conclusiones deriven

de evidencias y no de afirmaciones genéricas. La dependencia se refiere a la consistencia del procedimiento. La confirmabilidad exige que otro lector pueda rastrear por qué se llegó a una conclusión. La transferibilidad delimita qué partes del diseño pueden adaptarse a otros laboratorios o contextos.

StealLab mejora la credibilidad mediante hashes, PCAP, PV/EV y bitácora; la dependencia mediante procedimientos y rutas; la confirmabilidad mediante inventario de evidencias y matrices; y la transferibilidad mediante separación entre diseño genérico, casos validados y trabajo futuro. Esta estructura convierte el laboratorio en un resultado académico revisable, no en una práctica informal.

La credibilidad aumenta cuando varias evidencias independientes apuntan a la misma conclusión; la dependencia, cuando el proceso puede reconstruirse; la confirmabilidad, cuando las afirmaciones no dependen únicamente del autor; y la transferibilidad, cuando se describen suficientemente contexto y límites. StealLab no maximiza todas estas dimensiones por igual, pero hace explícitas las decisiones que las favorecen.

La literatura reciente sobre replicabilidad en seguridad advierte que configuraciones, artefactos y protocolos incompletos impiden contrastar resultados. El repositorio estructurado, las capturas seleccionadas y las matrices PV/EV responden a ese problema a escala de TFM (Olszewski et al., 2025).

Estos criterios adaptan el rigor cualitativo a un caso técnico. La credibilidad se refuerza mediante coherencia entre fuentes; la dependencia, documentando procedimiento y configuración; la confirmabilidad, separando evidencia de interpretación; y la transferibilidad, describiendo suficientemente el contexto para que otro investigador valore su aplicabilidad. Ninguno equivale a generalización universal. Su función es mostrar por qué una conclusión resulta razonable dentro del caso y qué información necesitaría un tercero para revisarla o repetirla.

6.19 Protocolo de análisis y regla de no sobreafirmación

Cada resultado del TFM debe interpretarse mediante una regla de cuatro pasos: evidencia observada, interpretación defensiva, límite y conclusión. Si una evidencia muestra que existe un PCAP, puede afirmarse que se capturó tráfico interno; no puede afirmarse que se detectó una familia real. Si qemu-img muestra un snapshot, puede afirmarse restaurabilidad del disco; no puede afirmarse disponibilidad operativa de la VM en ejecución en ese instante. Si virsh muestra la red activa, puede afirmarse estado runtime de la red; si las VMs están apagadas, no debe inferirse IP runtime mediante domifaddr.

Esta regla se aplica en toda la memoria para evitar el problema más común en trabajos técnicos: convertir observaciones parciales en conclusiones demasiado amplias. En ciberseguridad, la precisión es parte de la calidad científica.

La regla de no sobreafirmación debe aplicarse al vocabulario, al alcance y a la causalidad. Los verbos demostrar, validar o confirmar solo son adecuados cuando el criterio y la evidencia los sostienen; en otros casos deben emplearse observar, indicar, apoyar o ser compatible con. También debe evitarse atribuir intención, familia o impacto real a una simulación. Este control lingüístico no debilita el trabajo: mejora su precisión y permite distinguir resultados sólidos de hipótesis o trabajos futuros.

6.20 Protocolo metodológico futuro para análisis estático de código de stealers con LLM supervisado

La existencia de repositorios públicos que contienen código de familias maliciosas o de pruebas de concepto obliga a diferenciar entre disponibilidad técnica y uso metodológicamente aceptable. Que un código esté publicado en una plataforma de

alojamiento de software no convierte su análisis en una práctica automáticamente segura, legal ni pertinente para una memoria universitaria. En el contexto de StealLab, un eventual análisis de código fuente asociado a stealers debe plantearse como análisis estático, documental, controlado y no ejecutable, orientado a comprender patrones defensivos y no a reproducir capacidades maliciosas.

El papel de un LLM supervisado en este escenario no consiste en ejecutar código, completar funcionalidades, generar payloads, mejorar evasión ni facilitar despliegues. Su función aceptable es auxiliar al investigador en tareas de lectura, clasificación, explicación de dependencias, identificación de patrones de alto nivel, extracción de hipótesis defensivas, mapeo a técnicas conocidas y redacción de informes de análisis. Toda inferencia debe ser revisada por una persona y contrastada con evidencias estáticas; el modelo no debe tratarse como fuente de verdad ni como sustituto de herramientas de análisis.

El protocolo metodológico propuesto se resume en la siguiente tabla. Su finalidad es dejar preparado el marco teórico para una línea futura, sin afirmar que el análisis de código de malware real haya sido ejecutado en la versión validada del laboratorio.

Tabla 33. Protocolo seguro para análisis estático de código con LLM supervisado

Fase	Actividad permitida	Resultado esperado	Restricción de seguridad
1. Delimitación	Definir si el material se estudia por interés académico, defensivo o comparativo.	Ficha de alcance con finalidad, fuente, fecha de consulta y criterio de inclusión.	No seleccionar repositorios para reutilizar, compilar o desplegar capacidades maliciosas.
2. Cuarentena documental	Mantener el código como objeto de lectura estática en un espacio aislado y sin ejecución.	Manifiesto de ficheros y huellas de integridad si se conserva una copia controlada.	No ejecutar, no instalar dependencias, no resolver infraestructura externa y no conectarlo a Internet.
3. Inventario estático	Identificar lenguajes, módulos, dependencias, configuraciones y comentarios relevantes.	Mapa de componentes y posibles responsabilidades funcionales.	No reconstruir cadenas de ataque ni completar partes faltantes del código.
4. Análisis asistido por LLM	Dividir el material en fragmentos, pedir explicación defensiva y registrar incertidumbre.	Hipótesis sobre categorías de comportamiento observable.	No solicitar al LLM mejoras, optimizaciones, bypass, persistencia, exfiltración ni instrucciones operativas.
5. Contraste humano	Revisar manualmente cada conclusión y separarla de la evidencia observada.	Tabla evidencia-interpretación-límite.	Toda conclusión no verificable debe marcarse como PENDIENTE o NO DOCUMENTADO.
6. Salida defensiva	Transformar hallazgos en taxonomía, indicadores genéricos, controles y preguntas de detección.	Informe defensivo no ejecutable, trazable y apto para discusión académica.	No publicar código, secretos, endpoints activos ni detalles que faciliten abuso.

Este protocolo se alinea con el principio de gestión de riesgos de IA: el uso de modelos debe incorporar controles de confianza, límites de uso, supervisión y evaluación. También se relaciona con los riesgos específicos de aplicaciones LLM descritos por OWASP, especialmente la inyección de instrucciones, la revelación de información sensible, el manejo inseguro de salidas y la dependencia excesiva del resultado del modelo.

7 DISEÑO DEL LABORATORIO STEALLAB

StealLab se diseña como un entorno virtualizado y aislado para reproducir condiciones de observación defensiva. El laboratorio se organiza por roles: host físico, red virtual, servidor interno benigno, estación de análisis Linux, reserva de diseño Windows y repositorio de evidencias.

7.1 Requisitos del laboratorio

Tabla 34. Requisitos de diseño de StealLab

Requisito	Justificación	Solución adoptada
Aislamiento	Evitar salida accidental de tráfico o contacto con terceros.	StealLab-Net con bridge virbr-steal y red interna 10.10.10.0/24.
Reproducibilidad	Permitir revisión y repetición del flujo.	Repositorio estructurado y matrices PV/EV.
Restaurabilidad	Recuperar estado base tras pruebas.	Snapshots internos qcow2.
Trazabilidad	Relacionar prueba con evidencia.	IDs PV y EV, hashes, informes.
Seguridad ética	Evitar daño y exposición de datos.	M-001 benigno y datos DEMO/NO REAL.

Los requisitos se dividen en funcionales, de seguridad y de evidencia. Los funcionales permiten ejecutar y observar M-001; los de seguridad impiden que la prueba abandone el entorno; y los de evidencia permiten defender el resultado. La arquitectura solo se considera adecuada cuando satisface simultáneamente los tres grupos.

Se incorpora además un requisito de mínima complejidad. Cada componente debe justificar su presencia y no introducir servicios o rutas innecesarias. Este principio reduce superficie de error, facilita la revisión y mejora la repetición del caso.

Los requisitos se priorizan mediante una jerarquía de seguridad. Los requisitos obligatorios son aislamiento, ausencia de datos reales, restaurabilidad y trazabilidad; los requisitos funcionales cubren observación de host y red; y los requisitos de calidad incluyen legibilidad, mantenimiento y posibilidad de repetición. Si un requisito funcional entra en conflicto con uno de seguridad, prevalece el segundo y el escenario debe simplificarse.

7.2 Arquitectura general

La arquitectura se apoya en el host MSI-STEALTH-GS66 con Debian GNU/Linux forky/sid, virtualización KVM/libvirt, red StealLab-Net y storage pool bajo la ruta del repositorio canónico. La red está definida con bridge virbr-steal y dirección 10.10.10.1/24. Las reservas DHCP documentan VM-WIN-LAB en 10.10.10.10 como reserva de diseño, VM-LINUX-ANALYSIS en 10.10.10.20 y VM-SERVICES-SIM en 10.10.10.30.

Tabla 35. Arquitectura técnica verificada

Componente	Valor verificado	Interpretación
Repositorio canónico	/mnt/eb46eae5-fd5e-46da-9d69-7830b9d22abd/J/JULIO/UNIVERSIDAD_EUROPEA/MASTER_CIBERSEGURIDAD/TFM/tfm_steallab/TFM_StealLab	Ubicación real de memoria, laboratorio, evidencias y resultados.
Red	StealLab-Net	Red libvirt activa, persistente y con autostart.
Bridge	virbr-steal	Interfaz virtual de aislamiento.
Segmento	10.10.10.0/24	Rango interno del laboratorio.
IP bridge	10.10.10.1	Puerta interna de la red virtual.

Componente	Valor verificado	Interpretación
VM-SERVICES-SIM	10.10.10.30	Servidor HTTP interno benigno.
VM-LINUX-ANALYSIS	10.10.10.20	Estación de análisis y ejecución controlada.
VM-WIN-LAB	10.10.10.10	Reserva futura, no validada como VM implementada.

La arquitectura separa plano de control, plano de ejecución y plano de evidencia. El host y libvirt controlan redes, dominios y almacenamiento; las VMs ejecutan roles diferenciados; y el repositorio conserva los resultados fuera de la sesión efímera. Esta separación permite restaurar una VM sin perder el registro de lo observado.

VM-LINUX-ANALYSIS actúa como origen controlado del caso y VM-SERVICES-SIM como destino benigno. La ausencia de un tercer servicio externo evita que el tráfico de validación se confunda con comunicaciones ajenas al experimento.

7.3 Estado persistente y estado runtime

La verificación con virsh conectado a qemu:///system demuestra que StealLab-Net está activa, es persistente y tiene autostart habilitado. Las VMs VM-LINUX-ANALYSIS y VM-SERVICES-SIM aparecen registradas, pero apagadas en el momento de la comprobación. Por ello, domifaddr no devuelve direcciones runtime, lo que es coherente con el estado shut off y no contradice las reservas DHCP ni las evidencias persistidas.

Tabla 36. Verificación runtime de libvirt

Comando/elemento	Resultado	Conclusión
virsh -c qemu:///system net-list --all	StealLab-Net active yes yes	PV-01 reforzada: red definida, activa y persistente.
virsh -c qemu:///system list --all	VM-LINUX-ANALYSIS y VM-SERVICES-SIM shut off	VMs registradas pero apagadas durante la consulta.
net-dumpxml StealLab-Net	Bridge virbr-steal, IP 10.10.10.1, reservas DHCP	Arquitectura runtime coincide con el diseño.
domifaddr	Requested operation is not valid: domain is not running	Resultado esperado con dominios apagados.

El estado persistente incluye definiciones XML, imágenes qcow2, reservas DHCP y configuración de autostart. El estado runtime incluye dominios ejecutándose, leases activos, procesos, sockets y flujos. La memoria conserva ambos porque responden a preguntas distintas: qué está definido y qué estaba ocurriendo durante la observación.

La captura global del host muestra una instantánea runtime en la que ambas VMs se encuentran ejecutándose, StealLab-Net aparece activa, persistente y con autostart, y existen leases para 10.10.10.20 y 10.10.10.30. Esta evidencia no invalida comprobaciones previas con máquinas apagadas; documenta una fase posterior de validación y resuelve la aparente discrepancia mediante temporalidad.

```
echo "== STORAGE POOLS =="
virsh -c qemu:///system pool-list --all
echo

echo "== DHCP LEASES STEALLAB-NET =="
virsh -c qemu:///system net-dhcp-leases StealLab-Net
== VISTA GLOBAL STEALLAB DESDE HOST ==
2026-07-05T16:14:13+02:00
HOST=MSI-STEALTH-GS66
USER=jcri

== VMS ==
 Id   Name                State
-----------------------------------
 10   VM-SERVICES-SIM     running
 15   VM-LINUX-ANALYSIS   running


== REDES LIBVIRT ==
 Name           State      Autostart   Persistent
-----------------------------------------------------
 default        inactive   no          yes
 StealLab-Net   active     yes         yes
```

Figura 1. Estado runtime global de StealLab: dominios, red, pools y leases DHCP.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

7.4 Seguridad del diseño

La seguridad se basa en defensa por separación: red específica, roles de VM, ausencia de datos reales, servidor interno benigno, snapshots y repositorio controlado. El laboratorio no se presenta como entorno de producción ni sistema de detección automático; es un artefacto académico para observación y aprendizaje defensivo.

La seguridad se basa en defensa en profundidad: segmentación de red, ausencia de forward/NAT, datos sintéticos, roles separados, snapshots y conservación externa. Ningún control se considera absoluto. La combinación reduce la probabilidad de salida no prevista y limita el impacto de un error de operación.

El modelo de amenaza del TFM contempla principalmente errores de configuración, exposición accidental de datos y sobreinterpretación. No contempla un adversario que ataque el hipervisor ni malware con técnicas avanzadas de escape, porque esas capacidades están fuera del alcance y no se ejecutan muestras reales.

La seguridad se apoya en defensa en profundidad: segmentación lógica, exclusión de interfaces externas, servicios benignos mínimos, principio de mínimo privilegio, datos sintéticos, snapshots, control de rutas y revisión de evidencias. Ningún control se considera infalible de forma aislada. La combinación busca que un error de configuración sea detectable antes de convertirse en exposición, y que cualquier estado no conforme pueda revertirse sin conservar material peligroso.

7.5 Arquitectura de StealLab por capas OSI y TCP/IP

La arquitectura de StealLab puede explicarse por capas. En el plano físico se encuentra el host MSI-STEALTH-GS66, que proporciona CPU, memoria, almacenamiento y sistema operativo Debian. En el plano de virtualización se sitúan KVM y libvirt, responsables de definir máquinas, discos qcow2, redes virtuales y snapshots. En el plano de enlace aparece el bridge virbr-steal. En el plano IP se define la red 10.10.10.0/24. En el plano de transporte se observan puertos y conexiones. En el plano de aplicación aparece el servicio HTTP benigno interno de VM-SERVICES-SIM.

Esta lectura por capas también justifica por qué el laboratorio desactiva NAT y forward. Si existiera salida a Internet, una captura de red podría mezclar tráfico del caso M-001 con tráfico externo, actualizaciones, resolución DNS pública u otros flujos ajenos al experimento. Al mantener el laboratorio sin Internet desde las VMs, el PCAP se interpreta con más claridad y reduce riesgos éticos.

El diseño por capas no convierte StealLab en una infraestructura empresarial completa. Su función es experimental: proporcionar un espacio pequeño, controlado y documentado donde se pueda validar aislamiento, restaurabilidad, observabilidad y trazabilidad sin utilizar malware real ni datos reales.

La arquitectura de StealLab puede leerse como una arquitectura de contención por capas. En la capa de acceso a red, el bridge virbr-steal crea un dominio virtual controlado. En la capa de red, el segmento 10.10.10.0/24 delimita el alcance del laboratorio. En la capa de transporte, los puertos permitidos se reducen a servicios internos necesarios para la prueba. En la capa de aplicación, VM-SERVICES-SIM actúa como receptor benigno. En la capa de evidencia, los PCAP, hashes y fichas PV/EV permiten reconstruir lo sucedido sin recurrir a logs extensos dentro de la memoria.

Esta arquitectura no pretende ser una red empresarial completa. Su valor está en que cada componente cumple una función metodológica: aislar, observar, registrar, preservar o interpretar. VM-LINUX-ANALYSIS concentra la ejecución y captura; VM-SERVICES-SIM proporciona un servicio interno controlado; StealLab-Net define el límite de comunicación; y el repositorio de evidencias separa resultados verificables de la narración académica.

La lectura por capas también permite justificar futuras extensiones. VM-WIN-LAB añadiría observabilidad específica de Windows en capa host, eventos, registro, procesos y artefactos de navegador. Un SIEM futuro añadiría correlación en capa de monitorización. Un IDS como Zeek o Suricata añadiría análisis de red más rico. Estas ampliaciones son coherentes con el

diseño, pero no forman parte del alcance empírico ya cerrado salvo que se implementen y validen con evidencias nuevas.

8 IMPLEMENTACIÓN TÉCNICA

8.1 Repositorio canónico

El repositorio canónico actual del proyecto se encuentra en /mnt/eb46eae5-fd5e-46da-9d69-7830b9d22abd/J/JULIO/UNIVERSIDAD_EUROPEA/MASTER_CIBERSEGURIDAD/TFM/tfm_steallab/TFM_StealLab. Su estructura separa memoria, fuentes, laboratorio, evidencias, resultados, anexos, defensa y entrega final. Esta separación permite mantener fuera de la memoria principal las salidas completas de consola y conservarlas como evidencias externas cuando aportan trazabilidad.

La ruta canónica funciona como punto único de verdad documental. Evita que copias parciales o versiones de trabajo se confundan con la evidencia final y permite relacionar memoria, fuentes, laboratorio y resultados. Cada incorporación debe mantener nomenclatura, ubicación y propósito reconocibles.

El repositorio se entiende como parte del artefacto investigado. Sin él, la arquitectura podría existir, pero la investigación no sería auditable. La estructura también facilita el control previo al depósito y la separación entre material publicable y salidas técnicas extensas.

8.2 Estructura del repositorio

Tabla 37. Estructura principal del repositorio StealLab

Directorio	Contenido	Función documental
01_memoria	Versiones base de la memoria en DOCX/PDF	Evolución documental.
02_fuentes	Fuentes de referencia	Soporte bibliográfico y técnico.
03_laboratorio	Configs, scripts, snapshots, XML de red	Infraestructura del laboratorio.
04_evidencias	M-001 a M-005 y PV-01 a PV-07	Evidencias técnicas primarias y cierres de casos.
05_resultados	Bitácora, matrices, tablas fuente, textos	Síntesis y documentación de resultados.
06_anexos	Material complementario	Anexos finales.
07_defensa	Material de defensa	Soporte para presentación oral.
08_entrega_final	Entregas, contexto, hashes, capturas	Histórico de entrega y control documental.

La estructura jerárquica responde a separación de responsabilidades. 01_memoria conserva entregables; 02_fuentes reúne soporte; 03_laboratorio contiene configuraciones e imágenes; 04_evidencias organiza PV y casos; y 05_resultados agrega interpretación. M-001 conserva su estructura detallada y M-002 a M-005 se integran como casos complementarios con evidencias y cierres propios.

La captura histórica seleccionada documenta la estructura del caso M-001 y los cuatro datos DEMO. La memoria incorpora además tres evidencias visuales seleccionadas de M-003, M-004 y M-005, obtenidas mediante verificación offline de artefactos ya existentes. La selección evita capturas redundantes y prioriza integridad del staging, flujo HTTP interno y contraste positivo-negativo de contención.

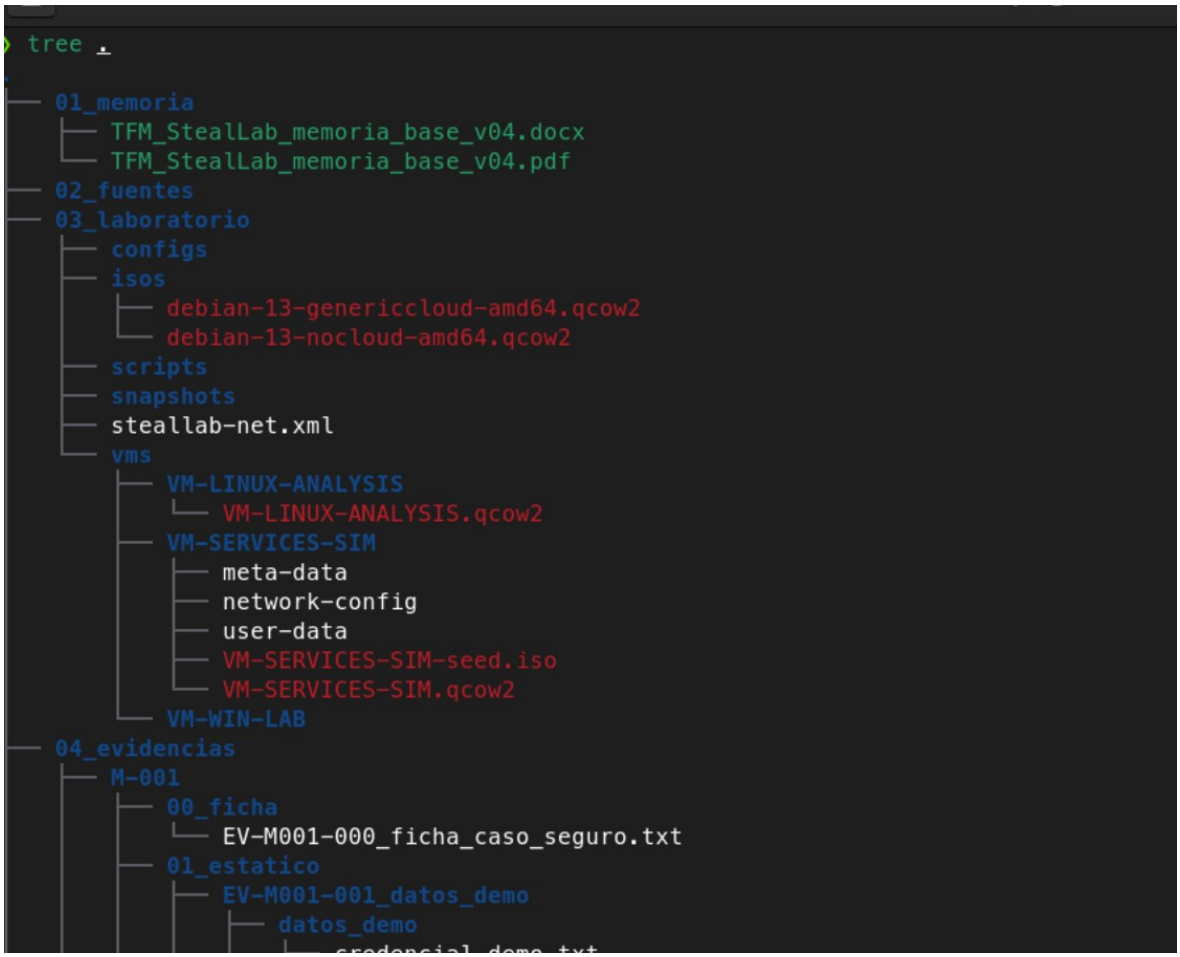


Figura 2. Estructura canónica del repositorio y evidencias del caso M-001.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

La estructura separa memoria, fuentes, laboratorio, evidencias, resultados, anexos, defensa y entrega final. Esta segregación reduce el riesgo de incorporar a la memoria salidas completas o archivos operativos, y permite aplicar controles distintos a cada zona. Las rutas citadas se tratan como identificadores documentales: si una evidencia cambia de ubicación o contenido, su ficha y su hash deben actualizarse para mantener la coherencia.

8.3 Evidencias del repositorio

El recuento de 94 ficheros correspondía al inventario verificado en el cierre previo centrado en M-001 y las PV. La verificación final realizada el 8 de agosto de 2026, tras incorporar M-002 a M-005, contabilizó 171 ficheros en 04_evidencias: 33 de M-001, 10 de M-002, 11 de M-003, 17 de M-004, 26 de M-005 y 74 asociados al grupo PV. El manifiesto global contiene igualmente 171 entradas y conserva SHA-256 4da7d19aea846aa6d08a80d6fff56f572043f31ff061156c364ccc9f26a5984f. El valor 94 se mantiene únicamente como referencia histórica y no como inventario final.

Tabla 38. Organización interna de evidencias

Grupo	Contenido principal	Ejemplos
M-001 (33 ficheros)	Caso principal de integración: datos, procesos, red e informe	EV-M001, EV-PROC y EV-PCAP-003/004
M-002 (10 ficheros)	Descubrimiento y enumeración controlada de corpus sintético	Cuatro ficheros DEMO, nota de control y EV-M002-004
M-003 (11 ficheros)	Agrupación/compresión y staging local	m003_corpus_demo.tar.gz y EV-M003-004

Grupo	Contenido principal	Ejemplos
M-004 (17 ficheros)	Comunicación HTTP interna benigna	EV-PCAP-005, EV-M004-008 y manifest M-004
M-005 (26 ficheros)	Contraste de contención y control de calidad documental	EV-PCAP-006/007 y EV-M005-004 a EV-M005-010
PV (74 ficheros)	Pruebas PV-01 a PV-07	Aislamiento, snapshots, procesos, red, repositorio, informe y LLM
TOTAL (171 ficheros)	Inventario final verificado de 04_evidencias	Manifiesto global: 171 entradas; SHA-256 verificado (hash completo en texto y repositorio).

Las evidencias no tienen idéntico peso. Algunas son primarias, como PCAP, hashes, salidas de estado y artefactos de cierre; otras son de contexto, como resúmenes, fichas o capturas. La clasificación evita que el volumen se confunda con calidad y permite seleccionar en la memoria solo los artefactos más informativos.

Cada evidencia debe responder al menos a cuatro preguntas: qué contiene, de qué prueba procede, cómo se verifica y qué límite presenta. Cuando una captura ilustra un estado, su valor depende de que pueda relacionarse con una salida textual o configuración preservada.

8.4 Datos sintéticos DEMO/NO REAL

Los cuatro ficheros sintéticos representan categorías conceptuales de información sin incluir datos reales. Su hash SHA-256 permite verificar que el contenido no se altera entre preparación, análisis y documentación.

Tabla 39. Hashes de datos sintéticos M-001

Fichero	SHA-256 verificado	Interpretación
credencial_demo.txt	de2912a49102d834f0a4bf71e1ddfe6e013ea90028191d67a6309f93021c2023	Representa credenciales DEMO/NO REAL.
navegador_demo.txt	36562d2c6adc4ca50fe0313b602416d5169f224c646b5e5a8c90957fe17ed483	Representa datos de navegador DEMO/NO REAL.
sistema_demo.txt	5c61534c50f56876be836a06b25c831e190ae3ce0659652e52aeb98e95de491b	Representa información de sistema DEMO/NO REAL.
wallet_demo.txt	35f39a7fc1c18debbd0e574903994b91a0eccd16a9eb77112e87bf9124823495	Representa wallet DEMO/NO REAL.

Los datos sintéticos se diseñan para conservar estructura semántica sin conservar secreto. credencial_demo representa un dato de autenticación ficticio; navegador_demo, un perfil de navegador sin cookies reales; sistema_demo, metadatos no sensibles; y wallet_demo, una referencia sin claves. El etiquetado explícito reduce el riesgo de confusión durante la revisión.

Los hashes permiten demostrar que los ficheros citados son exactamente los utilizados en el caso. No prueban que el contenido sea verdadero ni malicioso; prueban identidad e integridad respecto de la versión registrada. Esta distinción se mantiene en todas las interpretaciones.

Los datos sintéticos se diseñan para conservar forma y función sin conservar sensibilidad. Sus nombres y contenidos permiten diferenciar categorías de activos, pero incluyen marcas inequívocas de demostración y no reproducen secretos utilizables. Este enfoque permite comprobar lectura, agrupación, transmisión interna e integridad sin crear un conjunto que pueda confundirse con información personal o corporativa. La utilidad experimental depende de que esa condición sea revisable por terceros.

8.5 PCAP y tráfico controlado

El fichero EV-PCAP-003_m001_http_controlado.pcap mantiene el papel de evidencia de red del caso principal. Los casos complementarios amplían esta capa sin introducir tráfico externo real: M-004 incorpora EV-PCAP-005_m004_http_interno.pcap (11 paquetes, 0 dropped, SHA-256 4a1b14152f7e66517f97507a52765386f528752341e917f69e2666129354bdd5) y M-005 incorpora EV-PCAP-006_m005_control_interno.pcap (10 paquetes, flujo HTTP interno) y EV-PCAP-007_m005_destino_testnet.pcap (0 paquetes y 24 bytes de cabecera PCAP).

Las capturas de red se generan dentro de StealLab-Net y se interpretan junto con el estado de enrutamiento y las salidas de conexión. En M-004, la respuesta HTTP 200 y la coincidencia de hash del recurso de 398 bytes permiten correlacionar cliente, servidor y contenido sintético. En M-005, la captura vacía del destino TEST-NET no se trata como prueba autónoma de aislamiento: se combina con la ausencia de ruta y con el fallo de conexión observado.

Los hashes de los PCAP fijan las versiones analizadas y permiten separar evidencia primaria de interpretación. El PCAP interno de M-005 tiene SHA-256 7fdae0da33316eda7b1c859c3f0857bc2676ea98e99ff8e9246a9d3b2630547c; el PCAP del destino TEST-NET tiene SHA-256 704e5e5b3234433c01fcfd1b20a306e77e985038120492dc53965c3edd38a4ea. Ninguno de estos valores demuestra intención maliciosa ni aislamiento universal; identifican artefactos concretos del escenario documentado.

8.6 Snapshots documentados por qcow2

La verificación qemu-img info muestra snapshots internos en los discos qcow2 de VM-SERVICES-SIM y VM-LINUX-ANALYSIS. En VM-SERVICES-SIM se documenta PV02_VM_SERVICES_SIM_BASE_OK_20260705 y en VM-LINUX-ANALYSIS se documenta PV02_VM_LINUX_ANALYSIS_BASE_OK_20260705. Esto refuerza PV-02, aunque se recomienda conservar también evidencia de virsh snapshot-list cuando las VMs estén activas o registradas en la sesión de administración correspondiente.

La restaurabilidad se verifica en dos niveles: propiedades de la imagen qcow2 y snapshots asociados al dominio. El snapshot PV02_VM_LINUX_ANALYSIS_BASE_OK_20260705 conserva un punto de retorno identificado, fechado y marcado como actual en la evidencia seleccionada. Esta identificación reduce ambigüedad frente a snapshots con nombres genéricos.

Un snapshot no sustituye a una copia de seguridad ni garantiza por sí solo consistencia de aplicaciones. En este TFM se utiliza como mecanismo de repetición controlada del estado de laboratorio, con el límite de que la restauración completa debe validarse mediante una prueba separada cuando se requiera mayor rigor.

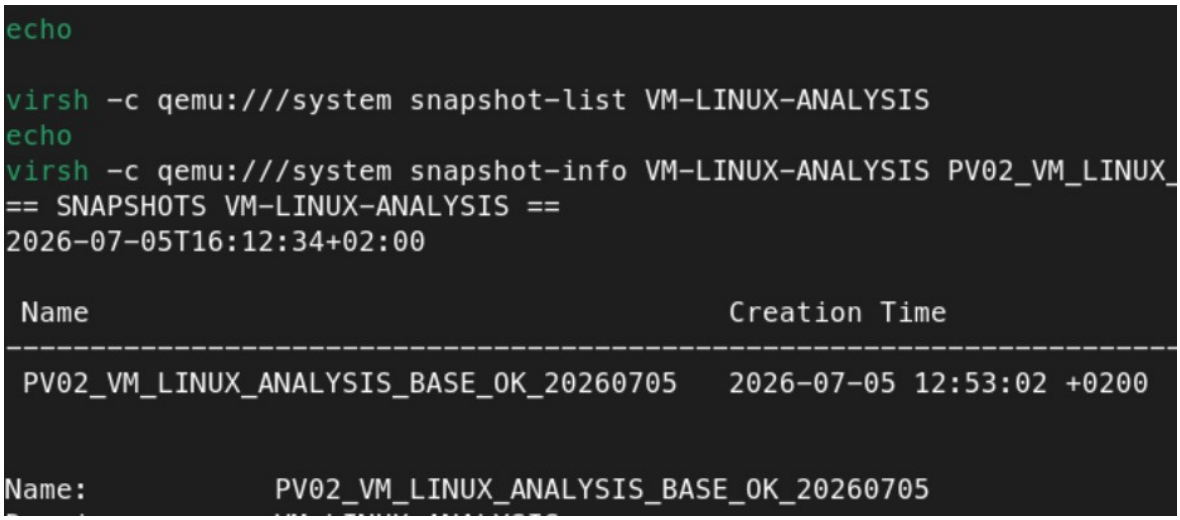


Figura 3. Snapshot documentado de VM-LINUX-ANALYSIS asociado a PV-02.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

8.7 Implementación de M-001

M-001 se implementa como secuencia determinista: preparar los cuatro ficheros DEMO, registrar su integridad, ejecutar el artefacto benigno, observar procesos, transferir contenido sintético al servicio interno, capturar tráfico y generar manifiestos. Cada paso produce una salida identificable y ninguna fase requiere privilegios o acceso externo no justificados.

El caso se diseñó para fallar de forma segura. Si el servicio interno no responde, la transferencia no abandona la red; si la captura no se inicia, no se afirma resultado de red; y si un hash cambia, la evidencia se invalida hasta documentar una nueva versión.

La implementación mantiene una separación estricta entre comportamiento simulado y capacidad ofensiva. M-001 lee únicamente el conjunto DEMO, genera los artefactos previstos y se comunica con un receptor HTTP benigno dentro del segmento aislado. No incorpora mecanismos de persistencia, evasión, descubrimiento expansivo, explotación ni comunicación externa. Estas ausencias no son carencias accidentales, sino decisiones de diseño que delimitan lo que el caso puede demostrar.

Los casos complementarios reutilizan las mismas salvaguardas y el mismo repositorio. M-002 realiza descubrimiento controlado sobre cuatro ficheros DEMO/NO REAL y una nota de control; su cierre EV-M002-004 está documentado como PASS. M-003 agrupa el corpus en m003_corpus_demo.tar.gz (587 bytes; SHA-256 a0c366cb9e4422a6207eb7875d96b5d7e71a2f3e492d41a476f9c43b3ae54cd5) y valida su extracción offline, con cierre EV-M003-004 PASS.

M-004 valida comunicación HTTP interna desde VM-LINUX-ANALYSIS (10.10.10.20) hacia VM-SERVICES-SIM (10.10.10.30:8080). El recurso sintético tiene 398 bytes y SHA-256 2b54346a8c2d7f31b72cb72166547a9782976c95738b76ac688214532c26b363; se observó HTTP 200 y coincidencia de hash en recepción. La limitación específica es que no se documentó el PID runtime del servidor, por lo que el mecanismo se sostiene mediante systemd y la respuesta runtime, no mediante ese dato ausente.

M-005 contrasta el control interno permitido con un destino documental 192.0.2.1 TEST-NET. La VM cliente carecía de ruta por defecto; ip route get devolvió Network is unreachable (RC 2) y el intento curl finalizó con RC 7, HTTP 000 y 0 bytes. El resultado se considera PASS para esta configuración concreta, sin extrapolarlo a un aislamiento universal.

8.8 Lectura técnica del estado libvirt verificado

La comprobación con virsh sobre qemu:///system confirma que la red StealLab-Net no es solo un fichero XML guardado, sino una red registrada en libvirt, activa, persistente y configurada con autostart. Esta diferencia es metodológicamente importante: una cosa es conservar la definición de red en el repositorio y otra comprobar que el hipervisor la reconoce como recurso operativo.

El XML de red documenta el bridge virbr-steal, la IP 10.10.10.1/24 y reservas DHCP para VM-WIN-LAB, VM-LINUX-ANALYSIS y VM-SERVICES-SIM. La reserva de VM-WIN-LAB se mantiene como diseño futuro; no debe interpretarse como validación de una VM Windows implementada.

La lectura de libvirt se realiza con conexión explícita qemu:///system para evitar confundir dominios de usuario y sistema. Se comprueban redes, dominios, pools y leases porque cada vista responde a un plano distinto. La convergencia de estas salidas aporta mayor confianza que una única captura de interfaz gráfica.

El estado observado debe interpretarse con fecha. Las capturas del 5 de julio de 2026 muestran fases sucesivas de preparación y ejecución. Por ello, la memoria evita convertir un estado puntual en una propiedad permanente del laboratorio.

8.9 Arquitectura lógica de comunicación

La comunicación de M-001 está diseñada para permanecer dentro del segmento 10.10.10.0/24. VM-LINUX-ANALYSIS actúa como estación de análisis y ejecución controlada; VM-SERVICES-SIM actúa como servidor HTTP benigno; el host proporciona virtualización, almacenamiento y bridge aislado. No existe C2 real porque no hay mando remoto, persistencia criminal ni infraestructura externa.

La comunicación permitida se reduce al trayecto VM-LINUX-ANALYSIS -> StealLab-Net -> VM-SERVICES-SIM:8080. No existe necesidad metodológica de resolver nombres externos ni de alcanzar Internet. El servicio HTTP se ejecuta como receptor benigno y registra una respuesta local verificable.

La evidencia de VM-SERVICES-SIM muestra la interfaz 10.10.10.30/24, ausencia de ruta por defecto, servicio activo y puerto 8080 en escucha. La respuesta HTTP 200 confirma disponibilidad funcional sin probar exfiltración ni C2.

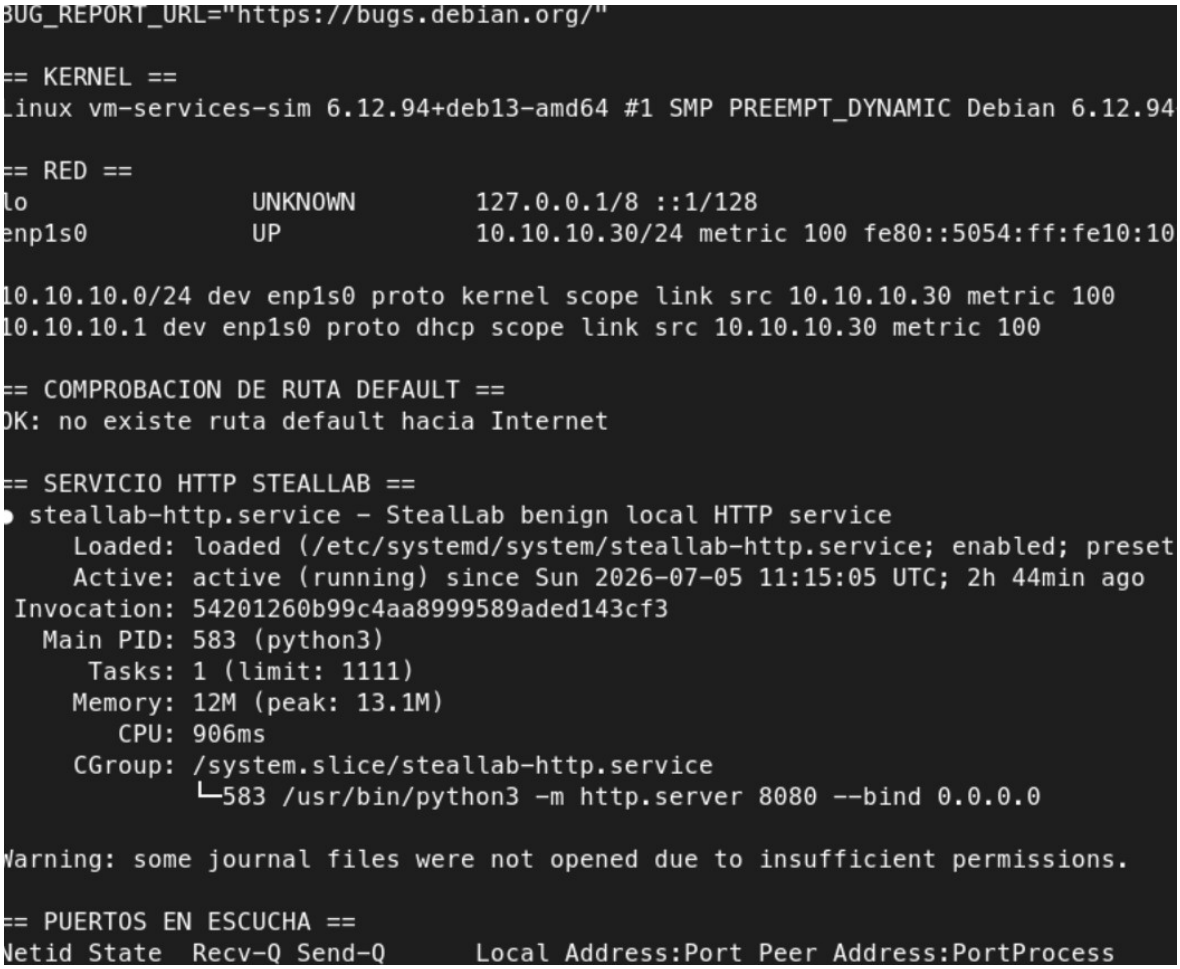


Figura 4. Estado de VM-SERVICES-SIM y servicio HTTP benigno en el puerto 8080.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

8.10 Datos sintéticos como instrumento experimental

Los cuatro ficheros DEMO no son un accesorio menor: constituyen el instrumento experimental que permite representar categorías de información sin introducir datos reales. credencial_demo.txt representa credenciales; navegador_demo.txt representa artefactos de navegador; wallet_demo.txt representa activos digitales; sistema_demo.txt representa información general del equipo. Sus hashes permiten comprobar que el conjunto no se modificó entre preparación y análisis.

El uso de datos sintéticos mejora control interno porque el conjunto de entrada es conocido y estable. Permite comprobar qué ficheros se procesan y qué contenido llega al receptor sin introducir incertidumbre sobre procedencia o consentimiento.

Su principal coste es la pérdida de realismo: los ficheros no reproducen formatos cifrados, bloqueo de navegador, ACL, perfiles complejos ni variabilidad de sistemas reales. Esta limitación se acepta porque la pregunta de investigación evalúa el laboratorio y la trazabilidad, no la eficacia de extracción.

8.11 Interpretación de los PCAP de validación

Los PCAP de M-001, M-004 y M-005 se interpretan como evidencia de observabilidad de red y no como prueba de exfiltración real. M-001 y M-004 documentan comunicación HTTP interna controlada; M-005 añade un contraste en el que el flujo interno funciona y el destino TEST-NET no resulta alcanzable bajo la configuración observada.

La interpretación se realiza por capas: enlace y red sitúan los flujos dentro del segmento; transporte identifica sesiones y puertos; aplicación permite observar HTTP cuando existe. En M-005, la ausencia de paquetes hacia TEST-NET solo adquiere significado al combinarse con la ausencia de ruta y el fallo de conexión; no se utiliza como demostración universal de contención.

No se atribuye intención, familia, evasión ni comportamiento C2. Tampoco se extrapolan volumen, protocolo o ausencia de paquetes a operaciones reales. Los PCAP son evidencias de observabilidad y de un contraste de conectividad definido, no reproducciones de infraestructura criminal.

8.12 Nomenclatura EV y trazabilidad documental

La nomenclatura de evidencias no es estética; reduce ambigüedad. EV-M001 a EV-M005 identifican evidencias por caso; EV-PCAP identifica capturas de red; EV-PROC identifica procesos; EV-SNAP identifica snapshots; y EV-LLM identifica validación documental con revisión humana. Esta taxonomía permite navegar el repositorio y asociar cada artefacto a su función.

La nomenclatura EV-M00X-NNN mantiene identidad de caso, secuencia y función. Cuando una evidencia se deriva de otra, la ficha registra la relación para evitar que un resumen se trate como fuente primaria. En M-005 esta regla conserva expresamente EV-M005-005 como FAIL histórico del script de decisión y EV-M005-006 como corrección documental sobre las mismas evidencias, sin reejecución ni tráfico nuevo.

La consistencia nominal se considera un control de calidad. Variaciones no justificadas, duplicados o rutas rotas deben resolverse antes del depósito. El cierre formal de M-005 queda fijado en EV-M005-010 como PASS, manteniendo visible la incidencia previa en lugar de sobrescribirla.

8.13 Decisiones de exclusión técnica

Se excluyen deliberadamente persistencia, evasión, cifrado malicioso, descarga de cargas, robo real de credenciales y comunicación externa. Estas exclusiones no deben ocultarse: forman parte del diseño ético. El laboratorio se valida sobre observabilidad y trazabilidad, no sobre peligrosidad de la muestra.

Tabla 40. Arquitectura lógica verificada de StealLab

Elemento	Rol lógico	Evidencia o estado	Interpretación
Host MSI-STEALTH-GS66	Infraestructura física	Ruta canónica y herramientas	Soporte del laboratorio
StealLab-Net	Red aislada	active/persistent/autostart	Contención lógica
virbr-steal	Bridge libvirt	XML de red	Interconexión interna
VM-SERVICES-SIM	Servidor benigno	Registrada; IP reservada 10.10.10.30	Simula receptor HTTP interno
VM-LINUX-ANALYSIS	Estación de análisis	Registrada; IP reservada 10.10.10.20	Ejecución M-001 y captura
VM-WIN-LAB	Reserva futura	IP reservada 10.10.10.10	No validada en alcance actual

M-001 y los casos complementarios se implementan como simulaciones benignas defensivas. Ningún artefacto incorpora capacidades de malware real: no persiste, no evade, no roba datos reales, no accede a credenciales reales y no contacta infraestructura externa. Las operaciones se limitan a datos sintéticos, tratamiento local controlado y comunicación interna cuando el caso lo requiere.

También se excluyeron configuraciones que habrían aumentado realismo sin aportar evidencia proporcional: NAT temporal, descarga automatizada de muestras, resolución DNS externa, agentes de control remoto y reutilización de perfiles reales de navegador. La exclusión documentada evita que futuras ampliaciones interpreten esos elementos como pendientes triviales. Cualquier incorporación exigiría un nuevo análisis de riesgos y un protocolo independiente.

8.14 Justificación de cada componente de la arquitectura

El laboratorio se diseña con componentes mínimos, controlados y separables. El host físico proporciona capacidad de virtualización y almacenamiento; libvirt/KVM aporta aislamiento y gestión de dominios; StealLab-Net establece el perímetro lógico; VM-LINUX-ANALYSIS actúa como punto de preparación y observación; VM-SERVICES-SIM proporciona un extremo HTTP interno benigno; el repositorio conserva evidencias; y los snapshots permiten volver a un estado conocido. Cada elemento responde a un requisito concreto y evita dependencias innecesarias.

Tabla 41. Justificación arquitectónica de componentes

Componente	Función	Por qué es necesario	Riesgo que reduce
Host Debian	Ejecuta virtualización y conserva repositorio.	Permite control local y trazabilidad.	Dependencia de servicios externos.
KVM/libvirt	Gestión de VMs y redes.	Proporciona aislamiento reproducible.	Ejecución no controlada.
StealLab-Net	Red privada de laboratorio.	Limita comunicaciones a segmento controlado.	Exposición a Internet o redes reales.
VM-LINUX-ANALYSIS	Análisis, preparación y captura.	Centraliza observación defensiva.	Mezcla de pruebas con host personal.
VM-SERVICES-SIM	Servidor HTTP interno benigno.	Sustituye C2 real por endpoint seguro.	Comunicación con infraestructura maliciosa.
Snapshots	Restauración de estado.	Permiten repetición y rollback.	Deriva de estado experimental.
Repositorio PV/EV	Conservación estructurada.	Facilita auditoría y defensa.	Pérdida de trazabilidad.

Cada componente debe aportar una propiedad verificable. KVM/libvirt proporciona definición y control del entorno; qcow2 y los snapshots soportan restaurabilidad; StealLab-Net delimita la comunicación; VM-LINUX-ANALYSIS concentra la observación; VM-SERVICES-SIM ofrece un destino benigno; el repositorio conserva la trazabilidad; y los hashes permiten comprobar integridad. Los componentes que no contribuyen a una categoría o evidencia quedan fuera del diseño mínimo.

8.15 Razonamiento de aislamiento de red

El aislamiento de red es el control más importante del laboratorio porque el objeto de estudio se relaciona con malware. Aunque M-001 a M-005 son casos benignos y no malware real, el TFM aplica la misma prudencia de contención exigible a un laboratorio defensivo. StealLab-Net usa un bridge específico, un segmento privado y reservas de dirección. La verificación con qemu:///system confirmó que la red está activa, es persistente, tiene autostart y emplea el bridge virbr-steal.

La presencia de una reserva para VM-WIN-LAB no implica que la VM exista como alcance validado. Su inclusión en el XML se interpreta como reserva de diseño, no como resultado ejecutado. Esta precisión evita una sobreafirmación y permite mantener una línea clara entre alcance validado y trabajos futuros.

La ausencia de forward/NAT e Internet desde las VMs es una decisión metodológica y ética. M-005 refuerza empíricamente esa lectura para una configuración y un destino concretos: el control HTTP interno funciona, mientras 192.0.2.1 TEST-NET no dispone de ruta útil y la

conexión falla. Este resultado complementa la configuración de red, pero no permite afirmar que ninguna ruta de fuga pudiera existir bajo otras configuraciones o destinos.

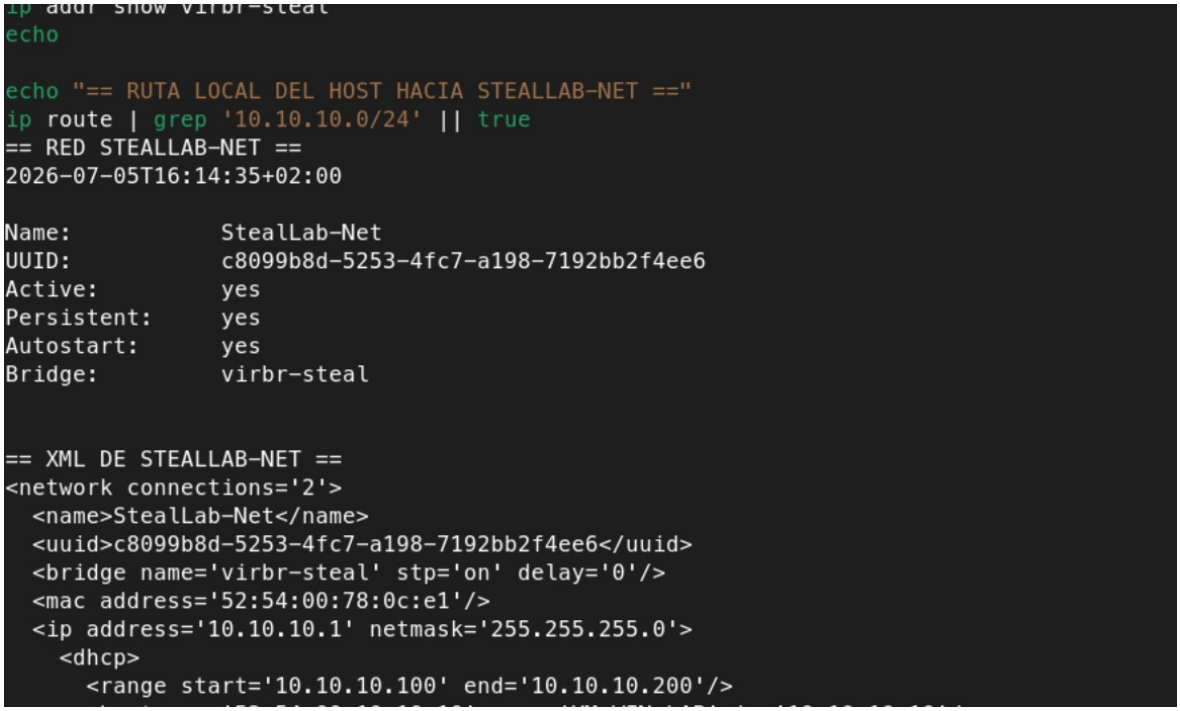


Figura 5. Configuración de StealLab-Net, bridge virbr-steal y direccionamiento interno.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

8.16 Trazabilidad del procedimiento de implementación

La implementación técnica se documenta en tres niveles. El primer nivel es descriptivo: qué se construyó y por qué. El segundo nivel es verificable: qué comandos o evidencias demuestran la existencia del componente. El tercer nivel es interpretativo: qué significa esa evidencia para los objetivos del TFM. Esta triple lectura impide que la memoria se convierta en un conjunto de comandos y, al mismo tiempo, evita que la explicación sea abstracta.

La ruta canónica del repositorio, el árbol aportado, los hashes, los manifiestos de cierre y las salidas de qemu-img y virsh son elementos verificables. El cierre del 8 de agosto de 2026 fija el inventario de 04_evidencias en 171 ficheros y el manifiesto global en 171 entradas; el antiguo recuento de 94 ficheros se conserva exclusivamente como fotografía histórica del estado previo a los casos complementarios. En la memoria principal se presentan resultados sintéticos y evidencias seleccionadas; las salidas completas se conservan como evidencias externas.

8.17 Decisiones técnicas descartadas

Un diseño técnico robusto no solo explica qué se hizo, sino también qué se descartó. En StealLab se descartó el uso de Internet desde VMs porque introduciría riesgo y ruido. Se descartó un C2 real porque sería innecesario y éticamente inaceptable. Se descartó el uso de credenciales reales por protección de datos y minimización. Se descartó presentar VM-WIN-LAB como implementada porque no existe validación empírica de esa VM como dominio ejecutado. Se descartó incluir volcados completos de consola porque reducen claridad académica y no aportan interpretación.

Tabla 42. Decisiones técnicas descartadas y alternativas adoptadas

Decisión descartada	Motivo	Alternativa adoptada
Ejecutar malware real	Riesgo ético, legal y operativo.	Simulación benigna M-001.
Usar credenciales reales	Riesgo de privacidad y exposición.	Datos DEMO/NO REAL.
Usar C2 real	Comunicación con infraestructura maliciosa.	VM-SERVICES-SIM HTTP interno benigno.
Permitir Internet desde VMs	Riesgo de fuga y ruido experimental.	Red aislada sin forward/NAT.
Presentar VM-WIN-LAB como validada	No implementada como VM real.	Reserva de diseño y trabajo futuro.
Pegar terminales completos	Baja aportación académica.	Síntesis en memoria y evidencias externas.

Registrar alternativas descartadas evita presentar la arquitectura final como única solución posible. El criterio de decisión combina reducción de riesgo, compatibilidad con los objetivos, facilidad de auditoría y coste de mantenimiento. Una opción técnicamente viable puede ser metodológicamente inadecuada si introduce dependencias no controladas o dificulta explicar qué produjo cada resultado.

8.18 Diseño teórico de VM-WIN-LAB

VM-WIN-LAB se mantiene en esta memoria como diseño teórico y trabajo futuro, no como máquina implementada y validada. Esta aclaración es importante porque muchas familias de stealers tienen una presencia histórica relevante en entornos Windows, especialmente por la relación con navegadores de escritorio, perfiles de usuario, credenciales almacenadas, cookies de sesión, tokens locales, clientes de correo y aplicaciones de usuario. Sin embargo, incorporar Windows al laboratorio exige controles adicionales de licencia, telemetría, aislamiento, snapshots y protección de datos.

El diseño previsto para VM-WIN-LAB mantiene el mismo principio que M-001: usar únicamente datos sintéticos DEMO/NO REAL, no ejecutar malware real, no utilizar credenciales personales, no conectar con C2 real y no permitir salida a Internet. Su función sería ampliar la observabilidad del laboratorio hacia eventos de Windows, procesos, servicios, registros del sistema y artefactos de navegador simulados. La máquina tendría una reserva de diseño en StealLab-Net con IP 10.10.10.10, tal como aparece en la definición XML de la red, pero esa reserva no debe interpretarse como validación de una VM Windows ya construida.

Desde el punto de vista defensivo, VM-WIN-LAB permitiría comparar señales de Linux y Windows ante casos benignos equivalentes. En Linux, el TFM ya valida procesos, ficheros y tráfico de M-001. En Windows, una futura iteración podría observar eventos del sistema, registros de seguridad, trazas de procesos y cambios sobre artefactos sintéticos de navegador. Esa ampliación tendría valor académico porque permitiría estudiar diferencias de telemetría entre sistemas operativos sin modificar la ética del laboratorio.

Tabla 43. Diseño teórico de VM-WIN-LAB y controles de seguridad

Elemento previsto	Función	Control obligatorio	Estado en esta memoria
VM-WIN-LAB	Entorno Windows para telemetría futura	Red StealLab-Net sin Internet	Diseño no implementado
IP 10.10.10.10	Reserva de direccionamiento	Interpretar como diseño, no como actividad runtime	Definida en XML de red
Datos sintéticos	Representar navegador, cookies y tokens DEMO	Prohibido usar datos reales	Pendiente de futura implementación
Herramientas defensivas	Registro de eventos, procesos y red	Uso solo de monitorización y análisis	Pendiente de selección

Elemento previsto	Función	Control obligatorio	Estado en esta memoria
Snapshot base	Restaurabilidad de la VM	Crear antes de cualquier prueba	Pendiente de validación
Caso M-WIN-001	Simulación benigna equivalente	Sin malware real ni C2 real	Trabajo futuro

8.19 Procedimiento seguro previsto para una futura VM-WIN-LAB

El procedimiento futuro debe plantearse como protocolo de laboratorio, no como ejecución ofensiva. Primero, se definiría el alcance: objetivo académico, red aislada, ausencia de Internet desde la VM y prohibición de datos reales. Segundo, se construiría la VM Windows con licencia válida y configuración mínima necesaria. Tercero, se conectaría únicamente a StealLab-Net y se comprobaría que no existe NAT ni forward hacia redes externas. Cuarto, se crearían snapshots base antes de cualquier prueba. Quinto, se prepararían artefactos sintéticos de navegador, credenciales DEMO, tokens DEMO y wallets ficticias. Sexto, se ejecutaría un caso benigno equivalente a M-001. Séptimo, se recogerían eventos, procesos, hashes, PCAP y fichas PV/EV. Octavo, se restauraría el snapshot y se documentarían límites y resultados.

Las herramientas previstas deben seleccionarse con criterio defensivo. Sysmon, registros de eventos de Windows, monitorización de procesos, capturas de red y herramientas de análisis de artefactos pueden aportar visibilidad, pero no deben convertir el laboratorio en una guía de ataque. La prioridad no sería demostrar compromiso, sino validar que el laboratorio puede observar cambios y comunicaciones controladas en Windows con el mismo rigor documental aplicado a Linux.

El resultado esperado de esta línea futura sería una submatriz de comprobaciones Windows vinculada a las categorías de PV-01 a PV-07 y un caso M-WIN-001 claramente separado del alcance actual. Hasta que esa validación se ejecute, cualquier mención a VM-WIN-LAB debe permanecer marcada como diseño previsto o trabajo futuro, sin ampliar artificialmente la matriz de pruebas validada.

8.20 Diseño de un flujo seguro para análisis de código fuente malicioso asistido por LLM

La ampliación natural de StealLab no debe limitarse a observar comportamiento dinámico benigno. También puede incorporar un flujo de análisis estático de código fuente potencialmente malicioso, siempre que el laboratorio trate dicho código como material peligroso y no como software a ejecutar. En este diseño, el código procedente de repositorios públicos se considera evidencia documental de amenaza y se analiza para responder preguntas defensivas: qué activos intenta localizar, qué categorías de datos prioriza, qué mecanismos de comunicación declara, qué dependencias utiliza y qué controles permitirían detectarlo o contenerlo.

El flujo propuesto se apoya en tres zonas lógicas. La primera es una zona de recepción documental, donde se registra la procedencia y se calcula integridad. La segunda es una zona de análisis estático, sin ejecución, sin compilación y sin conectividad externa. La tercera es una zona de producción de conocimiento, donde el LLM supervisado ayuda a transformar observaciones en descripciones, tablas de evidencias, relaciones con MITRE ATT&CK y controles defensivos. Las tres zonas pueden existir dentro de la VM-LINUX-ANALYSIS o como subcaso futuro separado, pero no deben mezclarse con datos reales ni con credenciales válidas.

El diseño seguro del flujo se sintetiza a continuación.

Tabla 44. Flujo seguro para análisis estático de código asistido por LLM

Componente del flujo	Función dentro de StealLab	Control requerido
Repositorio documental	Conservar únicamente el material necesario para análisis estático, junto con fecha, fuente, hash y motivo de inclusión.	Copia aislada, sin ejecución automática y con control de acceso local.
Preprocesamiento seguro	Separar ficheros por lenguaje, tamaño, dependencias y posible responsabilidad funcional.	No resolver dependencias, no instalar paquetes y no contactar servicios externos.
Interfaz con LLM supervisado	Enviar fragmentos limitados para explicación defensiva, extracción de conceptos y clasificación.	Instrucciones con prohibición explícita de mejora ofensiva, ejecución, evasión o reconstrucción operativa.
Registro de análisis	Guardar pregunta, fragmento analizado, respuesta, verificación humana y decisión final.	Trazabilidad completa y marca de incertidumbre cuando exista ambigüedad.
Salida académica	Producir tablas, glosario, matriz de comportamiento y discusión de límites.	No incluir código funcional ni instrucciones reutilizables para abuso.

Este flujo no altera las conclusiones empíricas ya cerradas, porque no añade una prueba ejecutada. Su valor es metodológico y prospectivo: permite mostrar cómo el laboratorio podría crecer hacia análisis de código real manteniendo aislamiento, ética, trazabilidad y control humano.

PARTE IV. PRUEBAS, VALIDACIÓN Y RESULTADOS

9 PLAN DE PRUEBAS Y VALIDACIÓN

El plan de pruebas mantiene siete pruebas de validación PV. Los casos M-002 a M-005 no crean nuevas PV: aportan observaciones complementarias a criterios ya definidos. Así, el plan conserva estabilidad metodológica mientras aumenta la cobertura empírica de procesos, red, repositorio y aislamiento.

Tabla 45. Plan de pruebas PV/EV

PV	Nombre	Criterio de aceptación	Evidencias principales
PV-01	Aislamiento de red	Red definida, activa y persistente; sin dependencia de Internet para los casos	EV-ISO-RED, qemu:///system y M-005 (contraste TEST-NET)
PV-02	Snapshots y restaurabilidad	Existencia de snapshot base para VMs validadas	EV-SNAP-001, EV-SNAP-002, qemu-img info
PV-03	Captura de procesos/eventos	Registro de actividad local controlada	EV-PROC y evidencias M-001 a M-005 según caso
PV-04	Captura de tráfico	PCAP interno analizable y, cuando procede, contraste negativo	EV-PCAP-003, EV-PCAP-005, EV-PCAP-006 y EV-PCAP-007
PV-05	Repositorio de evidencias	Estructura, integridad y trazabilidad verificables	EV-REPO, cierres M-002..M-005 y manifiestos
PV-06	Informe técnico	Informe de M-001 e integración académica de casos	EV-INF-001 y síntesis de resultados
PV-07	Validación LLM supervisada	Uso del LLM como apoyo documental revisado por humano	EV-LLM-001 a EV-LLM-003

9.1 Criterios de aceptación

Una prueba se considera aceptada cuando existen evidencias identificadas, verificables y coherentes con el objetivo de la prueba. La aceptación no implica ausencia absoluta de limitaciones, sino cumplimiento dentro del alcance definido. Por ejemplo, PV-01 se acepta porque la red StealLab-Net está definida y activa; el hecho de que las VMs estuvieran apagadas durante domifaddr no invalida la red, sino que documenta el estado runtime de las VMs.

Los criterios se fijan antes de interpretar resultados y se expresan de forma observable. Por ejemplo, PV-01 exige ausencia de salida externa y configuración coherente; PV-04 exige una captura válida y analizable; PV-05 exige inventario y hashes. Esta formulación reduce sesgo retrospectivo.

Un criterio puede cumplirse con reservas. En ese caso se registra el cumplimiento y el límite, en lugar de forzar una clasificación binaria. Esta práctica es especialmente relevante para restaurabilidad y LLM, donde la evidencia demuestra procedimiento y control, pero no cobertura universal.

El plan incluye comprobaciones negativas. M-005 formaliza esta lógica: contrasta un control HTTP interno positivo con un destino TEST-NET no alcanzable y vincula el resultado a PV-01, PV-03, PV-04 y PV-05. M-002 se relaciona principalmente con PV-03/PV-05; M-003 con PV-03/PV-05; y M-004 con PV-03/PV-04/PV-05. La relación se interpreta como refuerzo de PV existentes, no como creación de PV adicionales.

9.2 Tratamiento de salidas de consola

Las salidas completas de consola se conservan fuera de la memoria principal. En el cuerpo del TFM solo se incluyen fragmentos, tablas o interpretaciones que aportan valor. Este tratamiento preserva la evidencia sin convertir la memoria en un volcado de terminal.

Las salidas completas se mantienen como evidencia y la memoria incorpora solo fragmentos representativos. La selección se basa en relevancia, legibilidad y ausencia de datos innecesarios. Cada captura debe poder relacionarse con una salida textual o ficha para reducir dependencia de la imagen.

No se corrigen retrospectivamente las salidas técnicas para hacerlas parecer más limpias. Cuando existe una advertencia no crítica, se conserva y se explica. Esta política evita presentar un entorno idealizado y facilita distinguir error, ruido y resultado.

10 CASOS DE VALIDACIÓN: M-001 Y CASOS COMPLEMENTARIOS

M-001 se mantiene como caso principal de validación de StealLab. M-002, M-003, M-004 y M-005 se incorporan como casos complementarios cerrados con resultado PASS que prueban aspectos específicos del mismo laboratorio: descubrimiento, staging local, comunicación HTTP interna y contención negativa. Todos comparten las restricciones defensivas del diseño y refuerzan las PV-01 a PV-07 ya definidas.

10.1 Finalidad del caso

La finalidad del capítulo es validar el laboratorio mediante un caso principal y varios contrastes complementarios, no demostrar capacidades de una familia maliciosa real. M-001 recorre la cadena extremo a extremo; M-002 a M-005 aíslan observables adicionales y permiten comprobar si la interpretación permanece trazable al variar el tipo de operación benigna.

M-001 es una prueba de integración. M-002 a M-005 no sustituyen esa función: la complementan. El criterio común de éxito exige evidencia identificada, resultado reproducible dentro del escenario y una limitación explícita; el número de ejemplos no amplía por sí solo la validez externa.

La finalidad secundaria es demostrar proporcionalidad ética: descubrimiento, agrupación local, comunicación interna y contraste de contención pueden estudiarse con artefactos sintéticos y destinos controlados. Esta decisión conserva valor técnico sin introducir malware, secretos, C2, persistencia, evasión ni exfiltración reales.

M-001 funciona como caso principal del método y M-002 a M-005 como casos complementarios de validación. La combinación aumenta la variedad de observables sin convertir el estudio en emulación de adversario. Su valor reside en demostrar que las categorías metodológicas producen evidencias coherentes dentro de un entorno aislado y auditable.

10.2 Restricciones de seguridad

- No contiene ni usa malware real.
- No contiene credenciales, cookies, tokens, wallets ni datos personales reales.
- No usa C2 real ni Internet.
- No implementa persistencia.
- No implementa evasión.
- No altera sistemas fuera del laboratorio.
- No automatiza decisiones críticas mediante LLM.

Las restricciones se aplican como controles verificables y no solo como declaraciones. Los casos usan datos DEMO/NO REAL; la comunicación se limita a StealLab-Net; M-005 utiliza 192.0.2.1 exclusivamente como destino TEST-NET documental y no como servicio real; y el cierre mantiene evidencias originales aun cuando exista una incidencia documental.

También se prohíbe reutilizar artefactos fuera del caso, introducir endpoints personales o copiar muestras desde repositorios públicos. El cierre incluye revisar repositorio y memoria para confirmar que no se haya incorporado material sensible durante la documentación.

10.3 Datos sintéticos utilizados

Los datos sintéticos se diseñan para representar categorías, no para reproducir información sensible. M-001 y M-002 reutilizan cuatro ficheros DEMO/NO REAL; M-003 agrupa ese corpus localmente; M-004 y el control interno de M-005 emplean un recurso sintético de 398 bytes. El objetivo es que cada transformación o comunicación pueda verificarse sin riesgo para personas, cuentas o sistemas reales.

Los cuatro ficheros permiten representar diversidad de activos sin ampliar innecesariamente la muestra. M-002 añade una nota de control para distinguir corpus y metadatos; M-003 conserva la relación con el corpus mediante un archivo tar.gz de 587 bytes y verificación de extracción offline. Estos artefactos no contienen credenciales, cookies, tokens o wallets reales.

El contenido se diseñó para ser inequívocamente ficticio y carecer de utilidad fuera del experimento. En M-004 y M-005, el recurso de 398 bytes conserva SHA-256 2b54346a8c2d7f31b72cb72166547a9782976c95738b76ac688214532c26b363, lo que permite comparar origen y recepción sin convertir el contenido en dato sensible.

La selección de cuatro ficheros sintéticos permite representar clases de información diferenciadas sin aumentar innecesariamente el volumen. Cada fichero dispone de nombre, contenido, ruta y hash conocidos, lo que facilita comprobar entradas y salidas. La muestra no pretende reproducir la complejidad de perfiles reales de navegador o wallets; su función es ofrecer un conjunto controlado cuya manipulación pueda explicarse y verificarse.

10.4 Evidencias estáticas, dinámicas y de red

Tabla 46. Evidencias asociadas a M-001 y casos complementarios

Caso	Evidencia observada principal	Resultado y límite
M-001	Datos DEMO, procesos, EV-PCAP-003/004 e informe	Integración benigna observable; no malware real.
M-002	Cuatro ficheros DEMO, nota de control y EV-M002-004	Descubrimiento controlado PASS; no datos reales.
M-003	m003_corpus_demo.tar.gz, extracción offline y EV-M003-004	Staging local PASS; no exfiltración.
M-004	HTTP 200, recurso 398 bytes, EV-PCAP-005 y EV-M004-008	Comunicación interna PASS; PID runtime del servidor no documentado.
M-005	Control interno, ruta TEST-NET, EV-PCAP-006/007 y EV-M005-004 a EV-M005-010	Contención negativa PASS para la configuración probada; no aislamiento universal.

M-002 cerró PASS con EV-M002-004 (SHA-256 0dc9bb58e2abad9858c2d03cf7d2b25c59403f596b15113d16a44a1393c68d5a). M-003 cerró PASS con EV-M003-004 (SHA-256 2341909f1d0d8c7f403f6650a2e447acf90cf515c4904e8c20ef52e8f7e7c8e1); el archivo m003_corpus_demo.tar.gz conserva SHA-256 a0c366cb9e4422a6207eb7875d96b5d7e71a2f3e492d41a476f9c43b3ae54cd5 y su extracción offline fue validada.



Figura 6. Verificación offline del staging local de M-003 mediante tamaño, SHA-256 y contenido del archivo comprimido.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab verificadas el 8 de agosto de 2026.

Observación: la captura muestra un archivo tar.gz de 587 bytes, su huella SHA-256 y el listado del corpus DEMO. Interpretación: respalda la integridad y la agrupación local documentadas para M-003. Límite: la imagen no demuestra exfiltración ni tratamiento de datos reales; documenta exclusivamente una verificación offline del artefacto sintético.

M-004 cerró PASS: se observó HTTP 200 desde 10.10.10.20 hacia 10.10.10.30:8080, se recibieron 398 bytes con hash coincidente y EV-PCAP-005 registró 11 paquetes con 0 dropped. El cierre EV-M004-008 tiene SHA-256 ac0d9255e635f7bda0060dfcec5a924945d189281603dba388428157a78284c4. No se documentó el PID runtime del servidor; por ello, ese dato no se afirma y la existencia funcional del servicio se apoya en systemd y la respuesta observada.

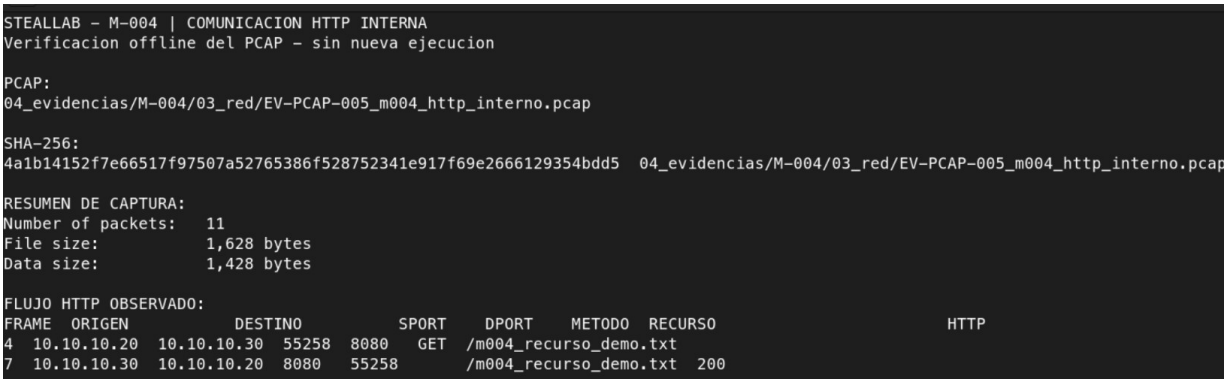


Figura 7. Verificación offline del PCAP de M-004 con comunicación HTTP interna entre 10.10.10.20 y 10.10.10.30:8080.

Fuente: elaboración propia a partir de EV-PCAP-005 y evidencias técnicas de StealLab verificadas el 8 de agosto de 2026.

Observación: el PCAP contiene 11 paquetes y conserva una petición GET desde 10.10.10.20 hacia 10.10.10.30:8080 y una respuesta HTTP 200. Interpretación: la evidencia apoya la comunicación interna benigna de M-004 y la observabilidad de PV-04. Límite: el PCAP acredita el flujo capturado, no una comunicación C2 ni una exfiltración real; el PID runtime específico del servidor durante M-004 permanece NO DOCUMENTADO.

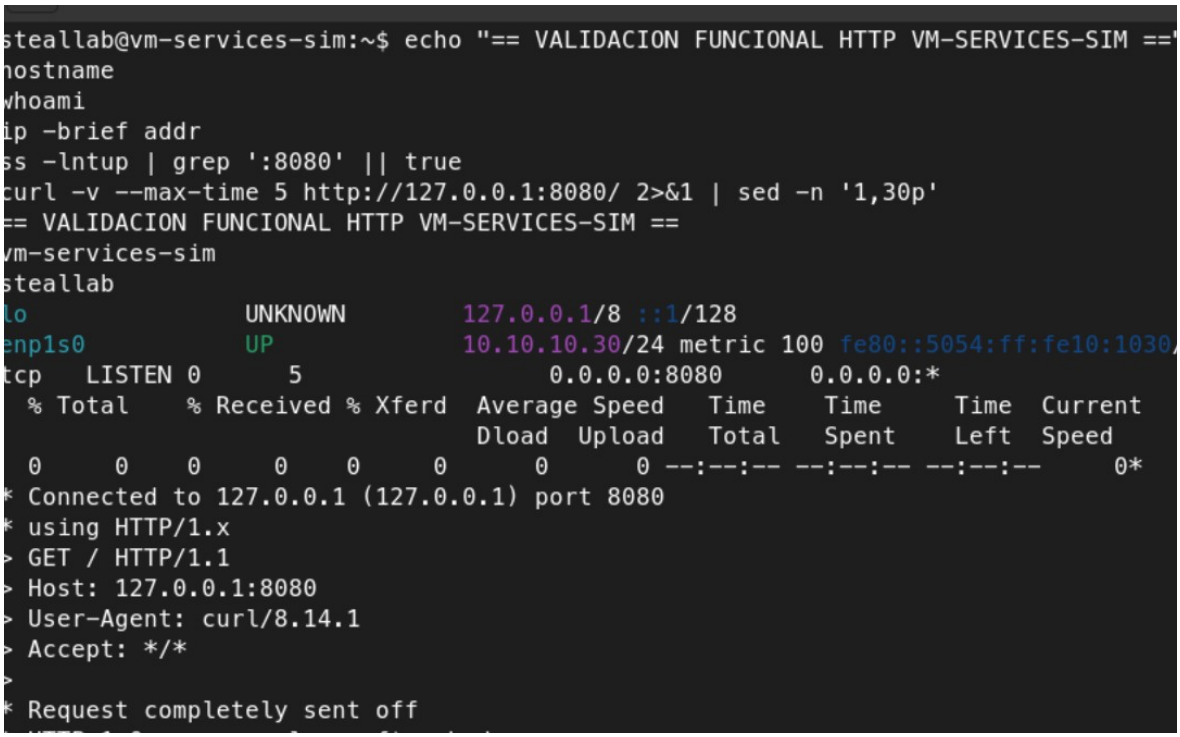


Figura 8. Validación funcional del receptor HTTP benigno en VM-SERVICES-SIM.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

M-005 cerró PASS al combinar evidencia positiva y negativa. El control interno produjo HTTP 200, 398 bytes y un PCAP de 10 paquetes. Para 192.0.2.1, ip route get devolvió Network is unreachable (RC 2), curl terminó con RC 7, HTTP 000 y 0 bytes, y EV-PCAP-007 no registró paquetes de datos. La conclusión se limita a esa configuración y destino; la ausencia de paquetes no se interpreta de forma aislada ni como prueba universal de aislamiento.

La trazabilidad de M-005 conserva una incidencia de control de calidad. EV-M005-005 registra un FAIL histórico causado por una variable no asignada en el script de decisión, no por un fallo empírico del escenario. EV-M005-006 documenta la corrección sobre las mismas evidencias, sin modificarlas, sin repetir el experimento y sin generar tráfico nuevo. El cierre formal EV-M005-010 queda registrado como PASS. La incidencia se mantiene para que la secuencia documental sea auditable y no se reescriba retrospectivamente.

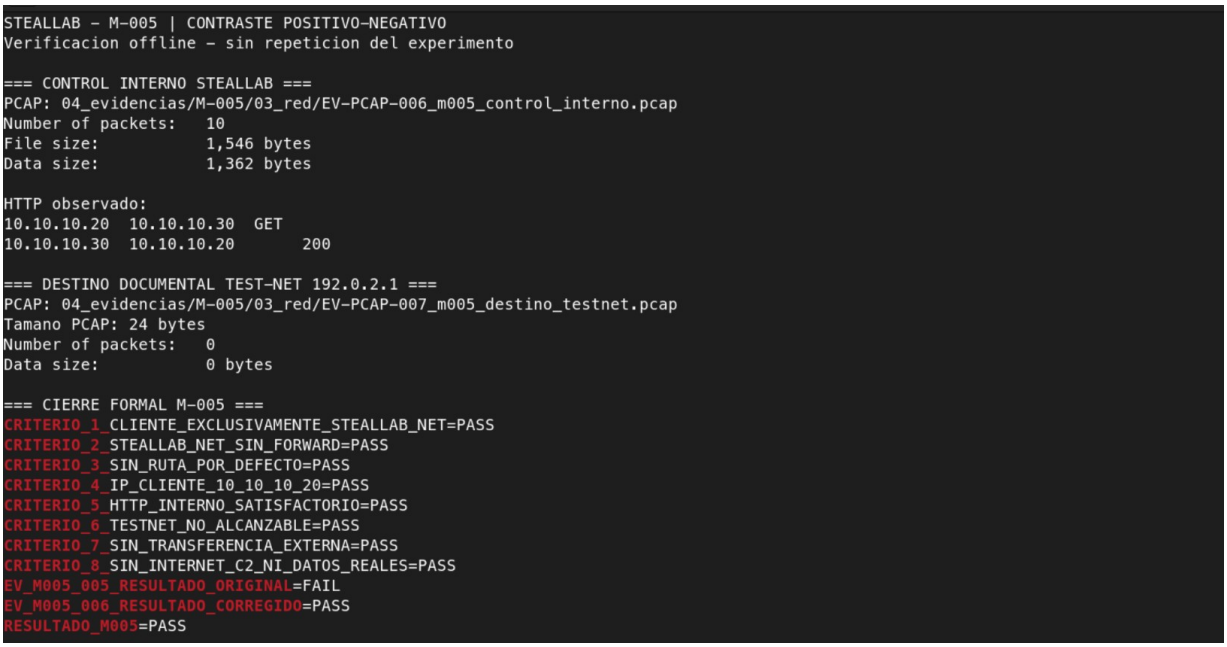


Figura 9. Verificación offline del contraste positivo-negativo y del cierre formal de M-005.

Fuente: elaboración propia a partir de EV-PCAP-006, EV-PCAP-007 y EV-M005-010, verificadas el 8 de agosto de 2026.

Observación: el control interno conserva 10 paquetes con GET y HTTP 200, mientras el PCAP del destino TEST-NET tiene 24 bytes de cabecera y 0 paquetes; el cierre registra ocho criterios PASS y preserva la secuencia EV-M005-005 FAIL, EV-M005-006 PASS y RESULTADO_M005=PASS. Interpretación: el conjunto aporta evidencia de contención para la configuración evaluada y de trazabilidad del control de calidad. Límite: cero paquetes no constituye por sí solo prueba universal de aislamiento y se interpreta junto con ausencia de ruta y fallo de conexión documentados durante el caso.

10.5 Interpretación defensiva

La interpretación conjunta debe ser prudente. M-001 a M-005 demuestran que StealLab puede observar y conservar distintos comportamientos benignos sobre datos sintéticos: integración, descubrimiento, staging local, comunicación interna y un contraste negativo de conectividad. No demuestran que el laboratorio detecte todas las familias de stealers ni que reproduzca evasión, persistencia, cifrado, extracción real o C2.

La interpretación se formula como analogía controlada. Los casos representan clases de señales que pueden ser relevantes para defensa, pero eliminan intención, secreto, persistencia, evasión y destino criminal. El valor adicional de M-002 a M-005 consiste en mostrar que el esquema evidencia-interpretación-limitación se mantiene ante varios ejemplos, no en aproximar el laboratorio a una operación ofensiva.

Cada evidencia responde a una pregunta concreta. Un hash valida identidad de contenido; un PCAP valida lo capturado; una respuesta HTTP valida disponibilidad funcional del servicio; y la ausencia de paquetes solo tiene sentido junto con enrutamiento y resultado de conexión. Esta granularidad evita que un único artefacto soporte conclusiones que exceden su alcance.

11 RESULTADOS

Los resultados se presentan por prueba de validación, con interpretación y limitaciones. Esta estructura evita que el apartado de resultados sea una acumulación de salidas técnicas y permite responder a los objetivos específicos del TFM.

11.1 Resultado PV-01: aislamiento

La red StealLab-Net aparece activa, persistente y con autostart en qemu:///system. El XML confirma bridge virbr-steal, IP 10.10.10.1 y reservas DHCP para VM-WIN-LAB, VM-LINUX-ANALYSIS y VM-SERVICES-SIM.

Limitación: Las VMs estaban apagadas durante la consulta domifaddr; por tanto, no se obtuvo IP runtime desde agente invitado en ese momento.

PV-01 se considera cumplida por convergencia de configuración y estado. M-005 añade un contraste empírico acotado: el tráfico interno hacia 10.10.10.30:8080 fue permitido, mientras 192.0.2.1 TEST-NET no tuvo ruta útil desde 10.10.10.20 y la conexión falló. La ausencia de paquetes hacia TEST-NET se interpreta como evidencia de apoyo junto con esos dos hechos, no como prueba universal de aislamiento.

El resultado no demuestra resistencia frente a escape de hipervisor, reconfiguración posterior, rutas alternativas o cualquier destino externo imaginable. Demuestra el aislamiento previsto y el comportamiento observado en las verificaciones documentadas, incluido el escenario concreto de M-005.

11.2 Resultado PV-02: restaurabilidad

qemu-img info documenta snapshots base en VM-SERVICES-SIM y VM-LINUX-ANALYSIS. Esto evidencia capacidad de retorno a estado base.

Limitación: La prueba no evalúa restauración repetida bajo múltiples escenarios, solo existencia del punto base.

PV-02 se apoya en imágenes qcow2 y en snapshots identificados. La captura del snapshot de VM-LINUX-ANALYSIS confirma nombre, dominio, estado, ubicación interna y metadatos. Esta información permite seleccionar un punto de retorno sin depender de memoria operativa.

La restaurabilidad validada es suficiente para repetir el caso benigno, pero no equivale a un plan de continuidad ni a una prueba de recuperación ante corrupción del host. El alcance se limita a los mecanismos del laboratorio.

El resultado demuestra disponibilidad de puntos de restauración documentados, no una garantía absoluta de recuperación ante cualquier fallo. La evidencia qcow2 confirma la existencia y consistencia declarada de snapshots, mientras que una validación futura más fuerte debería incluir restauraciones repetidas y comparación del estado posterior. Por ello,

PV-02 se interpreta como restaurabilidad técnica demostrada dentro del alcance disponible y con una oportunidad de refuerzo experimental.

11.3 Resultado PV-03: procesos

El repositorio contiene baseline y evidencias de ejecución de M-001, además de registros de actividad local asociados a M-002, M-003, M-004 y M-005 según la función de cada caso.

Limitación: No equivale a telemetría EDR avanzada ni detección automática.

PV-03 demuestra que el entorno permite observar actividad local relacionada con la preparación y ejecución del caso principal y de los casos complementarios. En M-002 y M-003 la observación se centra en descubrimiento y staging local; en M-004/M-005 se correlaciona con la comunicación interna y las comprobaciones de red.

La captura de procesos es puntual y puede omitir eventos breves. Por ello, el resultado acredita visibilidad básica y correlación documental, no cobertura equivalente a EDR, auditd o instrumentación de llamadas al sistema.

La observación de procesos aporta correlación temporal entre la ejecución controlada y la actividad del host. Su fuerza depende de conservar comando, usuario, PID, momento y contexto. No permite inferir intención maliciosa ni atribución de familia, pero sí confirma que el caso produjo actividad observable en la capa de host y que esa actividad puede vincularse con el procedimiento documentado.

11.4 Resultado PV-04: red

PV-04 dispone de varias capturas identificadas: EV-PCAP-003 para M-001, EV-PCAP-005 para M-004 y EV-PCAP-006/007 para M-005, todas tratadas como artefactos con integridad y contexto propios.

Limitación: El tráfico es HTTP interno benigno; no representa C2 real ni tráfico cifrado/evasivo.

PV-04 se considera cumplida porque existen PCAP íntegros y analizables para los flujos internos controlados. M-004 registra 11 paquetes y HTTP 200; M-005 registra 10 paquetes en el control interno y un PCAP TEST-NET sin paquetes de datos, cuyo significado se limita al contraste con ausencia de ruta y fallo de conexión.

El uso de HTTP claro mejora auditabilidad, pero no evalúa detección de TLS, DNS encubierto, proxies o canales alternativos. El resultado se restringe a la capacidad de capturar y explicar el flujo diseñado.

Los PCAP demuestran comunicaciones HTTP internas en M-001, M-004 y el control de M-005. No representan C2 real, cifrado, evasión o distribución. Su aportación es comprobar que la instrumentación conserva flujos explicables y que una observación negativa se interpreta con evidencias convergentes, no por ausencia aislada de tráfico.

11.5 Resultado PV-05: repositorio

El repositorio 04_evidencias conserva la estructura PV/EV del caso principal y los cierres documentados de M-002 a M-005. La comprobación final del 8 de agosto de 2026 contabilizó 171 ficheros: M-001=33, M-002=10, M-003=11, M-004=17, M-005=26 y PV=74. El manifiesto global generado sobre el repositorio contiene 171 entradas.

La verificación de cierre del 8 de agosto de 2026 documentó 171 ficheros en 04_evidencias y 171 entradas en el manifiesto global. Esta cifra se interpreta como medida de inventario, no como indicador automático de fortaleza probatoria; la validez de PV-05 depende de estructura, identificadores, hashes, manifiestos y contexto de adquisición.

PV-05 demuestra que las evidencias están agrupadas por caso, tipo y función, y que los artefactos críticos disponen de hashes o manifiestos. Los cierres de M-002 a M-005 refuerzan la trazabilidad sin necesidad de trasladar a la memoria un inventario exhaustivo de ficheros.

La calidad del repositorio no se deduce del número de ficheros, sino de su trazabilidad. Las plantillas EV/PV, manifiestos y nomenclatura reducen el riesgo de que una salida pierda contexto o sea atribuida a una ejecución distinta.

La existencia del árbol y del inventario se evalúa junto con su capacidad para enlazar pruebas, evidencias y resultados. Un repositorio ordenado no garantiza por sí mismo calidad científica; adquiere valor cuando evita duplicidades, permite localizar artefactos y conserva metadatos suficientes para revisar el procedimiento. El recuento verificado de evidencias debe entenderse como medida de inventario, no como indicador automático de fortaleza.

11.6 Resultado PV-06: informe técnico

Existe EV-INF-001 como informe técnico de M-001 y resultados finales en JSON/TXT.

Limitación: El informe describe un caso benigno, no una familia real.

PV-06 se cumple mediante la síntesis estructurada de M-001 y la incorporación académica de los casos complementarios: finalidad, procedimiento resumido, evidencia, resultado, interpretación y límite. Los informes y cierres no reproducen todas las salidas, sino que referencian los artefactos necesarios para contrastar la interpretación.

La capacidad de informar es un resultado independiente de la ejecución. Un caso técnicamente correcto pero no explicable sería débil como investigación; StealLab demuestra que la observación puede convertirse en comunicación auditada.

El informe técnico transforma datos operativos en una narración verificable. Su calidad depende de distinguir observación, interpretación, limitación y conclusión. El resultado de PV-06 se considera favorable porque el caso puede reconstruirse sin insertar en la memoria todas las salidas de consola, manteniendo los artefactos completos en el repositorio y presentando en el cuerpo únicamente la evidencia necesaria.

11.7 Resultado PV-07: LLM supervisado

El uso de LLM queda documentado mediante instrucción registrada, respuesta y revisión humana.

Limitación: El LLM no se considera fuente de verdad ni sistema de decisión autónoma.

PV-07 se considera cumplida en el plano documental: el LLM apoyó organización, revisión de coherencia y ampliación bibliográfica bajo comprobación humana. No intervino en la producción de hashes, el control de libvirt ni la decisión final sobre PV.

El resultado demuestra un uso gobernado, no una medida de precisión del modelo. Las posibles alucinaciones se mitigan mediante contraste con fuentes primarias y evidencia propia, y las afirmaciones no verificables se eliminan o se presentan como propuestas futuras.

La validación de PV-07 no mide precisión autónoma ni certifica capacidad forense del modelo. Comprueba que su intervención queda acotada a resumen, reorganización y apoyo de redacción, con revisión humana y contraste contra evidencias. Una salida no confirmada no se incorpora como resultado. Este uso es coherente con una gestión de riesgos basada en supervisión, trazabilidad y límites de propósito (National Institute of Standards and Technology, 2023, 2024).

11.8 Síntesis de resultados frente a objetivos

La síntesis muestra correspondencia entre objetivos y resultados dentro del alcance. OE1 se sustenta en la revisión y el marco conceptual; OE2 en arquitectura y aislamiento; OE3 en instrumentos y repositorio; OE4 en la implementación de M-001 y los casos complementarios; OE5 en PV-01 a PV-07 y su lectura transversal; y OE6 en la memoria y los apéndices.

El cumplimiento no elimina las limitaciones. La principal aportación es demostrar que la combinación funciona como método seguro y trazable; no demostrar eficacia frente a una población de muestras reales.

La síntesis muestra una cobertura desigual pero suficiente: los objetivos de diseño, aislamiento, observabilidad y trazabilidad cuentan con evidencias directas; la reproducibilidad dispone de soporte estructural y de integridad, aunque se beneficiaría de ejecuciones repetidas; y el componente LLM se valida como proceso supervisado, no como detector. Esta lectura evita reducir el cumplimiento a una suma de marcas positivas.

11.9 Lectura analítica transversal de PV-01 a PV-07

La lectura transversal de resultados muestra que las PV no son pruebas independientes sin conexión, sino capas de una misma validación. PV-01 proporciona contención; PV-02 proporciona reversibilidad; PV-03 y PV-04 proporcionan observabilidad; PV-05 organiza evidencias; PV-06 comunica resultados; PV-07 añade apoyo documental supervisado. En conjunto, estas pruebas responden a la pregunta de investigación mejor que una única ejecución técnica.

Tabla 47. Matriz de trazabilidad caso-PV-EV

Caso	PV relacionadas	Evidencias principales	Lectura defendible
M-001	PV-01 a PV-06; apoyo PV-07	EV-M001, EV-PROC, EV-PCAP-003/004, EV-INF-001	Integración benigna extremo a extremo.
M-002	PV-03, PV-05	Corpus DEMO y EV-M002-004	Descubrimiento controlado de artefactos sintéticos.
M-003	PV-03, PV-05	m003_corpus_demo.tar.gz y EV-M003-004	Agrupación/staging local e integridad.
M-004	PV-03, PV-04, PV-05	EV-PCAP-005, EV-M004-008, manifest M-004	HTTP interno observable y recurso íntegro.
M-005	PV-01, PV-03, PV-04, PV-05	EV-PCAP-006/007; EV-M005-004 a EV-M005-010; manifest	Control interno permitido y TEST-NET no alcanzable en la configuración probada.

La dependencia entre pruebas puede expresarse como cadena: los casos no sustituyen las PV, sino que aportan nuevas observaciones a sus criterios. M-002 y M-003 refuerzan host/repositorio; M-004 añade comunicación interna; M-005 combina aislamiento, host, red y repositorio. PV-02, PV-06 y PV-07 mantienen sus funciones originales y no requieren nuevos identificadores de prueba.

Esta lectura permite identificar puntos únicos de fallo metodológico y preservar incidencias. El FAIL histórico de EV-M005-005 no invalida el caso porque se atribuye al script de decisión y queda seguido por EV-M005-006, que corrige la evaluación sobre las mismas evidencias sin nueva ejecución. La secuencia refuerza confirmabilidad al no borrar el error documental.

11.10 Resultados que no deben sobreinterpretarse

Los resultados no prueban que StealLab detecte cualquier stealer real ni que M-001 a M-005 representen familias específicas como RedLine, Lumma o Raccoon. Tampoco prueban evasión, persistencia, exfiltración real o interacción con defensas avanzadas. Lo que sí

muestran es que el entorno puede capturar y organizar evidencias de varios comportamientos benignos controlados.

En particular, no puede afirmarse que StealLab detecte malware desconocido, que los hashes prueben autenticidad histórica o que una captura HTTP represente exfiltración criminal. En M-005, cero paquetes hacia TEST-NET no equivalen por sí solos a aislamiento universal; la conclusión depende también de la ausencia de ruta y del fallo de conexión.

11.11 Evidencias fuertes y evidencias de apoyo

Las evidencias fuertes son aquellas que sostienen directamente una conclusión: XML y estado de red libvirt para aislamiento; qemu-img y snapshots para restaurabilidad; hashes para integridad; PCAP para observabilidad de red; y manifiestos/identificadores de cierre para trazabilidad de casos. Las evidencias de apoyo contextualizan el proceso, como bitácoras, checklist y control de cambios.

Tabla 48. Clasificación de evidencias por fuerza probatoria interna

Tipo	Evidencia	Función
Fuerte	Estado qemu:///system de StealLab-Net	Confirma red activa y persistente
Fuerte	Hashes SHA-256 de datos, archivos y PCAP	Confirma integridad de artefactos concretos
Fuerte	qemu-img info con snapshots	Confirma restaurabilidad documentada
Fuerte	PCAP M-001/M-004/M-005 y cierres de caso	Confirma observabilidad y trazabilidad dentro del escenario
Apoyo	bitacora_laboratorio.md	Contexto cronológico
Apoyo	checklist_etico_seguridad.md	Control ético
Apoyo	matriz_llm.md	Control de PV-07

Se consideran fuertes las evidencias vinculadas directamente con una propiedad y obtenidas mediante un procedimiento reproducible, como XML de red, información qcow2, PCAP y hashes. Las capturas de pantalla facilitan la revisión y aportan contexto, pero pueden depender de encuadre, momento y selección. La combinación es útil siempre que la evidencia de apoyo no sustituya al artefacto original.

11.12 Resultado metodológico principal

El resultado metodológico principal es la conversión de un ejercicio técnico en un artefacto de investigación aplicada. La validación no se basa en afirmar que se ejecutó un script, sino en demostrar que cada decisión técnica tiene un propósito, produce una evidencia y se interpreta dentro de un límite. Esta transformación refuerza la profundidad metodológica del trabajo.

Tabla 49. Síntesis de cumplimiento de objetivos

Objetivo	Resultado obtenido	Grado de cumplimiento
OE1	Marco teórico ampliado sobre malware, stealers, MaaS, activos afectados y casos reales.	Cumplido con referencias y discusión crítica.
OE2	Arquitectura StealLab documentada y verificada parcialmente en runtime.	Cumplido para Linux/SERVICES; VM-WIN-LAB queda futura.
OE3	Repositorio PV/EV con casos M-001 a M-005, hashes y manifiestos críticos.	Cumplido; inventario final verificado de 171 ficheros y manifiesto global de 171 entradas.
OE4	PV-01 a PV-07 cerradas y reforzadas por casos complementarios.	Cumplido con limitaciones declaradas.
OE5	Discusión y amenazas a la validez explicitadas.	Cumplido.

Objetivo	Resultado obtenido	Grado de cumplimiento
OE6	Trabajos futuros definidos sin presentar M-002 a M-005 como pendientes.	Cumplido.

El resultado principal no es la transferencia HTTP ni el número de capturas, sino un patrón de investigación reproducible: delimitar, controlar, observar, preservar, interpretar y limitar. Este patrón puede transferirse a otros laboratorios defensivos aunque cambien sistema operativo, protocolo o familia estudiada.

La aportación documental se refuerza mediante una organización coherente: 61 tablas numeradas secuencialmente, índices consistentes, distinción temporal de estados y selección justificada de capturas. La coherencia formal forma parte de la validez documental.

11.13 Modelo ampliado de lectura PV/EV

El modelo PV/EV es el mecanismo que transforma una práctica técnica en un proceso de validación investigadora. PV identifica la prueba de validación y EV identifica la evidencia. La prueba responde a una pregunta de control; la evidencia aporta soporte; la interpretación conecta esa evidencia con el objetivo; y el límite impide generalizaciones indebidas.

Cada PV debe leerse como un contrato de validación. PV-01 pregunta si el laboratorio está aislado; PV-02 si puede restaurarse; PV-03 si se observan procesos; PV-04 si se captura tráfico; PV-05 si existe repositorio; PV-06 si se genera informe técnico; PV-07 si el LLM se usa de forma supervisada. Este esquema permite seguir la cadena lógica sin revisar todas las salidas brutas.

Tabla 50. Lectura ampliada de PV/EV

PV	Pregunta de validación	Evidencia principal	Resultado defendible	Límite
PV-01	¿Existe red aislada controlada?	virsh qemu:///system, XML y M-005	Red activa/segmentada; TEST-NET no alcanzable en M-005	No prueba todas las rutas/fugas posibles
PV-02	¿Existe restaurabilidad?	qemu-img info, snapshots	Snapshots base en discos qcow2	No sustituye backup externo
PV-03	¿Se capturan procesos/eventos?	EV-PROC y EV de casos	Observabilidad host en casos benignos	No equivale a EDR
PV-04	¿Se captura tráfico?	EV-PCAP-003/005/006/007	Observabilidad de red y contraste controlado	No C2 real ni Internet
PV-05	¿Existe repositorio trazable?	Árbol, hashes, cierres y manifiestos	Estructura documental verificable	El total de 171 es inventario de cierre; no sustituye la valoración probatoria individual.
PV-06	¿Se produce informe técnico?	EV-INF-001 y síntesis de casos	Comunicación técnica estructurada	No informe pericial oficial
PV-07	¿El LLM se usa con supervisión?	Instrucción registrada, respuesta y revisión humana	Apoyo documental controlado	No fuente de verdad

11.14 Lectura segura de M-001 y casos complementarios

M-001 se construye como una anatomía segura de integración tipo stealer, mientras M-002 a M-005 descomponen operaciones específicas para observarlas con mayor claridad. Ningún caso contiene credenciales, cookies, tokens o wallets reales, malware, persistencia, evasión, C2 o Internet reales.

El conjunto permite demostrar una secuencia de análisis defensivo: definir el observable, usar artefactos sintéticos, ejecutar una acción controlada, preservar la evidencia y limitar la

conclusión. La variación entre casos aporta contraste metodológico sin cambiar la frontera ética del laboratorio.

Tabla 51. Descomposición segura de M-001 a M-005

Caso/fase	Objeto	Evidencia	Interpretación
M-001	Integración extremo a extremo	EV-M001, EV-PROC, EV-PCAP, informe	Observabilidad y trazabilidad de la cadena benigna
M-002	Descubrimiento de corpus sintético	EV-M002-004	Enumeración controlada; no extracción real
M-003	Agrupación/staging local	Tar.gz, hash y EV-M003-004	Integridad y tratamiento local; no exfiltración
M-004	HTTP interno benigno	EV-PCAP-005 y EV-M004-008	Comunicación interna observable
M-005	Contraste positivo-negativo	EV-PCAP-006/007 y EV-M005-004 a EV-M005-010	Contención observada en el escenario; no universal

11.15 Análisis detallado de resultados por categoría

La lectura por categorías se mantiene, pero los casos permiten una comparación adicional. Infraestructura y gobierno ético permanecen constantes; lo que cambia entre M-001 y M-005 es el observable principal y el tipo de evidencia que refuerza PV existentes. Esta comparación hace visible qué aporta cada ejemplo sin confundirlos con nuevas pruebas metodológicas.

En conjunto, M-001 aporta integración, M-002 descubrimiento controlado, M-003 staging local, M-004 comunicación HTTP interna y M-005 un contraste de contención. Los cinco casos mantienen datos sintéticos y ausencia de malware/C2/Internet reales. La cobertura crece en variedad de observables, pero sigue limitada a un laboratorio local y a escenarios benignos diseñados por el autor.

Tabla 52. Comparación sintética de M-001 a M-005

Caso	Observable principal	Resultado	Limitación/alcance
M-001	Integración de datos, proceso y HTTP interno	PASS; cadena benigna trazable	No representa una familia real
M-002	Descubrimiento de artefactos sintéticos	PASS; corpus DEMO enumerado	No accede a datos reales ni perfiles protegidos
M-003	Agrupación/compresión y staging local	PASS; tar.gz íntegro y extracción offline	No exfiltración ni empaquetado malicioso
M-004	Comunicación HTTP interna	PASS; HTTP 200, 398 bytes y PCAP de 11 paquetes	PID runtime del servidor no documentado
M-005	Control interno frente a destino TEST-NET	PASS; interno funciona, TEST-NET sin ruta/conexión	Valida una configuración y un destino, no aislamiento universal

11.16 Interpretación de hashes como evidencia de integridad

Los hashes SHA-256 aportados para los ficheros DEMO, el archivo de M-003, los recursos y PCAP de M-004/M-005 y los cierres documentados permiten verificar que el contenido referenciado no ha cambiado respecto a cada evidencia identificada. En la memoria se presentan como identificadores de integridad, no como prueba de autoría, intención o momento por sí solos.

El valor probatorio de un hash depende del contexto. Un hash aislado solo identifica un contenido. Un hash asociado a ruta, fecha, caso, PV/EV y descripción se convierte en evidencia interpretable. Por ello, StealLab no se limita a generar hashes: los integra en fichas, matrices y resultados.

Los hashes se recalculan sobre contenido concreto y se registran junto a ruta y función. La captura incorporada permite comprobar los valores principales de M-001 y relacionarlos con los ficheros del repositorio. Si un fichero cambia, el hash obliga a documentar una nueva versión en vez de mantener una referencia ambigua.

SHA-256 reduce el riesgo de sustitución accidental, pero no prueba autenticidad de origen ni momento de adquisición por sí solo. Es una pieza de la trazabilidad y debe interpretarse con las fichas, el manifiesto y la bitácora.

Como control de cierre, se recalcularon 18 artefactos críticos de M-002 a M-005 mediante sha256sum -c y los 18 coincidieron con los valores esperados. Esta comprobación incluye cierres de caso, el tar.gz de M-003, el recurso de M-004, los PCAP de M-004/M-005 y los manifiestos de ambos casos. El resultado 18/18 OK refuerza la consistencia entre memoria y repositorio sin sustituir el contexto probatorio de cada evidencia.

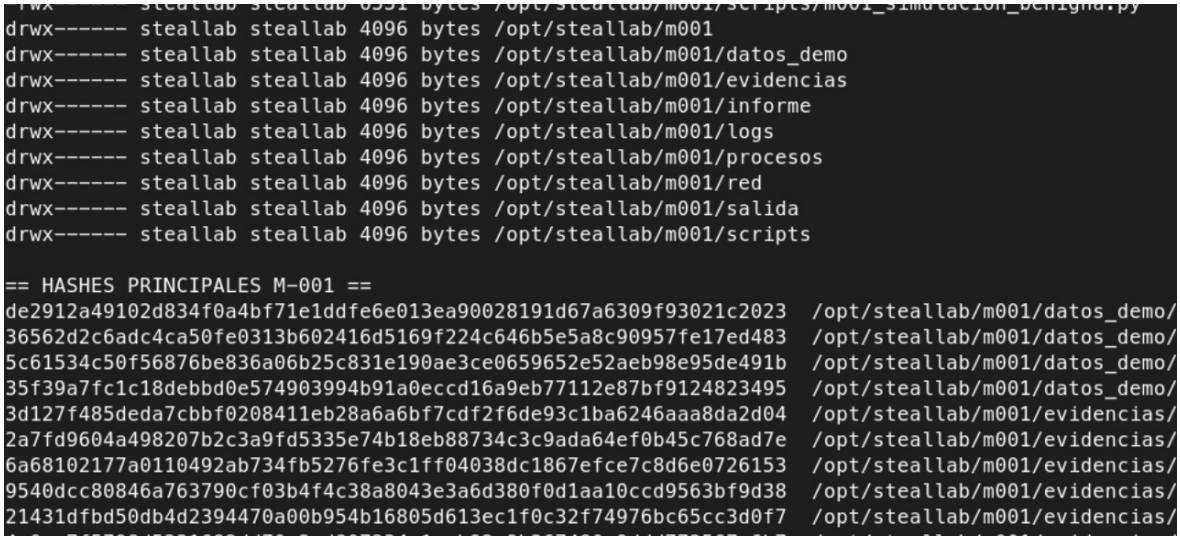


Figura 10. Inventario y hashes SHA-256 principales del caso M-001.

Fuente: elaboración propia a partir de evidencias técnicas de StealLab capturadas el 5 de julio de 2026.

12 DISCUSIÓN

Los resultados muestran que StealLab cumple su finalidad como laboratorio académico defensivo. La evidencia más sólida se encuentra en aislamiento y enrutamiento, snapshots, hashes, PCAP internos, cierres de caso y trazabilidad PV/EV. M-002 a M-005 amplían la variedad de observables sin alterar el principio de simulación benigna.

La decisión de no usar malware real reduce la generalización, pero aumenta seguridad, ética y control experimental. Los cinco casos deben leerse como validación del laboratorio y del método, no como sustitutos de muestras maliciosas. La ampliación de ejemplos mejora triangulación interna, no equivalencia con operaciones reales.

Comparado con casos reales como Snowflake/UNC5537, StealLab aborda una escala mucho más reducida, pero estudia la misma lógica defensiva de fondo: la importancia de credenciales, sesiones, tokens y datos reutilizables. Comparado con el caso Lumma, StealLab no reproduce infraestructura criminal ni evasión, pero sí justifica por qué los infostealers merecen laboratorios especializados.

12.1 Comparación con literatura y casos reales

Los casos reales demuestran que las credenciales robadas por infostealers pueden tener vida útil prolongada y consecuencias organizativas graves. Mandiant documentó que UNC5537 utilizó credenciales de clientes previamente expuestas por infostealers para acceder a instancias Snowflake, y que muchas cuentas carecían de MFA. Este tipo de incidente valida la relevancia del objeto de estudio de StealLab, aunque el laboratorio solo represente comportamientos de forma sintética.

La literatura y los casos reales coinciden en que el valor de un infostealer depende de la reutilización posterior de credenciales, sesiones y perfiles. StealLab representa únicamente observables seguros: descubrimiento de artefactos sintéticos, tratamiento local y comunicaciones internas controladas. La comparación es estructural y defensiva, no operacional.

Estas fuentes justifican la selección de activos, pero no amplían automáticamente lo demostrado por los casos experimentales (Google Cloud, 2024; Nurmi et al., 2023; Europol, 2026).

La comparación con literatura debe buscar convergencias y diferencias, no equivalencias. StealLab coincide con estudios previos en la importancia de aislamiento, observabilidad y preservación, pero se diferencia por su uso de simulación benigna y por el alcance académico. Los casos reales aportan plausibilidad externa a las categorías seleccionadas, mientras la evidencia propia demuestra únicamente propiedades del laboratorio. Mantener ambos niveles separados permite discutir relevancia sin convertir el contexto documental en resultado experimental.

12.2 Valor de la simulación benigna

La simulación benigna permite trabajar con categorías de información sin exponer datos reales. En docencia e investigación aplicada, esto ofrece una vía intermedia entre teoría pura y ejecución de malware real. El valor se encuentra en el diseño experimental, la trazabilidad y la discusión crítica, no en la peligrosidad del artefacto.

La simulación benigna maximiza control y seguridad a costa de realismo. Esta compensación es adecuada cuando la pregunta evalúa infraestructura, procedimiento y evidencia. Permite repetir la prueba, conocer la entrada y revisar el resultado sin depender del comportamiento variable de una muestra.

Su valor educativo es especialmente alto: el estudiante puede practicar correlación de endpoint y red, preservación y redacción técnica antes de trabajar en entornos de mayor riesgo. La simulación debe presentarse como etapa formativa y no como sustituto permanente de toda investigación de malware.

El principal valor de la simulación benigna es metodológico: permite probar el sistema de observación y documentación sin introducir una capacidad peligrosa. Su utilidad aumenta cuando el objetivo consiste en validar infraestructura, procedimientos y criterios, y disminuye cuando se pretende medir comportamiento adaptativo o eficacia de detección frente a muestras reales. Por ello, debe evaluarse por adecuación a la pregunta, no por similitud absoluta con una campaña. Esta perspectiva convierte la reducción de riesgo en una propiedad del diseño y no en una justificación posterior.

12.3 Riesgos de sobreinterpretación

El principal riesgo sería afirmar que M-001 a M-005 equivalen a stealers reales o que StealLab está validado contra todas las familias. La memoria evita esa sobreinterpretación. Los resultados se limitan a capacidades de observación, contención y documentación en los escenarios controlados ejecutados.

El mayor riesgo es transformar similitud superficial en equivalencia. Leer cuatro ficheros no demuestra acceso a almacenes de navegador; una solicitud HTTP no demuestra C2; y un proceso Python no representa técnicas de evasión. La memoria combate este riesgo mediante lenguaje limitado y columnas explícitas de interpretación.

Otro riesgo es confundir ausencia de señal con ausencia de capacidad. M-005 ilustra esta precaución: un PCAP sin paquetes hacia TEST-NET solo apoya la conclusión cuando se combina con Network is unreachable y con el fallo de curl. Ninguna ausencia aislada se utiliza para afirmar cobertura o aislamiento universal.

12.4 Papel del LLM en el proceso documental

El LLM aporta velocidad para organizar material, detectar repeticiones y proponer relaciones bibliográficas, pero también introduce riesgo de referencias inexistentes, simplificación excesiva y lenguaje persuasivo no sustentado. La revisión de esta memoria identificó y corrigió referencias incorrectas, lo que demuestra la necesidad de verificación externa.

La supervisión se estructura mediante tres controles: fuente primaria para hechos actuales, evidencia propia para resultados y revisión humana para inferencias. El modelo no recibe autoridad para completar huecos técnicos ni para convertir una hipótesis en resultado.

En el plano documental, el LLM puede ayudar a detectar incoherencias terminológicas, resumir evidencia ya interpretada y proponer estructuras de exposición. No debe completar datos ausentes, decidir si una prueba se supera ni sustituir la lectura de fuentes. Esta delimitación convierte el modelo en una herramienta de asistencia comparable a otros apoyos de edición, pero sometida a controles adicionales por su capacidad para generar formulaciones plausibles no respaldadas.

12.5 Discusión crítica sobre el realismo del laboratorio

El realismo de StealLab no procede de usar malware real, sino de reproducir condiciones analíticas relevantes: separación de roles, red aislada, artefactos de datos, captura de red, observabilidad de procesos, hashes y repositorio. En investigación aplicada, un modelo no necesita reproducir todos los rasgos de la realidad para ser útil; necesita representar los elementos relevantes para la pregunta planteada.

El laboratorio sacrifica realismo ofensivo para ganar control experimental. Esta decisión es coherente con el contexto universitario y con el objetivo de producir conocimiento defendible. Un laboratorio que ejecutara malware real sin controles suficientes podría parecer más realista, pero sería menos ético y posiblemente menos reproducible.

El realismo de StealLab es funcional, no adversarial. La arquitectura reproduce separación de roles, estados, red y evidencia, pero no reproduce distribución, ofuscación, persistencia, anti-análisis ni infraestructura remota. Esta elección aumenta validez interna para la pregunta planteada y reduce validez externa frente a amenazas reales.

Un laboratorio más realista no sería automáticamente más científico. La literatura sobre sandboxes muestra que configuración, estímulos y visibilidad modifican los resultados; por ello, aumentar complejidad sin documentar controles puede reducir reproducibilidad (Alrawi et al., 2024).

El realismo de un laboratorio es multidimensional. Puede existir realismo arquitectónico, procedimental, de telemetría o de amenaza, y no todos alcanzan el mismo nivel. StealLab prioriza arquitectura, control y trazabilidad, mientras reduce deliberadamente realismo ofensivo. Declarar esta distribución permite evaluar el artefacto con criterios adecuados. Un entorno más peligroso no sería necesariamente más válido si introduce variables no controladas, dificulta la repetición o supera la capacidad de contención disponible.

12.6 Comparación con sandboxes automáticos

Un sandbox automático ofrece análisis rápido y normalmente más completo de muestras reales, pero puede funcionar como caja negra: el analista recibe un informe sin comprender todos los supuestos, configuraciones o límites. StealLab, en cambio, prioriza transparencia. Cada elemento del entorno puede explicarse: red, VMs, rutas, evidencias, hashes y restricciones.

Esta diferencia no implica que StealLab sea superior a un sandbox profesional. Su valor es docente e investigador: permite comprender por qué se observa una evidencia, cómo se conserva y qué conclusión permite o no permite sostener.

Los sandboxes automáticos ofrecen escalabilidad, instrumentación y clasificación, mientras StealLab prioriza transparencia pedagógica y control manual. No compite en volumen ni cobertura; permite comprender cada capa y conservar evidencia de una prueba definida.

La comparación también revela complementariedad. Un trabajo futuro podría enviar artefactos benignos equivalentes a un sandbox y comparar telemetría, pero debería controlar versiones, estímulos y red. Las guías recientes advierten que no existe una configuración universal y que el contexto del caso determina qué señales se observan (Alrawi et al., 2024).

12.7 Implicaciones defensivas

La principal implicación defensiva es que la observabilidad debe diseñarse antes del incidente. Si no existe captura de red, baseline, repositorio o criterios de evidencia, el análisis posterior será parcial. StealLab muestra que incluso un caso benigno puede generar una cadena documental útil si el entorno está preparado.

La primera implicación es que la respuesta debe orientarse al activo: contraseñas, cookies, tokens y wallets requieren medidas distintas. La segunda es que endpoint y red deben correlacionarse. La tercera es que la integridad de evidencia condiciona la capacidad para investigar y comunicar.

En un entorno corporativo, estas implicaciones se traducirían en revocación de sesiones, rotación de secretos, revisión de actividad SaaS y reconstrucción del endpoint, además de

detección del binario. StealLab no ejecuta esas acciones, pero prepara el marco conceptual para decidirlas.

12.8 Implicaciones académicas

Académicamente, el trabajo aporta una estructura replicable para TFM técnicos de ciberseguridad: problema, marco teórico, diseño controlado, muestra técnica, pruebas, evidencias, discusión y limitaciones. La memoria evita presentar el laboratorio como una colección de comandos y lo convierte en un objeto de estudio con criterios de validación.

El TFM demuestra que un artefacto defensivo puede evaluarse sin convertir la memoria en manual operativo. La estructura pregunta-objetivo-categoría-PV-EV-conclusión ofrece un patrón reusable para proyectos técnicos.

También muestra que la ética puede formar parte del método y no limitarse a una declaración final. Datos sintéticos, red aislada y exclusiones determinan qué se hace, qué se observa y qué se concluye.

El proyecto muestra que un TFM técnico puede conservar profundidad investigadora cuando explicita problema, categorías, criterios de aceptación, evidencias y límites. La aportación pedagógica no reside solo en aprender herramientas, sino en practicar formulación de hipótesis de trabajo, documentación de resultados negativos y argumentación condicionada. El modelo puede adaptarse a otras prácticas defensivas siempre que se redefinan los riesgos y las categorías de validación.

12.9 Discusión sobre datos sintéticos

El uso de datos sintéticos puede verse como limitación o como fortaleza. Es limitación porque no reproduce complejidades de datos reales. Es fortaleza porque evita exposición de terceros, permite publicar hashes y facilita reproducibilidad. En este TFM pesa más la segunda dimensión, porque el objetivo es validar el laboratorio y no comprometer secretos reales.

Los datos sintéticos aportan control, consentimiento implícito y facilidad de publicación. Permiten saber exactamente qué información debería aparecer en una salida y detectar desviaciones. Su diseño, sin embargo, debe evitar ser tan trivial que elimine toda semejanza estructural con el activo representado.

La siguiente evolución debería incorporar conjuntos sintéticos versionados con formatos más cercanos a perfiles reales, pero sin secretos ni identificadores. Esto permitiría evaluar parsers y controles de acceso manteniendo la misma política ética.

Los datos sintéticos permiten representar estructura y flujo sin reproducir sensibilidad. Su calidad depende de que conserven propiedades relevantes para la prueba -tipo, formato, ruta o relación entre artefactos- y de que no incorporen accidentalmente valores reales. También deben identificarse de forma inequívoca para evitar confusión posterior. En StealLab, su función no es aproximar estadísticamente datos de usuarios, sino actuar como marcadores controlados que permiten observar tratamiento, transferencia y conservación de evidencia.

12.10 Discusión sobre generalización

La generalización de resultados debe ser cautelosa. StealLab permite afirmar que se han validado cinco casos benignos complementarios en Linux y una red interna controlada. No permite afirmar que el laboratorio esté validado frente a familias Windows reales, técnicas de evasión, C2 cifrado, Internet real o malware polimórfico. La transferencia se limita al método y a las categorías observables.

El LLM se utiliza como apoyo documental para resumir, estructurar y revisar información técnica, siempre bajo supervisión humana. No se utiliza como fuente primaria, no valida

evidencias por sí mismo y no toma decisiones de seguridad. Esta restricción es coherente con la necesidad de evitar alucinaciones, errores de clasificación o generación de afirmaciones no verificadas.

La generalización es analítica y no estadística. Los resultados apoyan que el método puede trasladarse a otros casos con ajustes; no permiten estimar tasas de detección ni afirmar cobertura de familias. La transferibilidad depende de conservar arquitectura, protocolo y criterios suficientemente descritos.

Cambios de hipervisor, distribución o herramientas podrían producir salidas distintas sin invalidar el principio. Lo esencial es mantener equivalencia funcional y documentar divergencias.

La generalización posible es analítica y no estadística. Los resultados pueden informar el diseño de otros laboratorios que compartan objetivos y restricciones, pero no permiten estimar comportamiento de todas las familias ni eficacia en producción. La transferibilidad depende de que el lector conozca arquitectura, alcance, instrumentos y límites. Este tipo de generalización es coherente con el estudio de caso: se transfieren principios de diseño y trazabilidad, no porcentajes de detección ni conclusiones poblacionales (Yin, 2018).

12.11 Discusión sobre familias reales frente a simulación benigna

La comparación entre familias reales y los casos benignos debe hacerse con prudencia. Familias como Lumma, RedLine, Raccoon o Vidar pueden incluir mecanismos de evasión, empaquetado, persistencia, comunicaciones cifradas, módulos variables y técnicas dependientes del sistema operativo. M-001 a M-005 no reproducen esas capacidades. Su función es validar que el laboratorio puede registrar señales básicas y conservar evidencia bajo condiciones seguras.

Esta diferencia no debilita el TFM si se formula correctamente. En investigación aplicada, un modelo controlado puede ser útil cuando permite aislar dimensiones del fenómeno. Del mismo modo que un laboratorio de redes puede simular tráfico sin reproducir Internet completo, StealLab simula señales defensivas sin introducir malware real. La clave es no confundir validez metodológica con equivalencia funcional.

La comparación debe hacerse en el nivel de conceptos y observables, no en el de equivalencia funcional. Las familias reales pueden incorporar cifrado, evasión, persistencia, múltiples canales y lógica variable que M-001 excluye deliberadamente. Sin embargo, la simulación permite estudiar cómo preparar una observación, conservar un PCAP, calcular hashes y separar evidencia de inferencia. Su valor es preparatorio y metodológico.

12.12 Discusión sobre la aportación frente a un catálogo de herramientas

Un riesgo habitual en trabajos técnicos es convertir la memoria en un catálogo de herramientas. StealLab evita ese riesgo mediante tres decisiones. Primera: las herramientas se subordinan a categorías de análisis. Segunda: las evidencias se interpretan mediante PV/EV. Tercera: las conclusiones se formulan por objetivos y no por comandos ejecutados. Así, Wireshark, tcpdump, qemu-img o virsh no son el centro del TFM; son instrumentos al servicio de una pregunta investigadora.

El valor diferencial no reside en instalar KVM, sino en justificar por qué una red sin forward/NAT, snapshots, datos sintéticos, PCAP y una matriz de evidencias forman un laboratorio defendible. La profundidad del trabajo procede de la relación explícita entre decisiones técnicas, pruebas, evidencias, interpretación y límites.

El TFM no evalúa herramientas por cantidad de funciones ni propone una selección universal. Cada instrumento se justifica por su relación con una categoría y una evidencia. Esta orientación reduce el riesgo de obsolescencia y facilita sustituir una herramienta sin alterar el método: si otro capturador produce un PCAP verificable bajo el mismo procedimiento, la lógica investigadora puede mantenerse.

12.13 Riesgos, controles y límites del LLM supervisado

El uso de LLM en StealLab se limita a apoyo documental supervisado. Esta delimitación es importante porque un LLM puede resumir, estructurar o ayudar a redactar, pero no verifica por sí mismo una evidencia técnica. La autoridad epistemológica reside en las evidencias, en los comandos ejecutados, en los ficheros preservados y en la revisión humana.

El valor del LLM en este TFM es organizativo: ayuda a transformar evidencias dispersas en informes y matrices. Su riesgo es la alucinación o sobreinterpretación. Por eso PV-07 no valida que el LLM detecte malware; valida que su respuesta fue revisada por una persona y que no sustituye el análisis técnico. Esta distinción debe permanecer visible en toda la memoria.

La investigación sobre transformers y LLM en malware muestra potencial para resumir reportes, extraer indicadores y relacionar artefactos, pero el área permanece sujeta a calidad de datos, explicabilidad y seguridad de uso (Kunwar et al., 2024). Trabajos recientes sobre capturas asociadas a infostealers ilustran utilidad para clasificación reactiva, no autoridad autónoma de decisión (Ruellan et al., 2025).

StealLab adopta una posición conservadora: el LLM puede ayudar a preguntar mejor y documentar mejor, pero no sustituye el análisis binario, la ejecución controlada ni la validación de fuentes.

Los riesgos principales son alucinación, pérdida de procedencia, exceso de confianza y filtración de información. Los controles aplicados son minimización de datos, ausencia de secretos, contraste contra artefactos, revisión humana y rechazo de cualquier salida que introduzca hechos no documentados. Por ello, el resultado no demuestra que un LLM sea adecuado para análisis autónomo de malware, sino que puede integrarse de forma limitada en una cadena documental gobernada.

El LLM puede contribuir a organizar información, detectar inconsistencias terminológicas y proponer estructuras de informe, pero no posee acceso autónomo a la verdad del laboratorio. Sus salidas dependen del contexto proporcionado y pueden introducir errores plausibles. La supervisión debe incluir verificación contra evidencias, rechazo de afirmaciones no soportadas y registro de decisiones relevantes. El valor metodológico aparece cuando el modelo reduce carga documental sin sustituir juicio técnico ni autoría académica.

12.14 Discusión sobre la extensión del laboratorio a Windows

La extensión a Windows es coherente con el objeto de estudio porque muchas amenazas orientadas al robo de información se apoyan en artefactos de usuario, navegadores y aplicaciones de escritorio. Sin embargo, esta coherencia temática no basta para afirmar resultados. La memoria distingue entre lo validado y lo diseñado: Linux y la red StealLab-Net forman parte del alcance empírico; Windows queda como extensión razonada.

Desde el punto de vista metodológico, Windows aportaría mayor realismo para estudiar telemetría de navegador y eventos de endpoint, pero también introduciría más variables: versión del sistema, configuración de seguridad, políticas locales, telemetría disponible, herramientas instaladas y diferencias entre navegadores. Por ello, una futura VM-WIN-LAB debería diseñarse como subcaso independiente, con sus propias pruebas, evidencias, hashes, snapshots y criterios de aceptación.

La discusión no presenta Windows como carencia que invalide el trabajo, sino como límite honesto y línea de evolución. StealLab demuestra que el marco de laboratorio, evidencias y metodología puede funcionar en un subcaso controlado. La ampliación a Windows permitiría evaluar transferibilidad, no sustituir las conclusiones ya obtenidas.

La extensión a Windows aumentaría relevancia externa por la presencia de familias dirigidas a ese ecosistema y permitiría observar registros, procesos y perfiles específicos. También elevaría complejidad, superficie de exposición y requisitos de licenciamiento e instrumentación.

La implementación debe comenzar con un caso benigno equivalente a M-001 para comparar observabilidad entre plataformas antes de considerar artefactos más complejos. Esta secuencia conserva continuidad metodológica y evita introducir múltiples variables a la vez.

12.15 Análisis teórico de código de stealers reales con LLM supervisado

Una línea de ampliación especialmente relevante consiste en analizar código fuente de stealers publicado en repositorios públicos, como GitHub, sin ejecutarlo y sin convertirlo en herramienta operativa. Este enfoque es viable académicamente si se formula como revisión estática y defensiva: el objetivo no es probar el malware ni obtener credenciales, sino comprender patrones recurrentes de diseño, activos perseguidos, capas afectadas, dependencias, condiciones de ejecución y señales que podrían transformarse en controles de detección o endurecimiento.

El uso de un LLM en este contexto debe entenderse como apoyo de lectura y síntesis. El modelo puede ayudar a explicar fragmentos complejos, agrupar funciones por responsabilidad, identificar términos técnicos, detectar dependencias sospechosas, proponer hipótesis sobre activos afectados y redactar una matriz de análisis. Sin embargo, sus salidas pueden contener errores, omisiones o interpretaciones no verificadas. Por ello, StealLab debe imponer una regla de doble validación: ninguna conclusión procedente del LLM se incorpora como resultado si no está respaldada por evidencia estática observable y revisión humana.

El análisis por tipos de stealer permite evitar una lectura genérica del malware. Cada subfamilia persigue activos distintos y genera preguntas defensivas diferentes. La siguiente tabla resume qué debería hacer un LLM supervisado en cada caso, manteniendo siempre una frontera estricta: describir y clasificar, no construir ni mejorar capacidades.

Tabla 53. Análisis defensivo con LLM por tipo de stealer

Tipo de stealer	Preguntas defensivas para el LLM	Salida aceptable	Límites que no deben cruzarse
Stealer de credenciales de navegador	¿Qué módulos parecen relacionados con almacenamiento de credenciales, perfiles de navegador o recuperación de datos guardados? ¿Qué artefactos defensivos deberían observarse?	Mapa de componentes, activos afectados, relación con T1555.003 y controles de hardening del navegador.	No explicar procedimientos de descifrado, extracción real, rutas operativas completas ni reutilización de credenciales.
Stealer de cookies y sesiones	¿El código diferencia cookies, sesiones, tokens o perfiles? ¿Qué riesgo de secuestro de sesión se deduce a nivel conceptual?	Clasificación de activos de sesión, relación con T1539, riesgos y mitigaciones como invalidación de sesiones y MFA resistente.	No indicar cómo capturar, transformar, importar o reutilizar cookies de sesión.
Stealer de wallets y criptoactivos	¿Qué patrones sugieren búsqueda de wallets, claves privadas o frases semilla? ¿Qué controles de protección serían pertinentes?	Inventario conceptual de activos cripto, nivel de criticidad y recomendaciones de custodia segura.	No listar rutas concretas, formatos explotables, semillas, claves ni métodos de transferencia.

Tipo de stealer	Preguntas defensivas para el LLM	Salida aceptable	Límites que no deben cruzarse
Stealer de tokens de API, SaaS o mensajería	¿Qué clases de token o credencial de servicio parecen estar representadas? ¿Qué impacto tendría su exposición?	Relación entre token, identidad, alcance de permisos, rotación y detección de uso anómalo.	No orientar sobre abuso de tokens, enumeración de servicios o acceso a cuentas.
File grabber o recolector de documentos	¿Qué tipos de extensiones o categorías documentales aparecen como objetivo? ¿Qué datos sensibles podrían quedar expuestos?	Taxonomía de información afectada y medidas DLP, clasificación y minimización.	No producir listas optimizadas para robo ni reglas de búsqueda ofensiva.
Keylogger o capturador de portapapeles	¿Qué señales estáticas sugieren captura de entrada, eventos de teclado o portapapeles? ¿Qué telemetría defensiva sería útil?	Descripción conceptual de riesgo, eventos de endpoint y controles EDR/HIDS.	No detallar implementación de captura, hooks, persistencia o ocultación.
Módulo de inventario del sistema	¿Qué información del host intenta recolectar el código y para qué podría usarse en una cadena de ataque?	Relación entre fingerprinting, priorización de objetivos y detección de reconocimiento local.	No convertirlo en checklist operativo para selección de víctimas.
Módulo de comunicación o exfiltración	¿Qué componentes sugieren empaquetado, serialización o comunicación saliente? ¿Qué capa OSI y TCP/IP quedaría implicada?	Descripción de indicadores genéricos de red, capa afectada y controles de segmentación/monitorización.	No explicar cómo configurar C2, endpoints, canales encubiertos o bypass de inspección.

El análisis también debe contemplar riesgos específicos del propio uso de IA. Un fragmento de malware puede contener comentarios, cadenas o instrucciones diseñadas para manipular al analista o al modelo. Por tanto, el LLM debe operar con instrucciones del sistema cerradas, sin herramientas de ejecución, sin acceso directo a red, sin capacidad de escribir ficheros fuera del área de trabajo y sin autonomía para tomar decisiones. Además, toda salida del modelo debe tratarse como borrador sujeto a revisión, especialmente cuando sugiera causalidad, intencionalidad o relación con una técnica concreta.

En términos académicos, esta ampliación permitiría comparar M-001 con patrones de código real sin abandonar el enfoque seguro. M-001 seguiría siendo el caso empírico validado; el análisis de código real quedaría como sublínea futura de análisis estático. La contribución consistiría en demostrar cómo un laboratorio universitario puede estudiar malware real sin ejecutarlo, transformando el riesgo en conocimiento defensivo: taxonomías, matrices de activos, indicadores genéricos, controles de prevención, reglas de documentación y preguntas para análisis posteriores.

El análisis estático futuro debe limitarse a descripción defensiva de estructuras, APIs, indicadores y posibles técnicas, sin ejecutar, completar ni optimizar código. El material tendría que permanecer en una zona sin red y someterse a control de procedencia, licencia y necesidad.

Las salidas del LLM se tratarían como hipótesis que un analista debe contrastar con herramientas estáticas y fuentes primarias. La calidad se mediría por trazabilidad de afirmaciones y utilidad defensiva, no por capacidad para producir código operativo.

PARTE V. CIERRE

13 LIMITACIONES Y AMENAZAS A LA VALIDEZ

13.1 Limitaciones técnicas

• VM-WIN-LAB no forma parte del alcance validado; es reserva de diseño y trabajo futuro.

• M-001 a M-005 no implementan persistencia, evasión, cifrado malicioso, C2 real ni exfiltración real.

• La captura de tráfico se limita a HTTP interno controlado y a un contraste negativo TEST-NET sin servicio real.

• La telemetría de procesos no equivale a EDR ni SIEM completo.

La instrumentación se limita a herramientas de sistema, libvirt y captura de red. No se recopilan llamadas al sistema completas, memoria, ETW, telemetría EDR ni eventos de un SIEM. Esto reduce granularidad y puede omitir procesos efímeros o relaciones causales finas.

La red utiliza un único segmento y un servicio HTTP simple. No se evalúan DNS, TLS, proxies, múltiples saltos, IPv6 operativo ni mecanismos de detección de anomalías. Estas exclusiones facilitan control, pero limitan realismo.

13.2 Limitaciones metodológicas

• La muestra técnica comprende un caso principal y cuatro casos complementarios benignos, todos diseñados en el mismo laboratorio.

• La validez externa frente a familias reales es limitada.

• No se realiza comparación cuantitativa entre herramientas de sandbox.

• La reproducibilidad depende de disponer de un entorno KVM/libvirt compatible.

La muestra consta de cinco casos benignos diseñados por el propio autor, lo que mantiene riesgo de confirmación y dependencia del contexto. Los criterios previos, los cierres de evidencia y la regla de no sobreafirmación reducen ese riesgo, pero no sustituyen una réplica independiente.

La revisión bibliográfica es narrativa estructurada y no sistemática. Puede omitir trabajos relevantes y combina fuentes académicas, institucionales y comerciales con niveles de evidencia diferentes. La jerarquía de fuentes y las correcciones bibliográficas mejoran transparencia, sin eliminar el sesgo de selección.

La principal limitación metodológica deriva de la amplitud todavía acotada de los casos frente al fenómeno real. Cinco escenarios controlados permiten comparar integración, descubrimiento, staging, comunicación y contención, pero no capturan diversidad de plataformas, familias, tiempos, técnicas ni comportamiento adaptativo. La variedad añadida mejora la cobertura interna sin convertir la muestra en representativa.

13.3 Amenazas a la validez

Tabla 54. Amenazas a la validez y medidas de mitigación

Tipo de validez	Amenaza	Mitigación
Interna	Errores de configuración o de scripts auxiliares	Evidencias PV/EV, hashes, verificación runtime y conservación de incidencias como EV-M005-005/006
Externa	Generalización indebida a malware real	Declaración explícita del alcance benigno de M-001 a M-005

Tipo de validez	Amenaza	Mitigación
Constructo	Confundir simulación con stealer real	Definiciones, restricciones y límites por caso
Conclusión	Interpretar outputs o ausencias como conclusiones automáticas	Triangulación de evidencias y análisis por objetivos
Reproducibilidad	Cambios de entorno, rutas o inventario	Repositorio, scripts, manifiestos y matriz de evidencias

La validez interna puede verse afectada por estados previos no controlados; la de constructo, por categorías demasiado amplias; la externa, por la distancia frente a malware real; y la de conclusión, por interpretar evidencia insuficiente. La tabla resume mitigaciones, pero ninguna convierte el resultado en universal.

La validez documental merece atención adicional: una tabla mal numerada, una evidencia desplazada o una referencia incorrecta pueden dificultar la defensa aunque el experimento sea correcto. La revisión final reordena tablas, completa índices y contrasta las fuentes añadidas para reducir esa amenaza.

La validez interna puede verse afectada por cambios de configuración no registrados; la validez de constructo, por equiparar aislamiento con una sola evidencia; la validez externa, por el carácter local y benigno del caso; y la fiabilidad, por no repetir todas las pruebas en múltiples sesiones. Las mitigaciones reducen estas amenazas, pero no las eliminan. El documento las mantiene visibles para que el lector distinga entre resultado verificado y capacidad potencial.

13.4 Limitaciones específicas del alcance experimental M-001 a M-005

M-001 a M-005 no incluyen persistencia, evasión, ofuscación maliciosa, movimiento lateral, robo real de credenciales, acceso a navegadores reales, comunicación con C2 real ni ejecución sobre Windows. Por tanto, no permiten evaluar detección frente a familias reales ni rendimiento de herramientas anti-malware. Su alcance es validar observabilidad defensiva, trazabilidad y controles de contención en escenarios benignos.

Esta limitación es deliberada. Introducir capacidades reales aumentaría riesgo, complejidad y responsabilidad legal y cambiaría el objetivo del TFM. La ampliación con M-002 a M-005 demuestra que pueden añadirse ejemplos metodológicamente útiles sin abandonar datos sintéticos, red interna y ausencia de malware real.

Los casos no acceden a almacenes protegidos, no descifran perfiles, no capturan cookies reales, no recolectan memoria y no intentan persistir. M-004 no documenta el PID runtime del servidor; M-005 solo contrasta un destino TEST-NET y una configuración concretos. Estas ausencias y límites se conservan como parte del resultado.

Los casos no fueron diseñados como campaña de repetición estadística bajo múltiples condiciones; por ello no permiten estimar variabilidad temporal o robustez poblacional. En M-005, la corrección EV-M005-006 no constituye una repetición experimental: reevalúa las mismas evidencias sin generar tráfico nuevo.

13.5 Amenazas a la validez externa

La validez externa se ve limitada porque los resultados de M-001 a M-005 no generalizan automáticamente a otros sistemas operativos, familias de malware o entornos corporativos. Un stealer real para Windows, un entorno con EDR/SIEM o una red con Internet producirían señales y riesgos distintos. Las conclusiones se formulan sobre StealLab y los escenarios ejecutados.

La mitigación consiste en presentar StealLab como base extensible y en separar claramente lo validado de lo futuro. M-002 a M-005 ya forman parte del alcance cerrado; VM-WIN-LAB, telemetría avanzada y otras extensiones siguen requiriendo validación específica antes de producir nuevas conclusiones.

Las familias reales pueden detectar virtualización, retrasar ejecución, utilizar cifrado o depender de interacción. StealLab no evalúa estas conductas y, por tanto, no debe emplearse para afirmar que una ausencia de señal implica ausencia de amenaza.

La transferencia del método a otros entornos requiere revisar modelo de amenaza, topología y legislación. La arquitectura es una base, no una receta universal.

La validez externa está condicionada por diferencias de sistema operativo, herramientas, políticas de red, telemetría y comportamiento de amenazas reales. Un laboratorio universitario puede transferir principios, pero no asumir que configuraciones o resultados se reproducirán sin adaptación. La descripción detallada del contexto permite que otro investigador juzgue semejanzas y diferencias. La transferencia debe formularse como hipótesis de aplicabilidad y someterse a nueva validación en cada entorno.

13.6 Amenazas a la validez documental

La validez documental depende de que las evidencias estén ordenadas, sean localizables y no se mezclen con borradores o salidas redundantes. La documentación de cierre distingue expresamente el inventario histórico de 94 ficheros del inventario verificado posterior a M-005, compuesto por 171 ficheros. La comparación entre ambos estados se utiliza únicamente como trazabilidad evolutiva y no como medida de calidad científica.

La amenaza documental más importante es la saturación. Demasiadas salidas de consola dificultan la lectura y reducen claridad. Por ello se adopta la regla: en la memoria solo se incluye resultado, interpretación, hash, ruta o captura útil; la salida completa queda como evidencia externa.

La dependencia de un repositorio local implica riesgo de pérdida, rutas rotas o divergencia entre memoria y artefactos. Los manifiestos, hashes y control previo al depósito mitigan el problema, pero sería recomendable conservar una copia versionada e inmutable.

Las capturas son evidencia de apoyo y pueden perder legibilidad al reducirse. Por ello, la memoria incorpora una selección limitada y mantiene las imágenes originales en los paquetes de evidencia.

La validez documental puede verse afectada por referencias rotas, índices desactualizados, versiones divergentes o evidencias cuya ruta no coincide con la memoria. También existe riesgo de que una captura conserve información insuficiente para interpretar el estado o de que una salida se separe de su contexto temporal. Los controles de nomenclatura, hashes, inventario y revisión cruzada reducen estas amenazas, pero no eliminan la necesidad de comprobar el repositorio antes de cada entrega. La documentación debe tratarse como parte del artefacto y no como producto secundario.

13.7 Limitación por no implementación de VM-WIN-LAB

La reserva de diseño de VM-WIN-LAB no equivale a implementación empírica. En consecuencia, la memoria no debe extraer resultados sobre eventos de Windows, Sysmon, navegadores reales de Windows, perfiles de usuario reales, credenciales almacenadas ni telemetría EDR. La aportación actual se limita al laboratorio KVM/libvirt validado, VM-SERVICES-SIM, VM-LINUX-ANALYSIS, StealLab-Net, M-001 a M-005 y las evidencias PV/EV asociadas.

Esta limitación es metodológicamente aceptable porque el trabajo no pretende cubrir todas las plataformas, sino diseñar y validar un laboratorio seguro para análisis defensivo. La futura implementación Windows permitiría ampliar la validez externa, pero no debe mezclarse con los resultados ya cerrados.

La ausencia de VM-WIN-LAB impide evaluar artefactos específicos de Windows, registros del sistema, perfiles de navegador propios de ese entorno y herramientas de observación asociadas. La arquitectura reserva su función, pero una reserva de diseño no equivale a

implementación. Por ello, cualquier afirmación relativa a Windows se mantiene en el plano teórico o de trabajo futuro.

13.8 Limitación por no ejecución de análisis de código real

Aunque la memoria propone un protocolo para análisis estático de código de stealers reales con LLM supervisado, dicho análisis no se ha ejecutado como prueba empírica cerrada. Por tanto, no se presentan resultados derivados de repositorios reales, no se afirman hallazgos sobre familias concretas a partir de código fuente y no se incorporan fragmentos de malware en la memoria. Esta decisión evita ampliar artificialmente el alcance y mantiene separada la validación real de StealLab, basada en M-001, de las líneas futuras propuestas.

No se descargó, compiló ni ejecutó código de stealers reales. En consecuencia, el TFM no valida identificación de funciones maliciosas, desempaquetado, ofuscación o correspondencia entre código y comportamiento. El flujo propuesto para análisis estático asistido por LLM es únicamente metodológico y defensivo. Su aplicación futura exigiría fuentes autorizadas, aislamiento reforzado, revisión legal y prohibición de producir código ejecutable.

14 CONCLUSIONES

El TFM demuestra que es posible construir y validar un laboratorio académico defensivo para estudiar comportamientos asociados a stealers mediante un enfoque seguro, reproducible y trazable. La validación ya no descansa en un único ejemplo: M-001 actúa como caso principal y M-002 a M-005 aportan contrastes complementarios cerrados/PASS sobre descubrimiento, staging local, comunicación interna y contención negativa.

14.1 Conclusiones por objetivo

La evaluación por objetivos confirma cumplimiento coherente, pero no homogéneo: los objetivos de diseño y documentación alcanzan mayor profundidad que los de cobertura de amenazas. Esta asimetría es coherente con la pregunta y debe mantenerse visible en la defensa.

OE1

Se ha definido un marco conceptual robusto sobre malware, stealers, activos afectados, MaaS y técnicas defensivas relacionadas. Esto permite que el trabajo no sea una simple instalación de herramientas, sino una investigación aplicada contextualizada.

El marco teórico y el estado de la cuestión permiten interpretar el stealer como parte de una economía de identidad y acceso, no solo como binario. La revisión vincula credenciales, cookies, tokens, perfiles y wallets con riesgos posteriores, y separa casos reales de evidencia propia.

OE1 se considera cumplido porque las categorías empleadas en M-001 proceden de fuentes contrastadas y se operacionalizan en el laboratorio. Su límite es que la revisión narrativa no agota la literatura ni prueba prevalencia de cada familia.

OE2

Se ha diseñado una arquitectura de laboratorio basada en KVM/libvirt, StealLab-Net, VMs separadas por rol y red aislada. La verificación qemu:///system confirma la existencia runtime de la red y el registro de VMs principales.

La arquitectura aislada fue diseñada y verificada en sus planos persistente y runtime. StealLab-Net, virbr-steal, el segmento 10.10.10.0/24, las VMs por rol y la ausencia de ruta por defecto forman una base coherente para pruebas benignas.

OE2 se cumple dentro del modelo de amenaza declarado. No se evalúa escape de hipervisor, segmentación multicapa ni resistencia frente a código malicioso avanzado.

OE3

Se ha construido un repositorio de evidencias con estructura PV/EV y se han incorporado cierres, hashes y manifiestos para M-001 a M-005. La verificación final contabiliza 171 ficheros en 04_evidencias y un manifiesto global de 171 entradas con SHA-256 4da7d19aea846aa6d08a80d6fff56f572043f31ff061156c364ccc9f26a5984f. El antiguo recuento de 94 ficheros queda identificado únicamente como estado histórico previo.

Los mecanismos de observación y preservación cubren procesos, sockets, tráfico, hashes, fichas y manifiestos. La trazabilidad PV/EV permite relacionar cada resultado con evidencia primaria y apoyo documental.

El objetivo se cumple como observabilidad básica y auditable. No se equipara a telemetría integral de un SOC o sandbox profesional.

OE4

Se han mantenido y validado PV-01 a PV-07 dentro del alcance definido. M-002 a M-005 refuerzan pruebas existentes: aportan evidencia adicional sobre procesos, red, repositorio y aislamiento, mientras PV-02, PV-06 y PV-07 conservan su función original.

La implementación materializa el diseño en componentes verificables y en un repositorio canónico. Además del caso principal, M-002 confirma descubrimiento controlado, M-003 staging local íntegro, M-004 HTTP interno con recurso coincidente y M-005 un contraste de contención. Las salidas completas permanecen fuera de la memoria.

La corrección de ubicación y numeración de las 61 tablas refuerza además la coherencia del artefacto documental, que forma parte de la implementación académica.

OE5

Se han discutido limitaciones y amenazas a la validez. La principal conclusión crítica es que M-001 a M-005 validan el laboratorio dentro de escenarios benignos diseñados, no el comportamiento completo de familias reales de stealers.

M-001 valida integración; M-002, descubrimiento; M-003, agrupación local; M-004, comunicación interna; y M-005, un contraste positivo-negativo de contención. La incidencia EV-M005-005/006 demuestra además que la trazabilidad debe conservar errores documentales y sus correcciones sin reescribir la evidencia.

El objetivo se cumple para los casos definidos y sus criterios, sin demostrar extracción real, evasión, persistencia, C2 ni capacidad de detección general. La cobertura adicional mejora la solidez interna, pero no elimina las limitaciones de validez externa.

OE6

Se han definido trabajos futuros para ampliar el laboratorio hacia Windows, SIEM, reglas defensivas y análisis estático supervisado. M-002 a M-005 dejan de figurar como trabajo futuro porque su fase experimental se considera cerrada.

La memoria consolida problema, método, evidencias, discusión, limitaciones y trabajos futuros sin convertir el contenido en guía ofensiva. El LLM se utilizó con supervisión y las referencias añadidas se contrastaron y corrigieron.

OE6 se considera cumplido porque el documento permite seguir una cadena argumental desde la pregunta hasta la evidencia, e incorpora índices completos de tablas y figuras para facilitar revisión.

Las conclusiones se presentan por objetivo para evitar una valoración global desvinculada de la evidencia. En cada caso se distingue el resultado alcanzado, la prueba que lo sostiene y el límite que condiciona su interpretación. Este patrón permite que un objetivo pueda considerarse cumplido con restricciones sin ocultar las actividades que todavía requieren validación adicional.

14.2 Respuesta a la pregunta de investigación

Sí es posible diseñar, construir y validar un laboratorio académico, seguro y reproducible para observar y analizar comportamientos defensivamente representativos de stealers sin ejecutar malware real ni utilizar datos sensibles reales. La validación es positiva dentro del alcance definido y se apoya en M-001 más cuatro casos complementarios; demuestra aislamiento acotado, observabilidad, integridad, trazabilidad y documentación, pero no generaliza a familias reales ni a escenarios de evasión avanzada.

La respuesta es afirmativa con condiciones. Es posible diseñar, construir y validar un laboratorio académico seguro y reproducible para estudiar comportamientos tipo stealer sin

malware real, siempre que la pregunta se limite a arquitectura, observabilidad, trazabilidad y capacidad de interpretación. StealLab aporta evidencia suficiente para esas dimensiones mediante red aislada, snapshots, captura de procesos y red, hashes, repositorio y PV/EV.

La respuesta sería negativa si se interpretara que el laboratorio reproduce el comportamiento completo de una familia, evalúa evasión o mide eficacia de detección. Esas afirmaciones exceden la muestra. La fortaleza de la conclusión reside precisamente en declarar la frontera entre lo validado y lo plausible.

El experimento muestra además que la seguridad ética no es incompatible con profundidad técnica. Al eliminar datos y destinos reales se pierde realismo ofensivo, pero se gana control, repetibilidad y posibilidad de publicación. Para la pregunta formulada, esa compensación es adecuada.

La respuesta es afirmativa dentro del alcance definido: es posible diseñar, implementar y validar un laboratorio aislado y reproducible para observar de forma defensiva comportamientos tipo stealer mediante datos sintéticos y evidencias PV/EV. La afirmación está condicionada a M-001 a M-005, a las plataformas implementadas y a las pruebas realizadas; no implica equivalencia con una sandbox profesional ni validación frente a malware real.

14.3 Contribución principal

La contribución principal del trabajo es un artefacto técnico-metodológico: un laboratorio defensivo especializado en stealers, acompañado de un caso principal, cuatro casos complementarios, una matriz de evidencias, restricciones éticas y una discusión crítica. La ampliación muestra que el método puede absorber nuevos ejemplos sin modificar las PV ni aumentar innecesariamente el riesgo.

La contribución principal es un artefacto técnico-documental integrado. No es solo una topología virtual ni una revisión bibliográfica: es una relación verificable entre amenaza, modelo conceptual, arquitectura, casos, evidencias y conclusiones. M-002 a M-005 refuerzan esta articulación al reutilizar la misma estructura PV/EV.

La segunda contribución es metodológica. El modelo PV/EV, la separación entre estado persistente y runtime, y la clasificación verificado-inferido-no demostrado proporcionan mecanismos concretos para evitar sobreafirmación. Estos mecanismos pueden reutilizarse en otros TFM de ciberseguridad.

La tercera contribución es ética y pedagógica. StealLab demuestra una ruta gradual para formar capacidades de análisis antes de trabajar con muestras reales: comenzar con datos sintéticos, validar observabilidad, consolidar trazabilidad y ampliar solo cuando los controles estén probados.

En conjunto, el TFM concluye que la calidad de un laboratorio de malware no depende del grado de peligrosidad de la muestra ni del número de ejemplos, sino de la claridad de la pregunta, la proporcionalidad de los controles y la fuerza de la evidencia. StealLab alcanza esos objetivos con cinco casos benignos delimitados y deja una base verificable para extensiones futuras.

La contribución principal es un método integrado que relaciona arquitectura, ética, prueba y evidencia. Técnicamente, proporciona un entorno controlado; metodológicamente, define categorías y criterios; documentalmente, conserva trazabilidad; y pedagógicamente, demuestra cómo estudiar una amenaza sin incrementar innecesariamente el riesgo. La novedad no se atribuye a cada herramienta por separado, sino a su articulación verificable en un caso académico.

15 TRABAJOS FUTUROS

La línea futura prioritaria es implementar VM-WIN-LAB como máquina real validada, porque muchas familias de stealers operan sobre Windows y navegadores de escritorio. Esta ampliación deberá mantener los mismos criterios éticos: sin credenciales reales, sin C2 real y con snapshots y red aislada.

Otra línea futura es integrar telemetría avanzada mediante SIEM, Sysmon o agentes equivalentes. Esto permitiría ampliar PV-03 desde captura básica de procesos hacia correlación de eventos y reglas defensivas. También se propone desarrollar reglas Sigma/YARA estrictamente defensivas sobre artefactos sintéticos y no sobre muestras reales.

Los casos complementarios M-002, M-003, M-004 y M-005 ya han sido ejecutados y cerrados con resultado PASS, por lo que dejan de considerarse trabajo futuro. Cualquier ampliación experimental posterior deberá responder a una necesidad metodológica nueva y explícitamente justificada, no al mero aumento del número de ejemplos.

Tabla 55. Trabajos futuros priorizados

Línea futura	Objetivo	Condición ética
VM-WIN-LAB	Validar observabilidad en entorno Windows.	Sin malware real ni datos reales en la primera ampliación.
SIEM/Sysmon	Aumentar observabilidad de host.	Solo telemetría defensiva y datos sintéticos.
Reglas Sigma/YARA	Formalizar detecciones defensivas.	Evitar contenido orientado a evasión.
Análisis estático supervisado	Comparar patrones de código sin ejecución.	Fuentes autorizadas, aislamiento y revisión humana.
Replicación externa	Evaluar transferibilidad del método en otro entorno controlado.	Repetir criterios sin introducir datos o infraestructura reales.

15.1 Línea futura prioritaria: implementación controlada de VM-WIN-LAB

La línea futura prioritaria consiste en implementar VM-WIN-LAB como subcaso completo y verificable. Esta línea debe comenzar por una especificación de alcance, continuar con construcción de la VM, validación de red aislada, creación de snapshot base, preparación de artefactos DEMO y ejecución de un caso benigno específico. El resultado no debería incorporarse al TFM actual como hecho consumado, sino a una evolución posterior del repositorio StealLab.

La evaluación futura debería incluir una matriz PV-WIN/EV-WIN equivalente a la ya utilizada: aislamiento, restaurabilidad, captura de procesos, captura de eventos de Windows, captura de tráfico, repositorio de evidencias, informe técnico y revisión humana. Esta estructura permitiría comparar Linux y Windows sin perder trazabilidad.

La prioridad debe ser reproducir M-001 en Windows con artefactos benignos equivalentes y criterios comparables. El éxito se mediría por aislamiento, restaurabilidad, eventos, procesos, red y trazabilidad, no por ejecutar una familia real.

Solo después de validar esa línea base deberían incorporarse formatos más realistas o telemetría avanzada. El avance por etapas permite atribuir diferencias a plataforma e instrumentación sin introducir simultáneamente riesgo y complejidad.

La implementación deberá someterse a puertas de control: aprobación del alcance, imagen base limpia, red sin salida, snapshots verificados, datos sintéticos, telemetría definida y procedimiento de destrucción o restauración. La fase no debe comenzar con muestras reales. Primero debe repetir M-001 en Windows y demostrar que el nuevo entorno conserva los mismos principios de trazabilidad y no exposición.

La extensión a Windows deberá formularse como replicación conceptual y no como simple clonación técnica. Será necesario adaptar fuentes de telemetría, rutas, mecanismos de persistencia del sistema y procedimientos de captura, manteniendo comparables las categorías centrales. La nueva VM deberá validarse primero con artefactos benignos y criterios equivalentes, de modo que las diferencias observadas puedan atribuirse a la plataforma y no a un cambio simultáneo de amenaza, herramientas y método.

15.2 Línea futura: integración blue team por capas

Una segunda línea futura consiste en conectar StealLab con herramientas blue team. La integración podría realizarse progresivamente: primero captura local, después logs estructurados, posteriormente SIEM o Wazuh, y finalmente reglas Sigma/YARA defensivas. La lectura por capas OSI y TCP/IP permitiría separar alertas de red, eventos de endpoint, indicadores de aplicación y evidencias de repositorio.

Esta ampliación debe conservar la regla central del TFM: el laboratorio no necesita malware real para validar observabilidad defensiva inicial. Puede crecer mediante casos benignos, datasets sintéticos y reglas de detección documentadas.

La integración blue team puede añadir reglas de detección sobre proceso, red y aplicación, además de procedimientos de respuesta por activo. Un SIEM o pipeline local permitiría correlacionar timestamps y evaluar si las evidencias PV/EV pueden transformarse en alertas reproducibles.

La evaluación debería incluir falsos positivos y cobertura de cada regla con datos benignos. El objetivo no sería declarar detección universal, sino demostrar trazabilidad entre observación, regla, alerta y respuesta.

La integración con herramientas blue team debería comenzar por telemetría local y reglas explicables, antes de incorporar una plataforma SIEM completa. El objetivo sería correlacionar eventos de host, red y repositorio sin convertir el laboratorio en una arquitectura de

producción. Cada nueva fuente deberá justificar qué categoría mejora, qué ruido introduce y cómo se conserva su evidencia.

La integración blue team debería diseñarse como cadena de trazabilidad desde evento hasta alerta. Cada regla tendría que declarar fuente de datos, condición, contexto, resultado esperado y posibles falsos positivos. La incorporación de SIEM o agentes no debe reducirse a desplegar software, sino a evaluar cobertura y capacidad de correlación. El éxito se mediría por reproducibilidad de la alerta y explicación de su relación con el caso, no por volumen de eventos ingeridos.

15.3 Línea futura: análisis estático de código de stealers con LLM supervisado

Como trabajo futuro, StealLab podría incorporar un subproyecto específico para análisis estático de código fuente de stealers reales publicados en repositorios públicos. Esta línea debería comenzar con un protocolo ético de selección, continuar con una zona de cuarentena documental, aplicar revisión estática asistida por LLM y finalizar con informes defensivos por tipo de stealer. La prioridad no sería ejecutar muestras, sino comparar estructuras de código con la taxonomía del marco teórico y mejorar la capacidad del laboratorio para producir conocimiento verificable sin incrementar el riesgo operativo.

La línea futura debería cerrarse con evidencias equivalentes a las PV/EV ya empleadas: manifiesto de materiales, hash de copias controladas si se conservan, registro de instrucciones defensivas, revisión humana de conclusiones, matriz de límites y un informe que separe evidencia estática, hipótesis del LLM, validación del investigador y utilidad defensiva.

Esta línea debe comenzar con corpus seguros, fragmentos no operativos o código desactivado y un protocolo de revisión humana. Las preguntas permitidas se limitarían a estructura, dependencias, indicadores y posibles relaciones ATT&CK.

Los criterios de aceptación deberían medir exactitud de citas al código, capacidad de reconocer incertidumbre y utilidad para priorizar revisión. Se excluirían generación, reparación o mejora de capacidades maliciosas.

Esta línea se limitará a código obtenido legalmente y tratado como texto no ejecutable. Las salidas admisibles serían resúmenes de alto nivel, identificación de activos objetivo, mapeo defensivo y preguntas para revisión humana. Quedarán prohibidos la compilación, la corrección de errores, la mejora de evasión, la reconstrucción de infraestructura y cualquier transformación que incremente capacidad operativa.

Esta línea futura requiere separar análisis de conocimiento y manipulación de capacidad ofensiva. El corpus deberá seleccionarse con autorización y controles, y las preguntas dirigidas al LLM limitarse a estructura, dependencias, indicadores y riesgos defensivos. Toda afirmación tendrá que contrastarse manualmente con el código y con fuentes técnicas. El resultado esperado sería una ficha analítica reproducible, no una mejora, compilación o ejecución del artefacto. La revisión ética y legal deberá preceder a cualquier incorporación de material real.

16 REFERENCIAS

Afianian, A., Niksefat, S., Sadeghiyan, B., & Baptiste, D. (2020). Malware dynamic analysis evasion techniques: A survey. ACM Computing Surveys, 52(6), Article 126. https://doi.org/10.1145/3365001

Alrawi, O., Wong, M. Y., Avgetidis, A., Valakuzhy, K., Adjibi, B. V., Karakatsanis, K., Ahamad, M., Blough, D., Monrose, F., & Antonakakis, M. (2024). SoK: An essential guide for using malware sandboxes in security applications: Challenges, pitfalls, and lessons learned. arXiv. https://arxiv.org/abs/2403.16304

Anliker, M., & Lain, D. (2025). Phishing attacks on browser-based password manager extensions. arXiv. https://arxiv.org/abs/2501.10933

Association for Computing Machinery. (2018). ACM Code of Ethics and Professional Conduct. https://www.acm.org/code-of-ethics

Avllazagaj, E., Caviglione, L., Mazurczyk, W., Wendzel, S., & Me, G. (2021). When malware changed its mind: An empirical study of variable program behaviors in the real world. Computers & Security, 110, 102419. https://doi.org/10.1016/j.cose.2021.102419

Campobasso, M., & Allodi, L. (2020). Impersonation-as-a-Service: Characterizing the emerging criminal infrastructure for user impersonation at scale. arXiv. https://arxiv.org/abs/2009.04344

Cybersecurity and Infrastructure Security Agency. (2020). LokiBot malware. https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-266a

Cybersecurity and Infrastructure Security Agency. (2023). MAR-10454006-1.v1: ICONICSTEALER. https://www.cisa.gov/news-events/analysis-reports/ar23-136a

Department of Homeland Security. (2012). The Menlo Report: Ethical principles guiding information and communication technology research. https://www.dhs.gov/publication/st-menlo-report

European Union Agency for Cybersecurity. (2024). ENISA threat landscape 2024. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024

European Union Agency for Cybersecurity. (2025). ENISA threat landscape 2025. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025

Europol. (2023). Cyber-attacks: The apex of crime-as-a-service. Publications Office of the European Union. https://www.europol.europa.eu/publications-events/main-reports/iocta-report

Europol. (2024). Internet organised crime threat assessment 2024. https://www.europol.europa.eu/publication-events/main-reports/internet-organised-crime-threat-assessment-iocta-2024

Europol. (2025a). Largest international operation against infostealer Lumma. https://www.europol.europa.eu/media-press/newsroom/news/largest-international-operation-against-infostealer-lumma

Europol. (2025b). Steal, deal and repeat: How cybercriminals trade and exploit your data. Publications Office of the European Union. https://doi.org/10.2813/4926508

Europol. (2026). The evolving threat landscape: How encryption, proxies and AI are expanding cybercrime - Internet Organised Crime Threat Assessment 2026. Publications Office of the European Union. https://doi.org/10.2813/5737847

Google Cloud. (2024). UNC5537 targets Snowflake customer instances for data theft and extortion. https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion

Google Cloud. (2025). M-Trends 2025. https://cloud.google.com/resources/m-trends

Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. MIS Quarterly, 28(1), 75–105. https://doi.org/10.2307/25148625

International Organization for Standardization. (1994). ISO/IEC 7498-1:1994: Information technology—Open Systems Interconnection—Basic Reference Model: The Basic Model.

International Organization for Standardization. (2012). ISO/IEC 27037:2012: Guidelines for identification, collection, acquisition and preservation of digital evidence.

International Organization for Standardization. (2015a). ISO/IEC 27041:2015: Guidance on assuring suitability and adequacy of incident investigative method.

International Organization for Standardization. (2015b). ISO/IEC 27042:2015: Guidelines for the analysis and interpretation of digital evidence.

International Organization for Standardization. (2015c). ISO/IEC 27043:2015: Incident investigation principles and processes.

Internet Engineering Task Force. (1989a). Requirements for Internet hosts—Communication layers (RFC 1122). https://doi.org/10.17487/RFC1122

Internet Engineering Task Force. (1989b). Requirements for Internet hosts—Application and support (RFC 1123). https://doi.org/10.17487/RFC1123

Internet Engineering Task Force. (2022a). HTTP semantics (RFC 9110). https://doi.org/10.17487/RFC9110

Internet Engineering Task Force. (2022b). Transmission Control Protocol (RFC 9293). https://doi.org/10.17487/RFC9293

Kunwar, P., Aryal, K., Gupta, M., Abdelsalam, M., & Bertino, E. (2024). SoK: Leveraging transformers for malware analysis. arXiv. https://arxiv.org/abs/2405.17190

libvirt Project. (2026a). Network XML format. https://libvirt.org/formatnetwork.html

libvirt Project. (2026b). Virtual networking. https://wiki.libvirt.org/VirtualNetworking.html

Meta. (2023). How we protect businesses from malware. https://about.fb.com/news/2023/05/how-we-protect-businesses-from-malware/

Microsoft. (2025a). Lumma Stealer: Breaking down the delivery techniques and capabilities of a prolific infostealer. https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/

Microsoft. (2025b). Microsoft Digital Defense Report 2025. https://www.microsoft.com/en-us/security/security-insider/intelligence-reports/microsoft-digital-defense-report-2025

MITRE. (s. f.-a). MITRE ATT&CK. https://attack.mitre.org/

MITRE. (s. f.-b). Browser Information Discovery (T1217). https://attack.mitre.org/techniques/T1217/

MITRE. (s. f.-c). Credential Access (TA0006). https://attack.mitre.org/tactics/TA0006/

MITRE. (s. f.-d). Credentials from Password Stores (T1555). https://attack.mitre.org/techniques/T1555/

MITRE. (s. f.-e). Credentials from Web Browsers (T1555.003). https://attack.mitre.org/techniques/T1555/003/

MITRE. (s. f.-f). Steal Web Session Cookie (T1539). https://attack.mitre.org/techniques/T1539/

MITRE. (s. f.-g). Data from Local System (T1005). https://attack.mitre.org/techniques/T1005/

MITRE. (s. f.-h). Local Data Staging (T1074.001). https://attack.mitre.org/techniques/T1074/001/

MITRE. (s. f.-i). Exfiltration Over C2 Channel (T1041). https://attack.mitre.org/techniques/T1041/

MITRE. (s. f.-j). System Information Discovery (T1082). https://attack.mitre.org/techniques/T1082/

National Institute of Standards and Technology. (2006). Guide to integrating forensic techniques into incident response (Special Publication 800-86). https://doi.org/10.6028/NIST.SP.800-86

National Institute of Standards and Technology. (2013). Guide to malware incident prevention and handling for desktops and laptops (Special Publication 800-83 Rev. 1). https://doi.org/10.6028/NIST.SP.800-83r1

National Institute of Standards and Technology. (2015). Secure Hash Standard (FIPS PUB 180-4). https://doi.org/10.6028/NIST.FIPS.180-4

National Institute of Standards and Technology. (2022). Digital evidence preservation: Considerations for evidence handlers (NISTIR 8387). https://doi.org/10.6028/NIST.IR.8387

National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). https://doi.org/10.6028/NIST.AI.100-1

National Institute of Standards and Technology. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). https://doi.org/10.6028/NIST.AI.600-1

Nurmi, J., Niemelä, M., & Brumley, B. B. (2023). Malware finances and operations: A data-driven study of the value chain for infections and compromised access. In Proceedings of the 18th International Conference on Availability, Reliability and Security (Article 108, pp. 1-12). ACM. https://doi.org/10.1145/3600160.3605047

Olszewski, D., Tucker, T., Butler, K. R. B., & Traynor, P. (2025). SoK: Towards a unified approach to applied replicability for computer security. In 34th USENIX Security Symposium (pp. 469-488). USENIX Association. https://www.usenix.org/conference/usenixsecurity25/presentation/olszewski

Or-Meir, O., Nissim, N., Elovici, Y., & Rokach, L. (2019). Dynamic malware analysis in the modern era—A state of the art survey. ACM Computing Surveys, 52(5), Article 88. https://doi.org/10.1145/3329786

OWASP Foundation. (2025). OWASP Top 10 for LLM applications 2025. https://genai.owasp.org/llm-top-10/

Page, M. J., McKenzie, J. E., Bossuyt, P. M., Boutron, I., Hoffmann, T. C., Mulrow, C. D., Shamseer, L., Tetzlaff, J. M., Akl, E. A., Brennan, S. E., Chou, R., Glanville, J., Grimshaw, J. M., Hróbjartsson, A., Lalu, M. M., Li, T., Loder, E. W., Mayo-Wilson, E., McDonald, S., ... Moher, D. (2021). The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. BMJ, 372, n71. https://doi.org/10.1136/bmj.n71

Patsakis, C., Arroyo, D., & Casino, F. (2024). The malware-as-a-service ecosystem: A systematic mapping study. Computers & Security, 137, 103606. https://doi.org/10.1016/j.cose.2023.103606

Peffers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. Journal of Management Information Systems, 24(3), 45–77. https://doi.org/10.2753/MIS0742-1222240302

QEMU Project. (2026a). QEMU disk image utility. https://www.qemu.org/docs/master/tools/qemu-img.html

QEMU Project. (2026b). Qcow2 image file format. https://www.qemu.org/docs/master/interop/qcow2.html

Rahimian, A., Ziarati, R., & Preda, S. (2014). On the analysis of Citadel botnet. 2014 International Conference on Cyber Security and Protection of Digital Services. https://doi.org/10.1109/CyberSecPODS.2014.7019170

Ruellan, E., Clay, E., & Ascoli, N. (2025). LLM-based identification of infostealer infection vectors from screenshots: The case of Aurora. arXiv. https://arxiv.org/abs/2507.23611

Scientific Working Group on Digital Evidence. (2019). SWGDE position on the use of MD5 and SHA1 hash algorithms in digital and multimedia forensics. https://www.swgde.org/documents/published-complete-listing/

Scientific Working Group on Digital Evidence. (2025). Best practices for digital evidence collection. https://www.swgde.org/documents/published-complete-listing/

Somé, D. F., Airan, M., Durumeric, Z., & Staicu, C.-A. (2025). User profiles: The Achilles' heel of web browsers. arXiv. https://arxiv.org/abs/2504.17692

Squarcina, M., Tempesta, M., Veronese, L., Calzavara, S., & Maffei, M. (2023). Cookie crumbles: Breaking and fixing web session integrity. 32nd USENIX Security Symposium. https://www.usenix.org/conference/usenixsecurity23/presentation/squarcina

The Tcpdump Group. (2026). tcpdump(1) manual page. https://www.tcpdump.org/manpages/tcpdump.1.html

Thomas, K., Li, F., Zand, A., Barrett, J., Ranieri, J., Invernizzi, L., Markov, Y., Comanescu, O., Eranti, V., Moscicki, A., Margolis, D., Paxson, V., & Bursztein, E. (2017). Data breaches, phishing, or malware? Understanding the risks of stolen credentials. Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, 1421–1434. https://doi.org/10.1145/3133956.3134067

Trend Micro. (2025). Vidar 2.0: The evolution of a resilient information stealer. https://www.trendmicro.com/en_us/research/25/e/vidar-2-0.html

Tyler, M., & Nunes, P. (2024). Towards browser controls to protect cookies from malicious extensions. Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security. https://doi.org/10.1145/3658644.3670319

U.S. Department of Justice. (2023). Criminal marketplace disrupted in international cyber operation. https://www.justice.gov/opa/pr/criminal-marketplace-disrupted-international-cyber-operation

U.S. Department of Justice. (2024a). U.S. charges RedLine and META infostealer administrator after international disruption. https://www.justice.gov/opa/pr/us-charges-redline-and-meta-infostealer-administrator-after-international-disruption

U.S. Department of Justice. (2024b). Ukrainian national sentenced to prison for operating Raccoon Infostealer. https://www.justice.gov/opa/pr/ukrainian-national-sentenced-prison-operating-raccoon-infostealer

U.S. Department of Justice. (2025). Justice Department seizes domains used to support LummaC2 information-stealing malware. https://www.justice.gov/opa/pr/justice-department-seizes-domains-used-support-lummac2-information-stealing-malware

Unit 42. (2019). CookieMiner: Cryptocurrency-stealing malware targets Mac users. https://unit42.paloaltonetworks.com/cookieminer-cryptocurrency-stealing-malware-targets-mac-users/

Wireshark Foundation. (2026). Wireshark User’s Guide. https://www.wireshark.org/docs/wsug_html_chunked/

WithSecure. (2022). DUCKTAIL: An infostealer malware targeting Facebook business accounts. https://labs.withsecure.com/publications/ducktail-an-infostealer-malware

Yin, R. K. (2018). Case study research and applications: Design and methods (6th ed.). SAGE.

Zeltser, L. (2026). REMnux documentation. https://docs.remnux.org/

Zheng, X., Jiang, J., Liang, J., Duan, H., Chen, S., Wan, T., & Weaver, N. (2015). Cookies lack integrity: Real-world implications. 24th USENIX Security Symposium, 707–721. https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/zheng

17 APÉNDICES

17.1 Diario de experimentos

El diario de experimentos se conserva en 05_resultados/bitacora_laboratorio.md y en las tablas fuente asociadas. La fase complementaria registra M-002, M-003, M-004 y M-005 como cerrados/PASS. La memoria resume su función y sus incidencias relevantes, sin reproducir todas las entradas ni salidas de consola.

Cada entrada debería registrar fecha y zona horaria, operador, estado inicial, comandos o procedimiento, artefactos producidos, incidencias, decisión tomada y relación con PV/EV. Este nivel de detalle permite distinguir repetición de reconstrucción y facilita explicar cambios de estado entre capturas.

El diario debe conservar también resultados negativos e incidencias documentales. En M-005 se preserva EV-M005-005 como FAIL histórico del script de decisión y EV-M005-006 como corrección posterior sobre las mismas evidencias, sin repetición experimental; esta secuencia evita reescribir retrospectivamente el historial.

Para que el diario sea útil como instrumento de investigación, cada entrada debe identificar objetivo, precondiciones, versión del entorno, acciones, artefactos generados, incidencias, decisión y vínculo PV/EV. Las entradas posteriores no deben sobrescribir las anteriores: las correcciones se registran como nuevas observaciones. Así se conserva la evolución del razonamiento y se facilita explicar por qué una prueba fue repetida o descartada.

17.2 Manual de instalación resumido

Tabla 56. Manual de instalación resumido

Paso	Descripción	Evidencia relacionada
Preparar repositorio	Crear estructura 01_memoria a 08_entrega_final.	EV-REPO-001 y organización PV/EV.
Configurar libvirt	Definir red StealLab-Net y bridge virbr-steal.	EV-RED-001 y net-dumpxml.
Crear VMs	Implementar VM-SERVICES-SIM y VM-LINUX-ANALYSIS.	EV-VM-002 a EV-VM-011.
Crear snapshots	Guardar estado base de VMs.	EV-SNAP-001 y EV-SNAP-002.
Preparar M-001	Generar datos DEMO y artefacto benigno.	EV-M001-001 y EV-M001-002.
Ejecutar casos complementarios	Aplicar M-002 a M-005 con datos sintéticos y controles de red.	EV-M002-004, EV-M003-004, EV-M004-008, EV-M005-010.
Capturar y cerrar evidencias	Procesos, PCAP, hashes, manifiestos y resultados.	EV-PROC, EV-PCAP y cierres de caso.

17.3 Manual de usuario resumido

El uso del laboratorio debe seguir una secuencia segura: verificar red aislada, confirmar estado de VMs, restaurar snapshot si procede, preparar datos sintéticos, seleccionar el caso benigno documentado, capturar los observables previstos, calcular hashes, registrar resultados y actualizar la matriz PV/EV. M-002 a M-005 reutilizan esta disciplina sin habilitar malware, C2 o Internet reales.

El manual debe utilizarse junto con las restricciones éticas y la matriz de pruebas. Su propósito es reproducir el caso seguro, no ofrecer una guía genérica de análisis de malware. Antes de cada sesión se recomienda registrar la versión de la memoria, el estado de las VMs y

el snapshot de partida; después, cerrar la sesión con inventario y hashes de los artefactos que vayan a conservarse.

17.4 Guía de solucionado de errores

Tabla 57. Guía de solucionado de errores

Incidencia	Causa probable	Tratamiento
virsh sin redes ni VMs	Consulta en sesión no correspondiente o sin qemu:///system.	Usar virsh -c qemu:///system.
domifaddr falla	La VM está apagada o sin agente disponible.	Arrancar VM si procede o usar reservas DHCP/XML solo como diseño.
PCAP sin tráfico	Puede ser error de captura o resultado esperado en un contraste negativo.	Correlacionar interfaz, ruta, servicio y resultado de conexión antes de interpretar.
Hash no coincide	Fichero modificado o ruta incorrecta.	Recalcular desde ruta canónica y registrar incidencia.
Tabla demasiado larga en memoria	Volcado excesivo de consola.	Mover salida completa al repositorio y resumir en tabla.

17.5 Inventario de evidencias externas

El inventario completo se conserva en el repositorio local. En la verificación final del 8 de agosto de 2026 se contabilizaron 171 ficheros en 04_evidencias, distribuidos en M-001=33, M-002=10, M-003=11, M-004=17, M-005=26 y PV=74. El manifiesto global contiene 171 entradas y SHA-256 4da7d19aea846aa6d08a80d6fff56f572043f31ff061156c364ccc9f26a5984f. Para M-002 a M-005, la memoria documenta además identificadores de cierre, hashes críticos, manifiestos y PCAP relevantes.

El inventario debe incluir tamaño, hash cuando proceda, tipo MIME o extensión, caso, PV relacionada y nivel de fuerza probatoria. Las imágenes de los paquetes screenshots.tar.gz y screenshoots2.tar.gz se consideran evidencia visual de apoyo y se incorporan de forma selectiva en la memoria.

La selección final prioriza evidencias que concentran valor probatorio. No se añade una captura vacía del PCAP TEST-NET de M-005: su ausencia de paquetes se expresa en texto y tabla junto con la ausencia de ruta y el fallo de conexión. Las figuras existentes se mantienen como apoyo visual del laboratorio y M-001.

El inventario debe permitir detectar tanto ausencia como duplicidad. Para ello, cada elemento requiere identificador único, ruta relativa, tamaño, hash cuando proceda, fecha, origen, PV asociada, clasificación probatoria y estado de revisión. Una evidencia reemplazada no se elimina silenciosamente: se registra como obsoleta o supersedida para mantener la historia documental.

17.6 Instrumento de verificación ética aplicado

Tabla 58. Instrumento de verificación ética aplicado

Control	Estado esperado antes del depósito
Portada y preliminares	Portada, resumen, abstract, agradecimientos e índices en orden.
Paginación	Todas las páginas numeradas y sin saltos no justificados.

Control	Estado esperado antes del depósito
Títulos y subtítulos	Numeración coherente y sin duplicidades.
Tablas	Título breve, numeración visible, sin cortes ilegibles y con interpretación textual.
Acrónimos	Definidos en tabla integral y en primera aparición relevante.
Referencias	Solo fuentes citadas o utilizadas; correspondencia cita-referencia revisada y presentación homogeneizada conforme a APA 7.
Evidencias	Salidas completas fuera del cuerpo principal; memoria con síntesis interpretativa.
Ética	Sin datos reales, sin malware real, sin C2 real y sin instrucciones ofensivas accionables.

El cierre ético verifica tanto contenido como capacidad operativa. Debe confirmar que no existen secretos, muestras, URLs de C2, código accionable ni configuraciones que expongan terceros. También debe revisar metadatos, capturas y archivos comprimidos.

Un control superado debe quedar documentado; si falla, el depósito se detiene hasta eliminar o anonimizar el material. La ausencia de hallazgos se registra como resultado de revisión, no como suposición.

El instrumento se presenta como parte del método aplicado y no como una lista administrativa de entrega. Sus controles verifican que el caso y las evidencias respetan el alcance aprobado: datos sintéticos, ausencia de malware real, inexistencia de C2, no exposición de secretos, minimización de información y supervisión humana del LLM. Cada control debe vincularse con una evidencia o con una declaración explícita de no aplicabilidad.

17.7 Plantilla de ficha de evidencia EV

Cada evidencia externa del repositorio debe poder describirse mediante una ficha homogénea. Esta ficha no sustituye al fichero original; actúa como metadato académico para facilitar la revisión por terceros y la reproducibilidad del estudio.

Tabla 59. Plantilla académica de ficha de evidencia EV

Campo	Descripción
ID de evidencia	Identificador EV único
Prueba/caso asociado	PV o caso al que apoya
Ruta relativa	Ubicación dentro del repositorio canónico
Tipo	Texto, PCAP, hash, script, informe, checklist o manifest
Fecha	Fecha de generación si está documentada
Hash	SHA-256 si procede
Interpretación	Qué demuestra dentro del alcance
Limitación	Qué no demuestra

La ficha debe incluir también procedencia, método de obtención, integridad, relación con otras evidencias y límite de uso. Esta información evita que el mismo artefacto se cite para sostener afirmaciones incompatibles. Cuando la evidencia sea una captura, se conserva además el artefacto fuente que permita comprobar el contexto mostrado.

17.8 Plantilla de ficha de prueba PV

Cada prueba de validación debe mantener una estructura clara para evitar que el resultado dependa de una lectura subjetiva de consola. La ficha PV vincula objetivo, criterio, evidencia y conclusión.

Tabla 60. Plantilla académica de ficha de prueba PV

Campo	Descripción
ID PV	Identificador de prueba

Campo	Descripción
Objetivo	Qué pretende validar
Precondiciones	Estado requerido antes de ejecutar
Procedimiento resumido	Pasos esenciales sin volcado completo
Criterio de aceptación	Condición observable de cierre
Evidencias asociadas	EV y casos relacionados
Resultado	Aceptada, parcial o no aceptada
Límites	Amenazas a la interpretación

La ficha incorpora precondiciones, pasos, criterio de aceptación, resultado, incidencias, evidencia principal, evidencias auxiliares y conclusión limitada. Su diseño permite registrar una prueba no superada sin perder valor documental. Una prueba fallida puede revelar una amenaza a la validez o una condición del entorno que deba controlarse en la siguiente ejecución.

17.9 Manual de interpretación de evidencias

Para interpretar las evidencias, el lector debe aplicar tres reglas. Primera: una evidencia técnica no equivale automáticamente a una conclusión; requiere contexto. Segunda: una evidencia ausente no debe suplirse con suposiciones. Tercera: una evidencia sintética solo valida el escenario diseñado, no familias reales completas.

La interpretación debe declarar el nivel de confianza y las explicaciones alternativas razonables. Si dos artefactos parecen contradictorios, no se selecciona únicamente el favorable; se revisan estado, momento, herramienta y alcance. Solo después se decide si la contradicción puede resolverse, si exige repetir la prueba o si debe conservarse como limitación.

17.10 Comandos mínimos de verificación local

Los comandos completos permanecen en el repositorio. Para reproducibilidad, la memoria solo conserva comandos mínimos de verificación: listar red y dominios libvirt con qemu:///system, calcular hashes críticos, contar evidencias y consultar información qcow2. El objetivo es que otro investigador pueda comprobar el estado esencial sin reproducir todos los logs.

La selección de comandos obedece al principio de mínima suficiencia. Cada comando debe responder a una pregunta concreta, producir una salida no destructiva y evitar modificar el estado que pretende observar. Las acciones que alteran snapshots, redes o discos se mantienen fuera de esta lista y requieren un procedimiento separado con validación previa.

17.11 Protocolo de control de exposición de información

Antes del depósito, se debe comprobar que el documento no contiene credenciales reales, tokens, cookies, wallets reales, direcciones de infraestructura maliciosa operativa ni instrucciones ofensivas accionables. También se debe comprobar que los anexos no contienen volcados extensos innecesarios y que cualquier evidencia externa queda ubicada en el repositorio.

El protocolo revisa contenido visible, metadatos, rutas, nombres de usuario, direcciones, capturas, archivos comprimidos y propiedades del documento. La ausencia de secretos no se presume por utilizar datos sintéticos, ya que una captura puede incluir información incidental del host. Cualquier hallazgo se anonimiza o elimina antes de que el artefacto sea marcado como apto para difusión académica.

17.12 Protocolo de verificación de consistencia y reproducibilidad

Antes del depósito final, el repositorio debe someterse a una verificación de consistencia. Esta verificación no consiste en repetir todos los experimentos, sino en confirmar que las evidencias citadas en la memoria existen, que los hashes principales pueden reproducirse, que las rutas son coherentes, que las VMs y la red aparecen registradas en libvirt y que las limitaciones están redactadas sin ambigüedad.

El procedimiento mínimo es: confirmar la ruta canónica actual, listar evidencias por caso, recalcular hashes principales, verificar StealLab-Net en qemu:///system, verificar discos qcow2 con qemu-img, comprobar snapshots, abrir los PCAP principales y revisar la matriz PV/EV. En el cierre del 8 de agosto de 2026 estas comprobaciones fijaron el inventario en 171 ficheros y verificaron 18 de 18 hashes críticos sin divergencias. En futuras entregas, el recuento debe obtenerse de nuevo y compararse con el manifiesto, sin reutilizar automáticamente cifras históricas.

Tabla 61. Protocolo de verificación de consistencia y reproducibilidad

Control	Comando o fuente	Resultado esperado	Acción si falla
Ruta canónica	pwd	Coincidencia con la ruta canónica documentada en 8.1.	No depositar hasta corregir rutas o documentar migración.
Inventario EV	find 04_evidencias -type f | wc -l	171 ficheros en el cierre del 8 de agosto de 2026; comparar con manifiesto de 171 entradas.	Actualizar memoria y manifiesto si el total cambia antes de una nueva entrega.
Hashes DEMO	sha256sum datos_demo/*.txt	Coincidencia con memoria	Revisar modificación accidental.
Hashes de casos	sha256sum sobre artefactos/PCAP citados	Coincidencia con M-003, M-004 y M-005	Preservar copia y documentar cualquier divergencia.
Red runtime	virsh -c qemu:///system net-info StealLab-Net	Active yes, Persistent yes, Autostart yes	Recrear o documentar estado.
VMs	virsh -c qemu:///system list --all	VMs registradas; estado final tras M-005 apagado	Explicar cualquier diferencia temporal.
Snapshots	qemu-img info discos qcow2	Snapshot base presente	No afirmar restaurabilidad si no existe.

El protocolo conecta memoria y repositorio mediante una comprobación bidireccional. Desde la memoria se verifica que cada PV/EV citada existe; desde el repositorio se comprueba que cada artefacto conservado tiene función, contexto y estado. También se recalculan hashes críticos y se revisan las diferencias entre configuración persistente y runtime. La finalidad es detectar divergencias documentales, no ocultarlas antes del cierre.